PROYECTO FINAL DE INGENIERÍA

UMBRAL: agente inteligente de vigilancia conductual y mitigación de riesgo de identidad para PyMEs argentinas (2026)

Autor/es:

Mociulsky Santiago - LU: 1158033

Muntaabski Federico - LU: 1158981

Carrera:
Ingeniería en Informática

Tutor/es:
Britez Daniel

Año:
2026

Universidad Argentina de la Empresa
Facultad de Ingeniería y Ciencias Exactas

UADE

PROYECTO FINAL DE INGENIERÍA

UMBRAL: agente inteligente de vigilancia conductual y mitigación de riesgo de identidad para PyMEs argentinas (2026)

Mociulsky, Santiago – LU 1158033
Ingeniería en Informática

Muntaabski, Federico – LU 1158981
Ingeniería en Informática

Tutor:
Britez Daniel,
(UADE) Universidad Argentina de la Empresa Lima 757, Cdad. Autónoma de Buenos Aires, Argentina.

2026

UNIVERSIDAD ARGENTINA DE LA EMPRESA
FACULTAD DE INGENIERÍA Y CIENCIAS EXACTAS

Índice

1 Introducción **9**
1.1 Objetivos . . . 9
1.1.1 Objetivo general . . . 9
1.1.2 Objetivos específicos . . . 9
1.2 Alcance . . . 10
1.3 Descripción . . . 11
1.4 Metodología de desarrollo . . . 11
1.5 Estructura del documento . . . 12

2 Antecedentes **14**
2.1 Marco teórico . . . 14
2.1.1 El punto ciego post-autenticación: problema central del proyecto . . . 14
2.1.2 Zero Trust Architecture . . . 15
2.1.3 User and Entity Behavior Analytics: fundamentos . . . 15
2.1.4 Gestión de identidad y acceso: del control tradicional al acceso basado en riesgo . . . 16
2.1.4.1 Control de acceso basado en roles (RBAC) . . . 16
2.1.4.2 Control de acceso basado en atributos (ABAC) . . . 17
2.1.4.3 Control de acceso adaptado al riesgo (RADAC) . . . 17
2.1.5 Modelos de inteligencia artificial para detección de anomalías conductuales 18
2.1.5.1 LSTM Autoencoder . . . 18
2.1.5.2 Isolation Forest . . . 18
2.1.6 Introducción a los datasets: datos reales vs. datos sintéticos . . . 19
2.1.7 Concept drift y reentrenamiento periódico del modelo . . . 20
2.1.7.1 Definición y tipos de concept drift . . . 20
2.1.7.2 Estrategias de adaptación . . . 20
2.1.7.3 Ventana de reentrenamiento . . . 21
2.1.8 Estándares y marcos normativos . . . 21
2.1.9 Marco legal: protección de datos personales . . . 21
2.1.10 Fundamentos técnicos de la arquitectura . . . 23
2.2 Estado del arte . . . 23
2.2.1 Soluciones comerciales vigentes . . . 24
2.2.1.1 Microsoft Sentinel UEBA . . . 24

2.2.1.2 Splunk UBA . . . 25
2.2.1.3 Exabeam . . . 25
2.2.1.4 Microsoft Entra ID Protection . . . 26
2.2.2 Trabajos académicos: modelos de detección de anomalías . . . 27
2.2.2.1 Control de acceso adaptativo basado en riesgo (RADAC) . . . 27
2.2.2.2 UEBA con aprendizaje automático y aprendizaje profundo . . . 28
2.2.2.3 Isolation Forest aplicado a seguridad y comportamiento de usuarios . . . 29
2.2.3 Tecnologías o enfoques alternativos . . . 29
2.2.3.1 Autenticación adaptativa . . . 30
2.2.3.2 Autenticación continua basada en biometría conductual . . . 30
2.2.3.3 Control de acceso adaptativo basado en riesgo . . . 31
2.2.3.4 Plataformas de detección y respuesta en el endpoint (EDR/XDR) 31
2.2.4 Limitaciones reportadas por otros autores . . . 32
2.2.5 Tendencias emergentes . . . 33
2.2.5.1 Integración de XAI en pipelines de seguridad . . . 34
2.2.5.2 UEBA en entornos *cloud-native* y multiusuario . . . 34
2.2.5.3 Arquitecturas de respuesta autónoma (SOAR + UEBA) . . . 34
2.2.5.4 Ensambles heterogéneos y modelos híbridos . . . 35
2.2.6 Conclusión del estado del arte . . . 35

3 Análisis comparativo del estado del arte 37
3.1 Comparación general de alternativas . . . 37
3.1.1 Microsoft Sentinel UEBA . . . 37
3.1.2 Splunk UBA . . . 38
3.1.3 Exabeam . . . 38
3.1.4 Microsoft Entra ID Protection . . . 39
3.1.5 Okta Adaptive MFA . . . 39
3.1.6 RADAC académico (ad-RACs) . . . 40
3.1.7 Proyecto propuesto . . . 40
3.2 Matriz de capacidades . . . 41
3.3 Comparación de algoritmos de inteligencia artificial . . . 42
3.3.1 CatBoost (score de riesgo por solicitud) . . . 43
3.3.2 LSTM secuencial . . . 43
3.3.3 Graph Neural Networks (GNN) . . . 43
3.3.4 Clustering no supervisado (K-Means, DBSCAN, OPTICS, GMM) . . . 44
3.3.5 Isolation Forest . . . 44

3.3.6 Revisión sistemática . . . 45
3.3.7 Isolation Forest + LSTM Autoencoder (proyecto propuesto) . . . 45
3.4 Síntesis de diferenciadores . . . 46
3.5 Contraste con la práctica profesional en seguridad de la información: resultados de las entrevistas . . . 47
3.5.1 Perfil de los especialistas consultados . . . 47
3.5.2 Validación de decisiones de diseño . . . 48
3.5.3 Líneas de evolución identificadas . . . 49
3.6 Contraste con la percepción de los usuarios finales: resultados de la encuesta . . . 50
3.6.1 La autenticación como portón, no como control continuo . . . 50
3.6.2 Confianza y percepción de protección post-login . . . 51
3.6.3 Gobernanza y visibilidad de los controles existentes . . . 51
3.6.4 La respuesta percibida como menos disruptiva no es la más restrictiva . . . 51
3.6.5 Las funcionalidades priorizadas y su cobertura en el sistema . . . 52
3.6.6 Factores de adopción: sin un factor dominante . . . 52
3.6.7 Inclinación favorable entre los participantes, sin consenso . . . 53
3.6.8 El costo de la detección tardía . . . 53
3.6.9 Síntesis . . . 53

4 Requerimientos, casos de uso e historias de usuario 55
4.1 Alcance del relevamiento . . . 55
4.2 Actores del sistema . . . 55
4.3 Requerimientos funcionales . . . 55
4.3.1 Módulo 1: Agente local y recolección de telemetría (CU-01) . . . 56
4.3.2 Módulo 2: Motor de scoring y decisión (CU-01) . . . 56
4.3.3 Módulo 3: Respuesta adaptativa y mitigación (CU-01) . . . 57
4.3.4 Módulo 4: Panel de administración y gestión de políticas (CU-02) . . . 58
4.3.5 Módulo 5: Ciclo de vida del modelo y reentrenamiento (CU-03) . . . 59
4.3.6 Módulo 6: Alta de usuario nuevo y cold-start (CU-04) . . . 60
4.3.7 Módulo 7: Integración con sistemas IAM (transversal) . . . 60
4.4 Requerimientos no funcionales . . . 61
4.5 Casos de uso . . . 63
4.5.1 CU-01: Detección de desviación conductual y mitigación automática en el endpoint . . . 63
4.5.2 CU-02: Ajuste de umbrales y políticas de respuesta . . . 64
4.5.3 CU-03: Reentrenamiento periódico del modelo . . . 65
4.5.4 CU-04: Alta de usuario nuevo y período de aprendizaje (cold-start) . . . 66

4.6 Historias de usuario . . . 66
4.6.1 Épica 1: Detección y respuesta en el endpoint (CU-01) . . . 67
4.6.2 Épica 2: Panel de administración y políticas (CU-02) . . . 67
4.6.3 Épica 3: Ciclo de vida del modelo (CU-03) . . . 68
4.6.4 Épica 4: Alta de usuarios y cold-start (CU-04) . . . 69
4.6.5 Épica 5: Requerimientos transversales . . . 69

5 Justificación de diseño y mockups 71
5.1 Metodología de diseño . . . 71
5.2 Decisiones de diseño transversales . . . 71
5.3 Arquitectura de navegación . . . 72
5.4 Catálogo de pantallas . . . 72
5.4.1 Acceso (Login) . . . 72
5.4.2 Usuarios (listado) . . . 74
5.4.3 Detalle de usuario . . . 76
5.4.4 Pantalla «Por qué pasó esto» . . . 78
5.4.5 Alertas . . . 81
5.4.6 Configuración de umbrales . . . 83
5.4.7 Auditoría . . . 86
5.4.8 Estado del sistema . . . 88
5.4.9 Con historial . . . 90

6 Diagramas UML 93
6.1 Diagrama de flujo de información . . . 93
6.2 Diagrama de componentes . . . 95
6.3 Diagrama de clases — agente PEP . . . 96
6.4 Diagramas de clases — API PDP . . . 97
6.5 Diagrama de objetos . . . 103

7 Arquitectura y tecnologías 104
7.1 Arquitectura lógica . . . 104
7.2 Lenguajes de programación . . . 105
7.3 Frameworks y librerías . . . 105
7.3.1 API de *scoring* . . . 105
7.3.2 Agente . . . 106
7.3.3 *Dashboard* . . . 106
7.3.4 *Pipeline* de entrenamiento . . . 107
7.4 Servicios e infraestructura . . . 107

7.5 Arquitectura de despliegue . . . 108
7.5.1 Entorno local de desarrollo . . . 108
7.5.2 Despliegue en la nube . . . 109
7.5.3 Contenedores . . . 111
7.5.4 Viabilidad técnica . . . 111
7.6 Protocolos de comunicación . . . 113
7.7 Síntesis . . . 114

8 Datos **115**
8.1 Conjunto de datos . . . 115
8.2 Selección y preparación . . . 115
8.3 Variables y modelos . . . 116
8.3.1 Isolation Forest . . . 116
8.3.2 LSTM Autoencoder . . . 117
8.3.3 Partición y parámetros . . . 117
8.4 Adaptación de la telemetría del agente . . . 118
8.5 Modelo de datos . . . 120
8.5.1 Modelo relacional . . . 120
8.5.2 Modelo no relacional . . . 124
8.6 Síntesis . . . 124

9 Producto implementado **125**
9.1 Visión general . . . 125
9.2 Funcionalidades . . . 125
9.2.1 Agente local . . . 125
9.2.2 Motor de *scoring* . . . 127
9.2.3 Redacción asistida del correo . . . 128
9.2.4 *Dashboard* . . . 128
9.2.5 Reentrenamiento periódico . . . 128
9.2.6 Usuarios nuevos y período de aprendizaje . . . 130
9.2.7 Control de acceso . . . 130
9.3 Estado del despliegue . . . 131
9.4 Tratamiento de datos personales y viabilidad legal . . . 131
9.4.1 Conservación de los datos y cadena de hashes . . . 134
9.4.2 Datos de entrenamiento . . . 135
9.4.3 Descargo de responsabilidad . . . 135
9.5 Limitaciones conocidas . . . 135

9.6 Síntesis 141

10 Pruebas y resultados **142**
10.1 Estrategia de pruebas 142
10.2 Pruebas automatizadas 144
10.2.1 Inventario 144
10.2.2 Resultados de la ejecución 145
10.2.3 Integración continua 146
10.2.4 Cobertura de código 146
10.2.5 Cobertura de los requerimientos 148
10.3 Pruebas funcionales de extremo a extremo 148
10.4 Pruebas de rendimiento 149
10.4.1 Latencia de evaluación de eventos (RNF-01) 149
10.4.2 Latencia en la nube 150
10.4.3 Verificación del despliegue 151
10.4.4 Consumo de recursos del agente (RNF-02) 152
10.5 Evaluación del modelo sin etiquetas 152
10.5.1 Métricas sin etiquetas 153
10.5.2 Metas de evaluación 154
10.6 Validación por escenarios inyectados 155
10.6.1 Método 155
10.6.2 Resultados 155
10.6.3 Sensibilidad según el umbral 156
10.6.4 Interpretación 157
10.7 Evaluación con escenarios etiquetados 158
10.7.1 Escenarios 158
10.7.2 Partición y métricas 159
10.7.3 Resultados en HOLDOUT 160
10.7.4 Lectura de los resultados 161
10.7.5 Contraste con las metas 162
10.7.6 Escenarios controlados adicionales 162
10.8 Evaluación de usabilidad 165
10.9 Decisiones tomadas a partir de los resultados 165
10.10 Limitaciones de las pruebas 168
10.11 Síntesis 169

11 Análisis de mercado y competitividad **171**

11.1 Marketing mix: producto, precio y plaza . . . 171
11.1.1 Producto . . . 171
11.1.2 Precio . . . 172
11.1.3 Plaza . . . 172
11.2 Tamaño del mercado objetivo . . . 173
11.3 Análisis FODA . . . 173
11.3.1 Fortalezas . . . 174
11.3.2 Debilidades . . . 175
11.3.3 Oportunidades . . . 175
11.3.4 Amenazas . . . 175
11.4 Cruz de Porter: 5 fuerzas . . . 176
11.5 Matriz Boston Consulting Group (BCG) . . . 177

12 Modelo de negocio y viabilidad económico-financiera 179
12.1 Cliente, usuario y pagador . . . 179
12.2 Lienzo del modelo de negocio . . . 179
12.3 Monetización y economía unitaria . . . 180
12.4 Viabilidad económico-financiera . . . 182
12.4.1 Supuestos . . . 182
12.4.2 Escenarios . . . 184
12.4.3 Indicadores . . . 185
12.4.4 Interpretación . . . 186
12.5 Identidad de marca . . . 188
12.5.1 Nombre . . . 188
12.5.2 Logotipo . . . 188
12.5.3 Posicionamiento y mensaje . . . 188

13 Conclusiones y trabajo futuro 189
13.1 Cumplimiento de los objetivos . . . 189
13.2 Resultados principales . . . 191
13.3 Trabajo futuro . . . 192

Bibliografía 194

Anexo 199
Anexo A: Cronograma de actividades . . . 200
Anexo B: Resultados de la encuesta . . . 202
Anexo C: Transcripción de la entrevista a Pablo Rodolfo Villarino . . . 210

Anexo D: Transcripción de la entrevista a Luciana Jacubovich 225
Anexo E: Transcripción de la entrevista a Guillermo Pita 235
Anexo F: Transcripción de la entrevista a Alejandro Francisco Peña 247
Anexo G: Cuestionario escrito respondido por Matías Gabriel Ruiz 257
Anexo H: Diagramas ampliados 260

1 Introducción

Esta sección presenta los objetivos del proyecto, su alcance, una descripción general del sistema propuesto y de sus componentes, la metodología de desarrollo y la estructura del documento.

1.1 Objetivos

Los objetivos del proyecto se organizan en dos niveles. El objetivo general enuncia el propósito del sistema en su conjunto, y los objetivos específicos lo descomponen en metas verificables sobre el agente, el modelo de detección, la respuesta en el equipo, el panel de administración, la protección del propio sistema, el marco legal y las pruebas. El grado de cumplimiento de cada uno se analiza en la sección 13.1.

1.1.1 Objetivo general

Desarrollar un sistema de seguridad conductual que evalúe de forma continua, durante toda la sesión, la desviación del comportamiento de cada usuario respecto de su conducta habitual mediante un puntaje de riesgo dinámico, y que ejecute en el propio equipo una respuesta proporcional a ese riesgo, siguiendo la separación entre punto de decisión y punto de aplicación de políticas propuesta por la arquitectura Zero Trust (Rose *et al.*, 2020).

1.1.2 Objetivos específicos

1. Implementar un agente para equipos Windows que recolecte únicamente metadatos de actividad (procesos, archivos y conexiones de red), los envíe a una API central por un canal cifrado con TLS, autenticándose con una credencial individual por agente, y consuma como máximo el 5 % de la CPU y 150 MB de memoria residente.

2. Entrenar un modelo híbrido de detección de anomalías (Isolation Forest y LSTM Autoencoder) sobre un conjunto de datos público de comportamiento de usuarios, y evaluarlo con escenarios de ataque inyectados y un conjunto reservado (*holdout*), informando la tasa de detección y la de alertas sobre actividad normal frente a las metas definidas en la sección 10.5.2.

3. Calcular un puntaje de riesgo de 0 a 100 por evento, con continuidad entre sesiones y decaimiento temporal, con una latencia de evaluación de percentil 95 menor o igual a 500 ms, medida desde el cliente en un entorno local aislado.

4. Ejecutar en el equipo una respuesta graduada según el nivel de riesgo, desde una alerta

hasta la terminación de procesos y la denegación de acceso a carpetas, reversible cuando el sistema operativo lo permita: la suspensión se reanuda y, cuando el agente se ejecuta con privilegios de administrador, el acceso a la carpeta se restaura al estado previo exacto desde un respaldo de la lista de control de acceso (ACL); la terminación de procesos no es reversible.

5. Proveer un panel de administración que muestre el estado de riesgo de cada usuario con su explicación y permita modificar umbrales, acciones y notificaciones sin reiniciar componentes.

6. Mantener la vigencia del modelo mediante un reentrenamiento periódico que se ejecuta en procesos separados del servicio de producción y promueve el modelo nuevo solo si sus métricas de comparación no empeoran más allá de un margen de tolerancia (criterio de no inferioridad), y tratar a los usuarios nuevos con un período de aprendizaje.

7. Proteger las credenciales del sistema y el canal entre sus componentes mediante cifrado en tránsito (TLS con certificado verificado), autenticación del agente con una credencial individual y revocable, ligada a su identidad y a los usuarios que monitorea, y sesiones del panel revocables que no expongan claves de administración al navegador. La autenticación mutua a nivel TLS (mTLS) queda diseñada como extensión.

8. Analizar el tratamiento de datos personales que realiza el sistema a la luz de la Ley 25.326 y de la normativa laboral argentina, e identificar los controles que lo hacen viable, distinguiendo los implementados en el prototipo de los requeridos para un despliegue productivo.

9. Verificar el sistema con pruebas automatizadas que alcancen una cobertura de código mínima del 85 % de las líneas, medida en la API y en el agente, pruebas de extremo a extremo y una evaluación de usabilidad del panel.

1.2 Alcance

El proyecto consiste en el desarrollo de un agente UEBA que trabaja en conjunto con una API central. La API incorpora un modelo de inteligencia artificial entrenado por el equipo para detectar anomalías en el comportamiento de los usuarios, y el sistema incluye un panel de administración para visualizar el nivel de riesgo de cada usuario y modificar los umbrales que definen las acciones a ejecutar. El agente se desarrolla para equipos con Windows y el producto se orienta a pequeñas y medianas empresas de Argentina. El alcance incluye el análisis del tratamiento de datos personales que realiza el sistema según la normativa argentina, pero no la implementación de los procesos organizacionales que esa normativa exige a la empresa que lo adopte (por ejemplo, la información a los empleados o la inscripción de la base de datos).

1.3 Descripción

Los sistemas de seguridad actuales suelen confiar en el usuario solo en el momento del inicio de sesión. Esto deja un punto ciego crítico: si un atacante logra robar credenciales válidas, puede moverse dentro de la red sin ser detectado. Este problema es cada vez más relevante, ya que las soluciones tradicionales han demostrado quedarse limitadas frente a amenazas más sofisticadas (Ansari y Ali, 2025). Ante este escenario, el proyecto propone sumar una capa de monitoreo continuo que acompañe toda la sesión. Esta solución actúa como un complemento a los sistemas de gestión de identidad (IAM) tradicionales y puede integrarse con ellos para validar no solo quién accede, sino también cómo se comporta. La idea es pasar a un modelo capaz de adaptarse a comportamientos cambiantes y detectar anomalías de forma más precisa.

Para lograrlo, el sistema se organiza en tres componentes: un agente instalado en el equipo local, una API central desplegada en la nube y un panel de administración (*dashboard*). El agente es un programa liviano que se ejecuta en segundo plano y recolecta información sobre la actividad del usuario, como procesos ejecutados e intentos de acceso a sistemas, aplicaciones o recursos de red. Estos datos se envían de forma segura a la API, que calcula en tiempo real el nivel de confianza mediante un modelo de inteligencia artificial y, con base en ese resultado, define la acción a tomar.

Dicho nivel de confianza no se calcula únicamente por la sesión; por el contrario, se apoya en el historial previo del usuario, manteniendo una continuidad entre sesiones, pero aplicando un decaimiento en el factor de riesgo con el paso del tiempo. En función del nivel de riesgo detectado, la API devuelve una respuesta al agente indicando la acción a ejecutar, que puede variar desde una simple alerta hasta restricciones más severas como limitación de permisos.

Por último, el sistema incluye un *dashboard web* que permite visualizar el estado de los usuarios y sus niveles de riesgo en tiempo real. Desde allí, los administradores pueden ajustar los umbrales de confianza y definir qué acciones se ejecutan en cada caso, adaptando el sistema a distintos contextos de seguridad. Además, el modelo de inteligencia artificial se reentrena para incorporar nuevos comportamientos de los usuarios, lo que permite mantener su precisión a lo largo del tiempo. El periodo en el que se realiza este proceso puede configurarse desde el panel de administración, de modo que no interfiera con el funcionamiento del entorno productivo.

1.4 Metodología de desarrollo

El proyecto se desarrolla mediante un proceso iterativo e incremental guiado por casos de uso (Larman y Basili, 2003). Cada incremento toma un conjunto de casos de uso, lo lleva a través de análisis, diseño, implementación y prueba, y entrega una versión ejecutable del sistema completo sobre la que se planifica el incremento siguiente. Se elige este enfoque por tres motivos. Primero, el comportamiento del modelo de detección no puede conocerse antes de entrenarlo y

probarlo contra la telemetría real del agente, de modo que los requerimientos se ajustan a partir de los resultados de cada iteración. Segundo, el sistema tiene tres componentes desplegados en forma independiente (agente, API y panel), y un incremento vertical que atraviesa los tres permite verificar la integración temprano. Tercero, un equipo de dos personas no justifica los roles y ceremonias de un marco como Scrum, pero sí la entrega frecuente de versiones verificables.

Se organizan dos incrementos principales. El primero cubre la detección y la mitigación en el equipo (CU-01) y el ajuste de políticas desde el panel (CU-02). El segundo incorpora el reentrenamiento periódico del modelo (CU-03), el alta de usuarios nuevos con período de aprendizaje (CU-04), la integración con sistemas de gestión de identidad y el endurecimiento de la ingesta, la autenticación y el canal. La planificación inicial del proyecto, previa a esta organización en incrementos, se presenta en el Anexo A.

El *pipeline* de entrenamiento del modelo se organiza en seis fases sucesivas, desde la preparación del conjunto de datos hasta la exportación de los artefactos que consume la API, y se ejecuta en forma separada del ciclo de desarrollo del software. Las fases son el análisis exploratorio y el perfilado del conjunto de datos; la limpieza y la clasificación de los usuarios por volumen y tipo; la ingeniería de variables para ambos modelos; el entrenamiento de Isolation Forest; el entrenamiento del LSTM Autoencoder; y la combinación de ambos en el puntaje híbrido, que fija los pesos, la vida media del decaimiento y los umbrales. Antes de la última fase se ejecutan dos auditorías de consistencia de los datos, la segunda de carácter bloqueante.

La gestión del trabajo se apoya en el control de versiones con ramas por funcionalidad, la revisión de cada cambio antes de integrarlo y un *pipeline* de integración continua que ejecuta el análisis estático, la compilación y las pruebas automatizadas en cada cambio (sección 10.2.3). La división de tareas responde a la especialización de cada integrante: uno concentra el entrenamiento del modelo y el otro el agente, la API y el panel.

1.5 Estructura del documento

El documento se organiza en trece secciones. La sección 2 presenta el marco teórico (el punto ciego posterior a la autenticación, la arquitectura Zero Trust, el análisis de comportamiento de usuarios y entidades, los modelos de control de acceso, los algoritmos de detección de anomalías, el marco legal de protección de datos personales y los fundamentos técnicos de la arquitectura) y el estado del arte en soluciones comerciales y trabajos académicos. La sección 3 compara el proyecto con esas alternativas y contrasta el diseño con entrevistas a profesionales de seguridad y con una encuesta a usuarios finales. La sección 4 define los actores, los requerimientos funcionales y no funcionales, los casos de uso y las historias de usuario. La sección 5 justifica el diseño del panel de administración con sus wireframes y pantallas, y la sección 6 presenta los diagramas UML. La sección 7 describe la arquitectura, las tecnologías elegidas, el despliegue y los protocolos de comunicación. La sección 8 presenta el conjunto de datos, la preparación,

los modelos y el modelo de datos del sistema. La sección 9 describe el producto implementado, el estado del despliegue, el tratamiento de datos personales y las limitaciones conocidas. La sección 10 reúne las pruebas automatizadas, funcionales, de rendimiento, la evaluación del modelo y la evaluación de usabilidad. La sección 11 analiza el mercado y la competencia, la sección 12 presenta el modelo de negocio, la viabilidad económico-financiera y la identidad de marca, y la sección 13 expone las conclusiones y el trabajo futuro.

Los anexos complementan el cuerpo del documento. El Anexo A presenta el cronograma de actividades; el Anexo B, los resultados completos de la encuesta; los Anexos C a F, las transcripciones de las entrevistas a cuatro de los profesionales consultados; el Anexo G, el cuestionario escrito respondido por el quinto, y el Anexo H, las versiones completas de los diagramas de la sección 6.

2 Antecedentes

Esta sección reúne los antecedentes del proyecto. El marco teórico presenta los conceptos en los que se apoya el sistema, y el estado del arte revisa las soluciones comerciales, los trabajos académicos y los enfoques alternativos existentes, junto con sus limitaciones y las tendencias del área.

2.1 Marco teórico

Esta sección presenta los conceptos que sustentan el diseño del sistema. Parte del problema central del proyecto, el punto ciego posterior a la autenticación, y recorre los marcos y las técnicas que permiten abordarlo: Zero Trust, el análisis de comportamiento de usuarios y entidades (UEBA), la gestión de identidad y acceso, los modelos de detección de anomalías, los tipos de *datasets*, el *concept drift*, los estándares de referencia, el marco legal de protección de datos personales y los fundamentos técnicos de la arquitectura.

2.1.1 El punto ciego post-autenticación: problema central del proyecto

Los modelos tradicionales de seguridad informática centran la verificación de identidad en el momento de la autenticación inicial. Una vez que el sistema valida las credenciales de un usuario, este obtiene un nivel de confianza que se mantiene durante toda la sesión, sin realizar nuevas verificaciones sobre su comportamiento. Este enfoque, conocido comúnmente como modelo de seguridad perimetral o *castle-and-moat*, presenta una limitación importante: si un atacante logra obtener credenciales válidas, puede operar dentro del entorno protegido sin generar alertas basadas en reglas o firmas predefinidas, ya que sus acciones aparentan corresponder a un usuario legítimo (Rose *et al.*, 2020). Este problema representa una de las principales preocupaciones de la seguridad informática actual. El robo de credenciales es una de las amenazas que el propio modelo Zero Trust identifica como críticas, ya que un atacante con credenciales válidas opera con los permisos del usuario legítimo (Rose *et al.*, 2020). Una vez que el atacante consigue ingresar al sistema, puede desplazarse por la infraestructura utilizando esas mismas credenciales comprometidas para acceder a nuevos recursos y obtener mayores privilegios. Este comportamiento es conocido como movimiento lateral.

Esta limitación motiva la necesidad de monitoreo continuo del comportamiento durante la sesión. En este contexto, los sistemas UEBA son relevantes porque permiten detectar patrones anómalos incluso cuando el usuario ya fue autenticado. Esto es especialmente importante porque los usuarios legítimos suelen tener altos niveles de privilegio, por lo que una cuenta comprometida representa un riesgo mayor que una intrusión externa (Artioli *et al.*, 2024).

2.1.2 Zero Trust Architecture

El enfoque Zero Trust plantea un cambio en la forma de entender la confianza dentro de los sistemas de seguridad. Bajo este enfoque, ningún usuario, dispositivo o sistema debe considerarse confiable de manera automática, independientemente de que se encuentre dentro o fuera de la red de la organización. La confianza debe construirse y mantenerse de forma continua a partir de información observable sobre el comportamiento del usuario y el contexto en el que se realiza cada acción, en lugar de basarse únicamente en la ubicación de red o en una autenticación realizada previamente. Estos principios fueron formalizados por el National Institute of Standards and Technology (NIST) en la publicación SP 800-207 *Zero Trust Architecture* (Rose *et al.*, 2020), documento que establece los lineamientos arquitectónicos y operativos de referencia para la adopción de este modelo de seguridad.

Entre los siete principios que define el estándar se encuentran la verificación continua, según la cual la autenticación y la autorización deben reevaluarse dinámicamente en función del tiempo transcurrido, los recursos accedidos o la detección de comportamientos anómalos, y la recopilación constante de información operativa para fortalecer la seguridad del sistema.

Desde la perspectiva del estándar NIST SP 800-207, la seguridad deja de apoyarse en perímetros estáticos para basarse en una infraestructura lógica que administra cada solicitud de acceso de forma dinámica mediante la interacción de tres componentes fundamentales: el Punto de Cumplimiento de Políticas (PEP), el Punto de Decisión de Políticas (PDP) y el Punto de Información de Políticas (PIP).

El Punto de Cumplimiento de Políticas (PEP) funciona como el componente operativo encargado de conectar, supervisar e interceptar las interacciones de los usuarios, permitiendo aplicar de manera efectiva las restricciones o medidas de mitigación necesarias durante una sesión activa. Las decisiones que determinan estas acciones dependen completamente del Punto de Decisión de Políticas (PDP), responsable de procesar continuamente el contexto y evaluar las desviaciones conductuales para establecer, en tiempo real, el nivel de confianza asignado a cada entidad.

Para que esta evaluación resulte precisa, el sistema se apoya en el Punto de Información de Políticas (PIP), que actúa como el repositorio central de información. Este componente proporciona las fuentes de telemetría, el historial de comportamiento previo y las reglas contextuales necesarias para que el motor inteligente pueda determinar la resolución más adecuada en cada situación.

2.1.3 User and Entity Behavior Analytics: fundamentos

User and Entity Behavior Analytics (UEBA) es una tecnología que permite aplicar los principios de Zero Trust al monitoreo continuo de las sesiones. Su objetivo es construir

perfiles de comportamiento habituales para usuarios y entidades a partir de información histórica, identificando en tiempo real aquellas actividades que se desvían de los patrones esperados y asignando un *score* de riesgo según la gravedad de la anomalía detectada. A diferencia de los sistemas tradicionales basados en reglas, UEBA no depende del conocimiento previo de técnicas de ataque específicas, sino que aprende qué comportamientos son normales y detecta aquellas acciones que se apartan de ellos.

La arquitectura funcional de un motor *User and Entity Behavior Analytics* (UEBA) comprende cuatro etapas principales: (i) la recolección de datos provenientes de registros del sistema, logs de aplicaciones, dispositivos y tráfico de red; (ii) la construcción de *baselines* de comportamiento individual y por grupo de rol mediante técnicas de aprendizaje automático; (iii) la detección de anomalías a partir de la comparación con los patrones de comportamiento establecidos; y (iv) la asignación de puntajes de riesgo (*risk scoring*) junto con mecanismos de respuesta adaptativa (Artioli *et al.*, 2024).

2.1.4 Gestión de identidad y acceso: del control tradicional al acceso basado en riesgo

La Gestión de Identidad y Acceso (*Identity and Access Management*, IAM) constituye un conjunto de políticas, procesos y tecnologías destinadas a gestionar las identidades digitales y regular el acceso de los usuarios a los recursos de una organización. No obstante, las deficiencias en su implementación continúan siendo una de las principales causas de incidentes de seguridad y brechas de datos. En este contexto, la evolución de los modelos de IAM resulta fundamental para superar las limitaciones de los enfoques tradicionales y adoptar mecanismos más avanzados de autenticación y autorización, fortaleciendo así la protección de los sistemas y facilitando la aplicación de principios de seguridad como el de menor privilegio (Glöckler *et al.*, 2024).

2.1.4.1 Control de acceso basado en roles (RBAC)

El modelo *Role-Based Access Control* (RBAC) asigna permisos a partir de roles previamente definidos, como administrador, vendedor o técnico. De esta manera, los usuarios adquieren automáticamente los privilegios asociados al rol que les ha sido asignado. Gracias a su simplicidad y facilidad de administración, RBAC se ha convertido en uno de los mecanismos de control de acceso más utilizados en entornos corporativos.

Sin embargo, RBAC presenta algunas limitaciones importantes. Este modelo toma las decisiones de acceso en función de los roles asignados a cada usuario, lo que dificulta incorporar información contextual y adaptarse a entornos dinámicos donde las condiciones de acceso pueden cambiar con frecuencia (Kuhn *et al.*, 2010).

Esta característica implica que, una vez concedido el acceso, el sistema continúa basando sus decisiones en los permisos asociados al rol del usuario. En consecuencia, un atacante que

haya comprometido credenciales válidas podría operar bajo los mismos permisos que el usuario legítimo mientras la sesión permanezca activa. Por esta razón, aunque RBAC resulta eficaz para gestionar la autorización inicial, no proporciona mecanismos específicos para detectar actividades anómalas o comportamientos potencialmente maliciosos durante el desarrollo de la sesión. Esta limitación ha impulsado la investigación de modelos más flexibles y adaptativos que complementan el control de acceso tradicional mediante el análisis continuo del contexto y del comportamiento del usuario.

2.1.4.2 Control de acceso basado en atributos (ABAC)

El modelo *Attribute-Based Access Control* (ABAC) basa las decisiones de acceso en atributos del usuario, del recurso y del contexto, lo que permite incorporar información contextual, como la ubicación, el horario, el dispositivo utilizado o el tipo de recurso solicitado (Hu *et al.*, 2014). Esto permite definir políticas más flexibles y adaptadas a cada situación.

Este enfoque es relevante porque permite considerar el contexto en el que ocurre cada acción, evaluando si el comportamiento es coherente con lo esperado para un usuario en particular.

2.1.4.3 Control de acceso adaptado al riesgo (RADAC)

El modelo *Risk-Adaptive Access Control* (RADAC) extiende los mecanismos tradicionales de control de acceso mediante la incorporación de una evaluación dinámica del riesgo durante el proceso de autorización. Este enfoque considera información contextual y factores situacionales para determinar el nivel de confianza requerido en cada solicitud, permitiendo que las decisiones de acceso se ajusten en tiempo real según el riesgo asociado a la operación (Xiao *et al.*, 2022).

En este enfoque, el nivel de confianza se expresa mediante un *score* que representa el riesgo de la actividad observada. Dependiendo de este valor y de los umbrales definidos, el sistema puede permitir el acceso normal, solicitar una autenticación adicional (*step-up authentication*) o restringir ciertos permisos. De este modo, la autorización deja de ser binaria y pasa a ajustarse de forma progresiva según el nivel de riesgo detectado.

En entornos críticos como los sistemas de salud, la combinación de RBAC, ABAC y controles basados en riesgo ha demostrado resultados prometedores para fortalecer la protección de accesos y la adaptación al contexto operativo (Atlam y Yang, 2025).

En conjunto, IAM y RBAC establecen la base de gestión de identidades y permisos, ABAC introduce el contexto de las solicitudes, y RADAC incorpora la evaluación dinámica del riesgo. Este enfoque no reemplaza los sistemas de gestión de identidad existentes, sino que los amplía mediante una capa de análisis continuo del comportamiento y adaptación a condiciones cambiantes.

2.1.5 Modelos de inteligencia artificial para detección de anomalías conductuales

La detección de anomalías en el comportamiento de usuarios es un problema complejo debido a una característica central de este tipo de sistemas: la baja disponibilidad de ejemplos reales de ataques. En escenarios reales, la gran mayoría de los eventos corresponden a actividad legítima, mientras que los casos de comportamiento malicioso son escasos, variados y difíciles de generalizar. Esta condición hace que los enfoques supervisados tradicionales no sean adecuados como estrategia principal, ya que requieren grandes volúmenes de datos etiquetados de ataques para funcionar correctamente. Por este motivo, se recurre principalmente a modelos no supervisados, capaces de aprender patrones de comportamiento normal sin depender de ejemplos explícitos de anomalías.

2.1.5.1 LSTM Autoencoder

Un autoencoder es una arquitectura de red neuronal diseñada para aprender representaciones comprimidas de los datos y reconstruirlos posteriormente. Durante el entrenamiento, el modelo aprende a codificar la información en una representación intermedia de menor dimensionalidad y luego a reconstruirla con la mayor fidelidad posible. Cuando el modelo se entrena exclusivamente con datos de comportamiento normal, su capacidad de reconstrucción se optimiza para ese tipo de patrones.

En este contexto, cuando el modelo recibe una secuencia que se desvía del comportamiento habitual, la reconstrucción tiende a ser menos precisa, lo que se refleja en un aumento del error de reconstrucción. Este error se utiliza como indicador de anomalía, ya que representa qué tan diferente es una observación respecto de lo aprendido como comportamiento normal.

La variante LSTM (*Long Short-Term Memory*) extiende esta arquitectura para trabajar con datos secuenciales (Hochreiter y Schmidhuber, 1997). A diferencia de los modelos que tratan los datos como observaciones independientes, LSTM permite capturar dependencias temporales entre eventos consecutivos, lo que resulta fundamental para representar patrones de comportamiento en el tiempo. Este enfoque se aplica con buenos resultados a la detección de anomalías en series temporales multivariadas, en especial cuando los patrones dependen del orden y de la evolución de los eventos (Malhotra *et al.*, 2016).

2.1.5.2 Isolation Forest

El algoritmo Isolation Forest basa su funcionamiento en el principio de aislamiento de las observaciones para detectar anomalías (Liu *et al.*, 2008). En lugar de generar un modelo detallado de la conducta normal, esta técnica emplea diversos árboles de decisión aleatorios para segmentar el espacio de datos. Aquellos registros que exhiben propiedades atípicas se diferencian

por quedar aislados tras una menor cantidad de particiones, lo que facilita su reconocimiento como posibles irregularidades.

Este método ofrece beneficios significativos al trabajar con grandes volúmenes de datos y múltiples dimensiones, ya que prescinde de requerimientos estadísticos rígidos o de la necesidad de contar con información previamente etiquetada. Asimismo, su bajo costo computacional lo convierte en una solución idónea para procesar flujos masivos de información. Este método obtiene resultados sólidos en contextos altamente desbalanceados (Al-Shehari *et al.*, 2023).

2.1.6 Introducción a los datasets: datos reales vs. datos sintéticos

En el ámbito del aprendizaje automático y del análisis de sistemas, un *dataset* es un conjunto estructurado de datos utilizado para entrenar, evaluar o validar modelos y algoritmos. Está compuesto por registros individuales que representan observaciones del fenómeno que se busca estudiar, junto con los atributos o variables que describen cada una de ellas. La calidad, el volumen y la representatividad del *dataset* son aspectos fundamentales, ya que influyen directamente en la capacidad de generalización de cualquier modelo desarrollado a partir de esos datos.

Según su origen, los *datasets* pueden clasificarse en dos grandes categorías: reales y sintéticos. Los datos reales son aquellos obtenidos directamente de sistemas en funcionamiento, interacciones humanas o procesos. Su principal ventaja es que reflejan la complejidad, el ruido y las distribuciones irregulares características de los entornos de producción, lo que los convierte en la fuente más confiable para evaluar el comportamiento de un sistema frente a situaciones reales. No obstante, su obtención suele estar sujeta a restricciones vinculadas con la privacidad, las regulaciones de protección de datos y la sensibilidad propia de la información que contienen, lo que con frecuencia requiere la aplicación de procesos de anonimización antes de su publicación o de ser compartidos.

Por otro lado, los datos sintéticos son generados de manera artificial mediante simulaciones, modelos estadísticos o técnicas generativas. Entre sus principales ventajas se encuentran la disponibilidad, el control sobre la distribución de clases y la ausencia de restricciones legales. Sin embargo, presentan una limitación importante: por más avanzado que sea el proceso de generación, resulta difícil reproducir con total fidelidad todos los patrones, anomalías y comportamientos emergentes presentes en sistemas reales. En áreas como la ciberseguridad, donde la detección de anomalías depende de identificar desviaciones sutiles respecto de un comportamiento basal auténtico, los datos reales ofrecen mayor validez y aplicabilidad que los sintéticos, a costa de las restricciones de privacidad y de la ausencia habitual de etiquetas.

2.1.7 Concept drift y reentrenamiento periódico del modelo

El reentrenamiento periódico de un modelo de IA no es solo una decisión técnica, sino una necesidad derivada de un fenómeno conocido como *concept drift*, ampliamente estudiado en *machine learning* aplicado a seguridad. Este fenómeno explica por qué los modelos pueden perder precisión con el tiempo si no se actualizan, ya que los patrones de comportamiento de los datos cambian de forma natural.

2.1.7.1 Definición y tipos de concept drift

El *concept drift* ocurre cuando los datos cambian con el tiempo y los patrones aprendidos dejan de representar el comportamiento actual (Gama *et al.*, 2014). En sistemas de análisis de comportamiento, esto es habitual: los hábitos de uso cambian por nuevas tareas, cambios de rol, herramientas o rutinas. Sin actualización, un comportamiento normal reciente puede ser interpretado como anómalo.

Este concepto se distingue entre distintos tipos: el gradual, cuando los cambios ocurren de forma progresiva; el súbito, cuando hay cambios abruptos en el comportamiento; y el recurrente, cuando ciertos patrones vuelven a aparecer con el tiempo (Gama *et al.*, 2014). En este tipo de sistemas, los cambios graduales y recurrentes son los más frecuentes, por lo que requieren estrategias de actualización constantes.

2.1.7.2 Estrategias de adaptación

Existen dos enfoques principales para mantener actualizados los modelos de detección de anomalías frente a cambios en los datos. El primero, conocido como adaptación reactiva, consiste en supervisar continuamente el comportamiento del sistema y reentrenar el modelo cuando se detectan indicios de degradación en su desempeño. Por ejemplo, esto puede ocurrir cuando la cantidad de anomalías observadas supera un umbral previamente definido (Bagui *et al.*, 2025). El segundo enfoque, denominado adaptación periódica, actualiza el modelo en intervalos regulares de tiempo, independientemente de que se hayan detectado cambios en los datos. Esta estrategia simplifica la planificación del mantenimiento y permite controlar mejor el impacto de las actualizaciones sobre el entorno productivo.

Cada estrategia presenta ventajas y limitaciones. La adaptación reactiva permite responder rápidamente a cambios en los datos, reduciendo el tiempo durante el cual el modelo opera con información desactualizada. Sin embargo, requiere mecanismos de monitoreo continuo y criterios adecuados para determinar cuándo iniciar el reentrenamiento. Por otro lado, la adaptación periódica se destaca por su simplicidad y previsibilidad, ya que las actualizaciones pueden programarse con anticipación y gestionarse de manera controlada. No obstante, la frecuencia de actualización debe definirse cuidadosamente: intervalos demasiado cortos pueden incorporar

ruido o comportamientos anómalos como parte del patrón normal, mientras que intervalos demasiado largos pueden provocar una pérdida de precisión frente a cambios recientes en los datos.

Existe además el riesgo de *attacker-induced drift*, donde un atacante introduce comportamientos maliciosos de forma gradual para que el sistema los aprenda como normales (Kuppa y Le-Khac, 2022). Este riesgo motiva la incorporación de controles previos al reentrenamiento, como la revisión humana de los eventos que se incorporan a la nueva línea base.

2.1.7.3 Ventana de reentrenamiento

La frecuencia de reentrenamiento se relaciona con el tiempo durante el cual el modelo mantiene un rendimiento estable antes de que el *drift* degrade su precisión: si ese tiempo es largo, alcanzan actualizaciones espaciadas, y si es corto, se requieren actualizaciones más frecuentes o una adaptación reactiva (Gama *et al.*, 2014). La configuración de esta ventana refleja un principio de adaptación continua de políticas (Rose *et al.*, 2020), aplicado al ciclo de vida del modelo.

2.1.8 Estándares y marcos normativos

NIST SP 800-207 (Rose *et al.*, 2020), cuyos principios y componentes se describen en la sección 2.1.2, constituye la referencia principal para arquitecturas Zero Trust, incluida la aplicación de distintos niveles de respuesta según el riesgo. Este estándar se complementa con NIST SP 800-207A (Chandramouli y Butcher, 2023), que adapta el modelo a entornos modernos basados en servicios en la nube y APIs, lo que lo hace especialmente relevante para arquitecturas distribuidas.

2.1.9 Marco legal: protección de datos personales

Un sistema que registra la actividad de los empleados en sus equipos de trabajo trata datos personales, por lo que su viabilidad depende del marco normativo de protección de datos y del derecho laboral. En Argentina, la norma principal es la Ley 25.326 de Protección de los Datos Personales (República Argentina, 2000), reglamentada por el Decreto 1558/2001.

La ley define como dato personal a la información de cualquier tipo referida a personas físicas o de existencia ideal determinadas o determinables (art. 2). Los registros de actividad que recolecta el agente están asociados a un identificador de equipo y de usuario, por lo que constituyen datos personales aunque no incluyan el contenido de archivos ni de comunicaciones.

Los principios relevantes para el proyecto son los siguientes:

- **Calidad y finalidad** (art. 4): los datos deben ser ciertos, adecuados, pertinentes y no excesivos en relación con la finalidad para la que se obtienen, y no pueden utilizarse para finalidades distintas o incompatibles con ella.

- **Consentimiento** (art. 5): el tratamiento requiere el consentimiento libre, expreso e informado del titular, salvo excepciones, entre ellas que los datos deriven de una relación contractual del titular y resulten necesarios para su desarrollo o cumplimiento.
- **Información al titular** (art. 6): al recabar los datos se debe informar la finalidad, los destinatarios, la existencia del archivo y su responsable, y la posibilidad de ejercer los derechos de acceso, rectificación y supresión.
- **Seguridad y confidencialidad** (arts. 9 y 10): el responsable debe adoptar las medidas técnicas y organizativas necesarias para garantizar la seguridad y confidencialidad de los datos, y quienes intervienen en el tratamiento están obligados al secreto.
- **Transferencia internacional** (art. 12): se prohíbe la transferencia de datos personales a países u organismos que no proporcionen niveles de protección adecuados, salvo las excepciones previstas.
- **Derechos del titular** (arts. 14 a 16): acceso, rectificación, actualización y supresión de sus datos.
- **Registro** (art. 21): las bases de datos privadas destinadas a proporcionar informes deben inscribirse en el registro que lleva el órgano de control.

El órgano de control es la Agencia de Acceso a la Información Pública (AAIP), que asumió las funciones de la entonces Dirección Nacional de Protección de Datos Personales. Entre las normas complementarias dictadas por ambos organismos se encuentran las medidas de seguridad recomendadas para el tratamiento de datos personales (Agencia de Acceso a la Información Pública, 2018) y las cláusulas contractuales tipo para la transferencia internacional, junto con la lista de países con legislación adecuada (Dirección Nacional de Protección de Datos Personales, 2016). Argentina aprobó además el Convenio 108 del Consejo de Europa para la protección de las personas con respecto al tratamiento automatizado de datos de carácter personal y su Protocolo adicional (República Argentina, 2019), y el Protocolo modificatorio que lo actualiza, conocido como Convenio 108+ (República Argentina, 2022).

En el ámbito laboral, la Ley de Contrato de Trabajo (República Argentina, 1974) admite que el empleador establezca sistemas de control personal destinados a la protección de sus bienes, siempre que salvaguarden la dignidad del trabajador, se practiquen con discreción y mediante medios de selección automática (art. 70). Esos controles, así como los relativos a la actividad del trabajador, deben ser conocidos por este (art. 71), y la autoridad de aplicación está facultada para verificar que no afecten su dignidad (art. 72). El monitoreo de la actividad en equipos provistos por la empresa se analiza en este marco: su legitimidad depende de que los empleados conozcan la existencia del control, su finalidad y su alcance.

2.1.10 Fundamentos técnicos de la arquitectura

Esta subsección presenta los conceptos técnicos sobre los que se construye la solución, sin entrar en la elección de herramientas concretas, que se justifica en la sección 7.

Interfaces REST. El estilo arquitectónico REST (*Representational State Transfer*) organiza la comunicación entre componentes distribuidos como solicitudes sin estado sobre recursos identificados por una dirección, mediante una interfaz uniforme (Fielding, 2000). Como cada solicitud contiene toda la información necesaria para atenderla, el servidor no conserva el contexto de la conversación con cada cliente, lo que facilita escalar y reemplazar los componentes.

Almacenamiento en memoria y almacenamiento relacional. Los almacenes clave-valor en memoria guardan los datos en la memoria principal y los acceden por una clave, lo que ofrece latencias bajas para un estado que se lee y se actualiza con alta frecuencia, a costa de un modelo de consulta limitado. Las bases de datos relacionales, en cambio, organizan los datos en tablas con un esquema definido y permiten consultas declarativas y transacciones con garantías de consistencia, por lo que se emplean para los registros que deben conservarse y consultarse a lo largo del tiempo.

Cifrado y autenticación del canal. El protocolo TLS (*Transport Layer Security*) establece un canal cifrado entre dos extremos en el que el cliente verifica la identidad del servidor mediante su certificado; en forma opcional, el servidor puede verificar también la del cliente con un certificado propio, lo que se denomina autenticación mutua (Rescorla, 2018).

Integridad de registros por encadenamiento de *hashes*. Una función de *hash* criptográfica produce un resumen de longitud fija que cambia ante cualquier modificación del contenido. Si cada registro incluye el *hash* del anterior, se forma una cadena en la que alterar o eliminar un registro rompe la verificación de todos los siguientes. Esta técnica se propuso para el sellado temporal de documentos digitales (Haber y Stornetta, 1991) y permite detectar modificaciones posteriores en registros de actividad.

Estadísticas incrementales. El algoritmo de Welford actualiza la media y la varianza de una serie con cada observación nueva, sin conservar los valores anteriores y con buena estabilidad numérica (Welford, 1962). Esto permite mantener líneas base de comportamiento que se actualizan evento a evento.

2.2 Estado del arte

Esta sección revisa las soluciones y la investigación existentes sobre detección de comportamiento anómalo y control de acceso basado en riesgo. Se analizan soluciones comerciales, trabajos académicos y enfoques alternativos, y se cierra con las limitaciones reportadas por otros autores y las tendencias emergentes.

2.2.1 Soluciones comerciales vigentes

Esta subsección analiza cuatro soluciones comerciales: Microsoft Sentinel UEBA, Splunk UBA, Exabeam y Microsoft Entra ID Protection. Para cada una se describen su objetivo, su funcionamiento, los datos que utiliza, los resultados que reporta y sus limitaciones.

2.2.1.1 Microsoft Sentinel UEBA

Microsoft Sentinel integra funciones de UEBA para enfrentar el desafío de detectar conductas atípicas que sugieran vulneraciones de cuentas, amenazas de origen interno o desplazamientos malintencionados en la infraestructura organizacional. Su objetivo principal es determinar desviaciones en las rutinas de actividad de los usuarios y diversas entidades corporativas.

Su funcionamiento se basa en la construcción de perfiles de comportamiento a partir de información histórica. El sistema analiza variables como la ubicación geográfica desde la que se accede, el dispositivo utilizado, la frecuencia de determinadas acciones y el historial de actividad de cada usuario o entidad. A partir de estos datos, genera líneas base de comportamiento y calcula puntajes de riesgo que permiten identificar actividades inusuales. Una característica diferencial de Sentinel es que no limita el análisis a usuarios individuales, sino que también incluye servidores, dispositivos de red y otros componentes de infraestructura, ampliando así el alcance de la detección.

Los datos utilizados provienen principalmente de registros de eventos, actividad de red, sistemas de autenticación, dispositivos y servicios integrados dentro del ecosistema de monitoreo. Esta capacidad de centralizar información de múltiples fuentes le permite construir una visión más completa del comportamiento de cada entidad analizada.

Según la documentación pública del fabricante, la solución mejora en la detección temprana de amenazas avanzadas y actividades anómalas que podrían pasar desapercibidas mediante mecanismos tradicionales basados únicamente en reglas o firmas. El uso de perfiles de comportamiento permite identificar riesgos incluso cuando se emplean credenciales válidas o técnicas previamente desconocidas.

No obstante, la solución presenta algunas limitaciones. Su modelo de costos se basa en el volumen de datos ingeridos, lo que puede resultar elevado en organizaciones con grandes cantidades de registros. Asimismo, la integración con plataformas externas al ecosistema Microsoft puede requerir esfuerzos adicionales de configuración. Por último, existe una falta de visibilidad en el funcionamiento de sus algoritmos de detección, lo cual limita la capacidad de los administradores para auditar los fundamentos de las alertas o personalizar con precisión la lógica del sistema.

2.2.1.2 Splunk UBA

El propósito central de Splunk User Behavior Analytics (UBA) es el descubrimiento de amenazas de origen interno, vulneraciones de cuentas y desplazamientos laterales maliciosos en la red corporativa. Esta herramienta busca reconocer conductas dudosas que los sistemas convencionales, regidos por firmas fijas o reglas preestablecidas, suelen omitir.

Para lograrlo, el sistema analiza grandes volúmenes de información provenientes de diferentes fuentes de seguridad y actividad de la infraestructura. A partir de estos datos, construye perfiles de comportamiento y establece relaciones entre eventos ocurridos en distintos sistemas y momentos. Esta capacidad de correlación le permite detectar patrones complejos y asignar niveles de riesgo a las actividades observadas, ayudando a priorizar las alertas más relevantes para los equipos de seguridad.

Los datos utilizados incluyen registros de autenticación, actividad de red, logs de sistemas, accesos a recursos y otra información generada por los distintos componentes tecnológicos de la organización.

Según el fabricante, Splunk UBA mejora la identificación de amenazas avanzadas y reducir la cantidad de falsos positivos en comparación con soluciones tradicionales de detección. Además, su capacidad para correlacionar eventos a lo largo del tiempo facilita la detección de ataques que se desarrollan de forma gradual y distribuida. Cabe señalar que Splunk anunció el fin de venta de Splunk UBA como producto independiente en diciembre de 2025, con fin de soporte previsto para enero de 2027, y orienta a sus clientes hacia la capacidad UEBA integrada en Splunk Enterprise Security. El análisis se mantiene porque describe un enfoque UEBA representativo del segmento corporativo.

Sin embargo, la solución presenta algunas limitaciones. Su puesta en marcha requiere integrar y normalizar múltiples fuentes de datos, lo que demanda conocimientos especializados para su configuración. Finalmente, aunque permite detectar y priorizar riesgos, las acciones de respuesta suelen depender de integraciones externas o configuraciones adicionales, ya que no incorpora de forma nativa mecanismos de respuesta adaptativa basados en el nivel de riesgo detectado.

2.2.1.3 Exabeam

Exabeam es una plataforma de seguridad orientada a la detección y respuesta ante amenazas, especialmente aquellas relacionadas con cuentas comprometidas, actividades anómalas de usuarios y ataques que logran evadir los mecanismos de detección tradicionales. Su objetivo principal es mejorar la capacidad de los equipos de seguridad para identificar incidentes complejos y reducir los tiempos de respuesta frente a posibles compromisos.

Su funcionamiento combina capacidades de gestión de eventos de seguridad (SIEM),

análisis de comportamiento de usuarios y entidades (UEBA) y automatización de respuestas (SOAR). A partir de la información recopilada, el sistema construye perfiles de comportamiento, correlaciona eventos provenientes de múltiples fuentes y asigna niveles de riesgo a usuarios, dispositivos y actividades. Esta combinación permite detectar patrones sospechosos que podrían pasar desapercibidas cuando los eventos se analizan de forma aislada.

Los datos utilizados incluyen registros de autenticación, actividad de usuarios, eventos de red, logs de aplicaciones, sistemas de seguridad y otras fuentes de telemetría disponibles dentro de la organización. Gracias a esta diversidad de información, la plataforma puede generar una visión unificada del comportamiento observado y detectar desviaciones relevantes.

Entre los resultados reportados por el fabricante, Exabeam permite mejorar la detección temprana de amenazas y acelerar los procesos de investigación y respuesta ante incidentes. Además, una de sus características más destacadas es la flexibilidad de implementación, ya que puede funcionar tanto como una plataforma independiente como integrarse con soluciones de seguridad ya existentes, ampliando sus capacidades de análisis.

No obstante, la plataforma presenta algunas limitaciones. Al tratarse de una solución comercial de nivel empresarial, el funcionamiento interno de sus modelos de detección no es completamente transparente para los usuarios, lo que dificulta comprender con precisión cómo se generan ciertos resultados o alertas. Asimismo, su rendimiento depende en gran medida de la calidad y cantidad de los datos disponibles. Finalmente, la solución se apoya principalmente en fuentes de información ya existentes dentro de la infraestructura y no incorpora de forma nativa un agente ligero y configurable para la recolección directa de datos desde los equipos finales.

2.2.1.4 Microsoft Entra ID Protection

Microsoft Entra ID Protection es una solución orientada a la protección de identidades que busca detectar accesos potencialmente comprometidos y reducir el riesgo asociado al uso indebido de credenciales. Su objetivo principal es identificar situaciones que puedan indicar la vulneración de una cuenta y aplicar medidas de protección antes de que se produzcan accesos no autorizados a los recursos de la organización.

Su funcionamiento se basa en la evaluación continua de señales de riesgo asociadas tanto a los usuarios como a los procesos de autenticación. Para ello, analiza distintos indicadores como ubicaciones de acceso inusuales, dispositivos desconocidos, intentos de autenticación sospechosos, credenciales filtradas y otros eventos que puedan representar una amenaza para la identidad digital del usuario. A partir de esta información, la plataforma calcula niveles de riesgo que pueden utilizarse para aplicar políticas de acceso condicional o requerir mecanismos adicionales de autenticación.

Los datos utilizados provienen principalmente de eventos de autenticación, registros de actividad de usuarios, información contextual de los dispositivos y señales de seguridad

recopiladas dentro del ecosistema de identidad de Microsoft. La combinación de estas fuentes permite construir una evaluación dinámica del riesgo asociado a cada acceso.

Según el fabricante, la solución contribuye a detectar intentos de compromiso de cuentas de manera temprana y permite automatizar respuestas ante situaciones de riesgo elevado. Asimismo, la integración con políticas de acceso condicional facilita la aplicación de controles de seguridad adaptativos sin necesidad de intervención manual por parte de los administradores.

No obstante, la solución presenta algunas limitaciones. El cálculo del riesgo se encuentra fuertemente ligado a las señales disponibles dentro del ecosistema Microsoft, lo que puede restringir la visibilidad sobre comportamientos generados en sistemas externos. Además, los criterios específicos utilizados para determinar ciertos niveles de riesgo no son completamente transparentes para los usuarios de la plataforma. Finalmente, aunque la solución permite adaptar requisitos de autenticación en función del riesgo detectado, su enfoque se encuentra principalmente orientado a la protección de identidades y no al análisis profundo del comportamiento operativo de los usuarios durante el uso continuo de los recursos.

2.2.2 Trabajos académicos: modelos de detección de anomalías

Esta subsección reúne trabajos académicos que proponen modelos de detección de anomalías y de control de acceso basado en riesgo. Se agrupan en tres líneas: el control de acceso adaptativo basado en riesgo, los enfoques UEBA con aprendizaje profundo y la aplicación de Isolation Forest a la seguridad.

2.2.2.1 Control de acceso adaptativo basado en riesgo (RADAC)

El control de acceso adaptativo basado en riesgo (RADAC) se ha consolidado como una de las principales líneas de investigación para abordar los desafíos de seguridad en entornos dinámicos. Dentro de este enfoque, destaca el desarrollo de *ad-RACs* (*Adaptive Risk-Based Access Control System*), un sistema diseñado para gestionar autorizaciones de acceso en tiempo real mediante la evaluación continua del riesgo asociado a cada solicitud (Aliyu *et al.*, 2024). A diferencia de los mecanismos tradicionales, que suelen basarse en verificaciones realizadas únicamente durante la autenticación inicial, esta propuesta considera el contexto de cada interacción antes de tomar una decisión de acceso.

Para ello, el sistema recopila y analiza cuatro factores principales: el contexto del usuario, incluyendo información como la ubicación geográfica y el horario de acceso; la sensibilidad del recurso solicitado; la criticidad de la acción que se desea ejecutar; y el historial de riesgo acumulado del usuario. Estos datos son procesados por un modelo de estimación de riesgo basado en el algoritmo de aprendizaje automático CatBoost, encargado de calcular un puntaje dinámico para cada solicitud. Posteriormente, este puntaje es evaluado mediante una política de control de acceso, que determina si el nivel de riesgo es aceptable para autorizar la operación.

Con el objetivo de validar la propuesta, los autores compararon su solución con un sistema existente de referencia (MAN-SVMDT). El sistema propuesto alcanzó un recall del 100 %, frente al 98 % de la referencia, y un F1 del 98 %, frente al 96 %, aunque con una precisión menor (95 % frente a 97 %). Estos resultados indican que el modelo fue capaz de identificar correctamente los accesos potencialmente riesgosos con una leve pérdida de precisión.

Los resultados de esta investigación demuestran que es posible utilizar modelos de aprendizaje automático para apoyar decisiones de seguridad en tiempo real, incluso en entornos con restricciones de latencia. Asimismo, evidencian que la incorporación de mecanismos de evaluación dinámica del riesgo puede mejorar la capacidad de detección de accesos sospechosos y contribuir a reducir incidentes relacionados con el uso indebido de credenciales y el acceso no autorizado a información sensible.

2.2.2.2 UEBA con aprendizaje automático y aprendizaje profundo

En el ámbito del análisis de comportamiento de usuarios, se publicó una investigación centrada en el uso de algoritmos de *clustering* no supervisado para sistemas UEBA en entornos corporativos (Artioli *et al.*, 2024). El estudio evaluó más de diez algoritmos diferentes, entre ellos K-Means, DBSCAN, OPTICS y modelos basados en mezclas gaussianas, utilizando conjuntos de datos reales de actividad de red. Los resultados mostraron que los enfoques basados en densidad y *clustering* jerárquico ofrecen una mayor capacidad para adaptarse a comportamientos dinámicos y cambiantes de los usuarios, aunque a costa de un mayor consumo de recursos computacionales. Además, los autores concluyeron que la gran diversidad existente entre los perfiles de los usuarios constituye uno de los principales desafíos para construir líneas base de comportamiento estables y precisas. Como resultado, la investigación destaca que no existe un único algoritmo capaz de ofrecer el mejor rendimiento en todos los escenarios, impulsando la adopción de enfoques híbridos que combinen múltiples técnicas de detección.

LADOHD (Long-term Anomaly Detection Over Historical Data) es un framework basado en redes neuronales LSTM orientado a la detección de amenazas internas mediante el análisis secuencial de eventos en sistemas informáticos (Villarreal-Vasquez *et al.*, 2023). El modelo aprende los patrones habituales de actividad a partir de datos históricos y detecta anomalías cuando identifica eventos cuya probabilidad de ocurrencia resulta significativamente baja según el comportamiento aprendido. La propuesta fue evaluada sobre un conjunto de 38,9 millones de eventos recolectados de una red comercial compuesta por 30 equipos durante un período de 20 días, incluyendo un ataque interno de cuatro días de duración. Entre sus principales aportes destaca la capacidad de identificar secuencias de ataque prolongadas en el tiempo, incluso cuando el atacante intercala acciones maliciosas con actividad legítima para dificultar su detección. No obstante, al igual que otros enfoques basados en el comportamiento, el rendimiento del modelo depende de la disponibilidad de datos históricos suficientes para construir representaciones

confiables del comportamiento normal, lo que puede afectar su desempeño en escenarios con usuarios nuevos o con poca actividad previa, conocido como problema de *cold-start*, uno de los principales desafíos en este tipo de sistemas.

Finalmente, se ha propuesto un sistema de detección de amenazas internas basado en Heterogeneous Graph Neural Networks (HGNN) (Tian *et al.*, 2023). A diferencia de los enfoques centrados exclusivamente en secuencias de comportamiento, el modelo representa usuarios y sus relaciones mediante grafos heterogéneos, permitiendo capturar dependencias complejas y relaciones implícitas entre entidades. Los resultados obtenidos sobre el conjunto de datos CERT demostraron que la incorporación de información estructural mediante grafos mejora la capacidad de detección respecto de enfoques tradicionales. No obstante, los autores señalan que la construcción y procesamiento de grafos heterogéneos introduce una mayor complejidad computacional y de implementación.

2.2.2.3 Isolation Forest aplicado a seguridad y comportamiento de usuarios

Extended Isolation Forest es una extensión del algoritmo Isolation Forest orientada a mejorar la detección de anomalías en conjuntos de datos complejos y de alta dimensionalidad (Hariri *et al.*, 2021). Los autores demostraron que la variante propuesta reduce los sesgos presentes en la versión original del algoritmo y mejora la capacidad para identificar observaciones atípicas distribuidas en diferentes regiones del espacio de características. Los resultados obtenidos evidencian que los enfoques basados en Isolation Forest constituyen una alternativa eficiente para la detección de comportamientos anómalos en grandes volúmenes de datos. No obstante, los autores señalan que el rendimiento del modelo depende significativamente de la representación de los datos de entrada y de la correcta selección de las variables utilizadas durante el entrenamiento.

De manera complementaria, la revisión sistemática sobre técnicas de detección de anomalías en registros de eventos (Landauer *et al.*, 2023) confirma varias de las tendencias observadas en los trabajos analizados. Los autores concluyen que los modelos basados en LSTM y *Autoencoders* se encuentran entre las soluciones más utilizadas para detectar anomalías secuenciales, mientras que algoritmos como *Isolation Forest* continúan siendo una alternativa eficiente en escenarios donde se requiere baja latencia y un menor costo computacional. Asimismo, la investigación destaca que gran parte de los estudios disponibles se basan en datasets de logs de sistemas y aplicaciones, existiendo una menor cantidad de trabajos enfocados específicamente en el comportamiento de usuarios.

2.2.3 Tecnologías o enfoques alternativos

Además de los sistemas UEBA, existen otros enfoques que ajustan la verificación de identidad o el control de acceso según el contexto. Esta subsección describe la autenticación adaptativa, la autenticación continua basada en biometría conductual, el control de acceso

adaptativo basado en riesgo y las plataformas de detección y respuesta en el *endpoint*.

2.2.3.1 Autenticación adaptativa

Un ejemplo ampliamente utilizado de autenticación adaptativa en entornos empresariales es Okta Adaptive Multi-Factor Authentication (Adaptive MFA), integrada dentro de la plataforma de gestión de identidad de Okta. Esta solución aplica un modelo de autenticación basado en riesgo que analiza distintas señales contextuales cada vez que un usuario intenta iniciar sesión. Entre estas señales se incluyen la ubicación geográfica, la dirección IP, el tipo de dispositivo, el estado de la red y patrones de comportamiento previamente registrados.

A partir de esta información, el sistema estima un nivel de riesgo asociado al intento de acceso y, en función de ese valor, aplica diferentes políticas de seguridad de forma dinámica. Dependiendo del nivel de riesgo detectado, puede solicitar factores adicionales de autenticación, exigir una verificación más estricta o directamente bloquear el acceso al recurso. Esto permite ajustar el nivel de seguridad según el contexto, evitando aplicar las mismas medidas a todos los usuarios sin distinción.

Okta Adaptive MFA trabaja con señales en tiempo real para construir un perfil de riesgo del inicio de sesión, considerando indicadores como el uso de un dispositivo nuevo, una ubicación inusual o patrones de red que se desvían del comportamiento esperado. Estos elementos influyen directamente en la decisión final de permitir o restringir el acceso.

Una de las principales ventajas de este enfoque es que mejora la seguridad sin afectar de manera constante la experiencia del usuario. Solo introduce pasos adicionales cuando el sistema detecta condiciones que considera sospechosas o de mayor riesgo. Además, permite definir políticas específicas según la aplicación o el tipo de usuario, lo que aporta flexibilidad en su implementación.

Sin embargo, una limitación importante de este tipo de soluciones es que la evaluación del riesgo se concentra principalmente en el momento de la autenticación inicial. Si bien puede existir cierta re-evaluación durante la sesión, el análisis no suele ser completamente continuo ni profundiza en el comportamiento del usuario una vez que el acceso fue concedido, lo que puede dejar algunos escenarios de ataque posteriores a la autenticación sin una detección adecuada.

2.2.3.2 Autenticación continua basada en biometría conductual

Un trabajo representativo en el área de autenticación continua propone un sistema basado en la combinación de múltiples características biométricas conductuales (Stylios *et al.*, 2023). En lugar de depender únicamente de una modalidad de autenticación, el modelo integra patrones de escritura en teclado y gestos táctiles realizados sobre dispositivos móviles. El objetivo principal fue mejorar la capacidad de identificar usuarios legítimos durante toda la sesión y reducir los problemas de precisión observados en soluciones que utilizan una única fuente de información.

Para validar el enfoque, los autores desarrollaron una aplicación específica para recopilar datos reales de interacción de los usuarios y evaluaron distintos mecanismos de fusión de características. Los resultados mostraron que la combinación de múltiples señales conductuales permitió mejorar significativamente el rendimiento respecto a los modelos individuales, alcanzando tasas de autenticación más estables y reduciendo errores de clasificación (Stylios *et al.*, 2023).

Sin embargo, los investigadores también identificaron limitaciones importantes. El rendimiento del sistema depende de la disponibilidad continua de interacciones del usuario y puede verse afectado cuando los patrones de comportamiento cambian con el tiempo. Además, la recopilación constante de datos biométricos plantea desafíos relacionados con privacidad y consumo de recursos en los dispositivos.

2.2.3.3 Control de acceso adaptativo basado en riesgo

El control de acceso adaptativo basado en riesgo (RADAC), definido en la sección 2.1.4.3, ha sido impulsado dentro de las arquitecturas Zero Trust como alternativa a las decisiones basadas solo en la identidad o en permisos predefinidos, y considera además la sensibilidad del recurso, el contexto de la operación, el estado del dispositivo y otras señales de seguridad.

Una de las principales ventajas de este enfoque es su capacidad para adaptarse a escenarios cambiantes, donde las condiciones de seguridad no son estáticas y pueden variar rápidamente. Esto permite responder a situaciones que los modelos tradicionales basados únicamente en roles o atributos no contemplan de manera efectiva. Sin embargo, su implementación puede ser compleja (Xiao *et al.*, 2022), ya que requiere la recolección y análisis de grandes volúmenes de información contextual, además de mecanismos de evaluación avanzados. Esto puede aumentar la dificultad operativa del sistema y, en algunos casos, reducir la transparencia de las decisiones de acceso tomadas automáticamente.

2.2.3.4 Plataformas de detección y respuesta en el endpoint (EDR/XDR)

Las plataformas de detección y respuesta en el *endpoint* (*Endpoint Detection and Response*, EDR), y su extensión a múltiples fuentes de datos (XDR), instalan un agente en cada equipo, recolectan telemetría de procesos, archivos, red y *scripts*, y pueden responder en forma automática, por ejemplo aislando el equipo o terminando un proceso. En el segmento de pequeñas y medianas empresas, dos ejemplos representativos son Microsoft Defender for Business, incluido en la licencia Microsoft 365 Business Premium, y Wazuh, una plataforma de código abierto y uso gratuito que combina funciones de SIEM y XDR y ejecuta respuestas activas en el agente a partir de reglas.

Estas plataformas comparten con el proyecto la presencia de un agente y la capacidad de actuar en el equipo, pero difieren en el objeto de la detección: su análisis se orienta a identificar técnicas y artefactos de ataque, como la inyección de código en procesos, el volcado

de credenciales o la ejecución de *malware*. Un análisis de las evaluaciones públicas de MITRE ATT&CK sobre productos EDR comerciales concluye que estos sistemas detectan mejor las técnicas llamativas y tienen menos confianza para alertar sobre técnicas presentes en la actividad cotidiana, como la recolección de correo, el archivado de datos recopilados o la exfiltración por canales ya establecidos, porque se confunden con el comportamiento de un usuario normal (Shen *et al.*, 2024). Una evaluación empírica de productos de seguridad del *endpoint* frente a vectores de ataque de amenazas persistentes avanzadas encontró, además, que la mayoría de los ataques no fueron bloqueados ni registrados (Karantzas y Patsakis, 2021). En la misma línea, durante el ataque de *Red Team* del estudio de LADOHD, el EDR comercial en producción generó solo cuatro alertas, mientras que el modelo de comportamiento marcó como anómalos los eventos asociados al ataque (Villarreal-Vasquez *et al.*, 2023). En el caso de Wazuh, la detección se apoya principalmente en reglas y decodificadores predefinidos o escritos por el administrador, y no construye de forma nativa una línea base de comportamiento por usuario ni un puntaje de riesgo acumulado entre sesiones.

En síntesis, un EDR responde a la pregunta de si una actividad corresponde a una técnica maliciosa conocida, mientras que el enfoque UEBA responde a si un usuario con credenciales válidas se aparta de su propia conducta habitual. Ambos enfoques son complementarios: un sistema UEBA no reemplaza a un EDR, sino que apunta a la actividad que parece legítima y que el EDR tiende a dejar pasar.

2.2.4 Limitaciones reportadas por otros autores

Al analizar la literatura y las soluciones de análisis conductual existentes, se identifican diversas limitaciones recurrentes que afectan el rendimiento de los sistemas UEBA. En primer lugar, una problemática central es el marcado desbalance de clases. Diversas investigaciones recientes (Artioli *et al.*, 2024; Villarreal-Vasquez *et al.*, 2023; Sharma *et al.*, 2020) coinciden en señalar que los conjuntos de datos utilizados en ciberseguridad suelen presentar una proporción muy reducida de eventos anómalos en comparación con los eventos legítimos, representando a menudo menos del 0,03 % del total de los registros disponibles (Sharma *et al.*, 2020). Esta disparidad dificulta que los modelos aprendan a identificar amenazas reales con precisión, lo que suele derivar en un incremento notable de falsos positivos cuando se intenta maximizar la sensibilidad del sistema para no pasar por alto ninguna intrusión.

De manera complementaria, se reporta de forma consistente el problema del *cold-start* o período de arranque en frío. Un estudio (Villarreal-Vasquez *et al.*, 2023) señala que los sistemas basados en perfiles de comportamiento requieren un período inicial de aprendizaje con historial suficiente antes de poder establecer una línea base representativa del comportamiento habitual. Durante esta etapa, los usuarios nuevos, aquellos que cambian de función dentro de la organización o quienes tienen una actividad poco frecuente, carecen de perfiles históricos

completos. Esto provoca una disminución del rendimiento del sistema y un aumento de falsas alertas durante las primeras etapas de monitoreo, lo que representa un desafío operativo crítico en organizaciones con alta rotación de personal.

Otra limitación metodológica relevante es la falta de explicabilidad o el efecto de "caja negra" inherente a los modelos de aprendizaje profundo más avanzados. Investigaciones previas destacan que algoritmos como LSTM, redes basadas en grafos (GNN) y *autoencoders* ofrecen una alta capacidad de detección, pero sus mecanismos de inferencia resultan complejos de interpretar para los analistas de un centro de operaciones de seguridad (SOC) (Landauer *et al.*, 2023). Ante una alerta, determinar con exactitud qué factores contextuales o qué variaciones específicas en el orden de los eventos motivaron la asignación de un determinado puntaje de riesgo se vuelve una tarea lenta, lo que dificulta la validación rápida de los incidentes. Si bien la integración de técnicas de Inteligencia Artificial Explicable (XAI) como SHAP o LIME busca mitigar esto, su procesamiento en tiempo real dentro de flujos de datos continuos sigue siendo un desafío técnico abierto debido a la sobrecarga computacional que introducen.

Asimismo, la degradación del rendimiento del modelo ante cambios naturales y legítimos del comportamiento humano, fenómeno asociado al *concept drift*, constituye una vulnerabilidad crítica documentada en la literatura (Artioli *et al.*, 2024). Modificaciones habituales en las rutinas de los usuarios —tales como la asignación a nuevos proyectos, cambios en los horarios de trabajo, transferencias de sector o la adopción de nuevas herramientas de software— provocan que las actividades válidas difieran drásticamente de los patrones con los que el modelo fue entrenado originalmente, disparando alarmas erróneas. Aunque el reentrenamiento periódico o adaptativo se propone como la solución estándar para asimilar estos cambios, esta estrategia introduce el riesgo de contaminación gradual del modelo (*attacker-induced drift*, sección 2.1.7.2).

Finalmente, diversas investigaciones sobre Graph Neural Networks (GNN) han señalado que existe una relación directa entre la complejidad de los modelos y el costo computacional necesario para entrenarlos y ejecutarlos. Los modelos basados en grafos presentan desafíos importantes relacionados con la escalabilidad, el consumo de recursos y los tiempos de procesamiento, especialmente cuando deben operar sobre grandes volúmenes de datos o estructuras de alta complejidad (Wu *et al.*, 2021). En muchos casos, los algoritmos que ofrecen los mejores niveles de precisión requieren una mayor cantidad de recursos de procesamiento y tiempos de inferencia más elevados, lo que puede dificultar su implementación en entornos donde las decisiones deben tomarse en tiempo real.

2.2.5 Tendencias emergentes

Esta subsección describe cuatro tendencias que se observan en el área: la integración de técnicas de inteligencia artificial explicable, la operación en entornos *cloud-native*, la combinación de UEBA con plataformas de respuesta automática y el uso de modelos híbridos.

2.2.5.1 Integración de XAI en pipelines de seguridad

La incorporación de técnicas de Inteligencia Artificial Explicable (XAI) en los sistemas de detección de anomalías conductuales representa una tendencia emergente en la investigación aplicada a la seguridad. La revisión sistemática presentada en la sección 2.2.2.3 (Landauer *et al.*, 2023) señala que los modelos basados en LSTM y *autoencoders* presentan una baja interpretabilidad que dificulta su integración en flujos de trabajo operativos reales. La capacidad de explicar por qué un modelo generó una alerta resulta fundamental para que los analistas de seguridad puedan comprender, validar y actuar sobre los resultados obtenidos. Como consecuencia, una de las tendencias actuales consiste en desarrollar modelos que mantengan altos niveles de precisión sin sacrificar la capacidad de interpretar las razones que llevaron a clasificar una actividad como potencialmente riesgosa.

2.2.5.2 UEBA en entornos *cloud-native* y multiusuario

A medida que las organizaciones migran cada vez más servicios e infraestructuras hacia la nube, la investigación en análisis de comportamiento de usuarios y entidades (UEBA) ha comenzado a enfocarse en soluciones capaces de operar sobre entornos distribuidos y altamente dinámicos. En estos escenarios, uno de los principales desafíos consiste en correlacionar y analizar eventos provenientes de múltiples fuentes de información, incluyendo servicios cloud, sistemas de identidad, aplicaciones empresariales y plataformas de seguridad. Como consecuencia, una línea de trabajo del área incorpora variables contextuales adicionales, como la ubicación geográfica, el tipo de dispositivo, los patrones de acceso y las características del servicio utilizado, con el objetivo de construir modelos más precisos y adaptables. Este enfoque busca mejorar la capacidad de detección de comportamientos anómalos en entornos cada vez más distribuidos, donde los usuarios interactúan simultáneamente con múltiples aplicaciones y recursos alojados tanto en infraestructuras locales como en la nube.

2.2.5.3 Arquitecturas de respuesta autónoma (SOAR + UEBA)

Una de las tendencias más relevantes en los entornos modernos de ciberseguridad es la integración de plataformas de UEBA con soluciones de *Security Orchestration, Automation and Response* (SOAR). El objetivo de esta combinación es no solo detectar actividades sospechosas, sino también ejecutar respuestas automáticas ante posibles amenazas sin depender exclusivamente de la intervención manual de los analistas. Herramientas como Splunk SOAR, Cortex XSOAR o Microsoft Sentinel permiten automatizar tareas como la generación de alertas, el aislamiento de dispositivos, la restricción de accesos o la ejecución de procesos de verificación adicionales cuando se detectan niveles elevados de riesgo. Este enfoque busca reducir los tiempos de respuesta frente a incidentes y mejorar la capacidad operativa de los equipos de seguridad. Como

resultado, cada vez más organizaciones avanzan hacia arquitecturas capaces de tomar decisiones automáticas basadas en información contextual y análisis de comportamiento, complementando las tareas tradicionales de monitoreo con mecanismos de respuesta adaptativa.

2.2.5.4 Ensambles heterogéneos y modelos híbridos

Los trabajos presentados en las secciones 2.2.2.2 y 2.2.2.3 coinciden en que cada técnica presenta fortalezas y limitaciones según el tipo de comportamiento analizado, la calidad de los datos disponibles y el contexto operativo (Artioli *et al.*, 2024; Landauer *et al.*, 2023). Como consecuencia, una de las tendencias más importantes en la literatura actual consiste en combinar múltiples modelos dentro de una misma arquitectura, aprovechando las ventajas de cada uno. Estos enfoques híbridos suelen integrar modelos especializados en el análisis de secuencias temporales, como LSTM o GRU, con algoritmos orientados a la detección de valores atípicos, como *Isolation Forest* o *One-Class SVM*, e incluso con técnicas basadas en grafos para analizar relaciones entre usuarios, dispositivos y recursos. La combinación de estos enfoques permite construir sistemas más robustos y capaces de detectar distintos tipos de anomalías, tanto aquellas que se manifiestan a lo largo del tiempo como las que aparecen de forma puntual o aislada. Como resultado, los modelos híbridos se han consolidado como una de las principales líneas de evolución en los sistemas modernos de análisis conductual y detección de amenazas.

2.2.6 Conclusión del estado del arte

Sobre la base del análisis de las soluciones actuales del mercado y de los marcos académicos vigentes, se evidencia una carencia en la etapa final del control de acceso: la respuesta ante los incidentes. Las herramientas comerciales consolidadas operan principalmente bajo un enfoque pasivo o reactivo. La telemetría se centraliza en la nube, se procesa y, ante la detección de una anomalía, la respuesta se delega a soluciones externas, como plataformas SOAR, o requiere la intervención manual de un administrador de seguridad. Como consecuencia, se genera una ventana de exposición temporal que puede ser aprovechada por un atacante para ejecutar movimientos laterales. Las plataformas EDR/XDR sí actúan en el equipo, pero sobre técnicas maliciosas conocidas; la actividad de un atacante que opera con credenciales válidas e imita el uso legítimo queda, en buena medida, fuera de su foco (sección 2.2.3.4).

La propuesta presentada busca mitigar este punto ciego posterior a la autenticación mediante el cierre autónomo del ciclo completo del modelo RADAC. Desde una perspectiva técnica, esto se logra mediante el despliegue de un agente local en el *endpoint*, que actúa como *Policy Enforcement Point* (PEP), mientras que la lógica de decisión se mantiene en la nube como *Policy Decision Point* (PDP), siguiendo los lineamientos del estándar NIST SP 800-207 (Rose *et al.*, 2020).

El diferencial del proyecto consiste en que este agente está diseñado para mantener una

conexión con el motor de IA de la API central e interceptar la respuesta de la API casi en tiempo real. Ante una desviación conductual inusual detectada durante la sesión activa, el sistema cambia de un estado de "monitoreo y alerta" a uno de "respuesta adaptativa", ejecutando restricciones dinámicas de permisos o el aislamiento preventivo del proceso directamente en la máquina del usuario, sin intermediarios y sin depender de un *re-login*.

La relevancia del problema excede a las grandes organizaciones. El robo de credenciales afecta también a pequeñas y medianas empresas que no cuentan con un centro de operaciones de seguridad ni con presupuesto para las plataformas relevadas, que están dimensionadas y tarifadas para el segmento corporativo. Un sistema que detecta el uso indebido de una sesión válida y responde sin depender de un analista disponible acerca a ese segmento una capacidad que hoy queda fuera de su alcance, y reduce el daño que un incidente puede causar a la organización, a sus empleados y a los datos de terceros que esta administra.

3 Análisis comparativo del estado del arte

Esta sección compara el proyecto con las alternativas relevadas en el estado del arte mediante una comparación general de soluciones, una matriz de capacidades, una comparación de algoritmos de inteligencia artificial y una síntesis de diferenciadores. Luego contrasta el diseño con la práctica de profesionales de seguridad y con la percepción de usuarios finales. El análisis competitivo se completa en la sección 11 con el marketing mix, el análisis FODA, las cinco fuerzas de Porter y la matriz BCG, construidos sobre las mismas alternativas.

3.1 Comparación general de alternativas

Incluye las cuatro soluciones comerciales relevadas, la tecnología de autenticación adaptativa (Okta, tratada aparte porque no es UEBA de sesión completa sino un enfoque relacionado) y el modelo académico más cercano conceptualmente al proyecto (RADAC / ad-RACs), contra el proyecto propuesto. Cada alternativa se compara en cinco dimensiones: Tipo, Funcionalidad principal, Tecnología / IA, Alcance de monitoreo y Diferenciador del proyecto propuesto. Las tablas 3.I a 3.VII presentan esa comparación.

3.1.1 Microsoft Sentinel UEBA

TABLA 3.I: Comparación: Microsoft Sentinel UEBA

Campo	Detalle
Tipo	SIEM + UEBA integrado (nube, ecosistema Microsoft)
Funcionalidad principal	Perfiles de comportamiento de usuarios y entidades (servidores, dispositivos de red) a partir de historial; calcula puntajes de riesgo por desviación de línea base
Tecnología / IA	Algoritmos propietarios no publicados; ingesta de logs de autenticación, red, dispositivos y servicios integrados
Alcance de monitoreo	Amplio (no se limita a usuarios individuales) pero centralizado en la nube, sin agente propio en el endpoint
Diferenciador del proyecto propuesto	El proyecto ejecuta la mitigación en el propio endpoint en tiempo casi real; su lógica de *scoring* (Isolation Forest + LSTM) es propia y auditable, no una caja negra propietaria de costo variable por volumen de datos

Fuente: elaboración propia a partir del estado del arte (sección 2.2).

3.1.2 Splunk UBA

TABLA 3.II: Comparación: Splunk UBA

Campo	Detalle
Tipo	Plataforma UEBA especializada en *insider threats* y movimiento lateral
Funcionalidad principal	Perfiles de comportamiento + correlación de eventos entre sistemas y momentos distintos; prioriza alertas por riesgo
Tecnología / IA	Motor de correlación propietario; ingesta multi-fuente (autenticación, red, logs de sistema, accesos a recursos)
Alcance de monitoreo	Centralizado, depende de integración con fuentes externas; sin agente propio de recolección
Diferenciador del proyecto propuesto	Splunk UBA no incorpora de forma nativa mecanismos de respuesta adaptativa: se detiene en detectar y priorizar. El proyecto cierra el ciclo completo detección, decisión, acción, sin depender de integraciones externas

Fuente: elaboración propia a partir del estado del arte (sección 2.2).

3.1.3 Exabeam

TABLA 3.III: Comparación: Exabeam

Campo	Detalle
Tipo	SIEM + UEBA + SOAR combinado
Funcionalidad principal	Perfiles de comportamiento, correlación multi-fuente, asignación de riesgo a usuarios/dispositivos/actividades, con automatización de respuesta
Tecnología / IA	No transparente (funcionamiento interno de los modelos no público); depende de fuentes de datos ya existentes en la infraestructura
Alcance de monitoreo	Es el más cercano en concepto (incluye SOAR), pero no incorpora un agente ligero propio para recolección directa en el endpoint
Diferenciador del proyecto propuesto	El proyecto no depende de orquestar herramientas externas ya integradas para actuar: el propio agente PEP ejecuta la mitigación directamente sobre el proceso/carpeta del endpoint

Fuente: elaboración propia a partir del estado del arte (sección 2.2).

3.1.4 Microsoft Entra ID Protection

TABLA 3.IV: Comparación: Microsoft Entra ID Protection

Campo	Detalle
Tipo	Protección de identidad (IAM)
Funcionalidad principal	Evaluación continua de señales de riesgo ligadas al usuario y al proceso de autenticación; aplica políticas de acceso condicional
Tecnología / IA	Señales propias del ecosistema Microsoft (ubicación, dispositivo, credenciales filtradas)
Alcance de monitoreo	Fuertemente atado al ecosistema Microsoft; enfocado en identidad, no en comportamiento operativo continuo durante el uso de recursos
Diferenciador del proyecto propuesto	El proyecto evalúa comportamiento durante toda la sesión activa, no solo señales de autenticación, y no depende de estar dentro del ecosistema de un proveedor de identidad específico

Fuente: elaboración propia a partir del estado del arte (sección 2.2).

3.1.5 Okta Adaptive MFA

TABLA 3.V: Comparación: Okta Adaptive MFA

Campo	Detalle
Tipo	Autenticación adaptativa basada en riesgo (no es UEBA de sesión completa)
Funcionalidad principal	Estima riesgo en el momento del *login* a partir de señales contextuales (ubicación, IP, dispositivo, red, patrones previos); aplica MFA adicional o bloqueo
Tecnología / IA	Motor de riesgo propietario de Okta, señales en tiempo real al momento de inicio de sesión
Alcance de monitoreo	La evaluación se concentra principalmente en la autenticación inicial; la reevaluación durante la sesión, si existe, no suele ser completamente continua ni profundiza en el comportamiento del usuario una vez concedido el acceso (sección 2.2.3.1).
Diferenciador del proyecto propuesto	Corresponde al "punto ciego post-*login*" que el proyecto toma como justificación central: Okta Adaptive MFA no cubre lo que pasa después de que el acceso ya fue concedido

Fuente: elaboración propia a partir del estado del arte (sección 2.2).

3.1.6 RADAC académico (ad-RACs)

TABLA 3.VI: Comparación: RADAC académico (ad-RACs)

Campo	Detalle
Fuente académica	Aliyu *et al.* (2024)
Tipo	Modelo académico de control de acceso adaptativo basado en riesgo
Funcionalidad principal	Autorización de acceso en tiempo real evaluando cuatro factores: contexto del usuario, sensibilidad del recurso, criticidad de la acción, historial de riesgo acumulado
Tecnología / IA	CatBoost (ML supervisado) para el *score* de riesgo por solicitud
Alcance de monitoreo	Modelo de decisión de acceso validado frente a un sistema existente de referencia (sección 2.2.2.1), pero sin agente de *enforcement* local descrito: es una política de decisión, no una implementación de PEP en el endpoint
Diferenciador del proyecto propuesto	El proyecto es, en la práctica, una implementación *end-to-end* de este mismo paradigma RADAC, pero cerrando el circuito con un PEP real en el endpoint: no se queda en el nivel de política de decisión

3.1.7 Proyecto propuesto

TABLA 3.VII: Comparación: proyecto propuesto (fila de referencia)

Campo	Detalle
Tipo	UEBA + *enforcement* local, arquitectura PDP/PEP (NIST SP 800-207)
Funcionalidad principal	*Score* dinámico de confianza por usuario, actualizado por evento, con decaimiento temporal y continuidad entre sesiones
Tecnología / IA	Modelo híbrido propio: Isolation Forest (agregado diario) + LSTM Autoencoder (secuencias), código propio auditable
Alcance de monitoreo	Agente ligero propio en el endpoint (Windows) + motor de decisión centralizado en la nube

Campo	Detalle
Diferenciador del proyecto propuesto	No aplica (fila de referencia). La síntesis de diferenciadores se presenta en la sección 3.4.

Fuente: elaboración propia.

Las valoraciones del proyecto propuesto en esta tabla y en la matriz de capacidades son una autoevaluación del equipo basada en lo implementado y verificado en las secciones de producto y de pruebas, y no una medición externa. Las valoraciones de los competidores se basan en lo que describe el estado del arte; cuando una fuente no se pronuncia sobre una capacidad, se marca N/D.

3.2 Matriz de capacidades

La matriz verifica qué capacidades cubre cada alternativa, a partir de lo que la sección 2.2 documenta sobre cada una. Donde la fuente no se pronuncia sobre una capacidad puntual de un competidor, se marca N/D (no documentado en el relevamiento). La tabla 3.VIII resume esa verificación.

TABLA 3.VIII: Matriz de capacidades

Solución	Detección de anomalías	Score de riesgo dinámico	Continuo durante toda la sesión	Enforcement automático en el endpoint	Explicabilidad (XAI)
Microsoft Sentinel UEBA	✓	✓	N/D	△ (vía SOAR, sin agente propio)	×
Splunk UBA	✓	✓	N/D	×	N/D
Exabeam	✓	✓	N/D	△ (vía SOAR, sin agente propio)	×
Microsoft Entra ID Protection	✓	✓	×	△ (solo acceso condicional/MFA)	×
Okta Adaptive MFA	△ (solo en *login*)	△	×	△ (solo MFA/bloqueo en *login*)	N/D

Solución	Detección de anomalías	Score de riesgo dinámico	Continuo durante toda la sesión	Enforcement automático en el endpoint	Explicabilidad (XAI)
RADAC académico (ad-RACs)	✓	✓	✓(por solicitud)	△ (política de acceso, sin PEP físico)	N/D
EDR/XDR para PyMEs (Defender for Business, Wazuh)	△ (técnicas y reglas conocidas; sin línea base por usuario)	△ (por alerta o equipo, no por usuario)	✓	✓	✓(técnica o regla que disparó la alerta)
Proyecto propuesto	✓	✓	✓	✓(terminar procesos / denegar carpeta)	△ (solo Isolation Forest, las 3 variables con mayor *z-score*; LSTM sin XAI propio)

Fuente: elaboración propia a partir del estado del arte (sección 2.2); las valoraciones del proyecto propuesto son una autoevaluación del equipo.

Lectura de la matriz. Ninguna de las soluciones relevadas reúne, según lo que documenta el estado del arte, una detección orientada a la desviación de cada usuario respecto de su conducta habitual, continuidad durante toda la sesión y *enforcement* automático en el *endpoint*. Las plataformas UEBA comerciales detectan desviaciones de comportamiento pero no actúan en el *endpoint* con un agente propio, y las plataformas EDR/XDR actúan en el *endpoint* pero detectan técnicas o reglas conocidas. Esa combinación es, con la evidencia reunida, el espacio que el proyecto ocupa, con la salvedad de que, en el proyecto propuesto, la explicabilidad hoy es parcial: cubre solo el componente Isolation Forest del *score* híbrido (sección 5.4.4). De la misma manera, la marca ✓en continuidad durante toda la sesión se refiere a la arquitectura.

3.3 Comparación de algoritmos de inteligencia artificial

Esta sección profundiza la comparación general de alternativas (sección 3.1) en lo referido a los modelos de inteligencia artificial, y muestra que la elección de Isolation Forest + LSTM no es arbitraria: responde directamente a limitaciones que la propia literatura relevada reporta sobre

cada técnica por separado. Cada enfoque se compara en cinco dimensiones: Fuente académica, Dataset / validación, Métrica reportada, Limitación reportada y Relación con el diseño del proyecto. Las tablas 3.IX a 3.XV presentan esa comparación.

3.3.1 CatBoost (score de riesgo por solicitud)

TABLA 3.IX: Comparación de algoritmos: CatBoost

Campo	Detalle
Fuente académica	Aliyu *et al.* (2024) (ad-RACs)
Dataset / validación	Comparación frente a un sistema existente (MAN-SVMDT)
Métrica reportada	*Recall* 100 %, precisión 95 %, F1 98 % (referencia: *recall* 98 %, precisión 97 %, F1 96 %)
Limitación reportada	No se reporta limitación explícita en el resumen relevado
Relación con el diseño del proyecto	El proyecto comparte el paradigma de *score* dinámico por evento, con un modelo distinto (no supervisado) porque no dispone de etiquetas de "acceso autorizado/denegado" como sí tenía este trabajo

3.3.2 LSTM secuencial

TABLA 3.X: Comparación de algoritmos: LSTM secuencial

Campo	Detalle
Fuente académica	Villarreal-Vasquez *et al.* (2023)
Dataset / validación	38,9 millones de eventos de un EDR comercial (30 equipos) y un ataque de *Red Team*
Métrica reportada	Tasa de verdaderos positivos 97,29 %, tasa de falsos positivos 0,38 %
Limitación reportada	*Cold-start*: depende de historial suficiente por usuario, baja el rendimiento en usuarios nuevos
Relación con el diseño del proyecto	El proyecto usa LSTM Autoencoder con el mismo problema de *cold-start*, y lo declara explícitamente vía el estado de cobertura "parcial"/"sin *score*" en vez de ocultarlo

3.3.3 Graph Neural Networks (GNN)

TABLA 3.XI: Comparación de algoritmos: Graph Neural Networks (GNN)

Campo	Detalle
Fuente académica	Tian *et al.* (2023)
Dataset / validación	CERT r6.2
Métrica reportada	F1 +8.3 % vs. modelos secuenciales
Limitación reportada	Alta complejidad de infraestructura para grafos a gran escala
Relación con el diseño del proyecto	El proyecto evalúa ese costo de infraestructura como desproporcionado para su alcance y prioriza Isolation Forest + LSTM por menor costo computacional y viabilidad de ejecución sin infraestructura de grafos dedicada

3.3.4 Clustering no supervisado (K-Means, DBSCAN, OPTICS, GMM)

TABLA 3.XII: Comparación de algoritmos: clustering no supervisado

Campo	Detalle
Fuente académica	Artioli *et al.* (2024)
Dataset / validación	Datasets reales de actividad de red
Métrica reportada	Sin un único algoritmo ganador en todos los escenarios
Limitación reportada	Mayor consumo de recursos en enfoques de densidad; alta diversidad entre perfiles de usuario dificulta líneas base estables
Relación con el diseño del proyecto	El proyecto sigue la conclusión de este trabajo: combina dos técnicas (Isolation Forest + LSTM) en vez de apostar a un único algoritmo

3.3.5 Isolation Forest

TABLA 3.XIII: Comparación de algoritmos: Isolation Forest

Campo	Detalle
Fuente académica	Hariri *et al.* (2021)

Campo	Detalle
Dataset / validación	Datos sintéticos bidimensionales y conjuntos de referencia de detección de anomalías
Métrica reportada	Mejora del área bajo las curvas ROC y de precisión-exhaustividad respecto de Isolation Forest estándar
Limitación reportada	Isolation Forest estándar introduce artefactos en el puntaje por usar cortes paralelos a los ejes; el rendimiento depende de la representación de los datos
Relación con el diseño del proyecto	El proyecto usa Isolation Forest estándar sobre ocho variables diarias estandarizadas y lo combina con LSTM, regla de piso y decaimiento temporal; la variante extendida queda como alternativa no evaluada

3.3.6 Revisión sistemática

TABLA 3.XIV: Comparación de algoritmos: revisión sistemática

Campo	Detalle
Fuente académica	Landauer *et al.* (2023)
Dataset / validación	Múltiples datasets de logs
Métrica reportada	Concluye que LSTM/Autoencoders dominan para anomalías secuenciales; Isolation Forest sigue siendo eficiente en baja latencia
Limitación reportada	Pocos trabajos enfocados específicamente en comportamiento de usuario (vs. logs de sistema en general)
Relación con el diseño del proyecto	El proyecto combina las dos familias de técnicas que esta revisión destaca: LSTM y autoencoders para anomalías secuenciales, e Isolation Forest para baja latencia

3.3.7 Isolation Forest + LSTM Autoencoder (proyecto propuesto)

TABLA 3.XV: Comparación de algoritmos: proyecto propuesto

Campo	Detalle
Dataset / validación	CLUE-LDS: 50 522 931 eventos reales seudonimizados de 920 usuarios de una plataforma de archivos en la nube, entre julio de 2017 y septiembre de 2022 (sección 8.1). La detección se evalúa con escenarios de ataque inyectados sobre historiales reales (secciones 10.6 y 10.7).
Métrica reportada	ROC-AUC del puntaje híbrido en la partición reservada para la evaluación final (HOLDOUT, sección 10.7.2) de 0,58 a 0,80 en los escenarios sin país; la detección operativa con el umbral del nivel alto se presenta en la sección 10.7.4. Las etiquetas provienen de los escenarios inyectados, no de ataques reales.
Limitación reportada	Detección baja cuando el ataque no cambia el país; el LSTM queda cerca del azar sin país; brecha de dominio entre los registros de la plataforma en la nube y la telemetría de un equipo Windows (secciones 10.7.4 y 10.10).
Relación con el diseño del proyecto	Sigue la orientación de la literatura hacia enfoques híbridos (Artioli *et al.*, 2024; Landauer *et al.*, 2023) y usa registros reales en lugar de datos sintéticos. La evaluación muestra que, sobre este conjunto de datos, el aporte del componente LSTM es limitado (sección 10.7.4)

Fuente: elaboración propia.

3.4 Síntesis de diferenciadores

La matriz de capacidades (tabla 3.VIII) permite resumir, para cada alternativa, qué le falta respecto del ciclo de detección, decisión y respuesta que plantea la conclusión del estado del arte (sección 2.2.6):

- **Microsoft Sentinel UEBA y Splunk UBA:** detectan anomalías y asignan un *score* dinámico, pero el relevamiento no documenta una respuesta en el *endpoint*; la acción queda en manos de un analista o de integraciones externas. Sentinel, además, no expone el funcionamiento de sus algoritmos.
- **Exabeam:** automatiza la respuesta, pero mediante una plataforma de orquestación externa (SOAR) y sin un agente propio en el equipo del usuario.

- **Microsoft Entra ID Protection y Okta Adaptive MFA:** evalúan el riesgo y actúan en el momento de la autenticación (acceso condicional, MFA o bloqueo), no durante el uso continuo de los recursos.
- **RADAC académico (ad-RACs):** comparte el paradigma de *score* por solicitud, pero se queda en la política de decisión, sin un punto de aplicación en el *endpoint*.
- **Plataformas EDR/XDR para PyMEs (Defender for Business, Wazuh):** tienen agente y actúan en el equipo, pero detectan técnicas o reglas conocidas y no la desviación de un usuario respecto de su propia conducta; el proyecto se plantea como complemento y no como sustituto.

El proyecto propuesto es la única fila de la matriz que reúne detección por desviación conductual del usuario, continuidad durante la sesión y *enforcement* automático en el *endpoint*, con explicabilidad parcial. Esa combinación se apoya en la separación entre el agente, que actúa como PEP, y la API, que actúa como PDP (sección 2.2.6).

3.5 Contraste con la práctica profesional en seguridad de la información: resultados de las entrevistas

Como complemento al análisis comparativo frente a herramientas comerciales y trabajos académicos, se realiza un relevamiento cualitativo con cinco profesionales vinculados a la seguridad de la información, mediante cuatro entrevistas semiestructuradas y un cuestionario escrito, con el objetivo de contrastar las decisiones de diseño del proyecto con la práctica profesional vigente y de identificar líneas de evolución del sistema.

3.5.1 Perfil de los especialistas consultados

El grupo de entrevistados reúne perfiles con responsabilidad directa sobre seguridad y gestión de accesos en organizaciones reguladas, además de una mirada complementaria desde una función adyacente. Luciana Jacubovich, con más de veinte años de trayectoria en seguridad, lidera un equipo de siete personas en el área de operaciones de seguridad y gestión de accesos de un grupo económico financiero integrado por una aseguradora, un banco y una compañía de leasing. Guillermo Pita se desempeña como director de ciberseguridad en un organismo estatal de alcance nacional, con responsabilidad sobre miles de estaciones de trabajo y cientos de sucursales, y actúa además como perito judicial en causas vinculadas a fraude informático. Alejandro Francisco Peña ocupa un rol de responsable de seguridad en una compañía financiera regulada, con experiencia en centros de operaciones de seguridad (SOC), gestión de identidades y accesos, y prevención de fuga de información. Matías Gabriel Ruiz aporta un perfil de seguridad orientado al monitoreo y la respuesta a incidentes, con experiencia en herramientas de tipo

SIEM/XDR y en la gestión de accesos. Finalmente, Pablo Rodolfo Villarino, ingeniero DevOps con catorce años de trayectoria en IBM Argentina, participa en proyectos para el sector bancario y aporta la perspectiva de un rol técnico adyacente al de seguridad, que interactúa de forma cotidiana con los equipos de seguridad de sus clientes. Tres de los cinco entrevistados ejercen funciones de seguridad en entornos financieros o regulados de Argentina, Ruiz ejerce funciones de seguridad sin que la entrevista escrita precise la organización o el sector en que se desempeña, y Villarino ofrece una mirada externa desde una disciplina técnica vecina. Ninguno de los cinco se desempeña en una PyME: sus aportes validan el problema y las decisiones de diseño desde la práctica profesional, pero no la demanda ni la disposición a pagar del segmento al que se orienta el producto, que se tratan en la sección 12.

A diferencia de las otras cuatro, la consulta a Ruiz se realiza mediante un cuestionario escrito. Su inclusión se justifica por el rol operativo que aporta: la atención de alertas en herramientas de tipo SIEM/XDR y la ejecución de procedimientos de respuesta (playbooks), que es la perspectiva de quien recibiría las alertas del sistema propuesto. Sus respuestas sobre factores de riesgo coinciden con las del resto de los entrevistados; su aporte específico está en la secuencia de respuesta ante un incidente, que se contrasta con el catálogo de acciones del proyecto en la sección 3.5.2. Los cinco profesionales autorizaron la publicación de su nombre y de sus respuestas.

3.5.2 Validación de decisiones de diseño

Modelo de confianza cero. Pita y Peña coinciden en que la ausencia de un perímetro definido exige partir de una desconfianza estructural hacia toda acción digital, validándola más de una vez antes de asumirla legítima. Peña resume este criterio al señalar que, ante una acción del usuario, "siempre se presupone ilegítima" hasta que se descarten las alternativas mediante análisis de contexto o consulta directa. Pita plantea un principio equivalente: todo debe ser validado más de una vez, coleccionado y correlacionado en más de una oportunidad antes de tomarse como confiable. Este planteo profesional resulta coincidente con el estándar NIST SP 800-207, que constituye la base conceptual adoptada por el proyecto para su arquitectura de confianza cero.

Catálogo de acciones de respuesta. El proceso de respuesta descrito por Ruiz ante una alerta de riesgo (validación para descartar falsos positivos, recopilación de evidencia, análisis de contexto del usuario y, de corresponder, escalamiento hacia medidas como bloqueo de cuenta, revocación de sesiones, limitación de accesos o aislamiento del equipo afectado) se corresponde con la lógica escalonada de acciones adoptada en el catálogo del proyecto, que también gradúa la respuesta según el nivel de riesgo detectado, desde el registro de una alerta hasta la denegación de acceso o el aislamiento de procesos en el equipo del usuario. En la misma línea, Peña describe casos concretos de su organización donde una descarga masiva de información dispara una alerta

inmediata al equipo de seguridad, y donde la filtración de datos sensibles por parte de un usuario deriva en un bloqueo inmediato de su cuenta, reforzando la pertinencia de contar con acciones automatizadas de distinta severidad según el tipo de evento.

Variables del modelo de scoring. Consultado sobre los factores que determinan el nivel de riesgo de un usuario, Ruiz enumera el nivel de privilegios, la criticidad de la información a la que accede, el tipo de operaciones que realiza, la ubicación y el dispositivo desde el que se conecta, el horario de actividad y las desviaciones respecto de su comportamiento habitual. Este conjunto de factores es consistente con las variables ya incorporadas en el modelo de scoring del proyecto, que combina indicadores de horario, dispersión geográfica, diversidad de tipos de evento y volumen de actividad para caracterizar el comportamiento de cada usuario. Los incidentes de mayor impacto mencionados de forma independiente por los entrevistados con responsabilidad directa en seguridad (robo de credenciales y abuso de privilegios, *phishing* y filtración de datos) coinciden además con el enfoque conductual (UEBA) que orienta el diseño del proyecto.

Perfil de comportamiento individual. Jacubovich señala la conveniencia de no agrupar usuarios bajo categorías compartidas por área o función, y sostiene que cada usuario debería contar con un índice de riesgo propio que se genere y actualice de forma automática en función de su historial de comportamiento individual, en lugar de heredar un nivel de riesgo preestablecido por pertenecer a un sector de la organización. Ruiz plantea un criterio afín al señalar que una decisión de riesgo bien fundamentada requiere combinar el contexto del negocio, el perfil del usuario, su historial de comportamiento y la información proveniente de múltiples fuentes. Ambos aportes respaldan la línea base personal que el sistema mantiene para cada usuario, actualizada en forma incremental con su historial (sección 9.2.2), y la decisión de no asignar el riesgo por pertenencia a un área: el rol y el departamento obtenidos del IAM se muestran como contexto y no intervienen en el puntaje (RF-30).

3.5.3 Líneas de evolución identificadas

Alcance de la recolección de datos. Pita argumenta que el registro exhaustivo de toda la actividad de un usuario no aporta valor proporcional al esfuerzo que implica, y que resulta más eficaz acotar la observación a los objetos considerados sensibles bases de datos, sitios y recursos críticos en lugar de monitorear de manera indiscriminada cada acción individual. Esta perspectiva aporta un criterio de priorización útil para definir el alcance de los mecanismos de recolección de datos del proyecto, orientando su extensión progresiva hacia los recursos de mayor criticidad antes que hacia una cobertura total e indiferenciada de la actividad del *endpoint*.

Casos de uso correlacionados. Pita, Jacubovich y Ruiz coinciden en que el valor de la detección surge de la correlación entre eventos de distintas fuentes, más que del análisis de un evento aislado. Pita ejemplifica esta lógica con el caso de dos inicios de sesión geográficamente

distantes en un lapso breve, que en conjunto constituyen una señal de riesgo aunque cada evento por separado resulte válido, y recomienda acotar el diseño a un número reducido de casos de uso críticos antes que abarcar un conjunto extenso y poco priorizado. Jacubovich aporta un ejemplo equivalente al describir la correlación entre el registro de acceso físico de un usuario y su posterior inicio de sesión en un sistema, como control cruzado entre eventos de naturaleza distinta. Estos aportes señalan la definición de un conjunto acotado de casos de uso correlacionados entre colectores como una línea de evolución del sistema.

3.6 Contraste con la percepción de los usuarios finales: resultados de la encuesta

Como complemento al contraste con la práctica profesional, se releva la percepción de los usuarios finales mediante una encuesta, elaborada en Google Forms y difundida a través de grupos de WhatsApp. Se trata de una muestra no probabilística por conveniencia: los participantes no se seleccionan al azar de una población definida, sino entre las personas que el equipo puede alcanzar y que deciden responder. Por lo tanto, los porcentajes que siguen describen a los participantes y no pueden generalizarse a la población de empleados de empresas argentinas; se utilizan como indicio del problema y como insumo de diseño, no como estimación estadística. La muestra tampoco se estratifica por tamaño de empresa ni por sector. Además, los participantes son usuarios de equipos corporativos y no necesariamente quienes deciden la compra de herramientas de seguridad, por lo que sus respuestas informan sobre la percepción del problema y no sobre la demanda del segmento PyME. Por estos motivos, en el resto de la sección los porcentajes se refieren siempre a los participantes.

Se obtienen 240 respuestas, de las cuales 55 personas (23 %) indican no utilizar una computadora provista por su empresa y, por lógica condicional, no responden el resto de las preguntas. Por lo tanto, la base efectiva de análisis comprende 185 respuestas (77 %), correspondientes a participantes que trabajan sobre infraestructura corporativa, público objetivo del sistema propuesto. Dentro de este grupo, el 51 % (niveles 4 y 5 combinados) accede habitualmente a datos o sistemas de criticidad media-alta o alta (figuras B.1 y B.2, Anexo B).

3.6.1 La autenticación como portón, no como control continuo

Uno de los resultados más relevantes de la encuesta es que, para una parte importante de los participantes, la seguridad se concentra en el inicio de sesión. El 75 % indica que su empresa no le exige cambiar la contraseña ni usar un segundo factor (MFA) de forma constante durante la jornada: un 40 % responde que no se lo exigen y un 35 % que solo al iniciar el día. Como la pregunta reúne ambos mecanismos en una sola opción, el resultado no distingue entre ellos. Además, solo el 24 % indica que se le exige revalidar su identidad de forma repetida dentro de una misma sesión; el 39 % responde que no y el 37 % que únicamente para ciertas acciones

(figuras B.3 y B.4, Anexo B).

Asimismo, el 63 % afirma que no existen controles adicionales de identidad después del inicio de sesión o desconoce si los hay (figura B.5, Anexo B). En relación con las computadoras desatendidas, el 46 % deja la sesión abierta o no realiza ninguna acción al alejarse, mientras que el 54 % bloquea la pantalla de forma manual o automática (figura B.6, Anexo B).

Esta situación también se refleja en la percepción del riesgo: el 75 % considera que, ante el robo de credenciales, no habría forma de detectar la actividad maliciosa una vez que el atacante ingresara, o desconoce si dicha capacidad existe. Solo uno de cada cuatro (25 %) confía en que los controles actuales serían suficientes (figura B.7, Anexo B). Entre los participantes, estos resultados son consistentes con la necesidad de complementar la autenticación inicial con mecanismos de verificación continua y detección de comportamiento anómalo, como los propuestos por el enfoque Zero Trust y el modelo UEBA.

3.6.2 Confianza y percepción de protección post-login

La confianza general en los sistemas de seguridad actuales se encuentra distribuida: el 39 % manifiesta poca confianza (niveles 1-2), mientras que el 40 % expresa una confianza alta (niveles 4-5) (figura B.8, Anexo B). Al consultar específicamente por la protección posterior al inicio de sesión frente al uso indebido de una cuenta, la percepción es algo más baja: el 41 % se ubica en los niveles 1-2 y solo el 32 % en los niveles 4-5 (figura B.9, Anexo B).

Esta diferencia, aunque moderada, es coherente con la idea de que la protección post-autenticación constituye uno de los puntos más débiles percibidos por los participantes y, por lo tanto, uno de los aspectos que el sistema busca fortalecer.

3.6.3 Gobernanza y visibilidad de los controles existentes

Solo el 20 % de los encuestados afirma conocer y seguir activamente la política de seguridad informática de su empresa. El resto no la conoce en detalle (21 %), considera que existe pero no fue comunicada (29 %) o afirma que no existe (31 %) (figura B.10, Anexo B).

Una situación similar se observa respecto de la detección de comportamientos inusuales: apenas el 22 % confirma que su empresa dispone de un mecanismo activo para detectar accesos anómalos a información, mientras que el 78 % restante no está seguro o considera que no existe (figura B.11, Anexo B). Esto evidencia no solo posibles limitaciones en los controles existentes, sino también un déficit de comunicación y visibilidad que debería ser considerado en la adopción de nuevas herramientas de seguridad.

3.6.4 La respuesta percibida como menos disruptiva no es la más restrictiva

La importancia asignada a que las herramientas actúen preventivamente mediante bloqueos, en lugar de limitarse a generar alertas, se inclina hacia los niveles altos: el 48 % la ubica

en los niveles 4-5 (25 % en el máximo), el 21 % en el nivel intermedio y el 31 % en los niveles 1-2, sin que exista un consenso amplio (figura B.12, Anexo B).

Sin embargo, ante un escenario de riesgo moderado, el 37 % considera que una notificación push para confirmar la identidad sería la respuesta menos disruptiva, seguida por el bloqueo temporal de la aplicación (32 %) y la reautenticación biométrica (30 %) (figura B.13, Anexo B). La diferencia entre las tres opciones es acotada. El resultado es consistente con un esquema de respuesta graduada como el del sistema: cada uno de los cuatro niveles de riesgo (bajo, medio, alto y crítico) puede asociarse a una acción distinta del catálogo, y esa asociación no está fijada por el sistema, sino que la define el administrador desde el panel (RF-14). La configuración por defecto reserva las acciones restrictivas para el nivel crítico (RF-07). La confirmación por notificación push no forma parte del catálogo actual de acciones; el resultado orienta su evolución. La distribución de las respuestas sugiere que la respuesta debería ajustarse al nivel de riesgo en lugar de aplicar siempre la máxima restricción.

3.6.5 Las funcionalidades priorizadas y su cobertura en el sistema

Al consultar las funcionalidades prioritarias de un sistema de monitoreo de comportamiento, los resultados son relativamente equilibrados, con porcentajes de selección entre el 52 % y el 62 %: detección de horarios anómalos (62 %), procesos no habituales (61 %), restricción automática de acceso (61 %), historial de auditoría completo (58 %), accesos inusuales a archivos (55 %) y alertas inmediatas a IT (52 %) (figura B.14, Anexo B).

La ausencia de una funcionalidad claramente dominante sugiere que los participantes valoran un sistema integral. El sistema cubre esas fuentes de forma desigual. El agente recolecta la actividad de procesos y de archivos, el modelo considera el horario de la actividad y el sistema ofrece la denegación de acceso a carpetas, el historial de puntajes y la notificación al administrador. Sin embargo, el modelo no evalúa el nombre del proceso ni del archivo, sino el volumen, la diversidad y el horario de la actividad (sección 8.4), por lo que los procesos no habituales y los accesos inusuales a archivos se recolectan, pero no se detectan como tales.

3.6.6 Factores de adopción: sin un factor dominante

En cuanto a los factores que podrían determinar la adopción del sistema, la garantía de privacidad y legalidad es la opción menos seleccionada (13 %), por debajo de la recomendación de proveedores (21 %), la facilidad de integración (18 %), la reacción de los empleados (18 %), la eficacia demostrada (17 %) y el costo (14 %) (figura B.15, Anexo B). Los porcentajes se distribuyen sin un factor claramente dominante. Esto no implica que la privacidad sea poco relevante: una lectura posible, que estos datos no permiten verificar, es que funcione como un requisito previo. Dado que la reacción de los empleados figura entre los factores más mencionados, resulta relevante comunicar qué información se recolecta y con qué finalidad; en este sentido, la

explicación que acompaña a cada evento (sección 5.4.4) constituye un elemento relevante para la adopción del sistema. El tratamiento de los datos personales que realiza el sistema y su encuadre en la Ley 25.326 se analizan en la sección 9.4.

3.6.7 Inclinación favorable entre los participantes, sin consenso

La percepción sobre la probabilidad de adopción del sistema por parte de la propia empresa se inclina levemente hacia el lado favorable: el 43 % la considera probable (niveles 4-5), el 23 % se ubica en el punto medio y el 34 % la considera improbable (niveles 1-2) (figura B.16, Anexo B).

Por lo tanto, los resultados no muestran un consenso favorable, sino una oportunidad acompañada de una resistencia significativa. Esto coincide con lo observado en las entrevistas a expertos (sección 3.5) y con el análisis FODA/Porter de la sección 11, donde se identifica un mercado con potencial de crecimiento, pero con una adopción condicionada por factores como la reacción de los empleados y la confianza en el proveedor.

3.6.8 El costo de la detección tardía

En relación con incidentes de seguridad ocurridos previamente, solo el 39 % de quienes poseen información al respecto (155 de las 185 respuestas; se excluye a quienes responden *no aplica / no tengo información*) estima que fueron detectados durante las primeras 24 horas. El resto señala períodos de días, semanas o meses, o incluso casos en los que la detección ocurrió únicamente cuando el daño ya era visible (19 %) (figura B.17, Anexo B).

Este resultado aporta un indicio, entre los participantes, del problema que motiva el proyecto: la distancia temporal entre el compromiso de una cuenta y su detección puede ser considerable. El scoring continuo con decaimiento temporal busca precisamente reducir esta ventana de exposición.

3.6.9 Síntesis

En conjunto, los resultados de la encuesta son consistentes con la premisa central del proyecto: la autenticación continúa siendo percibida por los participantes principalmente como un evento puntual y no como una garantía sostenida durante la sesión. Los resultados también son consistentes con varias decisiones de diseño: las funcionalidades del sistema cubren la mayoría de las fuentes que priorizan los participantes, aunque el modelo no distingue procesos ni archivos inusuales por su nombre, la respuesta graduada por niveles de riesgo se alinea con la preferencia por mecanismos menos disruptivos y la necesidad de explicabilidad resulta relevante dado el peso que los participantes asignan a la reacción de los empleados. Estas coincidencias describen a los 185 participantes de una muestra por conveniencia y no permiten estimar proporciones en la población de empleados de empresas argentinas ni en el segmento PyME.

Al mismo tiempo, la encuesta plantea dos desafíos para la adopción: la confianza en el proveedor y la reacción de los empleados tienen, para los participantes, mayor peso que la garantía de privacidad como criterio de decisión, y una parte significativa (34 %) considera improbable que su empresa adopte un sistema de este tipo, además del 23 % que se ubica en una posición intermedia. Por lo tanto, las respuestas sugieren una oportunidad para este tipo de solución, pero su adopción dependerá tanto de sus capacidades técnicas como de la confianza y aceptación que logre generar.

4 Requerimientos, casos de uso e historias de usuario

Esta sección presenta el análisis funcional del sistema. Se delimita primero el alcance del relevamiento y los actores que intervienen, y luego se especifican los requerimientos funcionales y no funcionales, los cuatro casos de uso y las historias de usuario que los detallan.

4.1 Alcance del relevamiento

Esta sección presenta el análisis funcional del sistema, compuesto por tres elementos: un agente local (PEP), una API central (PDP) que calcula un puntaje de riesgo (*score*) dinámico mediante un modelo híbrido Isolation Forest + LSTM Autoencoder, y un *dashboard* para visualizar el estado de los usuarios y administrar las políticas. Las funciones de cada componente se detallan en la sección 4.2 y su arquitectura, en la sección 7.1.

El análisis se organiza en cuatro casos de uso que abarcan la lógica de negocio del sistema: detección y mitigación (CU-01), ajuste de políticas (CU-02), reentrenamiento periódico del modelo (CU-03) y alta de usuarios nuevos con período de aprendizaje (CU-04). La integración con sistemas de gestión de identidad (IAM) se aborda como un módulo transversal.

4.2 Actores del sistema

En el sistema intervienen siete actores: tres humanos, tres internos y uno externo.

Entre los actores humanos, el administrador de seguridad opera el *dashboard* con el rol *admin*. Sus funciones incluyen monitorear a los usuarios, ajustar umbrales y políticas, configurar el reentrenamiento y consultar la auditoría. El analista de seguridad accede con el rol *operador*, de solo lectura, y consulta el historial y las explicaciones de los puntajes para fundamentar decisiones posteriores. Por su parte, el usuario monitoreado es un actor indirecto: genera actividad en su *endpoint* y constituye el sujeto de observación, pero no interactúa directamente con el sistema.

Los actores internos son el agente local (PEP), que recolecta metadatos de actividad, los envía a la API y ejecuta y confirma las acciones de mitigación en el *endpoint*; la API de *scoring* (PDP), que calcula el puntaje de riesgo, aplica el decaimiento temporal, asigna el nivel de riesgo y decide la acción de mitigación; y el planificador del sistema, que activa el reentrenamiento periódico del modelo según la periodicidad configurada. Finalmente, el proveedor IAM es un sistema externo que proporciona, de forma opcional, el rol y el departamento del usuario monitoreado.

4.3 Requerimientos funcionales

Los requerimientos funcionales, identificados de RF-01 a RF-31, se organizan en siete módulos (tablas 4.I a 4.VII). Los seis primeros dan soporte directo a uno de los cuatro casos

de uso definidos en la sección 4.5; el séptimo, de integración con sistemas IAM, es transversal. Junto a cada identificador se indica la prioridad asignada. Los 31 requerimientos se encuentran implementados; cuando la implementación o su verificación presentan alguna salvedad, esta se indica en la columna de estado o en las notas al pie de cada tabla.

4.3.1 Módulo 1: Agente local y recolección de telemetría (CU-01)

TABLA 4.I: Requerimientos funcionales del Módulo 1

ID	Requerimiento	Prioridad	Estado
RF-01	El agente local (PEP) debe ejecutarse en segundo plano y recolectar metadatos de actividad del usuario: procesos ejecutados (incluidas las aplicaciones de una lista vigilada), cambios en los archivos del primer nivel de las carpetas vigiladas (alta, baja, modificación y renombre) y conexiones a recursos de red. No captura contenido, pantallas ni pulsaciones de teclado. Los metadatos incluyen nombres de archivo y de proceso, IP y puerto remotos y el identificador host-usuario.	Alta	Implementado
RF-02	El agente debe enviar los eventos recolectados a la API central por un canal autenticado, identificándose con una clave propia por agente, y conservarlos en un *buffer* local cuando la API no esté disponible.	Alta	Implementado (ver nota a)

Fuente: elaboración propia.

4.3.2 Módulo 2: Motor de scoring y decisión (CU-01)

TABLA 4.II: Requerimientos funcionales del Módulo 2

ID	Requerimiento	Prioridad	Estado
RF-03	La API debe calcular, para cada evento recibido, un puntaje de riesgo en escala 0–100 mediante el modelo híbrido Isolation Forest + LSTM Autoencoder. Con cobertura completa se combinan ambos modelos en partes iguales; con cobertura parcial (el usuario aún no completó una secuencia de 50 eventos de tipo conocido para el LSTM) se utiliza solo Isolation Forest. Los identificadores de tipo dirección IP y las cuentas de volumen muy alto (más de 500 000 eventos) quedan sin puntaje.	Alta	Implementado

ID	Requerimiento	Prioridad	Estado
RF-04	El puntaje debe mantener continuidad entre sesiones del mismo usuario y aplicar un decaimiento temporal del riesgo acumulado según el tiempo transcurrido sin actividad. El decaimiento se aplica al cerrar cada día calendario; dentro del día el puntaje es provisional y no modifica el acumulado. El decaimiento tiene una vida media de 3 días. La vida media es fija: se define en la configuración del modelo al entrenarlo y no se modifica en tiempo de ejecución.	Alta	Implementado
RF-05	La API debe asignar a cada evento un nivel de riesgo a partir de los umbrales vigentes (por defecto: bajo $[0,40)$, medio $[40,70)$, alto $[70,90)$ y crítico $[90,100]$).	Alta	Implementado
RF-06	La API debe aplicar una regla de piso que eleve el nivel mínimo (por defecto, alto) cuando al menos uno de los dos modelos marca anomalía, evitando que la combinación diluya una señal fuerte.	Media	Implementado
RF-07	La API debe devolver al agente, en la respuesta del evento, la acción de mitigación correspondiente al nivel asignado según el mapeo nivel $\rightarrow$ acción vigente. Mapeo por defecto: bajo, medio y alto $\rightarrow$ `alertar`; crítico $\rightarrow$ `terminar_y_denegar` (configurable, RF-14).	Alta	Implementado

Fuente: elaboración propia.

4.3.3 Módulo 3: Respuesta adaptativa y mitigación (CU-01)

TABLA 4.III: Requerimientos funcionales del Módulo 3

ID	Requerimiento	Prioridad	Estado
RF-08	El sistema debe ofrecer un catálogo de acciones de mitigación: `alertar`, `terminar_procesos`, `denegar_carpeta`, `terminar_y_denegar`, `suspender_proceso` (reversible) y `notificar_admin`. Esta última no ejecuta ninguna acción en el agente: el correo lo dispara la configuración de niveles que notifican (RF-15).	Alta	Implementado
RF-09	El estado vigente de cada usuario (último puntaje, nivel, acción y explicación) y una lista acotada de eventos recientes se mantienen en Redis. El historial diario (PostgreSQL) guarda una fila por día cerrado con puntaje, nivel, acción sugerida, explicación y motivo del último evento del día. Los eventos crudos se persisten uno por uno, sin puntaje.	Alta	Implementado

ID	Requerimiento	Prioridad	Estado
RF-10	El agente debe ejecutar localmente la acción recibida, sin requerir un nuevo inicio de sesión del usuario, y confirmar a la API el resultado de las acciones que modifican el equipo (`terminar_procesos`, `denegar_carpeta`, `terminar_y_denegar` y `suspender_proceso`); `alertar` y `notificar_admin` no requieren confirmación.	Alta	Implementado
RF-11	El agente debe permitir revertir las acciones de mitigación aplicadas (restitución de permisos de carpeta y reanudación de procesos suspendidos).	Media	Implementado; la terminación de procesos no es reversible (ver RNF-06)

Fuente: elaboración propia.

4.3.4 Módulo 4: Panel de administración y gestión de políticas (CU-02)

TABLA 4.IV: Requerimientos funcionales del Módulo 4

ID	Requerimiento	Prioridad	Estado
RF-12	El administrador debe poder modificar desde el *dashboard* los umbrales que delimitan cada nivel de riesgo, con validación de rangos contiguos y sin solapamiento. La dimensión "rol" en los umbrales queda fuera del alcance.	Alta	Implementado
RF-13	La API trabaja con cuatro niveles de riesgo (bajo, medio, alto y crítico), cuyo orden se deriva de los umbrales configurados. La definición de una cantidad distinta de niveles y un motor de reglas libres, sin orden entre niveles, quedan fuera del alcance.	Media	Implementado
RF-14	El administrador debe poder configurar qué acción de mitigación se ejecuta para cada nivel de riesgo, validada contra los niveles vigentes.	Alta	Implementado
RF-15	El administrador debe poder configurar qué niveles de riesgo disparan una notificación por correo, con un intervalo mínimo entre notificaciones por usuario (10 minutos por defecto, definido en la configuración del servidor).	Media	Implementado
RF-16	El *dashboard* debe mostrar el listado de usuarios monitoreados con su puntaje, nivel, estado de aprendizaje e historial, y el detalle de los eventos recientes de cada uno.	Alta	Implementado

ID	Requerimiento	Prioridad	Estado
RF-17	La API debe registrar cada cambio de política (umbrales, acciones, notificaciones, reentrenamiento y umbral de aprendizaje) en un historial en el que la aplicación solo inserta, con fecha, valores anteriores y nuevos e identificador del actor (el rol de la sesión del panel o, para las claves que usan los scripts, un identificador derivado de la clave), consultable desde una vista de auditoría.	Media	Implementado
RF-31	La API puede asistir la redacción del correo de notificación con un modelo de lenguaje externo, que recibe el identificador del usuario, el puntaje, el nivel, las variables que lo explican y los eventos recientes de la alerta; si el servicio no está configurado o no responde, se utiliza un texto predefinido. El modelo solo redacta el correo: no interviene en el nivel ni en la acción (RNF-04).	Baja	Implementado (ver nota a)

Fuente: elaboración propia.

Notas:

a) Servicio opcional, con texto predefinido de respaldo y con controles de entrada y de salida (sección 9.2.3).

4.3.5 Módulo 5: Ciclo de vida del modelo y reentrenamiento (CU-03)

TABLA 4.V: Requerimientos funcionales del Módulo 5

ID	Requerimiento	Prioridad	Estado
RF-18	El administrador debe poder configurar la periodicidad (1 a 365 días) y la ventana horaria del reentrenamiento; el planificador solo dispara el proceso dentro de esa ventana.	Baja	Implementado
RF-19	El sistema debe registrar los eventos crudos que recibe y, en cada reentrenamiento, exportar todos los acumulados (sin los de prueba, de demostración ni las repeticiones del conjunto original) junto con el conjunto de datos original, como insumo del *pipeline* de reentrenamiento.	Alta	Implementado
RF-20	El reentrenamiento debe ejecutarse en un proceso aislado del que atiende producción, disparado por un planificador cuando se cumple la periodicidad configurada.	Alta	Implementado
RF-21	El sistema debe promover el modelo nuevo solo si no es inferior al vigente en la detección de escenarios de referencia (ROC-AUC medio no menor que el del vigente menos 0,02 y tasa de falsos positivos en nivel alto no mayor que la del vigente más 0,01), reemplazándolo sin reiniciar la API.	Alta	Implementado

ID	Requerimiento	Prioridad	Estado
RF-22	El sistema debe registrar cada reentrenamiento (fecha, eventos utilizados, variación de métricas y actor) y mostrarlo en el *dashboard*; también admite la carga manual de un reentrenamiento.	Baja	Implementado

Fuente: elaboración propia.

4.3.6 Módulo 6: Alta de usuario nuevo y cold-start (CU-04)

TABLA 4.VI: Requerimientos funcionales del Módulo 6

ID	Requerimiento	Prioridad	Estado
RF-23	El sistema debe dar de alta automáticamente a un usuario no registrado al recibir su primer evento, sin intervención del administrador.	Alta	Implementado
RF-24	Todo usuario nuevo debe quedar en estado “en aprendizaje” hasta acumular un umbral de eventos configurable en tiempo de ejecución (por defecto 20, rango 1 a 1000). El mismo umbral define la cantidad mínima de eventos a partir de la cual la línea base personal del usuario pondera en el puntaje.	Alta	Implementado
RF-25	Durante el aprendizaje, el sistema debe atenuar la acción de mitigación (no el nivel informado), forzándola a `alertar`, salvo para eventos sobre recursos sensibles (eventos de archivo: creación, escritura, renombrado y borrado), que se tratan con la política normal. La notificación por correo no se atenúa.	Alta	Implementado
RF-26	El *dashboard* debe indicar qué usuarios están en aprendizaje y su progreso respecto del umbral, a partir del estado que expone la API.	Media	Implementado
RF-27	La transición de “en aprendizaje” a monitoreo normal debe ser automática al alcanzar el umbral.	Media	Implementado

Fuente: elaboración propia.

4.3.7 Módulo 7: Integración con sistemas IAM (transversal)

TABLA 4.VII: Requerimientos funcionales del Módulo 7

ID	Requerimiento	Prioridad	Estado
RF-28	La API debe poder consultar a un proveedor IAM, Keycloak, el rol y el departamento del usuario monitoreado, mediante un adaptador seleccionable por configuración y desactivado por defecto. Ante cada cambio de nivel de riesgo, la API informa el nuevo nivel a Keycloak y, en nivel crítico, le solicita el cierre de las sesiones del usuario.	Media	Implementado; Keycloak validado contra un servidor real
RF-29	La respuesta del proveedor IAM debe almacenarse en caché durante 30 minutos y, ante una falla o indisponibilidad del proveedor, el cálculo del puntaje debe continuar sin ese contexto.	Media	Implementado
RF-30	El contexto obtenido del proveedor IAM debe conservarse como último valor por usuario e incluirse en la respuesta del evento evaluado y mostrarse en el detalle del usuario del *dashboard*, como información para el administrador; no es una variable de entrada del modelo.	Baja	Implementado

Fuente: elaboración propia.

4.4 Requerimientos no funcionales

Los requerimientos no funcionales son transversales a los casos de uso y definen criterios de calidad del sistema en su conjunto. La tabla 4.VIII los resume; las notas al pie amplían el estado de los que lo requieren.

TABLA 4.VIII: Requerimientos no funcionales

ID	Categoría	Requerimiento	Estado
RNF-01	Rendimiento	La evaluación de un evento debe completarse en tiempo casi real: percentil 95 de la latencia extremo a extremo menor o igual a 500 ms y percentil 99 menor o igual a 1 s, en red local.	Implementado: p95 de 14,9 ms y p99 de 148,9 ms en entorno local; la medición extremo a extremo en la nube se informa aparte (p95 de 3,1 s)
RNF-02	Eficiencia	El agente opera con un consumo acotado que preserva el uso normal del equipo: consumo medio de CPU menor o igual al 5 % de la máquina y memoria residente menor o igual a 150 MB.	Implementado: CPU media 0,09 % y memoria residente de 33 MB

ID	Categoría	Requerimiento	Estado
RNF-03	Seguridad	Toda operación de configuración debe requerir autenticación de administrador, y el acceso al *dashboard* requiere inicio de sesión.	Implementado
RNF-04	Seguridad / arquitectura	La decisión de riesgo se origina siempre en el motor de *scoring* central (PDP); el agente (PEP) ejecuta únicamente la acción que el PDP indica para cada evento, conforme a la separación entre PEP y PDP de NIST SP 800-207.	Implementado
RNF-05	Disponibilidad	Ante una caída de la API o un error de autenticación, el agente continúa el monitoreo y conserva los eventos no enviados en un *buffer* local acotado (vigencia de 3 horas y tope de 20 000 eventos), que reenvía al restablecerse la conexión, con reintentos y un mecanismo de *circuit breaker*.	Parcial: descarte por vigencia y tope
RNF-06	Reversibilidad	Las acciones de mitigación deben poder revertirse siempre que el sistema operativo lo permita.	Implementado
RNF-07	Configurabilidad	Umbrales, acciones, notificaciones, umbral de aprendizaje y reentrenamiento deben poder modificarse en tiempo de ejecución, sin reiniciar ni redesplegar componentes.	Implementado
RNF-08	Privacidad	El agente recolecta exclusivamente metadatos de actividad: nombres de archivo y de proceso, dirección y puerto remotos, marca temporal e identificador del par equipo-usuario, identificador del agente, identificador de proceso en las conexiones de red, código de país, indicador de IP local y, en los renombrados, el nombre anterior.	Implementado
RNF-09	Integridad y trazabilidad	Los eventos crudos deben almacenarse con encadenamiento de *hashes* verificable, con validación de tipos, formato, ventana temporal, identificadores reservados y tamaño en la ingesta.	Parcial: cadena verificada manualmente, sin test automatizado ni inmutabilidad; esquema no estricto
RNF-10	Aislamiento	El reentrenamiento se ejecuta en un proceso aislado que preserva la disponibilidad y la latencia del servicio de *scoring* en producción.	Implementado
RNF-11	Explicabilidad	Cada puntaje debe acompañarse de una justificación legible (principales variables que lo explican) y persistirse en el historial.	Parcial: cubre Isolation Forest; LSTM sin explicación

ID	Categoría	Requerimiento	Estado
RNF-12	Portabilidad / despliegue	El agente corre como un proceso nativo por dispositivo Windows, sin servidor propio ni contenedores.	Implementado
RNF-13	Confidencialidad en tránsito	La comunicación entre el agente y la API debe viajar cifrada mediante TLS.	Implementado en el despliegue
RNF-14	Concurrencia	El motor de *scoring* debe atender eventos concurrentes de múltiples usuarios manteniendo el estado de cada usuario consistente e independiente.	Implementado
RNF-15	Usabilidad	El *dashboard* debe representar el nivel de riesgo de cada usuario con indicadores visuales consistentes (color y etiqueta) en todas las vistas, para priorizar de un vistazo.	Implementado; evaluación heurística en la sección de pruebas

Fuente: elaboración propia.

4.5 Casos de uso

Esta sección describe los cuatro casos de uso del sistema: la detección de desviaciones conductuales con mitigación automática en el *endpoint* (CU-01), el ajuste de umbrales y políticas de respuesta (CU-02), el reentrenamiento periódico del modelo (CU-03) y el alta de usuarios nuevos con período de aprendizaje (CU-04). Para cada uno se describen los actores, el disparador y las precondiciones, el flujo principal y sus alternativas, el resultado esperado y los requerimientos e historias de usuario con que se vincula.

4.5.1 CU-01: Detección de desviación conductual y mitigación automática en el endpoint

El actor principal de este caso de uso es el agente local (PEP), mientras que la API de *scoring* (PDP) actúa como actor secundario. El caso se inicia cuando el usuario realiza una actividad en el equipo monitoreado: ejecuta un proceso, crea, modifica, renombra o elimina un archivo en una carpeta vigilada, o se conecta a un recurso de red. Como precondiciones, el agente debe estar instalado y autenticado ante la API mediante su clave, y los modelos deben estar cargados.

El flujo comienza cuando el agente captura el evento y lo envía a la API. Esta valida su estructura, descarta los reenvíos duplicados, actualiza el estado del usuario y persiste el evento sin procesar. Luego calcula el puntaje de riesgo mediante el modelo híbrido, lo combina con la línea base personal del usuario, aplica el decaimiento temporal y asigna el nivel correspondiente según los umbrales vigentes y la regla de piso. A continuación, genera la explicación del puntaje y determina la acción de mitigación según el mapeo nivel $\rightarrow$ acción.

Si hay un proveedor IAM configurado, la API también consulta el rol y el departamento

del usuario, utilizando caché y mecanismos de tolerancia a fallas. Esta integración es opcional y está desactivada por defecto. La información obtenida se muestra en el detalle del usuario en el *dashboard*, pero no interviene en el cálculo del puntaje. En sentido inverso, cuando el nivel de riesgo del usuario cambia, la API informa el nuevo nivel al proveedor IAM (en Keycloak, el atributo `ueba_risk_level`) y, si el nivel es crítico, le solicita cerrar las sesiones abiertas del usuario. Con nivel alto o crítico, Keycloak exige un segundo factor (OTP) en el próximo inicio de sesión, mediante su propia configuración. Si el proveedor no responde, el evento se evalúa igualmente y la sincronización se reintenta en un evento posterior. Una vez completado el procesamiento, la API responde al agente con el puntaje, el nivel de riesgo y la acción correspondiente. El agente ejecuta esta última localmente y, si modifica el equipo, confirma el resultado a la API. Además, cuando el nivel asignado tiene habilitadas las notificaciones, la API envía un correo al administrador antes de responder. Si el envío falla, la respuesta no se ve afectada; sin embargo, una demora del servidor de correo puede retrasarla.

El flujo contempla cuatro situaciones alternativas. Si la API no está disponible, el agente almacena el evento en el *buffer* local y reintenta el envío. Si la API rechaza la clave del agente, se activa el *circuit breaker* y el reenvío de los eventos pendientes pasa a realizarse mediante sondeos cada cinco minutos, mientras el agente continúa monitoreando la actividad. Si el evento corresponde a un usuario nuevo, el cálculo del puntaje sigue el flujo definido en CU-04. Por último, si el sistema operativo no permite ejecutar la acción de mitigación, el agente informa el error y este queda registrado.

Al finalizar, el evento queda registrado y su puntaje, nivel, acción y explicación se conservan en la lista acotada de eventos recientes. Además, el último evento de cada día se incorpora al historial diario. El resultado de la mitigación, tanto si se aplica correctamente como si falla, queda reflejado en la última confirmación de acción del usuario.

Este caso de uso se relaciona con los requerimientos RF-01 a RF-11 y RF-28 a RF-30, así como con las historias de usuario HU-01 a HU-04, HU-15 y HU-16. Su principal valor diferencial es que integra la detección, la decisión y la ejecución de la acción de mitigación en el propio *endpoint*, sin intermediarios ni necesidad de un nuevo inicio de sesión (sección 2.2.6).

4.5.2 CU-02: Ajuste de umbrales y políticas de respuesta

El actor principal es el administrador de seguridad, quien necesita ajustar la sensibilidad del sistema y definir las respuestas asociadas a cada nivel de riesgo. La única precondición es haber iniciado sesión en el *dashboard*.

Desde el *dashboard*, el administrador consulta el estado de los usuarios y la configuración vigente. A partir de esta información, puede modificar los umbrales de riesgo, las acciones asociadas a cada uno y los niveles para los que se deben generar notificaciones. Una vez enviados los cambios a la API, esta valida la coherencia de la política, verificando que los rangos sean

contiguos, que existan exactamente cuatro niveles, y que las acciones y la regla de piso sean consistentes con los niveles definidos. Si la configuración es válida, la API persiste la nueva política, registra el cambio en la auditoría y aplica la configuración actualizada a la evaluación de los eventos siguientes.

El caso de uso contempla dos flujos alternativos. Si el token de sesión es inválido, está vencido o pertenece a un usuario sin permisos de administración, la API rechaza la operación con un código HTTP 401 o 403, según corresponda. La autorización se verifica siempre en la API, a partir del rol asociado al token, por lo que la sesión del *dashboard* no sustituye esta validación. Por otro lado, si la configuración no cumple las reglas establecidas, la API rechaza el cambio e informa el motivo mediante un mensaje específico, sin modificar la política vigente.

Como resultado, la nueva política queda activa sin necesidad de reiniciar los servicios y el cambio queda registrado en la auditoría. Este caso de uso se relaciona con los requerimientos RF-12 a RF-17 y RF-31, así como con las historias de usuario HU-05 a HU-07 y HU-14. Su principal aporte es permitir que el administrador adapte la configuración a distintos contextos de seguridad sin depender del equipo de desarrollo y defina respuestas graduales según el nivel de riesgo, en línea con la preferencia por medidas menos disruptivas identificada en la encuesta (sección 3.6).

4.5.3 CU-03: Reentrenamiento periódico del modelo

El actor principal es el planificador del sistema, mientras que el administrador de seguridad participa como actor secundario. El caso de uso se activa cuando se cumple el período configurado desde el último reentrenamiento registrado, siempre que el planificador se encuentre dentro de la ventana horaria definida. Como precondiciones, el reentrenamiento automático debe estar habilitado y deben existir eventos crudos registrados en la base de datos. Sin embargo, el planificador no verifica si se incorporaron eventos nuevos desde el último entrenamiento.

Cuando detecta que corresponde reentrenar, el sistema exporta los eventos crudos acumulados junto con el conjunto de datos original, adaptándolos al formato requerido por el *pipeline* de entrenamiento. Este se ejecuta en un proceso aislado. Una vez generado el nuevo modelo, el sistema evalúa tanto este como el modelo vigente sobre los mismos escenarios de referencia. Si el nuevo modelo cumple el criterio de promoción, es decir, si su desempeño no resulta inferior al permitido, se incorpora como modelo vigente sin necesidad de reiniciar la API. Finalmente, el sistema registra el reentrenamiento, incluyendo la fecha, los eventos utilizados y la variación de las métricas obtenidas.

Como alternativa al disparo automático, el administrador de seguridad puede registrar manualmente un reentrenamiento realizado fuera del planificador. Si se produce un fallo en algún paso del *pipeline*, se restauran los artefactos del modelo vigente, que continúa en servicio. Si el *pipeline* falla, termina por una excepción o supera el tiempo máximo configurado, el intento se

registra como fallido, con su motivo, y se restauran los artefactos del modelo vigente.

Por otra parte, si el nuevo modelo no cumple el criterio de promoción, faltan escenarios de referencia, el corte temporal no coincide con el esperado o se produce un error durante el cálculo de las métricas, el sistema rechaza la promoción, conserva el modelo vigente y registra el motivo del rechazo.

Al finalizar el proceso, el modelo vigente se mantiene o se actualiza según el resultado de la evaluación, y el reentrenamiento queda registrado cuando corresponde. Este caso de uso se relaciona con los requerimientos RF-18 a RF-22 y con las historias de usuario HU-08 a HU-10. Su principal aporte es reducir el riesgo de degradación del modelo ante el *concept drift*, mediante reentrenamientos periódicos y una evaluación previa a la promoción, sin interrumpir el servicio ni incorporar modelos cuyo desempeño supere el margen de degradación permitido.

4.5.4 CU-04: Alta de usuario nuevo y período de aprendizaje (cold-start)

Los actores principales son el agente local y la API, mientras que el administrador de seguridad participa como actor secundario. El caso de uso se activa cuando la API recibe el primer evento de un usuario que aún no está registrado. Como precondición, el agente local debe estar operativo en el equipo del usuario.

Al detectar que el usuario no está registrado, la API crea su estado y lo establece en modo de aprendizaje, de acuerdo con el umbral configurado. Durante este período, los eventos se evalúan normalmente, pero la acción de mitigación se aplica de forma atenuada. A su vez, el *dashboard* muestra al usuario en aprendizaje e informa su progreso. Una vez alcanzado el umbral establecido, el sistema lo incorpora automáticamente al monitoreo normal. Si el administrador modifica el umbral durante el aprendizaje, el cambio se aplica a partir del siguiente evento. Sin embargo, cuando un evento afecta a un recurso sensible, se aplica la política normal, sin atenuar la acción de mitigación.

Al finalizar el caso de uso, el usuario deja el modo de aprendizaje y las acciones se aplican sin atenuación, según el mapeo configurado. No obstante, la cobertura del puntaje puede seguir siendo parcial hasta que se completen los 50 eventos requeridos por el modelo LSTM (RF-03). Este caso de uso se relaciona con los requerimientos RF-23 a RF-27 y con las historias de usuario HU-11 a HU-13. Su principal aporte es reducir los falsos positivos durante la incorporación de nuevos usuarios, asociados al problema de *cold-start*, una limitación documentada en la literatura (Villarreal-Vasquez *et al.*, 2023; Benova y Hudec, 2024).

4.6 Historias de usuario

Las historias de usuario se expresan con el formato “Como [rol], quiero [funcionalidad], para [beneficio]”, y sus criterios de aceptación se derivan de la estructura “Dado / Cuando / Entonces”. Se agrupan en cinco épicas alineadas con los casos de uso.

4.6.1 Épica 1: Detección y respuesta en el endpoint (CU-01)

Esta épica reúne las historias asociadas a CU-01: la recolección de actividad, el puntaje de riesgo por evento, la mitigación automática y la reversión de acciones.

HU-01: Recolección de actividad en el endpoint. Como administrador de seguridad, quiero que el agente recolecte en segundo plano la actividad de procesos, archivos, aplicaciones y red de cada equipo, para contar con la información necesaria para evaluar el comportamiento sin interrumpir al usuario. La historia se considera cumplida cuando, con un agente instalado, cada proceso ejecutado o archivo accedido por el usuario llega a la API como evento con identificador de usuario, tipo y marca temporal; cuando, si la API no responde, el evento queda en el *buffer* local y se envía al restablecerse la conexión; y cuando ningún evento incluye contenido de archivos, capturas de pantalla ni pulsaciones de teclado.

HU-02: Puntaje de riesgo por evento. Como administrador de seguridad, quiero que cada evento reciba un puntaje de riesgo y un nivel, para saber en tiempo casi real cuánto se desvía un usuario de su conducta esperada. Ante un evento válido, la API debe devolver un puntaje entre 0 y 100 y el nivel que corresponde a los umbrales vigentes. Cuando un usuario vuelve tras un período sin actividad, su riesgo acumulado debe haberse reducido por decaimiento temporal, y cuando al menos uno de los dos modelos marca anomalía, el nivel se mantiene en el piso o por encima de él, que por defecto es alto.

HU-03: Mitigación automática. Como administrador de seguridad, quiero que el agente aplique automáticamente la acción definida para cada nivel, para contener un posible compromiso sin depender de una intervención manual. Si un nivel está mapeado a `terminar_y_denegar`, al evaluarse el evento el agente debe terminar el proceso y denegar el acceso a la carpeta. Toda acción que modifica el equipo debe confirmarse a la API, y el usuario que mantiene la sesión abierta continúa sin repetir el inicio de sesión.

HU-04: Reversión de acciones. Como administrador de seguridad, quiero revertir las acciones de mitigación aplicadas, para restituir el acceso ante un falso positivo. Al ejecutarse la reversión, un permiso de carpeta denegado debe volver a su estado original y un proceso suspendido debe reanudarse; para un proceso terminado, en cambio, el resultado de la acción debe indicar que no es reversible.

4.6.2 Épica 2: Panel de administración y políticas (CU-02)

Esta épica reúne las historias asociadas a CU-02: el estado de riesgo de los usuarios, la configuración de umbrales, niveles y acciones, y las notificaciones y la auditoría.

HU-05: Estado de riesgo de los usuarios. Como administrador de seguridad, quiero ver en el *dashboard* el estado de riesgo de cada usuario y su historial, para priorizar qué casos revisar. Al ingresar al *dashboard*, cada usuario debe aparecer con su puntaje, nivel y estado de

aprendizaje, y al abrir su detalle deben mostrarse sus eventos recientes con la explicación de cada puntaje.

HU-06: Configuración de umbrales y acciones. Como administrador de seguridad, quiero configurar los umbrales y la acción de cada nivel, para adaptar el sistema al contexto de seguridad de la organización. Un cambio de umbrales válido, una vez guardado, debe aplicarse a la evaluación de los eventos siguientes, mientras que un cambio con rangos solapados, con una cantidad de niveles distinta de cuatro o con una acción asignada a un nivel inexistente debe rechazarse con un mensaje específico.

HU-07: Notificaciones y auditoría. Como administrador de seguridad, quiero recibir notificaciones por correo en los niveles que elija y consultar la auditoría de cambios, para enterarme de los casos relevantes y saber cuándo, qué y con qué rol o clave se modificó la política. Cuando un usuario alcanza un nivel marcado para notificar, debe enviarse un correo con el puntaje, el nivel y los eventos recientes, con un máximo de uno por usuario dentro del intervalo mínimo (10 minutos por defecto). Todo cambio de política, a su vez, debe quedar registrado con fecha y valores en la vista de auditoría.

4.6.3 Épica 3: Ciclo de vida del modelo (CU-03)

Esta épica reúne las historias asociadas a CU-03: la planificación del reentrenamiento, el reentrenamiento aislado con promoción controlada y el historial de reentrenamientos.

HU-08: Planificación del reentrenamiento. Como administrador de seguridad, quiero configurar cada cuánto y en qué franja horaria se reentrena el modelo, para que el reentrenamiento no interfiera con el entorno productivo. Un período de entre 1 y 365 días y una ventana horaria válida deben quedar persistidos al guardarse, y un valor fuera de rango o con formato inválido debe rechazarse.

HU-09: Reentrenamiento aislado y promoción controlada. Como administrador de seguridad, quiero que el modelo se reentrene automáticamente con los eventos nuevos y solo se reemplace si no detecta peor que el vigente, para incorporar cambios de comportamiento sin degradar la detección más allá del margen tolerado ni arriesgar el servicio. Cumplido el período, el planificador debe ejecutar el *pipeline* en un proceso aparte. Un modelo nuevo que satisface el criterio de no inferioridad sobre los escenarios de referencia debe reemplazar al vigente sin reiniciar la API; si no lo satisface, o si la evaluación queda incompleta, debe conservarse el vigente y registrarse el motivo.

HU-10: Historial de reentrenamientos. Como administrador de seguridad, quiero ver el historial de reentrenamientos, para auditar cómo evolucionó el modelo. Para cada reentrenamiento finalizado, el *dashboard* debe mostrar la fecha, los eventos utilizados, la variación de métricas y el actor, y debe permitir registrar los reentrenamientos realizados manualmente.

4.6.4 Épica 4: Alta de usuarios y cold-start (CU-04)

Esta épica reúne las historias asociadas a CU-04: el período de aprendizaje, el seguimiento de los usuarios en aprendizaje y la transición automática al monitoreo normal.

HU-11: Período de aprendizaje. Como administrador de seguridad, quiero que los usuarios nuevos se den de alta automáticamente y atraviesen un período de aprendizaje con acciones atenuadas, para evitar bloquear a alguien solo por no tener historial. Al llegar el primer evento de un identificador nuevo, debe crearse su estado en aprendizaje. Mientras dure ese período, la acción debe atenuarse sin alterar el nivel informado, salvo en los eventos sobre recursos sensibles, a los que se aplica la política normal.

HU-12: Seguimiento de usuarios en aprendizaje. Como administrador de seguridad, quiero ver qué usuarios están en aprendizaje y su progreso, y ajustar el umbral, para saber qué puntajes son todavía preliminares. Para cada usuario en aprendizaje, el *dashboard* debe mostrar un indicador con los eventos acumulados sobre el umbral, y un nuevo umbral entre 1 y 1000, una vez guardado, debe aplicarse desde el evento siguiente.

HU-13: Transición automática a monitoreo normal. Como administrador de seguridad, quiero que la salida del aprendizaje sea automática, para no tener que habilitar manualmente a cada usuario. Cuando un usuario alcanza el umbral, debe pasar a monitoreo normal y su indicador debe desaparecer del *dashboard*.

4.6.5 Épica 5: Requerimientos transversales

Esta épica reúne las historias que no dependen de un único caso de uso: la autenticación de acceso a la configuración, la explicación persistida de cada puntaje y el contexto organizacional obtenido del IAM.

HU-14: Autenticación de acceso y configuración. Como administrador de seguridad, quiero que el acceso al *dashboard* y a la configuración requiera autenticación, para que nadie sin autorización modifique las políticas. El *dashboard* solo es accesible para un usuario con sesión iniciada, y la API debe rechazar toda operación de configuración que no presente un token de sesión vigente con rol administrador, así como cualquier token cuya sesión se haya cerrado o haya vencido.

HU-15: Explicación persistida. Como analista de seguridad, quiero que la explicación de cada puntaje quede guardada en el historial, para poder justificar una decisión tiempo después, aunque el modelo se haya reentrenado. La explicación y el motivo de cada evento evaluado deben persistirse en el historial, y tras un reentrenamiento posterior, las explicaciones ya guardadas se conservan sin cambios.

HU-16: Contexto organizacional desde el IAM. Como administrador de seguridad, quiero que el sistema obtenga el rol y el departamento del usuario desde el IAM de la organi-

zación, para ver en el *dashboard* el contexto organizacional existente. Con un proveedor IAM configurado, la llegada de un evento de un usuario sin datos en caché debe provocar la consulta del rol y el departamento y su almacenamiento en caché. Si el proveedor no responde, el evento debe evaluarse igualmente, sin contexto IAM.

5 Justificación de diseño y mockups

El *dashboard* es uno de los tres componentes del sistema, junto con el agente PEP local y la API PDP. Constituye el punto de interacción entre el administrador de seguridad y el motor de *scoring* híbrido, compuesto por Isolation Forest y un LSTM Autoencoder. Su función va más allá de la visualización de información: permite configurar los umbrales y las políticas de respuesta definidos en CU-02, y brinda visibilidad operativa sobre la detección y mitigación automáticas contempladas en CU-01.

El relevamiento abarca las seis pantallas navegables del *dashboard*: Usuarios, Con historial, Alertas, Umbrales, Auditoría y Estado del sistema. También incluye la pantalla de acceso (Login) y la vista de detalle de usuario, a la que se accede seleccionando una fila del listado de Usuarios, y la vista explicativa «Por qué pasó esto», a la que se accede desde ese detalle.

5.1 Metodología de diseño

El diseño de este *dashboard* no parte de un *wireframe* estático, sino que se construye de forma iterativa, validando cada pantalla contra los requerimientos funcionales que soporta (RF-12 a RF-17, RNF-07, RNF-15) y refinando la presentación visual. Esa distinción se documenta explícitamente para no sobrerrepresentar el proceso: lo que se muestra a continuación no es un registro histórico de bocetos previos a la implementación, sino una reconstrucción de *wireframes* estructurales a partir de las pantallas ya construidas y validadas, que documenta la arquitectura de información y las decisiones de *layout* de forma independiente del estilo visual final.

Cada *wireframe* de este documento representa la estructura de esa pantalla ya validada (agrupación de información, jerarquía visual y controles disponibles). Se dibujan en formato de un *wireframe* de baja-media fidelidad, sin el detalle de estilo final, que se justifica a continuación y que se puede contrastar directamente contra la pantalla real.

5.2 Decisiones de diseño transversales

- Tema oscuro por defecto (con alternancia a claro): reduce la fatiga visual en un panel pensado para monitoreo prolongado, y es el estándar de facto en herramientas de seguridad/observabilidad (SOC *dashboards*) con las que el administrador ya está familiarizado.

- Codificación de color consistente por nivel de riesgo (bajo/medio/alto/crítico) en *badges*, *chips* de notificación y bordes de las tarjetas de umbral: la misma paleta se repite en Usuarios, Alertas y Umbrales, para que el administrador no tenga que reinterpretar el color en cada pantalla. El nivel de riesgo se codifica con una paleta semafórica: verde para el

nivel bajo, amarillo para el medio, naranja para el alto y rojo para el crítico, con variantes para los temas oscuro y claro.

- Botones de guardado independientes por sección de formulario en vez de un único guardado global en `/umbrales`: reduce el riesgo de que el administrador modifique un umbral sin querer y termine también reescribiendo la configuración de notificaciones.
- Estados vacíos explícitos con mensaje (ej. "Sin alertas activas") en lugar de una tabla en blanco sin explicación, para que el administrador distinga un sistema sano de una posible falla de carga.

5.3 Arquitectura de navegación

Todas las pantallas comparten una barra superior fija que incluye el nombre del sistema, accesos directos a las seis secciones (Usuarios, Con historial, Alertas, Umbrales, Auditoría y Estado del sistema), el logotipo de UMBRAL, un indicador de alertas activas, un selector de tema claro u oscuro y el botón para cerrar sesión. Esta estructura uniforme facilita la navegación entre las distintas vistas operativas, mantiene una disposición visual consistente y permite al administrador acceder rápidamente a las principales funcionalidades del sistema, independientemente de la sección en la que se encuentre.

5.4 Catálogo de pantallas

Para cada pantalla se presenta el *wireframe* estructural de baja fidelidad, la captura real del *frontend* implementado, y una justificación de diseño que vincula cada decisión visual con el requerimiento funcional, el requerimiento no funcional o el caso de uso que la motiva.

5.4.1 Acceso (Login)

Esta pantalla es el punto de entrada al sistema y precede a cualquier vista operativa. Permite iniciar sesión con credenciales de administrador u operario para acceder a la interfaz, sin introducir nuevos roles ni modificar los permisos de escritura que la API valida de forma independiente. Su diseño es minimalista, con una única tarjeta centrada y sin elementos adicionales, para mantener el foco en el inicio de sesión. La figura 5.1 presenta el *wireframe* de la pantalla, mientras que la figura 5.2 muestra su implementación.

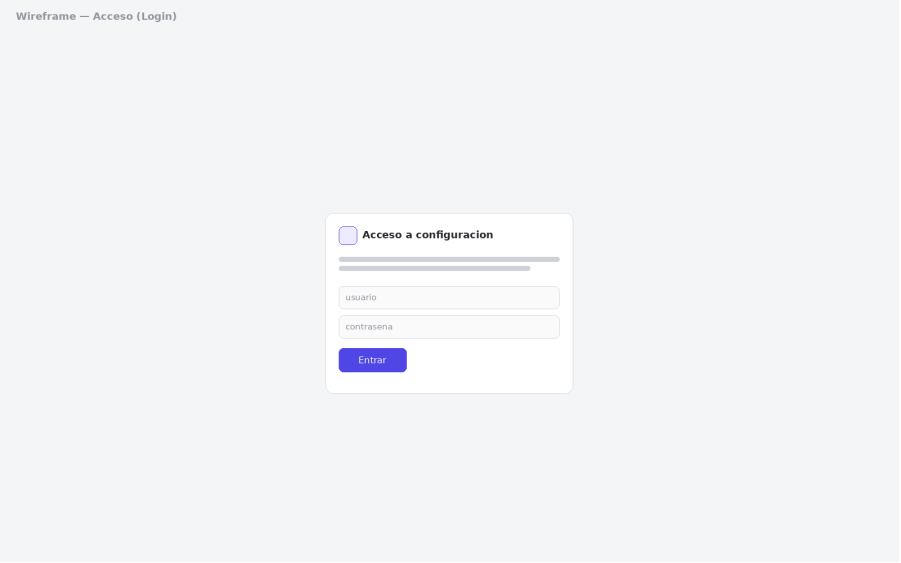


Figura 5.1: Wireframe de baja fidelidad: Acceso (Login)
Fuente: elaboración propia.

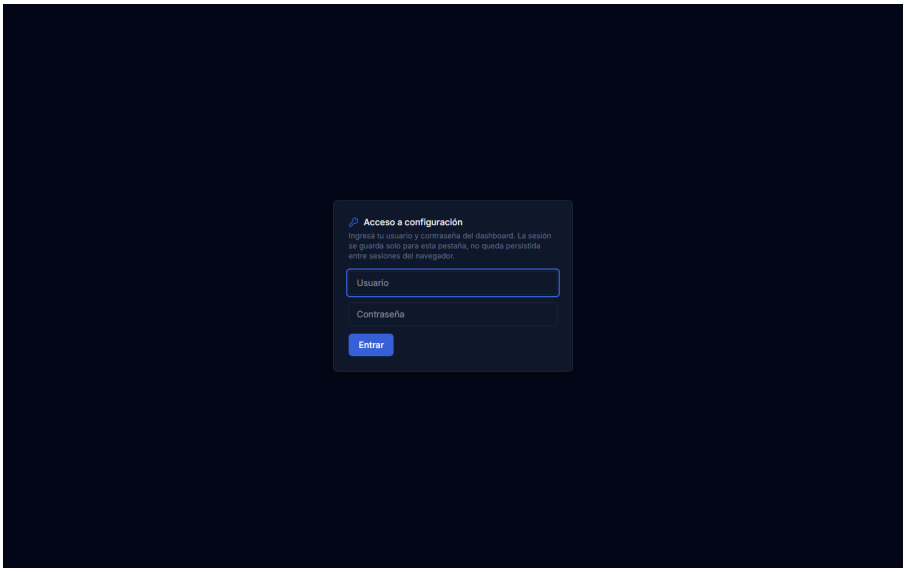


Figura 5.2: Pantalla real: `/login`
Fuente: elaboración propia, captura del sistema.

Desde el punto de vista de la usabilidad (RNF-15), la pantalla presenta un formulario centrado sobre un fondo oscuro, con los campos de usuario y contraseña y el botón de ingreso como únicos elementos interactivos. Esta disposición facilita la identificación de la acción requerida. En cuanto a la seguridad (HU-14 y RNF-03), el inicio de sesión restringe el acceso al *dashboard*, mientras que la API valida de forma independiente los permisos para modificar la configuración. De este modo, la interfaz no constituye la única barrera de control. La pantalla es el punto de entrada obligatorio para acceder a las funciones de ajuste de umbrales y políticas de respuesta contempladas en CU-02.

5.4.2 Usuarios (listado)

Esta pantalla presenta el listado de usuarios monitoreados y permite consultar su nivel de riesgo actual, la acción de mitigación vigente, la cobertura del *score* y la fecha de su última actividad. De este modo, el administrador puede conocer el estado general de los usuarios y detectar posibles situaciones que requieran atención sin necesidad de acceder individualmente a cada perfil. Esta funcionalidad responde al requerimiento RF-16, que establece la necesidad de brindar visibilidad en tiempo real sobre los usuarios monitoreados. La figura 5.3 presenta el *wireframe* de la pantalla, mientras que la figura 5.4 muestra su implementación.

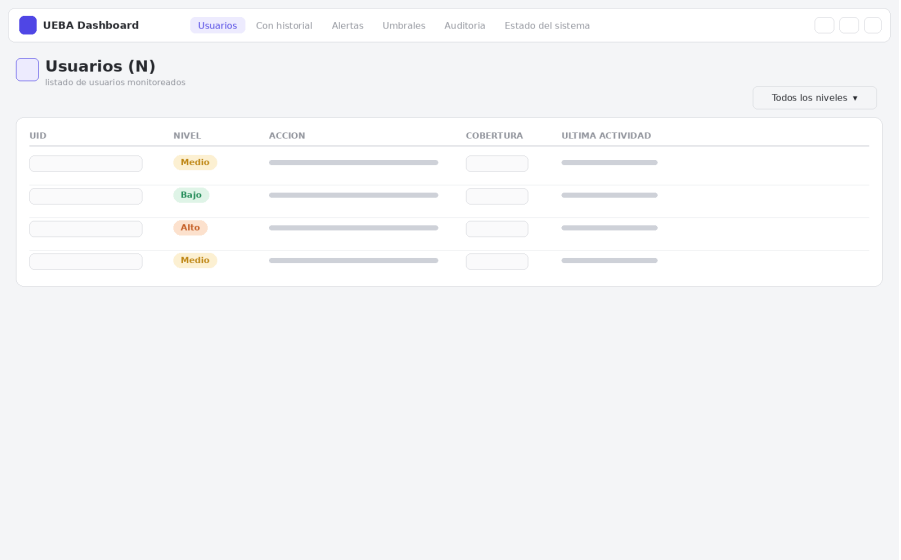


Figura 5.3: Wireframe de baja fidelidad: Usuarios (listado)
Fuente: elaboración propia.

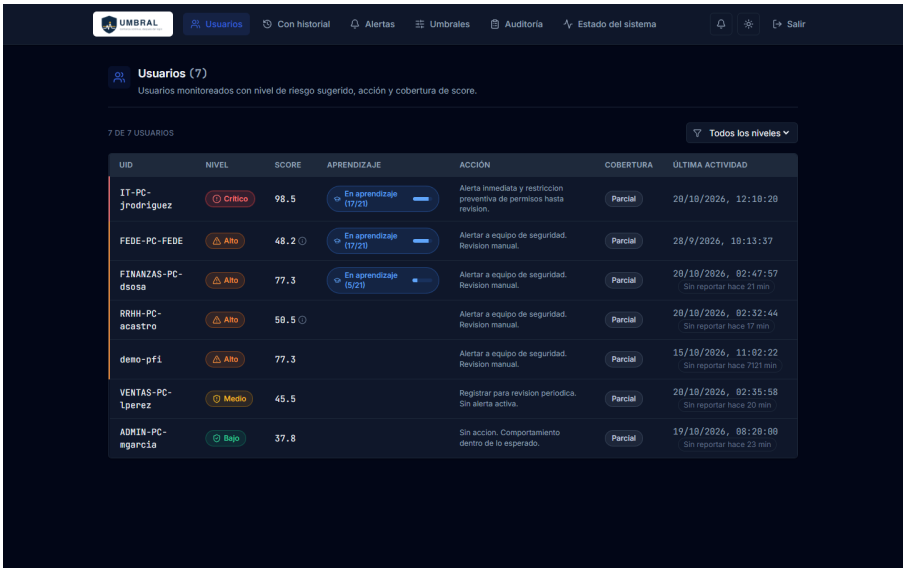


Figura 5.4: Pantalla real: / (listado de usuarios)
Fuente: elaboración propia, captura del sistema.

El diseño del listado responde a RF-16 al mostrar el *score* y el nivel de confianza de cada usuario en tiempo real, junto con un filtro por nivel de riesgo. En línea con RNF-15, este último se representa mediante un *badge* de color, lo que facilita la identificación y priorización de los casos. La paleta semafórica mantiene el mismo significado en todas las vistas (sección 5.2). Por último, la columna de acción de mitigación permite consultar la respuesta definida por la API para cada usuario, en cumplimiento de la postcondición de CU-01, sin necesidad de revisar los *logs* por separado.

5.4.3 Detalle de usuario

Se accede a esta vista haciendo clic sobre una fila del listado de Usuarios. Retoma los datos ya presentados en la tabla (`uid`, nivel y cobertura) y los complementa con el *score* exacto, la acción sugerida en detalle, un gráfico de evolución temporal del *score* y los eventos que dieron origen a la evaluación.

La tarjeta superior mantiene los mismos *badges* de nivel de riesgo y cobertura que la fila de origen, lo que permite identificar al usuario y conservar el contexto de navegación. El *score* se destaca mediante una tipografía de mayor tamaño, por ser el indicador que refleja el nivel de riesgo actual.

El gráfico de Histórico de *score* aclara que el punto «Actual» es provisional, dado que el día aún no ha finalizado, mientras que los demás valores corresponden a días cerrados. Esta decisión, compartida con las vistas Alertas y Con historial, hace explícitos los límites de la información presentada y evita interpretaciones erróneas sobre su grado de certeza. En la captura, el usuario es nuevo y todavía no tiene días cerrados, por lo que en lugar del gráfico se muestra ese aviso.

Por último, la tabla de Eventos recientes se limita a 30 filas (RF-09) y se presenta como complemento del *score* actual y del histórico diario, sin reemplazarlos. La figura 5.5 presenta el *wireframe* de la pantalla, mientras que la figura 5.6 muestra su implementación.

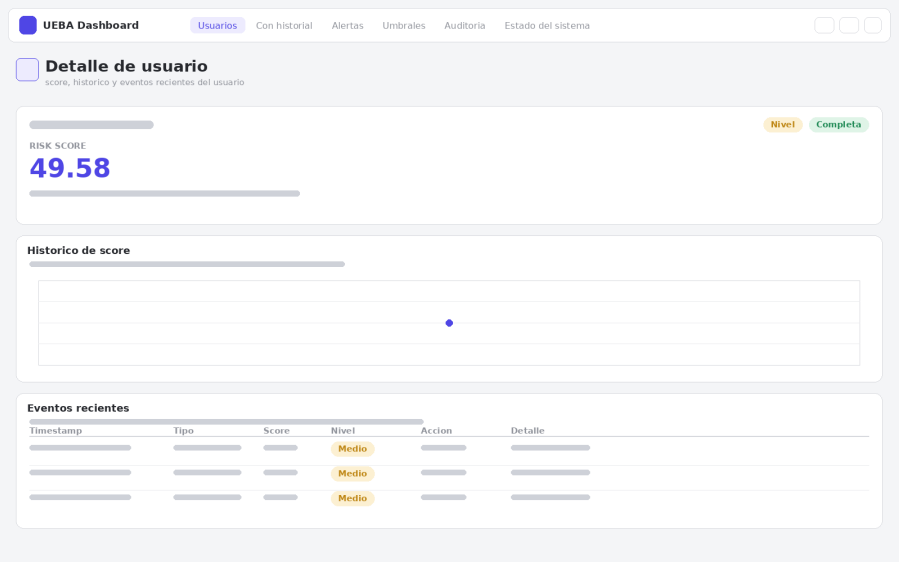


Figura 5.5: Wireframe de baja fidelidad: Detalle de usuario
Fuente: elaboración propia.

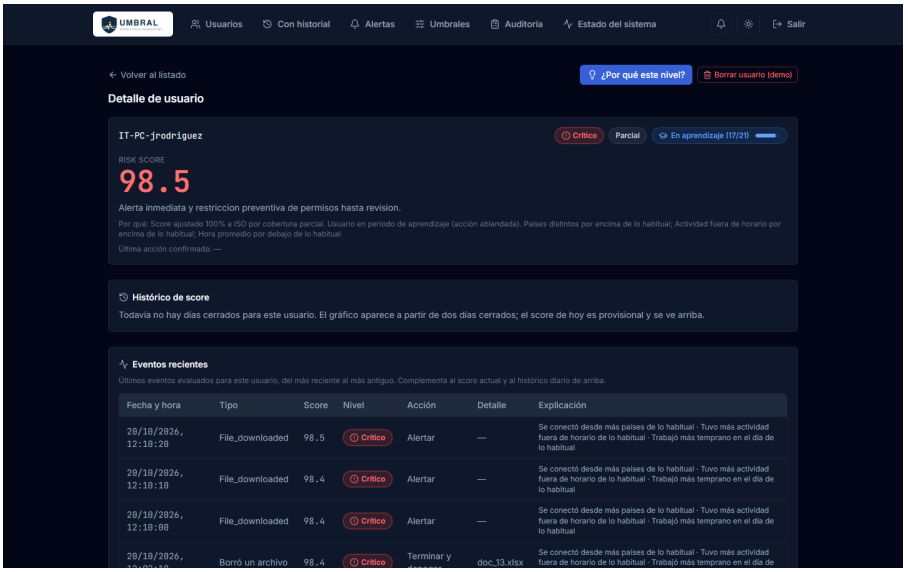


Figura 5.6: Pantalla real: `/usuarios/:uid` (detalle)
Fuente: elaboración propia, captura del sistema.

El diseño de esta vista responde a cuatro requerimientos. En cumplimiento de RF-09, la tabla muestra los 30 eventos evaluados más recientes, ordenados del más nuevo al más antiguo, y explicita este límite para evitar que se confunda con el historial completo. Además, complementa RF-16 al detallar el *score* y el nivel de confianza que el listado general resume mediante un *badge*, permitiendo pasar de la consulta general a la investigación de un usuario particular. En línea con RNF-15, mantiene los mismos *badges* de riesgo y el color de acento del *score* utilizados en Usuarios y Alertas, que también se aplica al punto correspondiente del gráfico. Por último, el desglose de cada evento (tipo, *score*, nivel, acción y proceso) responde a RNF-11, ya que permite rastrear los eventos que contribuyeron al *score* actual y comprender su origen.

5.4.4 Pantalla «Por qué pasó esto»

Se accede a esta pantalla desde el botón «¿Por qué este nivel?» del Detalle de usuario y permite consultar por qué se asignó el nivel de riesgo actual. Constituye la capa de explicabilidad (XAI) del proyecto y es de solo lectura: presenta la decisión de la API sin realizar nuevos cálculos. La información se organiza en cuatro bloques que explican qué ocurrió, cómo evolucionó el riesgo, qué señales influyeron y qué acción se tomó.

El encabezado identifica al usuario y muestra su nivel de riesgo, cobertura y estado de aprendizaje. La tarjeta «En resumen» presenta en lenguaje natural el nivel asignado, el puntaje sobre 100, el umbral correspondiente y la acción indicada al agente. «Cómo evolucionó el riesgo» incluye un gráfico de línea con las franjas de nivel vigentes, que permite observar la evolución del puntaje y su relación con los umbrales.

El bloque «Señales que se desviaron» muestra las tres características con mayor contribución, ordenadas por su *z-score* respecto del comportamiento típico aprendido por Isolation Forest. Para facilitar su interpretación, utiliza barras de intensidad y etiquetas descriptivas en lugar de valores crudos. Por último, «Acción» indica la respuesta comunicada por el PDP al PEP.

Las tarjetas independientes facilitan la lectura. Las limitaciones se indican junto a los datos correspondientes; entre ellas, que la explicación compara con el comportamiento típico poblacional y no con el historial individual.

La figura 5.7 presenta el *wireframe*, mientras que las figuras 5.8 y 5.9 muestran la implementación de la pantalla, respectivamente, antes y después de desplazarse por la página.

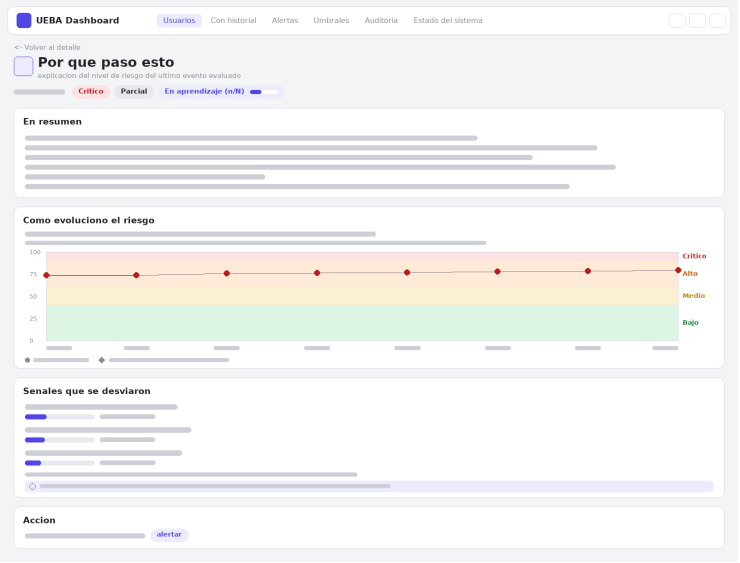


Figura 5.7: Wireframe de baja fidelidad: Por qué pasó esto
Fuente: elaboración propia.



Figura 5.8: Pantalla real: Por qué pasó esto (parte superior: resumen y evolución del riesgo)
Fuente: elaboración propia, captura del sistema.



Figura 5.9: Pantalla real: Por qué pasó esto (scroll: señales que se desviaron y acción)
Fuente: elaboración propia, captura del sistema.

El diseño de esta vista responde, en primer lugar, a RNF-11. La tarjeta de señales acompaña el puntaje con las principales variables que contribuyeron al resultado, expresadas en lenguaje legible. Como la explicación cubre únicamente Isolation Forest y no el LSTM Autoencoder, la pantalla declara esta limitación mediante la nota «En calibración».

El resumen también explicita las reglas que determinan el resultado: muestra el umbral del nivel asignado (RF-05) y, cuando el puntaje combinado corresponde a una franja inferior, aclara si el nivel se debe a la regla de piso, activada porque uno de los modelos detectó una anomalía (RF-06). Así, un nivel superior al que corresponde a la franja del puntaje (por ejemplo, un puntaje de 55 con nivel alto) no se confunde con un error. El *badge* de cobertura cumple una función similar respecto de RF-03, al indicar cuándo el puntaje proviene de un solo modelo.

El encabezado muestra el progreso del usuario durante el período de aprendizaje (RF-24 a RF-26), mientras que el resumen aclara que la acción se atenúa a `alertar` durante esta etapa, excepto ante eventos sobre archivos. Esto evita que una acción leve asociada a un nivel de riesgo alto se interprete como una inconsistencia.

La tarjeta de acción muestra la respuesta que el PDP comunica al agente según el mapeo nivel $\rightarrow$ acción vigente (RF-07). Su carácter de solo lectura refuerza RNF-04, ya que la decisión se origina en el PDP. A su vez, el gráfico presenta la evolución a partir de la lista acotada de eventos recientes que mantiene la API (RF-09) y lo aclara en la leyenda para distinguirla del historial completo.

Por último, en línea con RNF-15, el gráfico, los puntos de cada evento y los *badges* del encabezado mantienen la paleta semafórica del resto del sistema, dando continuidad a RF-16 desde el listado general hasta la explicación de un evento particular.

5.4.5 Alertas

Esta vista muestra únicamente los usuarios que se encuentran en nivel de riesgo alto o crítico, por lo que permite identificar rápidamente los casos que requieren atención durante un incidente, sin necesidad de filtrar el listado completo. Debajo del título se explicita una limitación del sistema: no existe un historial persistente de alertas ni se envían notificaciones *push*; la acción «Reconocer» solo oculta el resaltado durante la sesión del navegador.

La captura muestra usuarios en niveles alto y crítico, cada uno con su correspondiente botón de reconocimiento. Cuando no hay alertas activas, la pantalla presenta el mensaje «Sin alertas activas», que representa el estado esperado durante el funcionamiento normal del sistema. La figura 5.10 presenta el *wireframe* de la pantalla, mientras que la figura 5.11 muestra su implementación.

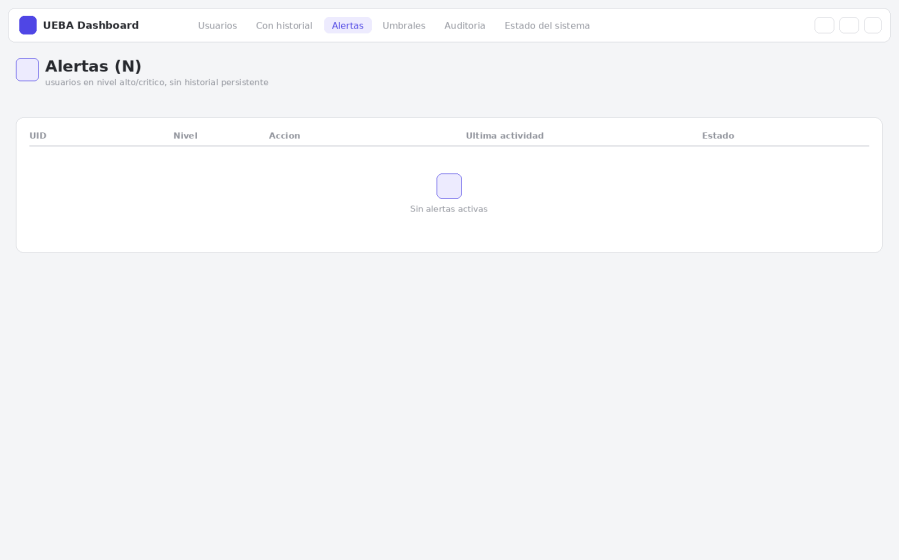


Figura 5.10: Wireframe de baja fidelidad: Alertas
Fuente: elaboración propia.

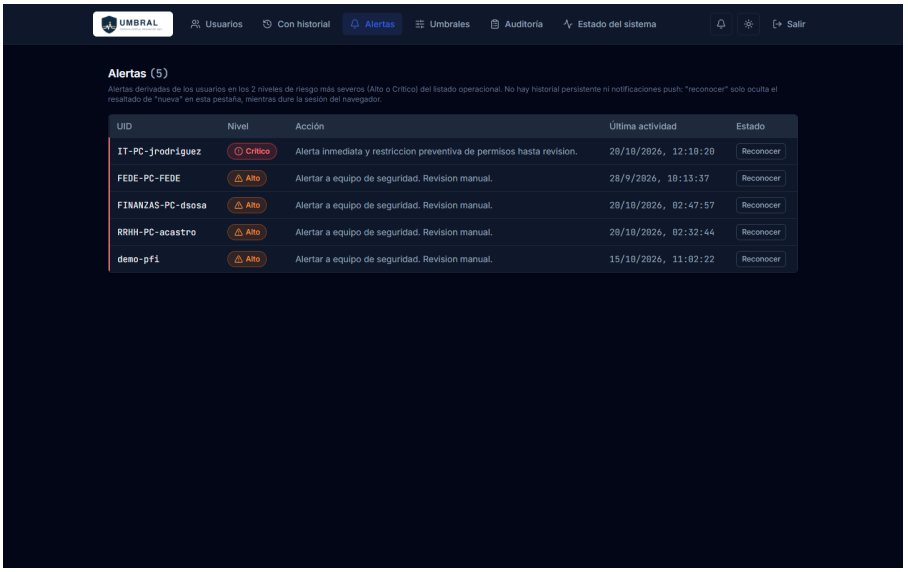


Figura 5.11: Pantalla real: `/alertas` (con alertas activas)
Fuente: elaboración propia, captura del sistema.

La pantalla mantiene el mismo patrón visual de *badges* de nivel de riesgo que el listado general, en línea con RNF-15. Esta consistencia facilita la interpretación de los niveles y evita confusiones durante un incidente. Además, la interfaz explicita que las alertas no se almacenan de forma persistente ni generan notificaciones *push*. Esta decisión responde a un criterio de transparencia: comunicar claramente las limitaciones del sistema y evitar atribuirle funcionalidades que no están implementadas.

5.4.6 Configuración de umbrales

Esta es la pantalla con mayor densidad funcional del *dashboard*, ya que reúne los formularios necesarios para configurar las políticas de respuesta contempladas en CU-02 (RF-12 a RF-15 y RF-17), además de la periodicidad de reentrenamiento correspondiente a RF-18. Los controles se organizan en secciones jerarquizadas: Umbrales por nivel; una grilla de tres columnas con Acción por nivel, Periodicidad de reentrenamiento y Umbral de aprendizaje; y, por último, Notificaciones, Proveedores de identidad (IAM) y el Log de reentrenamientos. Cada sección cuenta con su propio botón de guardado (sección 5.2).

En el bloque de Notificaciones se utilizan *chips* interactivos de tipo *toggle*, uno por nivel de riesgo, en lugar de *checkboxes* convencionales. Este diseño permite seleccionar varios niveles y mantiene la coherencia visual con los *badges* de riesgo utilizados en el resto del sistema.

La figura 5.12 presenta el *wireframe* de la pantalla, mientras que las figuras 5.13 y 5.14 muestran su implementación, respectivamente, en la parte superior y después de desplazarse por la página.

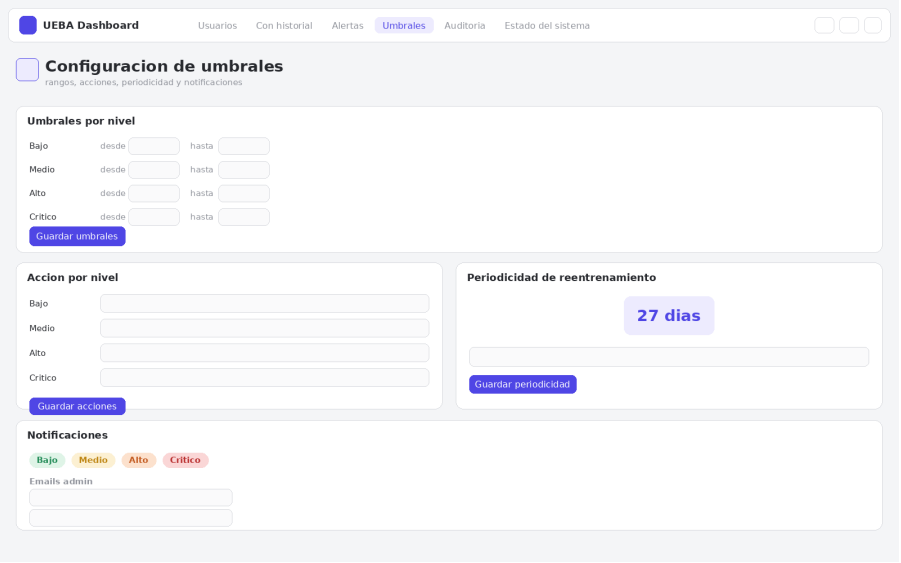


Figura 5.12: Wireframe de baja fidelidad: Configuración de umbrales
Fuente: elaboración propia.

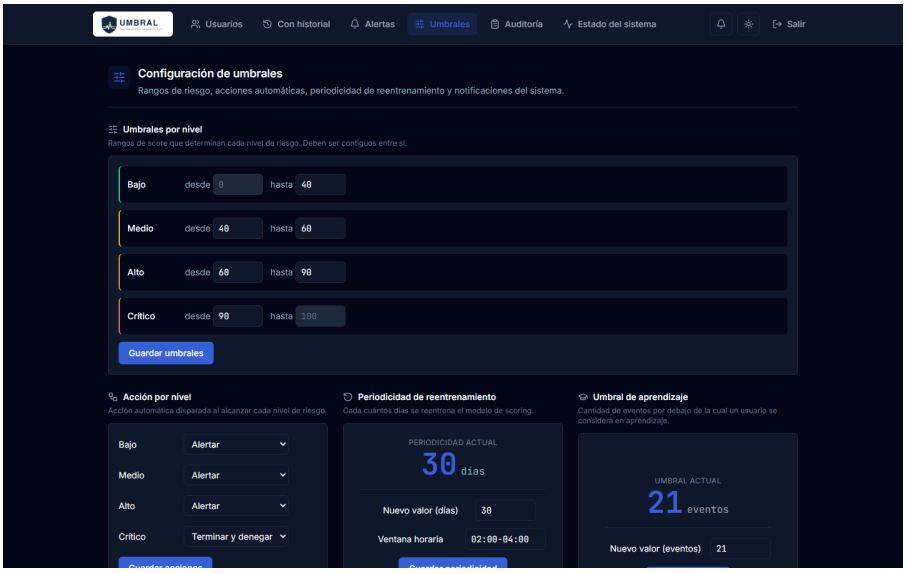


Figura 5.13: Pantalla real: `/umbrales` (parte superior: rangos por nivel)
Fuente: elaboración propia, captura del sistema.

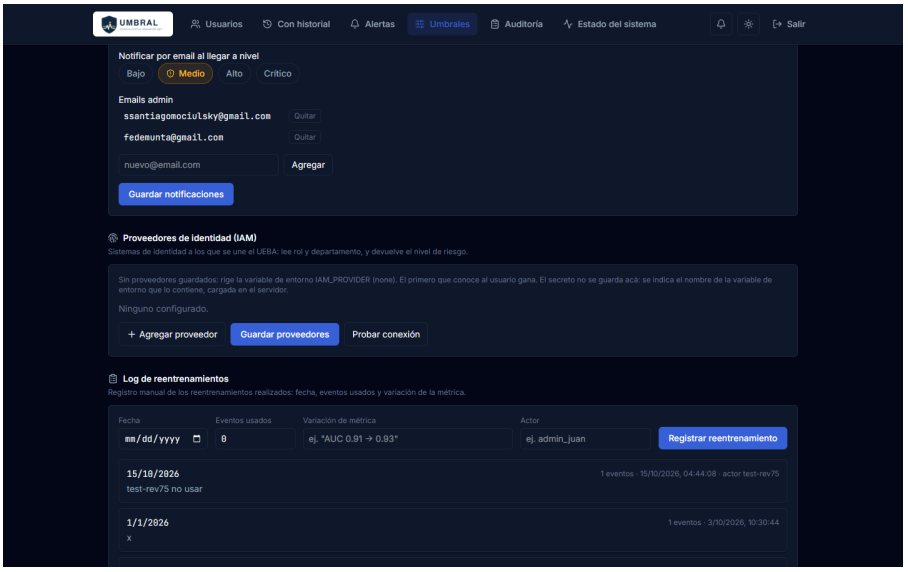


Figura 5.14: Pantalla real: `/umbrales` (scroll: notificaciones, proveedores de identidad y log de reentrenamientos)

Fuente: elaboración propia, captura del sistema.

La división en secciones independientes refleja también la comunicación del *dashboard* con la API: cada subformulario (umbrales, acciones, periodicidad y notificaciones) envía su propio `PUT` al *endpoint* correspondiente, en línea con RF-12, RF-14, RF-15 y RF-18. Los botones de guardado independientes hacen explícita esta separación en la interfaz.

En el bloque de umbrales, los campos se organizan en pares desde/hasta contiguos para cada nivel (RF-12), lo que facilita identificar posibles solapamientos antes de guardar, aunque la validación definitiva corresponde a la API. Además, todas las modificaciones se aplican en caliente, sin reiniciar servicios, según RNF-07; por eso, la interfaz no incluye una acción de «aplicar y reiniciar». Por último, los *chips* de Notificaciones mantienen la forma redondeada y los colores por nivel de los *badges* utilizados en el resto del sistema, en línea con RNF-15.

5.4.7 Auditoría

Esta pantalla responde a RF-17 y permite consultar el historial de cambios en las políticas desde el *dashboard*, facilitando su trazabilidad. Cada entrada se presenta como una tarjeta que incluye el tipo de cambio (por ejemplo, Acción por nivel, Periodicidad, Notificaciones, Proveedores de identidad o Umbral de aprendizaje), los valores anterior y nuevo en formato monoespaciado tipo *diff*, la fecha y hora, y el actor responsable.

El formato `valor_viejo` → `valor_nuevo` permite identificar qué cambió, en lugar de mostrar únicamente la configuración resultante, ya que la auditoría busca registrar las modificaciones y no solo consultar el estado actual, disponible en `/umbrales`. La figura 5.15 presenta el *wireframe*, mientras que la figura 5.16 muestra la pantalla implementada.

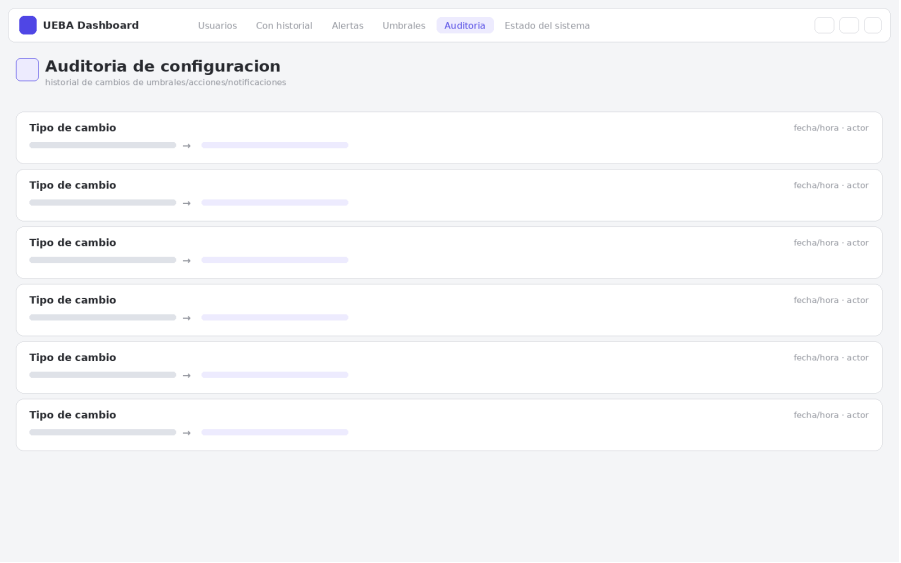


Figura 5.15: Wireframe de baja fidelidad: Auditoría
Fuente: elaboración propia.

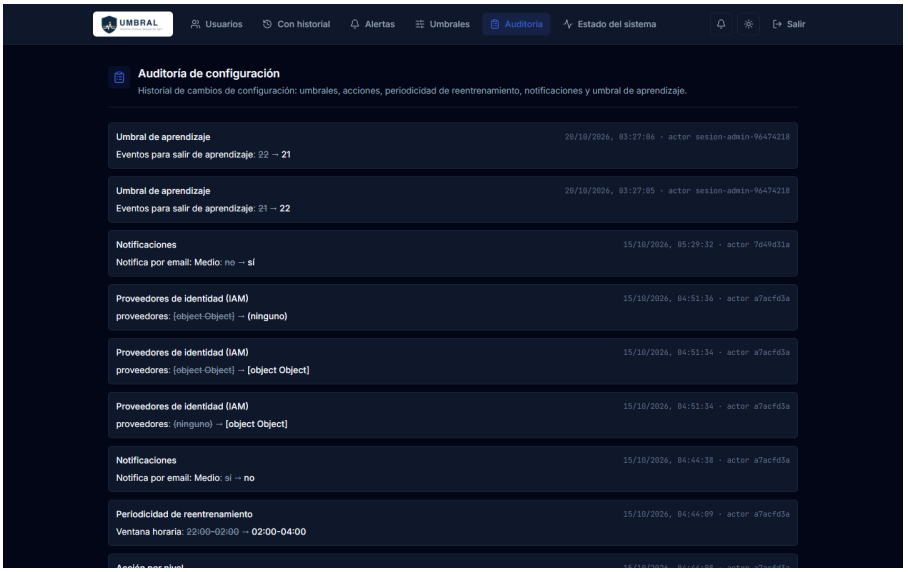


Figura 5.16: Pantalla real: `/auditoria`
Fuente: elaboración propia, captura del sistema.

El diseño cumple con RF-17 al mostrar el historial de cambios de las políticas en el *dashboard*, ordenado cronológicamente del más reciente al más antiguo e identificando al actor responsable. Además, registrar el campo modificado junto con sus valores anterior y nuevo, en lugar de un mensaje genérico como «configuración actualizada», permite identificar qué cambió y quién realizó el cambio, y contribuye parcialmente a la explicabilidad planteada en RNF-11.

5.4.8 Estado del sistema

Esta pantalla permite verificar el estado técnico del sistema a partir de la información que devuelve el endpoint `/health` de la API: estado general, carga de los artefactos del modelo y conectividad con Redis y Postgres. También presenta el estado de cada artefacto individual, incluidos `isolation_forest`, `lstm_autoencoder`, los *scalers*, el *encoding*, los umbrales del modelo y las referencias de entrenamiento.

Está orientada a la verificación rápida del funcionamiento del sistema, más que al uso operativo cotidiano del administrador de seguridad. Se incluye en este relevamiento aunque no responda a un requerimiento funcional específico, ya que documenta una decisión de diseño: ofrecer visibilidad sobre el estado técnico de los componentes, con un alcance acotado y sujeto a revisión. La figura 5.17 presenta el *wireframe*, mientras que la figura 5.18 muestra la pantalla implementada.

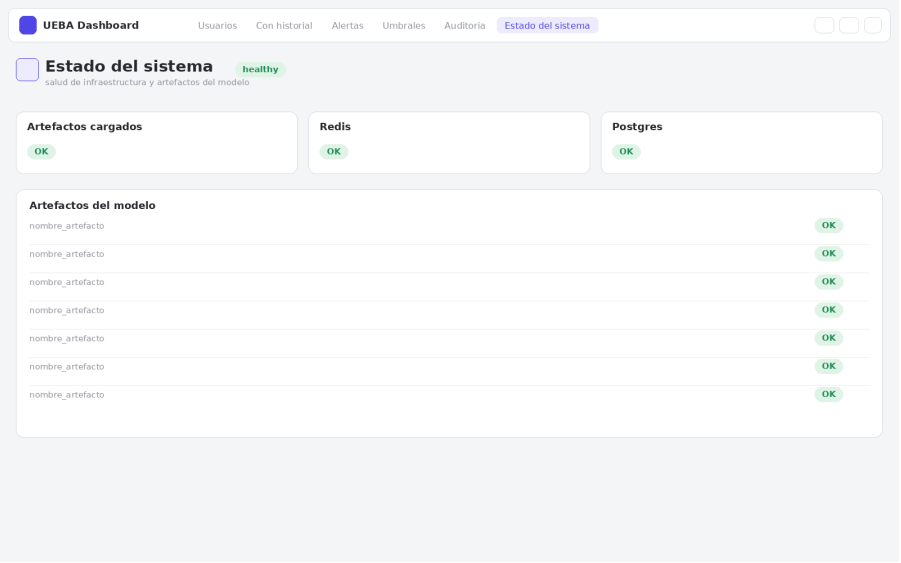


Figura 5.17: Wireframe de baja fidelidad: Estado del sistema
Fuente: elaboración propia.

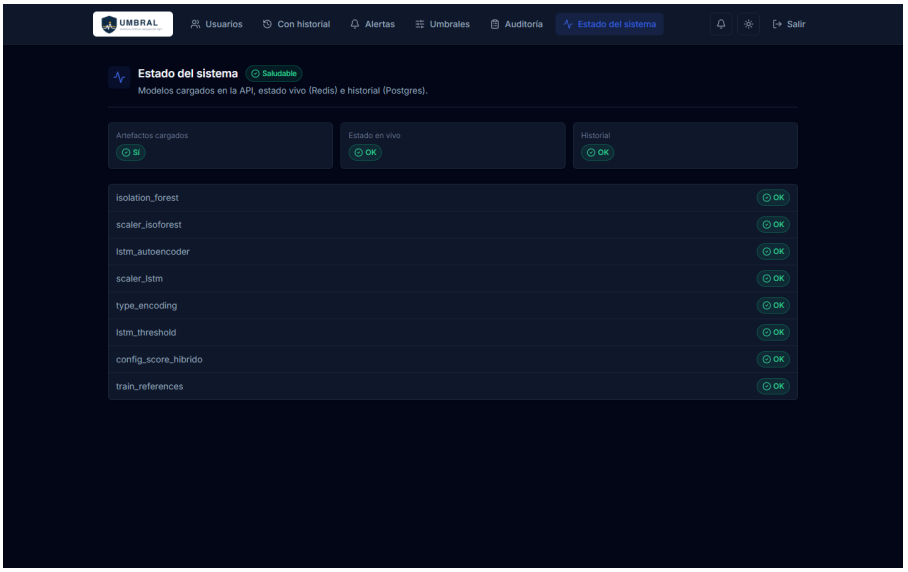


Figura 5.18: Pantalla real: `/salud`
Fuente: elaboración propia, captura del sistema.

Si bien la pantalla no deriva de un requerimiento funcional puntual, adopta el principio de consistencia visual de RNF-15: emplea el mismo lenguaje de *badges* de estado (OK o *healthy*) que el resto del sistema utiliza para el nivel de riesgo, aplicado en este caso a la salud de la infraestructura en lugar del riesgo de los usuarios. Así, el administrador interpreta el estado técnico con las mismas convenciones que ya conoce, sin necesidad de aprender una codificación nueva.

5.4.9 Con historial

Esta pantalla reúne a los usuarios que tienen al menos un día cerrado en `historial_scores` (Postgres), facilitando el acceso a quienes cuentan con una evolución temporal registrada. A diferencia del listado general de Usuarios, muestra únicamente el UID, sin repetir el *score*, el nivel de riesgo ni la acción de mitigación, ya que estos valores pueden haber cambiado desde el cierre del día y confundirse con el estado actual.

El texto bajo el título también aclara que la lista de Postgres puede diferir del listado operativo de Redis: si se restablece el estado de un `uid` en Redis, su historial permanece en Postgres. Así, la interfaz distingue explícitamente el estado operativo del registro histórico. La figura 5.19 presenta el *wireframe*, mientras que la figura 5.20 muestra la pantalla implementada.

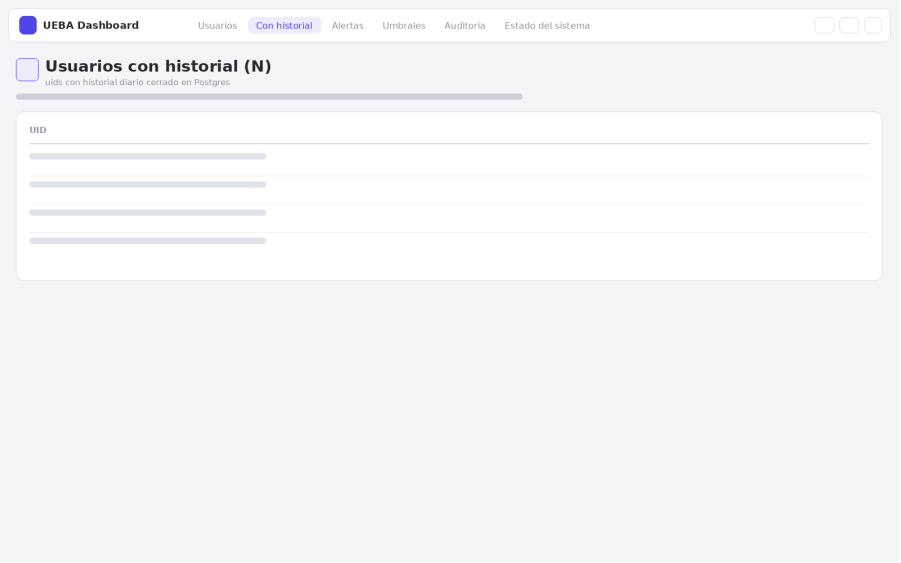


Figura 5.19: Wireframe de baja fidelidad: Con historial
Fuente: elaboración propia.

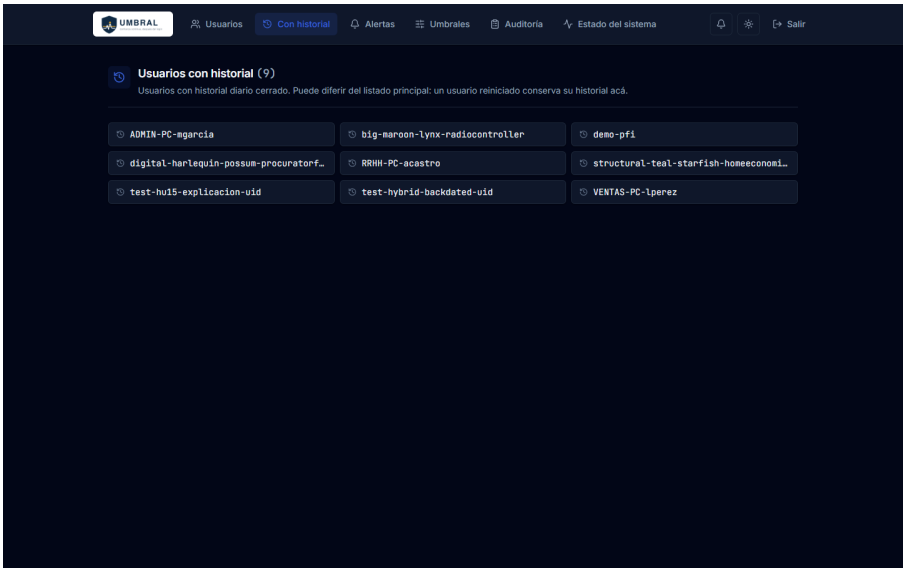


Figura 5.20: Pantalla real: `/historial`
Fuente: elaboración propia, captura del sistema.

Esta vista complementa RF-16 al ampliar la visibilidad del listado operacional con acceso a los datos históricos persistidos, sin mezclar ambas fuentes en una misma tabla. Además, la nota sobre las posibles diferencias entre Redis y Postgres explicita esta distinción para evitar que la ausencia de un usuario en el listado se interprete como una falta de historial registrado.

6 Diagramas UML

Esta sección presenta los diagramas que describen el funcionamiento interno del sistema: el recorrido de un evento entre los componentes (figura 6.1), los componentes y los protocolos con que se comunican (figura 6.2), las clases del agente (figura 6.3) y de la API (figuras 6.4 a 6.9), y un diagrama de objetos construido con una instancia real (figura 6.10). Los diagramas de esta sección se conservan en formato vectorial y pueden ampliarse en la versión digital; los diagramas de flujo, de componentes y de clases, salvo la vista de paquetes, se presentan como vistas de diseño, con los elementos y las relaciones principales, y el Anexo H reúne sus versiones completas.

6.1 Diagrama de flujo de información

La figura 6.1 presenta el recorrido de un evento: el agente lo arma a partir de las señales del equipo y lo envía por HTTPS con la credencial del agente; la API valida el esquema, autoriza al agente, deduplica, puntúa y asigna un nivel y una acción, y devuelve el veredicto que el agente aplica en el equipo. La versión completa, con el detalle técnico de cada paso y conexión, se presenta en el Anexo H.

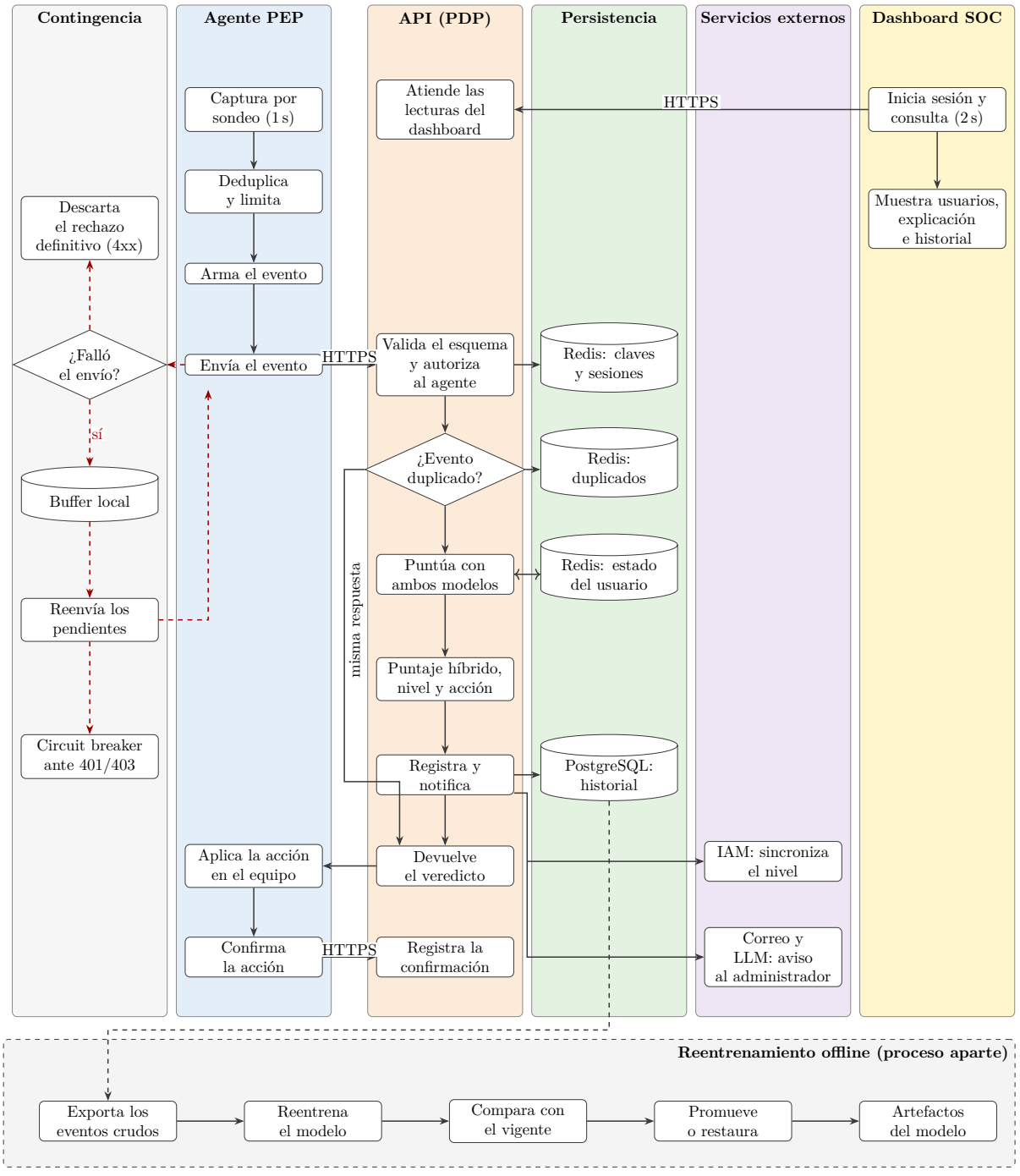


Figura 6.1: Diagrama de flujo de información del sistema (vista de diseño).
Fuente: elaboración propia.

6.2 Diagrama de componentes

La figura 6.2 presenta los componentes del sistema y los protocolos con que se comunican. La versión completa, con el detalle técnico de cada paso y conexión, se presenta en el Anexo H.

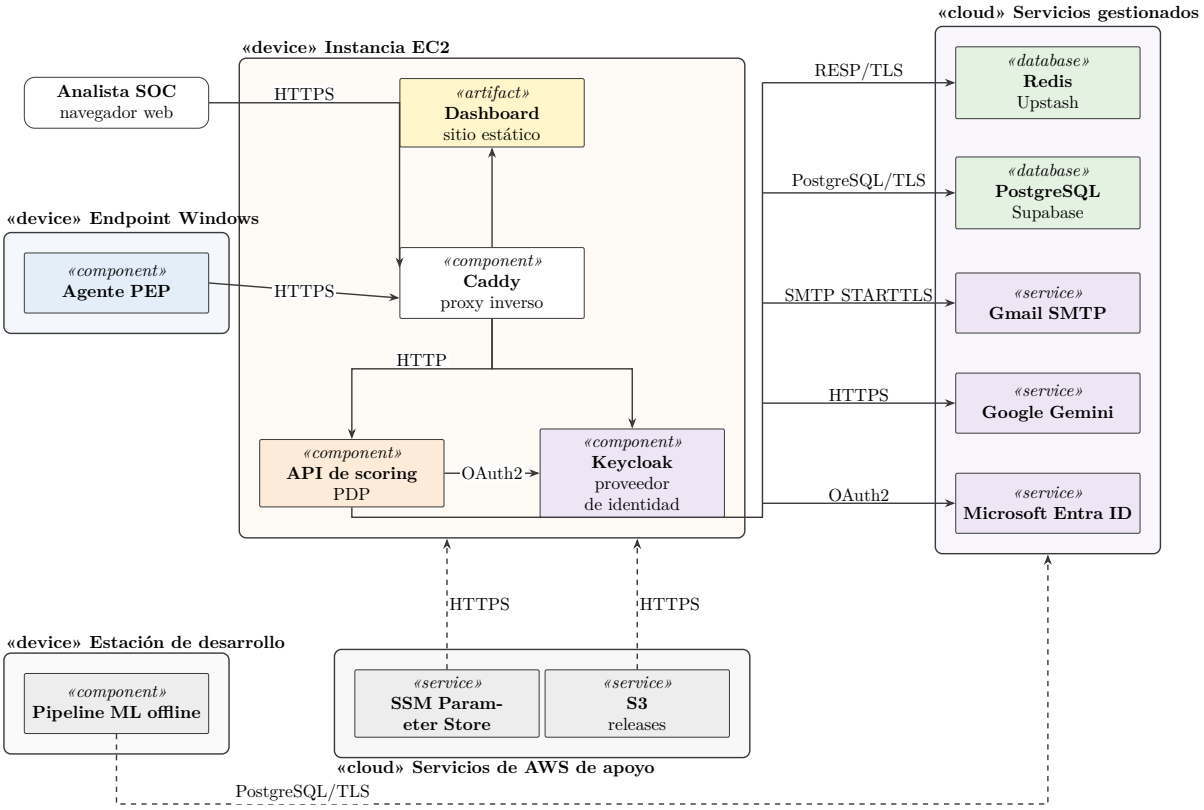


Figura 6.2: Diagrama de componentes con protocolos de comunicación (vista de diseño). Fuente: elaboración propia.

6.3 Diagrama de clases — agente PEP

La figura 6.3 presenta las clases del agente. La configuración (`AgentConfig`) reúne las carpetas vigiladas, los marcadores de procesos y aplicaciones, los parámetros del sondeo y del *buffer* local y la dirección de la API. Cuatro colectores (archivos, procesos, aplicaciones sensibles y red) generan señales comparando dos consultas sucesivas del sistema operativo; el `Debouncer` descarta las repetidas y limita su frecuencia, y `EventFactory` las convierte en eventos con el formato del contrato de la API. `ScoringClient` envía cada evento, conserva los no enviados en el *buffer* local y abre el *circuit breaker* ante rechazos de autenticación, mientras que `Enforcer` aplica la acción indicada por la API y conserva el respaldo necesario para revertirla. La versión completa, con todos los atributos y operaciones, se presenta en el Anexo H.

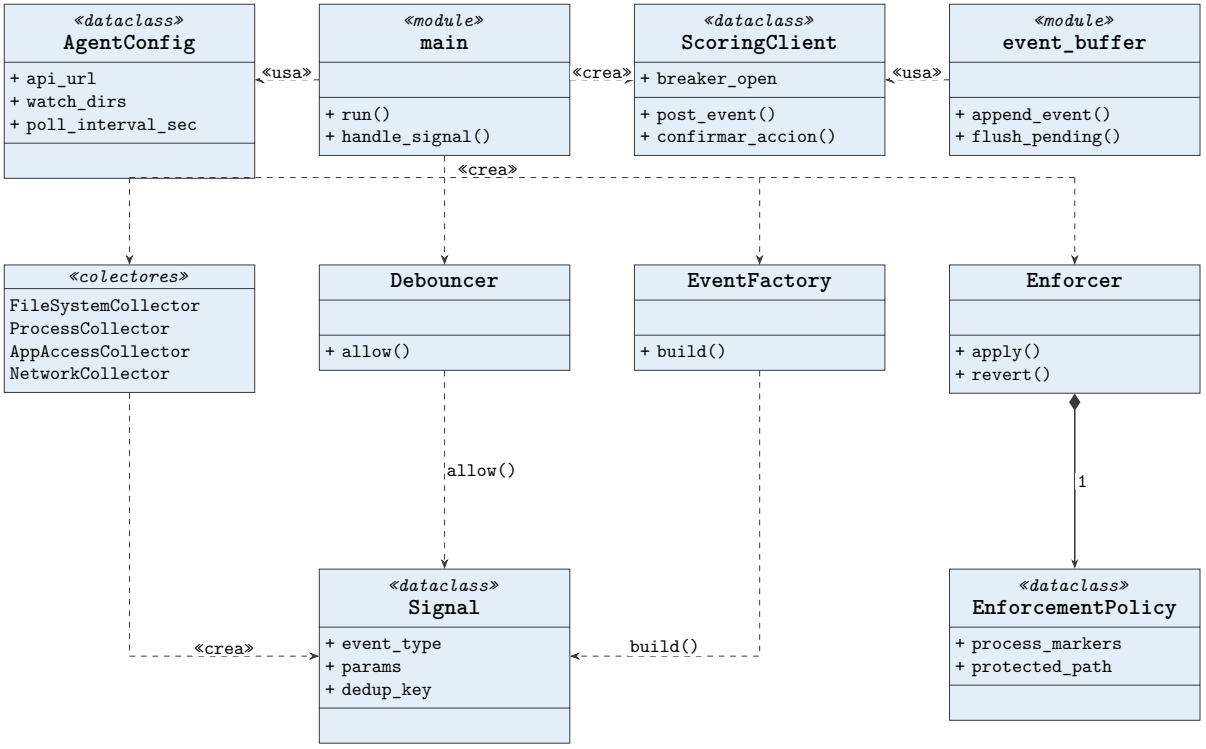


Figura 6.3: Diagrama de clases del agente PEP (vista de diseño).
Fuente: elaboración propia.

6.4 Diagramas de clases — API PDP

La API se documenta en seis diagramas. La figura 6.4 presenta la vista de paquetes: el estado de cada usuario en Redis (A), el cálculo del puntaje híbrido (B), los servicios de IAM, autenticación, deduplicación y notificaciones (C), las rutas HTTP con la configuración, el historial y el reentrenamiento (D) y los contratos de datos (E), con las dependencias entre ellos.

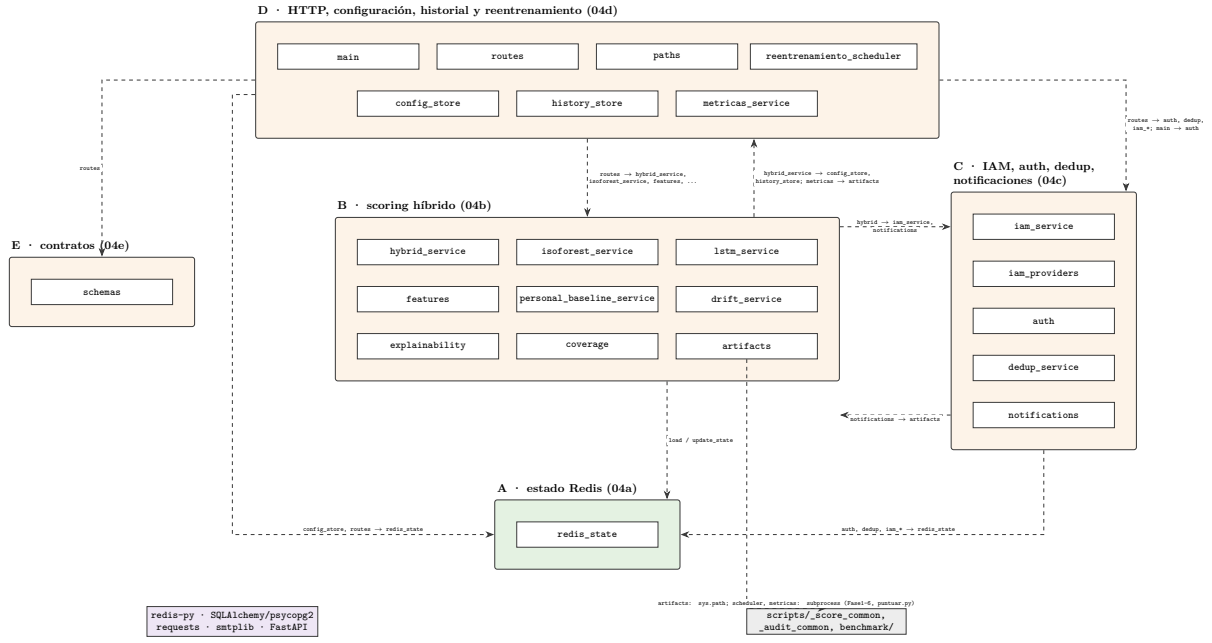


Figura 6.4: Diagrama de clases de la API PDP: vista de paquetes de scoring.
Fuente: elaboración propia.

La figura 6.5 detalla el estado que la API mantiene por usuario en Redis (`UserScoringState`), compuesto por la continuidad de la secuencia de eventos, el acumulado diario de Isolation Forest, el *buffer* del LSTM, el ancla del puntaje híbrido y la línea base personal, cuyas estadísticas se actualizan en forma incremental con el algoritmo de Welford. La versión completa, con todos los atributos y operaciones, se presenta en el Anexo H.

La figura 6.6 presenta las clases que calculan el puntaje: los servicios de Isolation Forest y del LSTM Autoencoder, la combinación híbrida con el decaimiento temporal y la regla de piso, la cobertura del puntaje, la explicación de las variables y los artefactos del modelo que se cargan al iniciar la API y se reemplazan sin reiniciarla. La versión completa, con todos los atributos y operaciones, se presenta en el Anexo H.

La figura 6.7 presenta la integración con los proveedores de identidad, mediante un adaptador con implementaciones para el proveedor simulado, Keycloak y Microsoft Entra ID, junto con las clases de autenticación: las sesiones del panel y las claves individuales de los

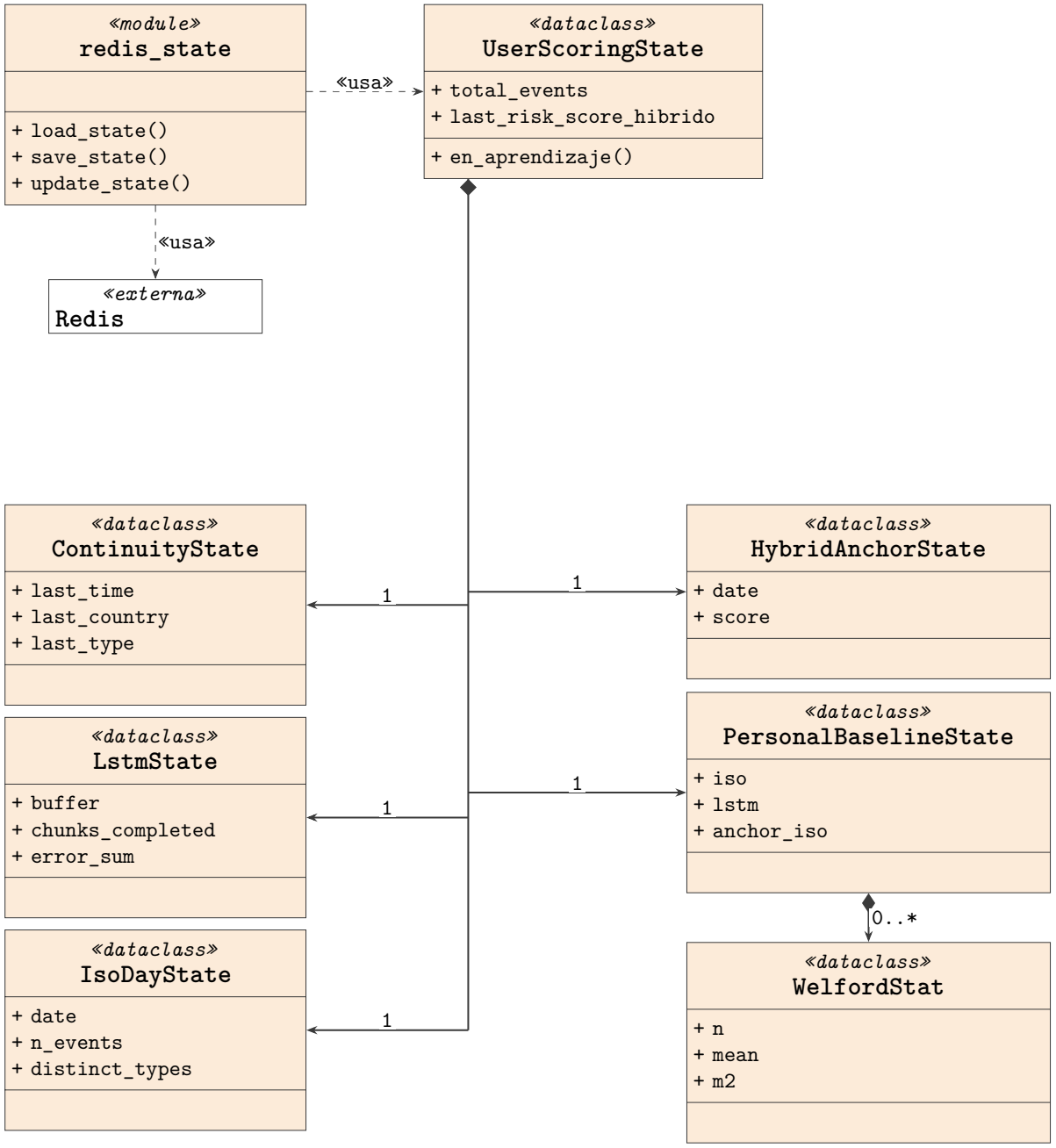


Figura 6.5: Diagrama de clases de la API PDP: estado del usuario en Redis (vista de diseño).
Fuente: elaboración propia.

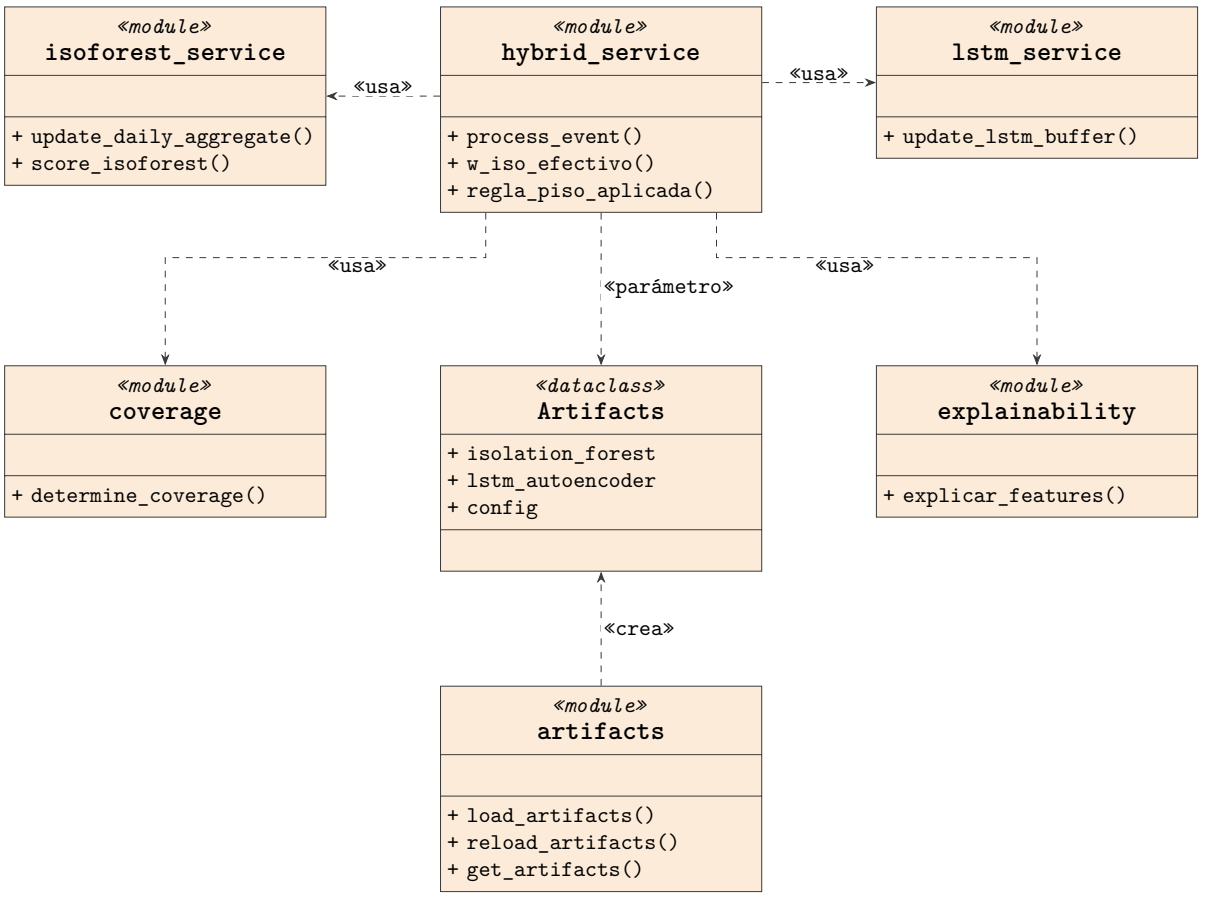


Figura 6.6: Diagrama de clases de la API PDP: puntaje y modelos (vista de diseño).
Fuente: elaboración propia.

agentes. La versión completa, con todos los atributos y operaciones, se presenta en el Anexo H.

La figura 6.8 presenta las rutas HTTP de la API y las clases de las que dependen: la persistencia del historial y de los eventos crudos en PostgreSQL, el almacén de la configuración en Redis y el planificador del reentrenamiento con su criterio de promoción. La versión completa, con todos los atributos y operaciones, se presenta en el Anexo H.

La figura 6.9 presenta los esquemas de datos que validan las solicitudes y respuestas HTTP, entre ellos el evento que envía el agente, la respuesta con el puntaje, el nivel y la acción, y la confirmación de la acción ejecutada. La versión completa, con todos los atributos y operaciones, se presenta en el Anexo H.

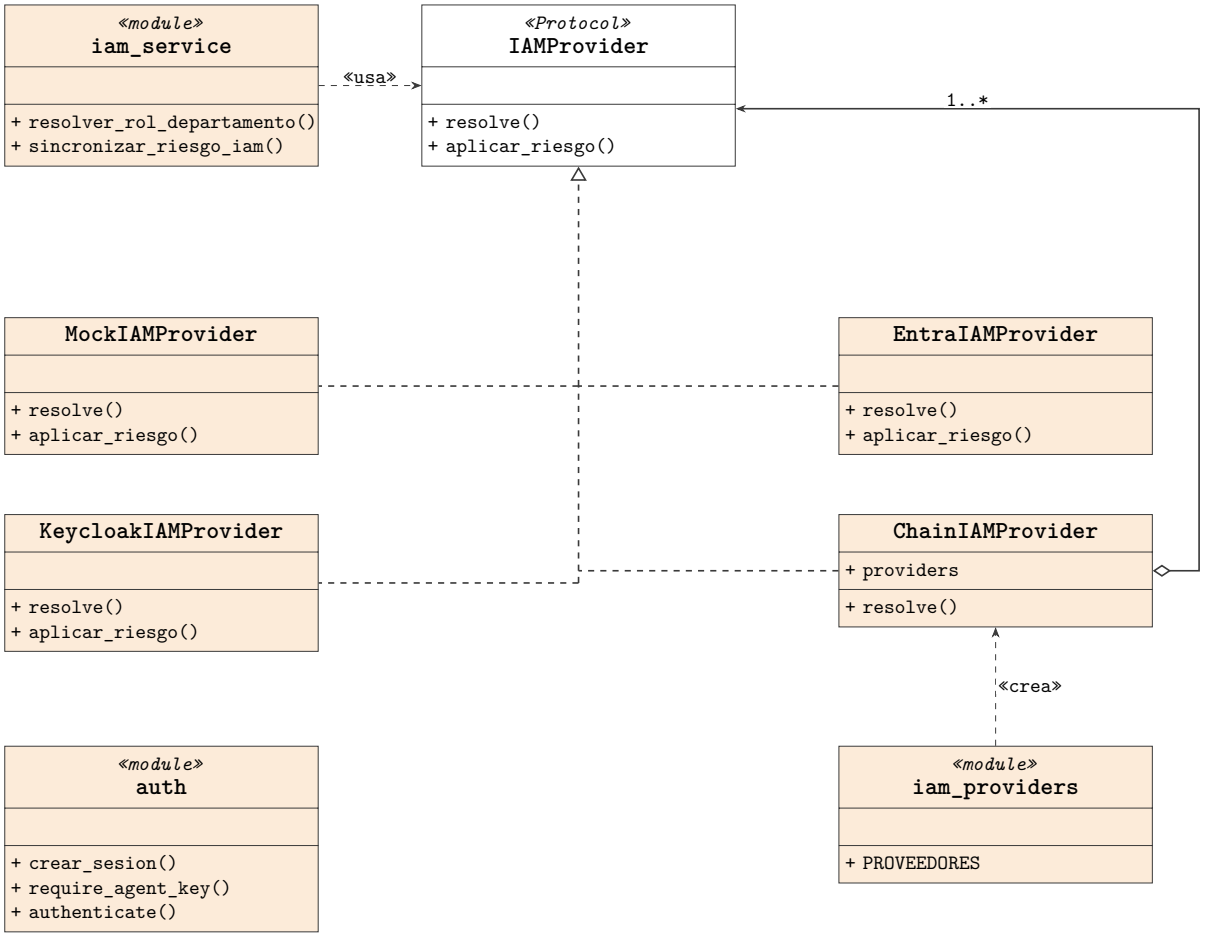


Figura 6.7: Diagrama de clases de la API PDP: proveedores de identidad y autenticación (vista de diseño).

Fuente: elaboración propia.

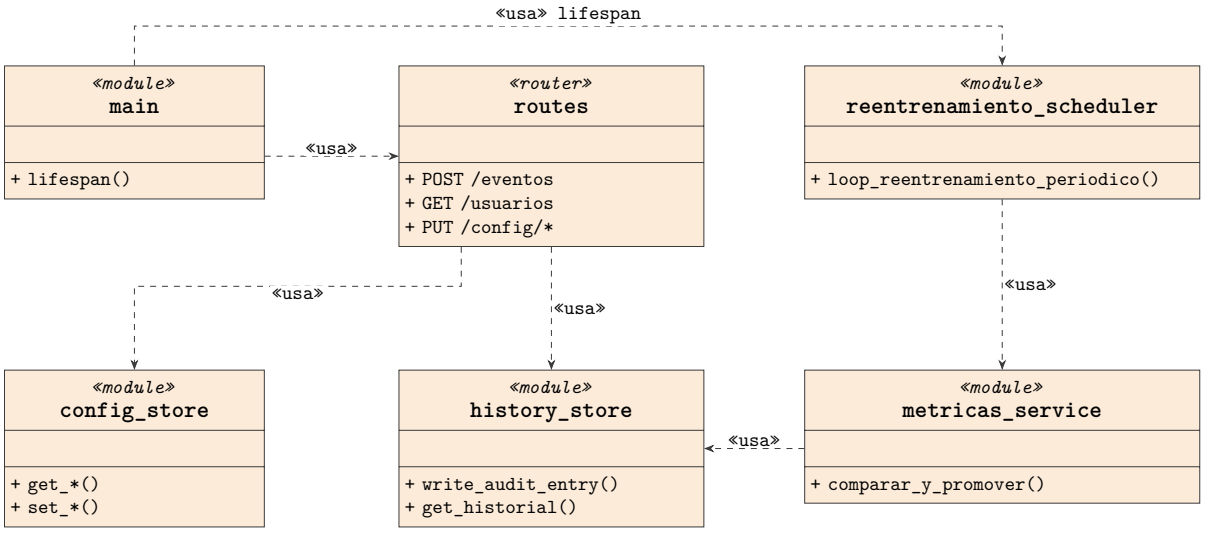


Figura 6.8: Diagrama de clases de la API PDP: rutas, persistencia, configuración y reentrenamiento (vista de diseño).

Fuente: elaboración propia.

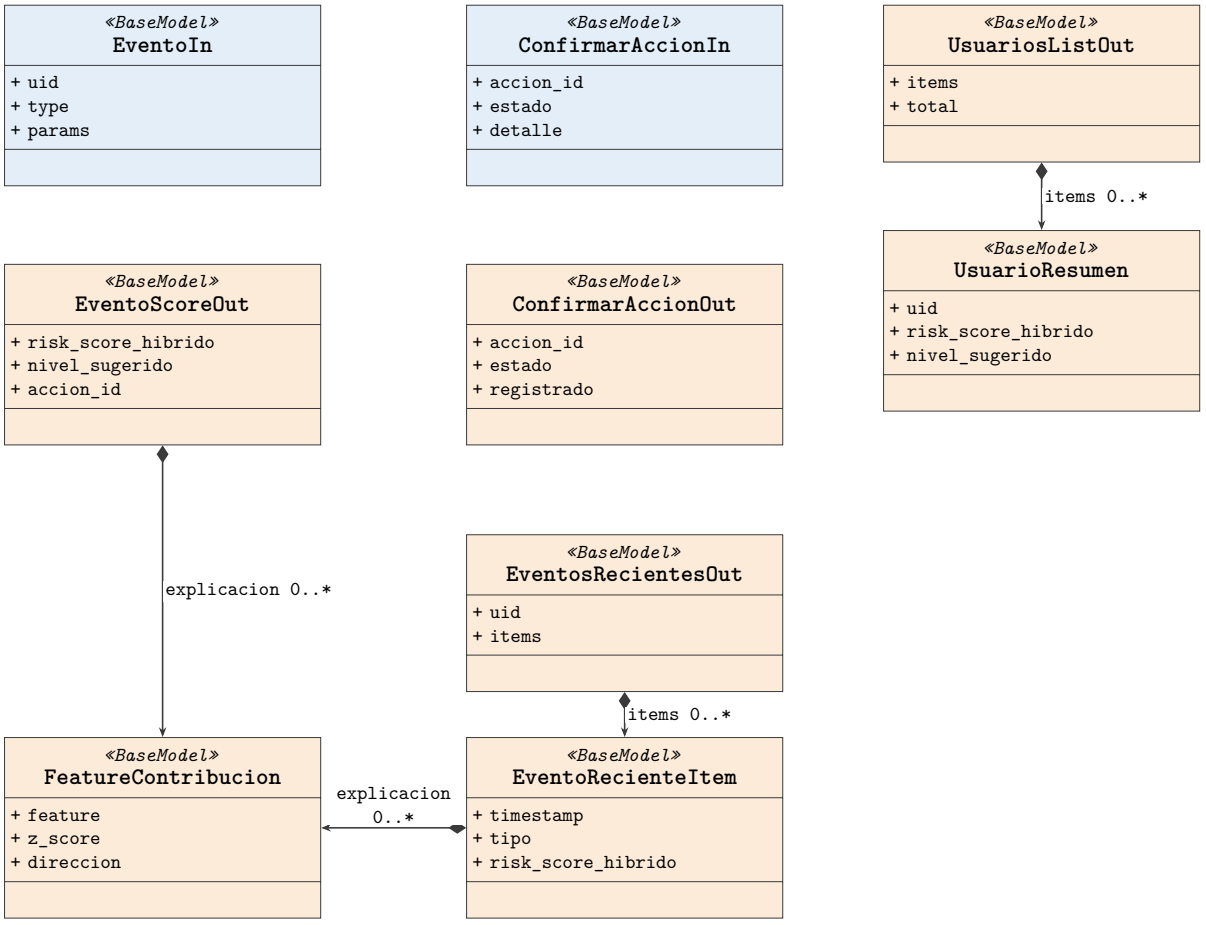


Figura 6.9: Diagrama de clases de la API PDP: esquemas HTTP (vista de diseño).
Fuente: elaboración propia.

6.5 Diagrama de objetos

La figura 6.10 presenta un diagrama de objetos construido con una instancia real del sistema.

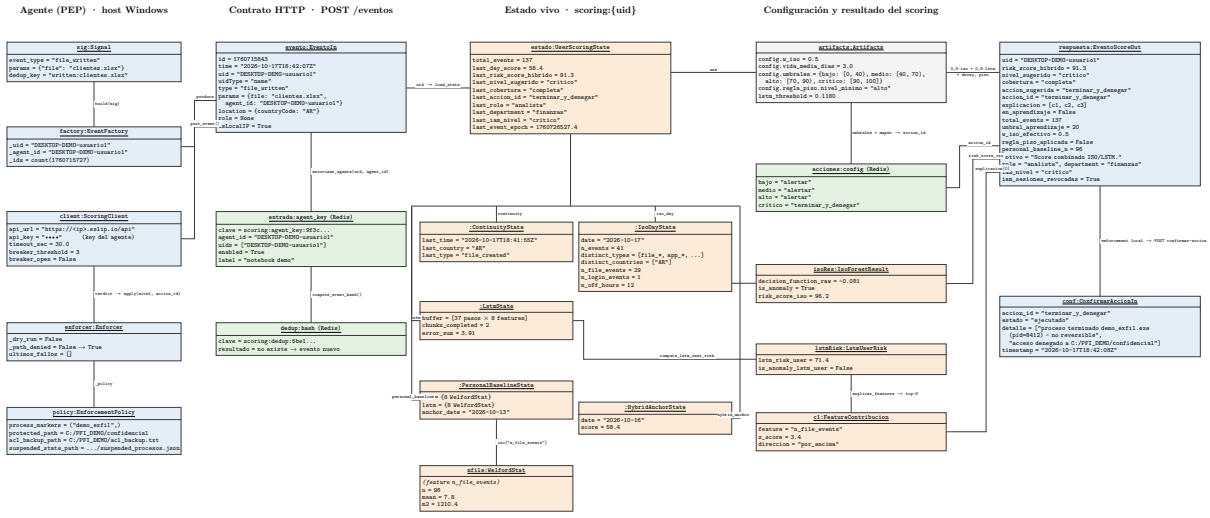


Figura 6.10: Diagrama de objetos con una instancia real (uid `DESKTOP-DEMO-usuario1`). Fuente: elaboración propia.

7 Arquitectura y tecnologías

Esta sección describe la arquitectura lógica del sistema, los lenguajes, frameworks, librerías y servicios elegidos para cada componente junto con la justificación de cada elección, la arquitectura de despliegue en el entorno local y en la nube, y los protocolos de comunicación entre los componentes.

7.1 Arquitectura lógica

La arquitectura sigue la separación entre el punto de decisión de políticas (PDP) y el punto de aplicación de políticas (PEP) propuesta por NIST SP 800-207 (Rose *et al.*, 2020). El agente local actúa como PEP: observa la actividad, la informa y aplica la decisión, pero no evalúa el riesgo. La API central actúa como PDP: concentra el modelo, la política vigente y el estado de cada usuario, y decide la acción. Esta separación permite cambiar el modelo o la política sin modificar los agentes instalados.

El sistema no es una aplicación monolítica sino un conjunto de componentes con funciones y entornos de ejecución distintos, organizados en un único repositorio con cinco subsistemas: la API de *scoring*, el agente, el *dashboard*, el *pipeline* de entrenamiento y los *scripts* de validación. La API es el único punto de acceso al estado y a la configuración, y la utilizan cuatro tipos de consumidores con distintos niveles de acceso:

- **Agente:** envía eventos y confirma las acciones ejecutadas, con una clave propia, ligada a su identificador y a los usuarios que puede reportar, que solo habilita esas dos operaciones.
- ***Dashboard* en modo consulta:** lee el estado de los usuarios, el historial y la configuración.
- ***Dashboard* en modo administración:** además, modifica la configuración y reinicia usuarios.
- **Público:** solo accede a la salud del servicio y al inicio y cierre de sesión.

El flujo principal comienza en el agente, que captura un evento y lo envía a la API. La API lo valida, actualiza el estado del usuario en Redis, persiste el evento crudo en PostgreSQL, calcula el puntaje y responde con el nivel y la acción. El agente ejecuta la acción y, si modifica el equipo, confirma el resultado. En paralelo, el *dashboard* consulta periódicamente la API para mostrar el estado actualizado, y el planificador de la API dispara el reentrenamiento cuando corresponde.

7.2 Lenguajes de programación

Los conceptos técnicos en los que se apoyan estas elecciones se presentan en la sección 2.1.10.

El lenguaje principal del sistema es Python, que se utiliza en la API, el agente, el *pipeline* de entrenamiento y los *scripts* de validación. La elección responde en primer lugar al ecosistema de aprendizaje automático empleado, basado en scikit-learn y TensorFlow, y en segundo lugar a que usarlo también en la API permite reutilizar el código de cálculo del puntaje validado durante el entrenamiento, sin reimplementarlo en otro lenguaje. Esto reduce el riesgo de diferencias entre lo que se valida y lo que se ejecuta en producción. El desarrollo se realiza con Python 3.12, mientras que la integración continua y el servidor utilizan Python 3.11.

El *dashboard* se desarrolla en TypeScript, un lenguaje que incorpora tipado estático para detectar errores de tipos durante el desarrollo. Esto resulta especialmente útil porque desde la interfaz se modifican parámetros que afectan el comportamiento del agente, como los umbrales de riesgo y las acciones asociadas a cada nivel. Además, se utiliza Zod, una biblioteca de validación que permite comprobar en tiempo de ejecución que los datos recibidos desde la API tengan la estructura y los tipos esperados. Así, ambas herramientas permiten detectar errores tanto durante el desarrollo como al procesar las respuestas del sistema.

Para automatizar las tareas específicas de cada entorno, se utilizan distintos lenguajes y herramientas. PowerShell, integrado en Windows, permite configurar el inicio automático del agente y publicar en la nube las nuevas versiones de la API desde el equipo de desarrollo. Por su parte, la infraestructura en la nube se define mediante HCL, el lenguaje utilizado por Terraform para describir y gestionar los recursos. Esta configuración se complementa con *scripts* en Bash, que ejecutan las tareas necesarias para preparar el servidor durante su primer arranque.

Se descarta un *backend* en Node.js porque igualmente habría requerido un servicio en Python para los modelos, y Java con Spring Boot porque implica más configuración y código para el alcance del proyecto.

7.3 Frameworks y librerías

Esta subsección justifica los frameworks y librerías de cada uno de los cuatro componentes de software: la API de scoring, el agente, el dashboard y el pipeline de entrenamiento.

7.3.1 API de *scoring*

La API se desarrolla con FastAPI y se ejecuta sobre Uvicorn. Este *framework* ofrece soporte para operaciones asincrónicas, valida automáticamente los datos de entrada y salida, y genera la documentación OpenAPI a partir del código. Estas características resultan especialmente útiles para una API que cuenta con 34 *endpoints*, ya que permiten mantener sus interfaces

documentadas y reducir la necesidad de incorporar extensiones adicionales, como ocurriría con Flask. Por su parte, los contratos de datos compartidos entre el agente, la API y el *dashboard* se definen mediante Pydantic 2, que permite validar la estructura y los tipos de los datos recibidos y rechazar los eventos mal formados sin necesidad de implementar manualmente esas validaciones.

El estado de cada usuario se guarda en Redis mediante redis-py. Se prefiere Redis frente a PostgreSQL para este fin porque el patrón de acceso es de alta frecuencia y baja latencia, y porque sus transacciones optimistas permiten a la API resolver escrituras concurrentes con hasta 20 reintentos. El historial y los eventos crudos se persisten en PostgreSQL con SQLAlchemy y psycopg2, usando consultas SQL explícitas, un grupo de conexiones reducido y tiempos de espera acotados para que una caída de la base de datos no bloquee la evaluación de eventos.

Para el desarrollo de los modelos se utilizan scikit-learn 1.4 y TensorFlow 2.16 con Keras. Scikit-learn proporciona la implementación de Isolation Forest, elegido por su bajo costo computacional frente a otras alternativas, como los autoencoders tabulares y las máquinas de vectores de soporte de una clase, y porque permite explicar los resultados a partir de las variables que más influyen en ellos. Por su parte, TensorFlow con Keras se utiliza para implementar el LSTM Autoencoder, seleccionado por su capacidad para modelar el orden de los eventos, a diferencia de Isolation Forest, que trabaja con agregados diarios. Sin embargo, la evaluación muestra que el modelo entrenado no logra aprovechar esa información temporal (sección 9.5). Se prefiere Keras frente a PyTorch por su API de alto nivel.

El procesamiento complementario se realiza con pandas, NumPy, SciPy y joblib, que permiten manipular datos, efectuar cálculos numéricos y serializar los modelos. Las dependencias de la API se fijan en versiones exactas para favorecer la reproducibilidad de los resultados, y las pruebas automatizadas se implementan con pytest.

7.3.2 Agente

El agente depende únicamente de tres librerías externas: psutil, para enumerar procesos y conexiones de red sin invocar directamente la API de Windows; requests, para enviar los eventos a la API en forma secuencial, por lo que no necesita un cliente asincrónico; y python-dotenv, para cargar la configuración local, como la dirección de la API y su clave. Las mitigaciones de denegación y su reversión modifican los permisos de carpetas con icacls, herramienta nativa de Windows. Dado que el agente se ejecuta en segundo plano directamente en el equipo del usuario, mantener pocas dependencias limita la superficie de ataque y el consumo de recursos.

7.3.3 *Dashboard*

El *dashboard* se desarrolla con React 19, que permite reutilizar componentes entre pantallas, como los indicadores de nivel de riesgo, cobertura y aprendizaje. Para construir la aplicación se utiliza Vite 8, que agiliza el arranque del entorno de desarrollo y la recarga de

cambios. Los datos recibidos de la API se validan con Zod 4, que complementa el tipado estático de TypeScript mediante verificaciones en tiempo de ejecución.

Las consultas a la API se gestionan con TanStack Query 5, que centraliza el caché, la revalidación y la actualización periódica de los datos cada dos segundos, evitando implementar manualmente la lógica de carga y error en cada solicitud. También permite reflejar de inmediato los cambios de configuración recién guardados. La navegación entre las nueve pantallas, incluidas las rutas protegidas por el inicio de sesión, se implementa con React Router 7. Para completar la interfaz, Recharts 3 permite representar la evolución del puntaje, mientras que Tailwind CSS 4 gestiona los estilos y los temas claro y oscuro. Por último, Oxlint se utiliza para el análisis estático del código y se integra en el proceso de integración continua.

7.3.4 *Pipeline* de entrenamiento

Las seis fases del *pipeline*, desde la exploración hasta el puntaje híbrido, se implementan como *notebooks* de Jupyter, ya que el trabajo de preparación y entrenamiento es exploratorio e iterativo y este formato conserva el código junto con sus resultados. Cuando el planificador dispara un reentrenamiento, nbconvert ejecuta los *notebooks* sin interfaz en un proceso separado de la API. Para consultar el conjunto de datos, de 14 GB en formato JSON por líneas, se emplea DuckDB, que permite ejecutar SQL sobre el archivo sin cargarlo en memoria ni administrar un motor de base de datos aparte.

7.4 Servicios e infraestructura

El estado operativo y la configuración del sistema se almacenan en Redis, y el historial, los eventos crudos, la auditoría y las métricas en PostgreSQL. Ambos se contratan como servicios gestionados, Upstash para Redis y Supabase para PostgreSQL, lo que evita administrar instancias propias y los hace accesibles tanto desde el entorno local como desde la nube. Supabase aporta además seguridad a nivel de fila y la extensión criptográfica que utiliza la cadena de *hashes*.

Para el despliegue se recurre a Amazon Web Services, que provee la instancia de cómputo de la API, el almacenamiento de objetos para el *dashboard* y las versiones publicadas, el almacén de parámetros para los secretos y la administración remota sin SSH. El *dashboard* y la API se publican con HTTPS mediante un proxy inverso (Caddy) que corre en la propia instancia. Los recursos de la nube se definen con Terraform, de modo que se crean, modifican y destruyen de forma reproducible y revisable, y GitHub Actions ejecuta en cada cambio el análisis estático, la compilación, las pruebas y la validación de la infraestructura, sin desplegar.

Por último, el sistema integra tres servicios opcionales. El envío de correo por SMTP permite notificar al administrador y, si no hay un servidor configurado, la notificación solo se registra. Gemini asiste en la redacción del correo, con un texto predefinido de respaldo para que la notificación no dependa de un servicio externo. El adaptador de identidad admite proveedores

IAM simulados, Keycloak y Microsoft Entra ID; Keycloak actúa como proveedor de referencia, está validado contra un servidor real y, como el resto, está desactivado por defecto, salvo en el despliegue en la nube. Además de leer el rol y el departamento, el adaptador informa al proveedor el nivel de riesgo y, en nivel crítico, solicita el cierre de las sesiones del usuario.

7.5 Arquitectura de despliegue

El sistema se ejecuta en dos configuraciones: un entorno local, que se usa para el desarrollo y las pruebas automatizadas, y un despliegue en la nube, que constituye la configuración de referencia. Esta subsección describe ambas, la decisión sobre el uso de contenedores y la viabilidad técnica de la solución.

7.5.1 Entorno local de desarrollo

En el entorno local, el agente, la API y el *dashboard* se ejecutan como procesos nativos en un equipo Windows y se conectan a Redis y PostgreSQL gestionados (figura 7.1). El agente se comunica con la API por loopback y el *dashboard* la consulta desde el servidor de desarrollo. Opcionalmente, la API consulta un proveedor IAM simulado o Keycloak. Esta configuración se utiliza para el desarrollo, las pruebas automatizadas y la medición del cómputo; la verificación de extremo a extremo con un agente real se realiza sobre el despliegue en la nube (sección 10.4.3).

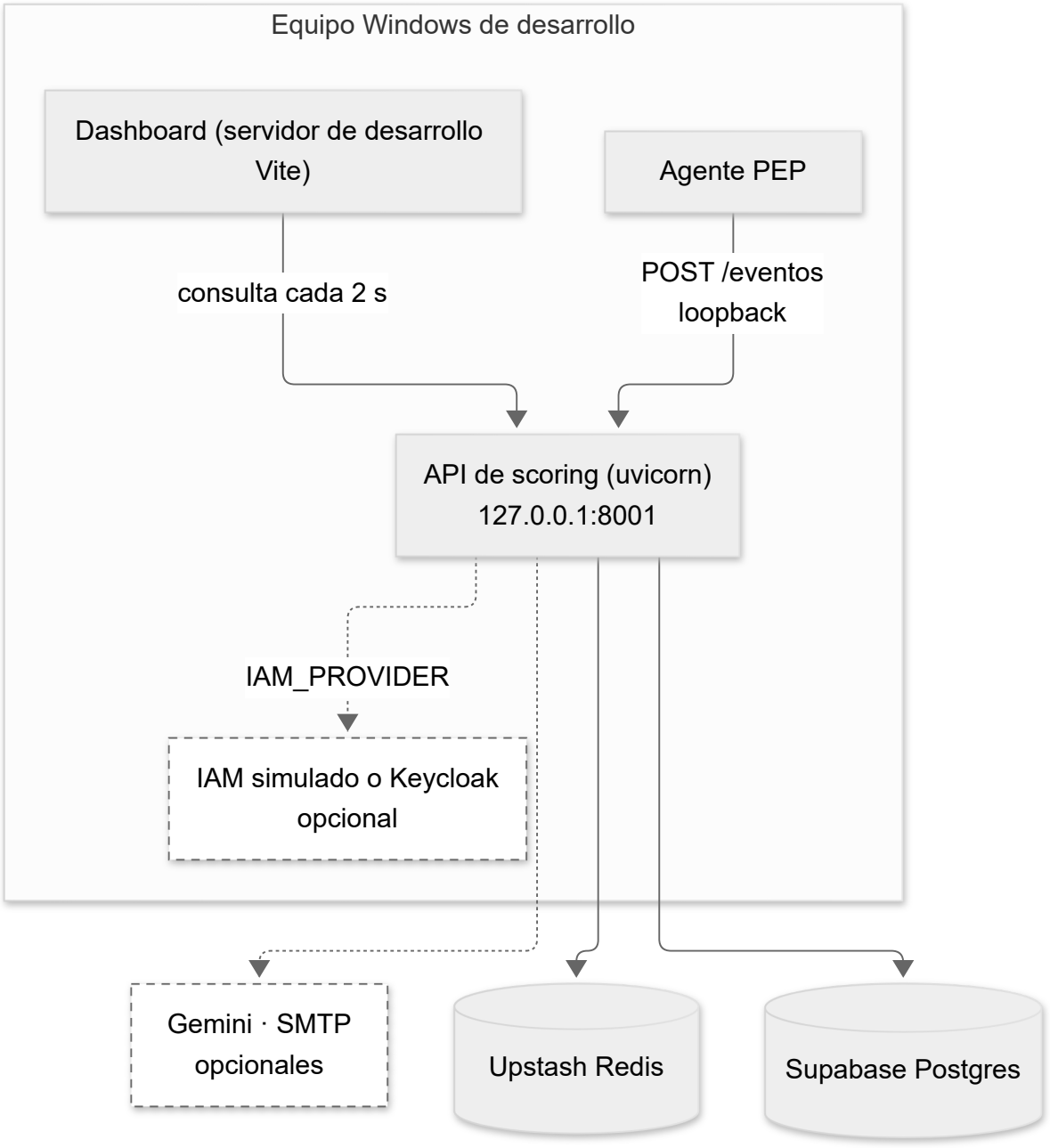


Figura 7.1: Arquitectura de despliegue local
Fuente: elaboración propia.

7.5.2 Despliegue en la nube

La infraestructura en la nube, definida mediante Terraform, ejecuta la API en una instancia de cómputo `t3.medium`, protegida por un proxy inverso (Caddy). Este se encarga de terminar las conexiones TLS mediante un certificado obtenido a través de ACME, servir el *dashboard* y redirigir a la API las solicitudes que llegan bajo la ruta `/api` (figura 7.2). En la misma instancia

se ejecuta Keycloak como proveedor IAM, mientras que el agente se comunica con la API desde el equipo que vigila.

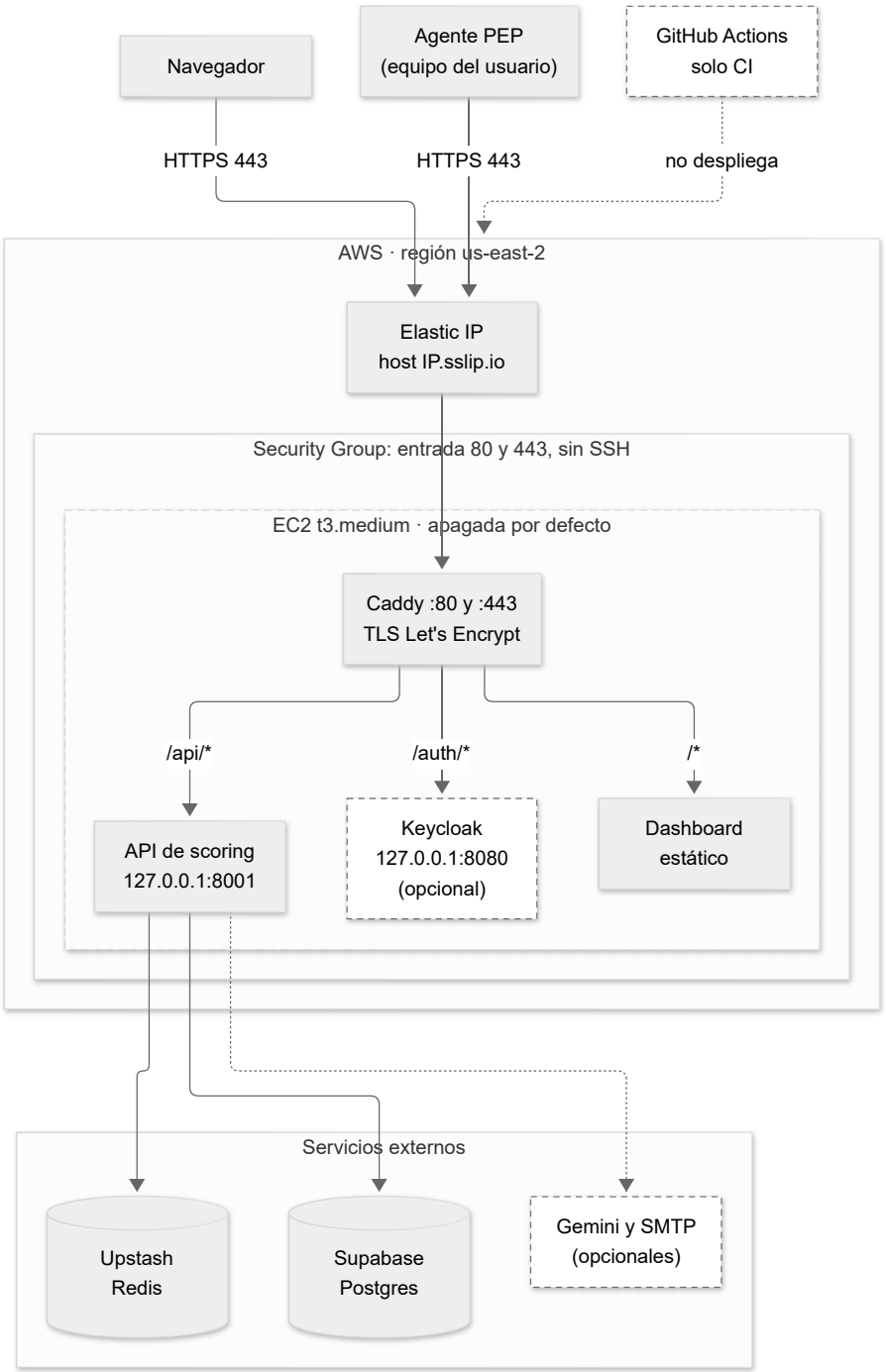


Figura 7.2: Arquitectura de despliegue en la nube
Fuente: elaboración propia.

La configuración incorpora varias medidas de seguridad. La API escucha únicamente

en la interfaz local de la instancia, por lo que las solicitudes externas deben pasar por el proxy. Además, el acceso a los metadatos de la instancia requiere la versión 2 del servicio y el disco se encuentra cifrado. Los secretos se almacenan en el servicio de parámetros del proveedor, en lugar de incluirse en el código, mientras que las tareas de administración y publicación de versiones se realizan mediante el almacenamiento de objetos y AWS Systems Manager (SSM), sin necesidad de habilitar el acceso por SSH.

Por su parte, la API funciona con la autenticación estricta habilitada y sin exponer su documentación interactiva. En el *dashboard*, las contraseñas son obligatorias y el inicio de sesión genera un *token* de sesión con vencimiento. De esta manera, las credenciales de administración no se envían ni se almacenan en el navegador.

La figura 7.3 muestra los recursos de apoyo: el rol de la instancia, los parámetros con los secretos, el administrador de sesiones, el bucket de las versiones de la API y del *dashboard* y el bucket del *dashboard*, creado pero sin uso, junto con CloudFront, definido en Terraform pero sin desplegar. La instancia conserva la misma dirección IP cada vez que se enciende.

7.5.3 Contenedores

Durante el desarrollo se evalúa utilizar Docker Compose para ejecutar la API, Redis y el *dashboard* en contenedores. Sin embargo, se descarta esta alternativa por tres razones. En primer lugar, el agente debe ejecutarse de forma nativa en Windows para acceder a los procesos y gestionar los permisos del sistema de archivos, por lo que no puede integrarse en este esquema de contenedores. En segundo lugar, Redis y PostgreSQL se reemplazan por servicios gestionados, lo que elimina la necesidad de ejecutarlos localmente. Por último, ejecutar la API como un servicio nativo en la instancia simplifica su administración mediante las herramientas del sistema operativo y del proveedor de nube.

La imagen de la API se conserva en el repositorio como alternativa de despliegue, aunque esta modalidad no forma parte del camino de despliegue verificado.

7.5.4 Viabilidad técnica

El sistema no requiere hardware específico para su funcionamiento. El agente se ejecuta como un proceso nativo en equipos con Windows que la organización ya posee y mantiene un consumo de recursos acotado, conforme a RNF-02. Por su parte, la API y el almacenamiento utilizan servicios de nube de propósito general, como cómputo, Redis y PostgreSQL gestionados, que pueden contratarse bajo demanda. Por lo tanto, la viabilidad técnica depende de la disponibilidad de estos servicios y de la infraestructura existente, sin necesidad de adquirir ni desarrollar dispositivos adicionales.

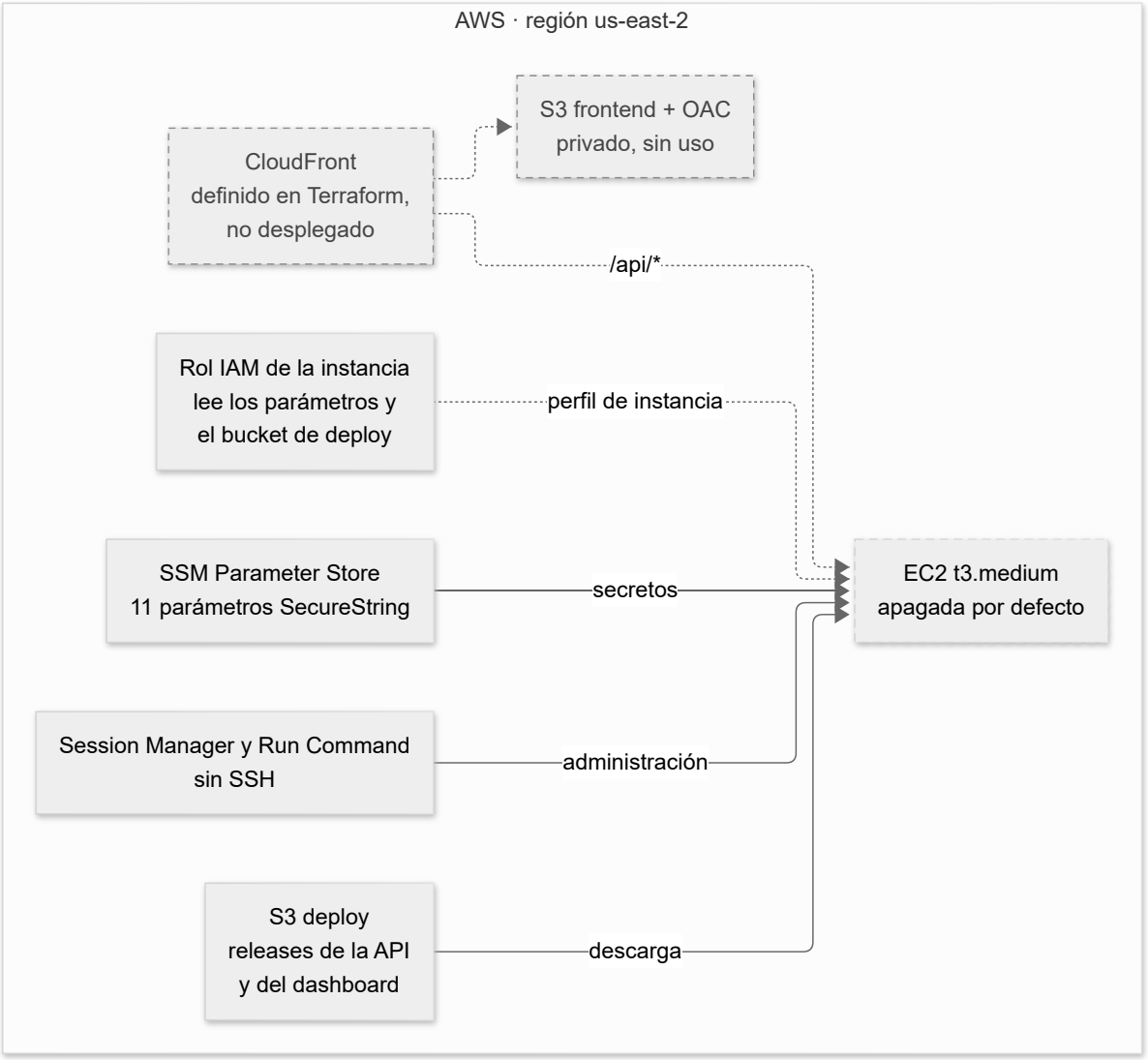


Figura 7.3: Recursos de apoyo de la instancia en la nube
Fuente: elaboración propia.

7.6 Protocolos de comunicación

La comunicación entre el agente, el *dashboard* y la API utiliza HTTP/REST con mensajes en JSON. Cada evento se envía como una solicitud independiente y recibe su propia respuesta, por lo que no es necesario mantener una conexión persistente. Los contratos de datos se definen con Pydantic en la API y Zod en el *dashboard*, lo que permite validar la estructura de los mensajes en ambos componentes. Las respuestas no cuentan con una firma propia, por lo que la integridad de los datos durante la transmisión depende de TLS (sección 9.5).

El *dashboard* actualiza el estado mediante consultas periódicas cada 2 s. Aunque el puntaje cambia con cada evento, los casos de uso no requieren notificaciones instantáneas, por lo que se descarta el uso de WebSockets. Esta alternativa habría requerido gestionar conexiones persistentes y mecanismos de reconexión sin aportar un beneficio proporcional a las necesidades del sistema.

La autenticación se apoya en claves enviadas en encabezados HTTP. Cada agente posee una clave propia, almacenada como *hash*, revocable y ligada a su identificador y a los usuarios que puede reportar. El *dashboard*, en cambio, inicia sesión con usuario y contraseña y recibe un *token* de sesión opaco, con rol y vencimiento, que envía en cada solicitud. Las claves fijas de los niveles de acceso no salen del servidor y quedan reservadas para las herramientas de línea de comandos del administrador.

Para el almacenamiento, la API se comunica con Redis mediante RESP y utiliza transacciones optimistas para garantizar que las actualizaciones del estado de cada usuario se realicen de forma atómica ante eventos concurrentes. La conexión con PostgreSQL utiliza el protocolo estándar, un grupo de conexiones y tiempos de espera acotados.

Los servicios externos también se consumen mediante canales cifrados. La API se conecta por HTTPS con Gemini y el proveedor de identidad IAM, y se autentica ante Keycloak y Microsoft Entra ID mediante OAuth 2.0 con credenciales de cliente. El *token* obtenido se mantiene en caché hasta su vencimiento. Las notificaciones, por su parte, se envían mediante SMTP con STARTTLS.

En la infraestructura de nube, el proxy inverso de la instancia termina las conexiones TLS tanto para el *dashboard* como para la API, y el agente solo acepta URLs HTTPS cuando el destino no corresponde a una dirección de *loopback*. En el entorno local de desarrollo, en cambio, el canal entre el agente y la API usa HTTP sin TLS sobre *loopback*, lo que resulta aceptable en ese ámbito. La autenticación entre el agente y la API es mutua a nivel de aplicación: el agente verifica el certificado del servidor mediante TLS y rechaza cualquier destino sin HTTPS fuera de *loopback*, y la API autentica al agente con su credencial individual, almacenada como *hash*, revocable y ligada a su identificador y a los usuarios que puede reportar. Lo que no se implementa es la autenticación mutua a nivel de transporte con certificados de cliente (mTLS), que agregaría

protección en el caso de que la credencial del agente fuera robada del propio equipo. Se declara como limitación (sección 9.5) y queda diseñada como trabajo futuro (sección 13.3).

7.7 Síntesis

La arquitectura separa la decisión, centralizada en la API, de la aplicación, distribuida en los agentes, siguiendo el modelo de Zero Trust. Las tecnologías se eligen por componente: Python para todo lo que toca al modelo, TypeScript para la interfaz y servicios gestionados para el almacenamiento. El despliegue en la nube está definido como código, con controles de seguridad explícitos y TLS terminado en la propia instancia, y se verifica de extremo a extremo con un agente real; el entorno local se reserva para el desarrollo y las pruebas.

8 Datos

Esta sección describe el conjunto de datos utilizado para entrenar el modelo, su selección y preparación, las variables construidas, la partición y los parámetros de entrenamiento, la adaptación de la telemetría del agente al esquema del conjunto de datos y el modelo de datos con el que el sistema persiste su estado.

8.1 Conjunto de datos

El modelo se entrena con CLUE-LDS (*Cloud-based User Entity Behavior Analytics Log Data Set*) (Landauer *et al.*, 2022a; Landauer *et al.*, 2022b). El conjunto contiene registros reales de actividad de los usuarios de una plataforma de almacenamiento y colaboración de archivos en la nube, seudonimizados mediante identificadores descriptivos. Abarca desde julio de 2017 hasta septiembre de 2022 y se distribuye bajo la licencia Creative Commons Atribución 4.0 (CC BY 4.0), que permite su uso con atribución a los autores.

Cada registro corresponde a un evento e incluye su tipo, la marca temporal, el identificador del usuario y su clase (nombre de usuario o dirección IP), parámetros específicos del tipo de evento y, cuando está disponible, la ubicación. El vocabulario comprende 44 tipos de evento propios de una plataforma de archivos compartidos, como accesos, creación y escritura de archivos, inicios de sesión y acceso a recursos compartidos públicamente.

El conjunto no incluye etiquetas que indiquen qué eventos corresponden a actividad maliciosa. Esta característica condiciona el entrenamiento, que es no supervisado, y la evaluación del modelo, que se presenta en la sección 10.5.

Los modelos vigentes se entrenan exclusivamente con registros reales de CLUE-LDS, sin generar, simular ni aumentar eventos, ni aplicar técnicas de balanceo de clases, dado que el conjunto no cuenta con etiquetas. Los conjuntos de prueba se obtienen mediante particiones de esos mismos datos (sección 8.3.3).

Los únicos datos creados por el equipo corresponden a escenarios de ataque inyectados sobre historiales reales (secciones 10.6 y 10.7). Estos escenarios no se utilizan para entrenar los modelos ni para calcular los percentiles de referencia, sino para evaluar la detección mediante las métricas correspondientes. Sin embargo, como no se dispone de ataques reales etiquetados, la capacidad de detección aún no se ha validado frente a incidentes reales (sección 10.10).

8.2 Selección y preparación

El conjunto completo contiene 50 522 931 eventos y 920 usuarios identificados por nombre. Los usuarios se clasifican según su volumen de actividad. No se descartan eventos por su contenido: solo se clasifican los usuarios. La tabla 8.I resume el resultado.

TABLA 8.I: Clasificación de los usuarios del conjunto de datos

Categoría	Criterio	Eventos	Usuarios
Válidos	Entre 20 y 500 000 eventos	8 494 589	291
Baja actividad	Menos de 20 eventos	3 000	617
Cuentas de servicio	Más de 500 000 eventos	41 879 451	12
Identificados por dirección IP	Usuario anónimo	145 891	–

Fuente: elaboración propia a partir de CLUE-LDS (Landauer *et al.*, 2022b).

Las cuentas de servicio concentran el 83 % de los eventos y su comportamiento automatizado no representa la conducta de una persona, por lo que se excluyen del entrenamiento. Los eventos identificados por dirección IP no pueden asociarse a un usuario y también se excluyen. El mismo criterio se aplica en producción: estos casos quedan sin puntaje (RF-03).

8.3 Variables y modelos

Cada uno de los dos modelos trabaja con una unidad de análisis y un conjunto de variables propios: Isolation Forest evalúa la actividad agregada por día y el LSTM Autoencoder, secuencias de eventos. Esta subsección describe ambos y presenta la partición de los datos y los parámetros de entrenamiento.

8.3.1 Isolation Forest

Isolation Forest evalúa la actividad de cada usuario por día calendario, tomando como referencia la zona horaria UTC. Para cada par usuario-día, se calculan ocho variables que caracterizan el comportamiento: la cantidad total de eventos, la diversidad de tipos de evento y de países, la cantidad de eventos relacionados con archivos (accesos, creaciones y escrituras) y de eventos de autenticación, la hora promedio de actividad, la proporción de eventos fuera del horario habitual (antes de las 7:00 o después de las 20:00) y la entropía de la distribución de los tipos de evento.

El entrenamiento incluye usuarios válidos y usuarios con baja actividad. En total, se consideran 908 usuarios de CLUE-LDS, lo que da como resultado 61 284 pares usuario-día. Antes del entrenamiento, las ocho variables se estandarizan para que sus diferencias de escala no afecten al modelo.

8.3.2 LSTM Autoencoder

El LSTM Autoencoder evalúa secuencias de 50 eventos consecutivos de cada usuario, sin solapamiento. Cada evento se representa con ocho variables: el tipo de evento codificado, la hora y el día de la semana en codificación cíclica (seno y coseno), el tiempo transcurrido desde el evento anterior del usuario, y dos indicadores de cambio, de país y de tipo de evento, respecto del evento previo. De los 291 usuarios válidos, 234 tienen al menos una secuencia completa, y se obtienen 169 737 secuencias. Los 57 usuarios restantes tienen menos de 50 eventos.

8.3.3 Partición y parámetros

Los modelos utilizan esquemas de partición diferentes, definidos en función de su unidad de análisis y del objetivo de evaluación. En Isolation Forest, se adopta una división temporal para evaluar su capacidad de generalización a períodos posteriores. En cambio, el LSTM Autoencoder se divide por usuario, de modo que su desempeño pueda evaluarse sobre usuarios que no participaron en el entrenamiento. La Tabla 8.II resume la configuración y los principales resultados del entrenamiento de ambos modelos.

TABLA 8.II: Configuración y entrenamiento de los modelos de detección de anomalías.

Aspecto	**Isolation Forest**	**LSTM Autoencoder**
Unidad de análisis	Par usuario-día.	Secuencia de 50 eventos.
Estrategia de partición	Temporal, con corte el 2 de agosto de 2021, correspondiente al cuantil 0,8 de la distribución de fechas.	Por usuario, con semilla fija para garantizar la reproducibilidad.
Distribución de los datos	Entrenamiento: 49 048 pares usuario-día. Prueba: 12 236 pares usuario-día.	Entrenamiento: 70 % (163 usuarios; 111 742 secuencias). Validación: 15 % (35 usuarios; 20 741 secuencias). Prueba: 15 % (36 usuarios; 37 254 secuencias).
Arquitectura y configuración	200 árboles y parámetro de contaminación de 0,02.	Codificador con dos capas LSTM de 64 y 32 unidades, *embedding* de dimensión 8 y decodificador simétrico. Total: 67 375 parámetros.
Entrenamiento	No requiere optimización iterativa.	Optimizador Adam, lotes de 128 secuencias y detención temprana.
Resultado del entrenamiento	No aplica.	Finalización en la época 22, con una pérdida de validación de 0,0805.
Criterio de detección	Umbral de puntuación determinado por el parámetro de contaminación.	Error de reconstrucción superior al percentil 95 de los errores de entrenamiento (0,1180).

Fuente: elaboración propia.

El umbral del LSTM de la tabla describe el comportamiento del modelo sobre los

conjuntos de entrenamiento y prueba (sección 10.5.1). En producción, el LSTM marca una anomalía cuando el error medio de reconstrucción del usuario, expresado como percentil respecto de la distribución de referencia del entrenamiento, supera el percentil 95 (sección 10.7.6).

Una vez obtenidas las puntuaciones de ambos modelos, se calcula un puntaje híbrido que asigna un peso de 0,5 a cada uno. Sobre este puntaje se aplica un decaimiento temporal con una vida media de 3 días. Los umbrales predeterminados para los distintos niveles de riesgo son 40, 70 y 90.

La diferencia entre los esquemas de partición también tiene implicaciones para la evaluación conjunta. Mientras que la división temporal de Isolation Forest permite analizar su capacidad para generalizar a registros futuros, la partición por usuario del LSTM Autoencoder permite evaluar su desempeño sobre usuarios no vistos durante el entrenamiento. Sin embargo, solo 15 usuarios coinciden en los conjuntos de prueba de ambos modelos, lo que limita la comparación conjunta de sus resultados. Esta restricción se considera en la evaluación presentada en la sección 10.5.

8.4 Adaptación de la telemetría del agente

El agente observa un *endpoint* Windows, mientras que el modelo se entrena con eventos de una plataforma de archivos en la nube. Para que el modelo pueda evaluar la telemetría del agente sin reentrenarse, cada señal del sistema operativo se traduce a un tipo de evento del vocabulario de CLUE-LDS. La tabla 8.III presenta esa correspondencia y su efecto sobre las variables de Isolation Forest.

TABLA 8.III: Correspondencia entre las señales del agente y los tipos de evento del conjunto de datos

Señal del sistema operativo	**Tipo de evento**	**Aporte a las variables de Isolation Forest**
Archivo creado	`file_created`	Todas, incluida la cantidad de eventos sobre archivos
Archivo modificado	`file_written`	Todas, incluida la cantidad de eventos sobre archivos
Archivo renombrado	`file_renamed`	Variables generales; no suma a los eventos sobre archivos
Archivo borrado	`file_deleted`	Variables generales; no suma a los eventos sobre archivos
Proceso o aplicación iniciado	`app_enabled`	Variables generales; no suma a ningún conteo específico

Señal del sistema operativo	**Tipo de evento**	**Aporte a las variables de Isolation Forest**
Proceso o aplicación finalizado	`app_disabled`	Variables generales; no suma a ningún conteo específico
Conexión de red saliente	`public_share_accessed`	Variables generales; no suma a ningún conteo específico
Inicio del agente	`login_successful`	Todas, incluida la cantidad de eventos de autenticación
Detención del agente	`logout_occured`	Variables generales

Fuente: elaboración propia.

En esta tabla, las variables generales son la cantidad de eventos, la variedad de tipos, la hora promedio, la proporción fuera de horario y la entropía. El LSTM utiliza para todos los eventos el tipo codificado, la información temporal y los indicadores de cambio.

Esta correspondencia constituye una decisión de diseño que permite reutilizar un modelo entrenado con datos reales, en lugar de recurrir a uno entrenado con datos sintéticos. Sin embargo, es importante tener en cuenta algunas limitaciones. En primer lugar, ninguno de los tipos de evento utilizados representa de forma nativa la ejecución de un proceso o una conexión de red. Los eventos de aplicación de CLUE-LDS corresponden a aplicaciones de la propia plataforma, mientras que el acceso a un recurso compartido públicamente se utiliza como una aproximación semántica a una conexión saliente.

En consecuencia, el modelo analiza los tipos de evento y su distribución temporal, pero no considera el nombre del proceso, el archivo involucrado ni el destino de la conexión. Por lo tanto, no identifica directamente procesos inusuales o destinos de red sospechosos, sino que detecta variaciones en el volumen, la diversidad y los horarios de la actividad. A estas limitaciones se suma que el 99,95 % de los eventos utilizados tiene el país registrado como desconocido, lo que reduce considerablemente la variabilidad de la variable de cambio de país durante el entrenamiento. Por último, el indicador de dirección local enviado por el agente describe la red del equipo y no la de la conexión, por lo que no se utiliza como entrada del modelo.

La forma de eliminar esta transferencia de dominio es reentrenar el modelo con telemetría propia de *endpoints*, recolectada por el agente durante un período de operación real. El mecanismo de reentrenamiento periódico ya incorpora los eventos crudos recibidos como insumo, aunque hoy el criterio de promoción rechaza esos reentrenamientos por el corrimiento del corte temporal (sección 9.5).

8.5 Modelo de datos

El sistema persiste su información en dos almacenes con funciones distintas. Redis guarda el estado operativo que se lee y actualiza en cada evento, y PostgreSQL guarda el historial y los registros que deben conservarse.

8.5.1 Modelo relacional

La base de datos relacional tiene siete tablas, presentadas en la tabla 8.IV. Las figuras 8.1 y 8.2 muestran su estructura.

TABLA 8.IV: Tablas del modelo relacional

Tabla	**Contenido**
`historial_scores`	Una fila por usuario y día cerrado: puntaje, nivel, cobertura, acción sugerida, explicación y motivo.
`eventos_crudos`	Cada evento recibido, sin puntaje, con su *hash* y el *hash* del evento anterior del mismo usuario.
`drift_alerts`	Corrimientos significativos de la línea base personal, con el modelo afectado y las variables involucradas.
`historial_politicas`	Auditoría de cambios de configuración, con los valores anteriores y nuevos y el actor.
`historial_ reentrenamientos`	Registro de cada reentrenamiento: fecha, cantidad de eventos, variación de las métricas y actor.
`metricas_modelo`	Métrica de cada modelo entrenado, cuál es el vigente y el resultado y el motivo del criterio de promoción.
`historial_agent_keys`	Altas y revocaciones de las claves de los agentes.

Fuente: elaboración propia.

Las tablas no utilizan claves foráneas, sino que se relacionan lógicamente mediante el identificador de usuario. Esta decisión simplifica la persistencia y permite que la evaluación de eventos continúe incluso cuando la base de datos no está disponible, lo que aporta tolerancia a fallas. Como contrapartida, la integridad referencial debe garantizarse desde la aplicación, que también se encarga de aplicar reglas como la existencia de un único modelo vigente por tipo. En cuanto a la seguridad, seis de las siete tablas tienen activada la seguridad a nivel de fila (*Row-Level Security*, RLS), lo que impide su lectura a través de la API pública de la plataforma de base de datos. El acceso a estas tablas queda restringido a la API del sistema, que utiliza sus propias credenciales. La tabla `historial_scores` constituye una excepción, ya que todavía no cuenta con esta protección; su incorporación se encuentra registrada como una mejora pendiente.

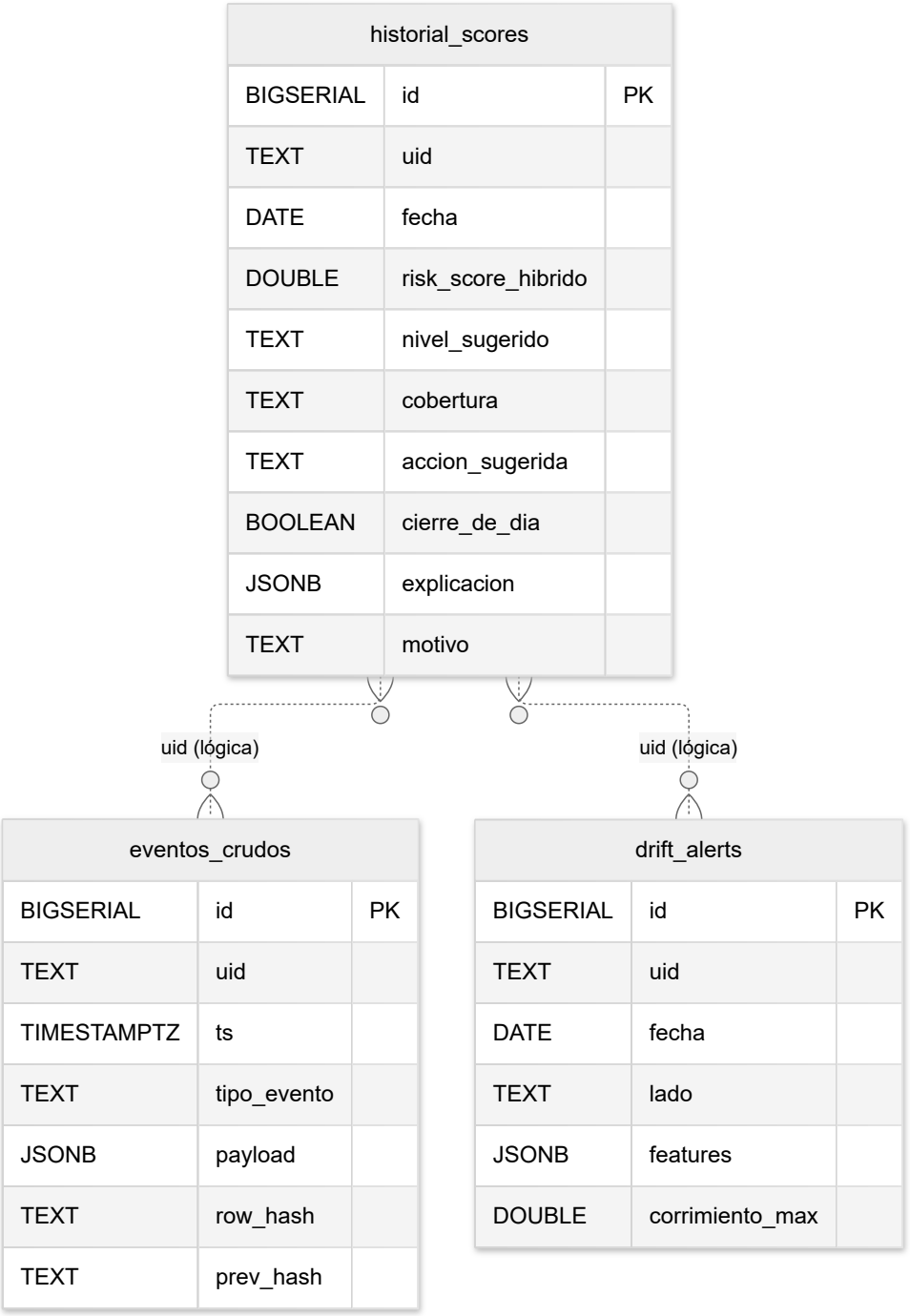


Figura 8.1: Modelo relacional: puntajes, eventos crudos y alertas de corrimiento
Todas las tablas tienen created_at TIMESTAMPTZ DEFAULT now(). En `historial_scores`, UNIQUE(uid, fecha). `drift_alerts.lado`: iso | lstm. Un disparador completa `row_hash` y `prev_hash`.
Fuente: elaboración propia.

Por otra parte, la integridad de los eventos crudos se protege mediante una cadena de *hashes* por usuario. Antes de cada inserción, un disparador de la base de datos calcula el *hash*

SHA-256 de la nueva fila a partir de sus campos y del *hash* de la fila anterior del mismo usuario. De este modo, cada registro queda vinculado al precedente, por lo que cualquier modificación o eliminación de una fila rompe la continuidad de la cadena a partir de ese punto y permite detectar alteraciones en los registros.

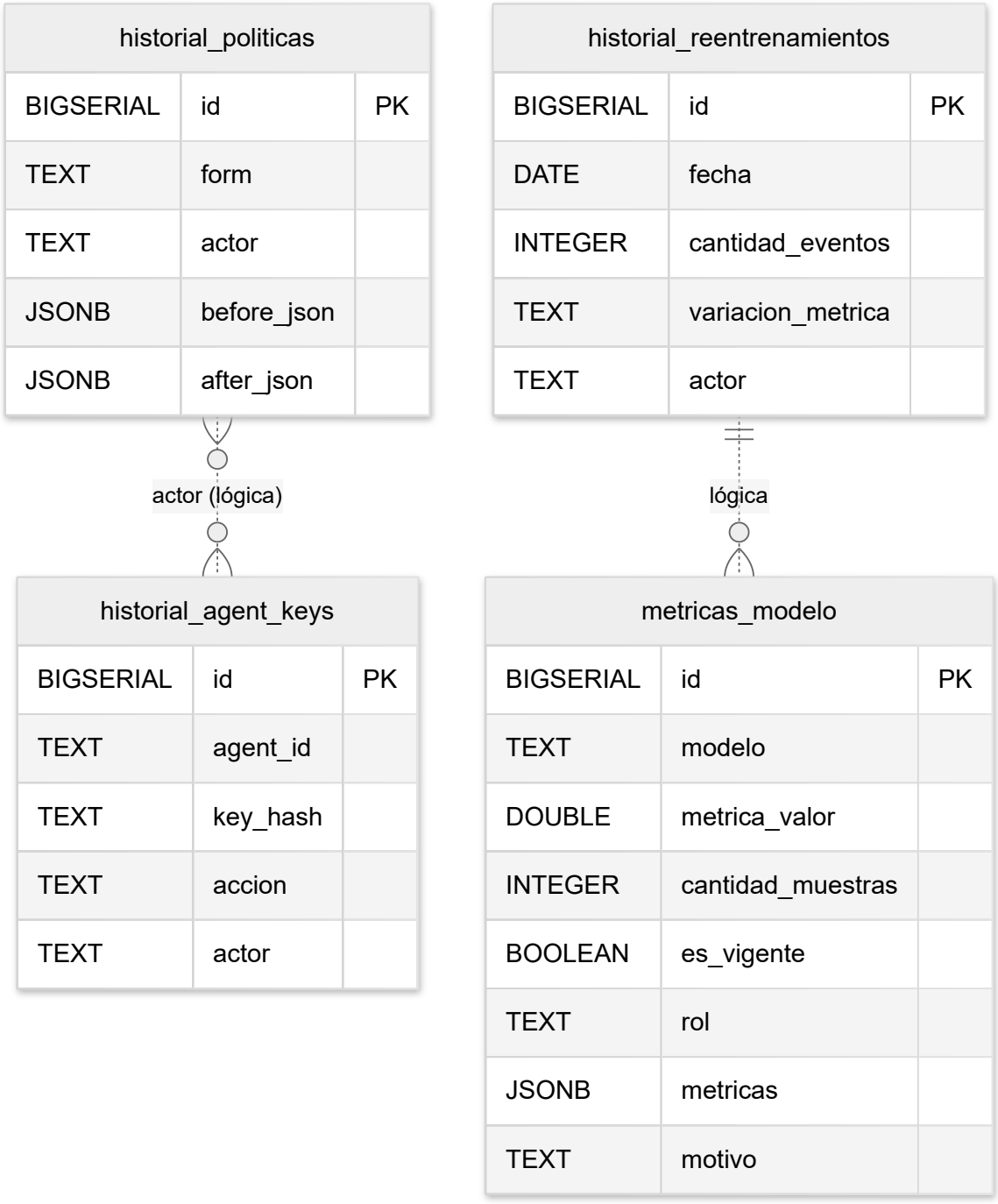


Figura 8.2: Modelo relacional: auditoría, reentrenamientos, métricas y claves de agentes
Todas las tablas tienen created_at TIMESTAMPTZ DEFAULT now(). `historial_politicas.form`: umbrales | acciones | reentrenamiento. `metricas_modelo.modelo`: iso | lstm | benchmark_dev; `rol`: candidato | vigente. `historial_agent_keys.accion`: alta | revocacion.
Fuente: elaboración propia.

8.5.2 Modelo no relacional

Redis almacena dieciséis tipos de clave, que pueden agruparse en ocho funciones según la información que guardan. La función central es el estado de cada usuario, que reúne todo lo necesario para el *scoring*: la continuidad de la secuencia, los acumulados de cada modelo, la línea base personal, el último puntaje con su nivel, acción y explicación, el contexto IAM y la última confirmación del agente. Junto a este estado se conserva una lista acotada con los últimos eventos evaluados de cada usuario. Redis guarda, además, la configuración del sistema: los umbrales, las acciones por nivel, los niveles que generan notificaciones y sus destinatarios, los parámetros de reentrenamiento, el límite de eventos recientes, el umbral de aprendizaje y los proveedores de identidad.

Estas tres funciones son permanentes, aunque la lista de eventos recientes está limitada por un tope configurable. El resto de las claves tiene una vigencia definida según su función. El intervalo de notificación registra hasta qué momento no se reenvía un correo para un mismo usuario y dura diez minutos. La deduplicación conserva durante seis horas la respuesta ya calculada para un evento, de modo que un reenvío del agente no se evalúe dos veces. Las sesiones del panel se representan con un *token* opaco que incluye el rol del usuario y su vencimiento, y caducan a las ocho horas o al cerrarse la sesión. La caché IAM mantiene el rol y el departamento del usuario durante treinta minutos, plazo que se reduce a un minuto cuando la consulta al proveedor falla, mientras que el *token* de acceso al proveedor se conserva hasta su propio vencimiento. Por último, las claves de los agentes se almacenan como *hash*, junto con el identificador del agente y su estado, y permanecen vigentes hasta su revocación.

La mayoría de estas claves gestiona el vencimiento desde la aplicación: la fecha de expiración se almacena junto con el valor y se verifica al acceder a la clave, en lugar de utilizar el mecanismo de expiración nativo de Redis. La deduplicación constituye una excepción, ya que combina este mecanismo con la expiración nativa. Por otra parte, el estado de cada usuario se actualiza mediante transacciones optimistas, con reintentos ante escrituras concurrentes, en cumplimiento del requerimiento RNF-14.

8.6 Síntesis

El modelo se entrena con 8,5 millones de eventos reales de 908 usuarios, sin etiquetas. Isolation Forest trabaja sobre variables diarias y el LSTM sobre secuencias de 50 eventos. La telemetría del agente se traduce al vocabulario del conjunto de datos, lo que permite usar un modelo entrenado con datos reales, a costa de una transferencia de dominio que limita qué patrones puede reconocer. El sistema separa el estado operativo, en Redis, del historial auditable, en PostgreSQL, y protege la integridad de los eventos crudos con una cadena de *hashes*.

9 Producto implementado

Esta sección describe el producto tal como se encuentra implementado: sus funcionalidades, el estado del despliegue, el tratamiento de los datos personales con su encuadre legal y las limitaciones conocidas.

9.1 Visión general

El producto se compone de tres piezas de software, el agente local, la API de *scoring* y el *dashboard*, y de un proceso de reentrenamiento periódico del modelo. La sección 7 describe cómo se organizan estos componentes, el flujo de información entre ellos (sección 7.1) y las tecnologías con que se construyen, junto con la justificación de su elección (sección 7.3). Esta sección, en cambio, se centra en el producto en su estado actual: las funcionalidades que ofrece cada componente, el estado del despliegue, el tratamiento de los datos personales y las limitaciones conocidas. El estado de cada requerimiento funcional y no funcional figura en las tablas de la sección 4.

9.2 Funcionalidades

Esta subsección describe las funcionalidades de cada componente: el agente local, el motor de scoring, la redacción asistida del correo de notificación, el dashboard, el reentrenamiento periódico, el tratamiento de los usuarios nuevos y el control de acceso a la API.

9.2.1 Agente local

El agente es un proceso de Python que se ejecuta de forma nativa en cada equipo Windows, sin controladores del sistema operativo. Consulta periódicamente el estado del sistema y genera eventos a partir de la comparación entre dos consultas sucesivas. Utiliza cuatro fuentes:

Archivos: creación, modificación, renombrado y borrado en el primer nivel de las carpetas vigiladas.

Procesos: inicio y finalización de procesos. Los procesos de los navegadores se agrupan para que su actividad de fondo no domine la telemetría.

Aplicaciones sensibles: inicio y finalización de aplicaciones de compresión, almacenamiento en la nube, transferencia de archivos y correo electrónico.

Red: conexiones salientes nuevas, con la dirección y el puerto remotos. En la configuración por defecto, esta fuente se limita a los procesos marcados para la demostración; una opción del agente la extiende a todos los procesos del usuario.

Cada evento contiene únicamente metadatos: el nombre del archivo o del proceso, la dirección y el puerto remotos, la marca temporal y el identificador del par equipo-usuario. El agente no captura el contenido de los archivos, las pantallas ni las pulsaciones de teclado.

Los eventos se envían a la API autenticados con una clave propia de cada agente. Si la API no está disponible, el agente los conserva en un *buffer* local, con una vigencia de 3 horas y un tope de 20 000 eventos, y los reenvía, del más antiguo al más reciente, cuando se restablece la conexión. Las fallas transitorias del servidor se reintentan hasta dos veces, con una espera creciente entre intentos. Los rechazos de autenticación, en cambio, se tratan de otro modo: tras tres rechazos consecutivos se abre un *circuit breaker* que espacia el reenvío del *buffer* a un intento cada 5 minutos hasta que la API vuelva a aceptar la credencial. Mientras el *circuit breaker* está abierto, los eventos nuevos, incluido el cierre de sesión, se conservan en el *buffer* y se descartan si superan la vigencia de 3 horas.

La respuesta de la API indica la acción de mitigación que corresponde aplicar. El agente la ejecuta y, cuando la acción modifica el equipo, informa el resultado a la API. Una acción desconocida no se ejecuta. La tabla 9.I resume las acciones disponibles y su reversibilidad.

TABLA 9.I: Acciones de mitigación del agente

Acción	**Efecto en el equipo**	**Reversión**
`alertar`	Ninguno.	No corresponde.
`terminar_procesos`	Finaliza los procesos del usuario relacionados con la actividad evaluada.	No reversible.
`denegar_carpeta`	Agrega una entrada de denegación en los permisos de la carpeta sensible.	Restituye los permisos previos desde un respaldo.
`terminar_y_denegar`	Combina las dos acciones anteriores.	Solo la denegación.
`suspender_proceso`	Suspende el proceso sin finalizarlo.	Reanuda el proceso.

Fuente: elaboración propia.

La reversión se ejecuta mediante un comando del agente. La restitución de los permisos es exacta cuando el agente se ejecuta con privilegios de administrador (sección 9.5). El agente dispone, además, de un modo de simulación que registra las acciones sin aplicarlas y que se utiliza en las pruebas y las demostraciones.

9.2.2 Motor de *scoring*

La API recibe cada evento y valida tanto su esquema como su ventana temporal, que admite eventos de hasta 90 días de antigüedad y hasta 5 minutos en el futuro. Para evitar el procesamiento redundante, los eventos duplicados recibidos dentro de un intervalo de 6 horas se descartan. Cada evento válido se evalúa mediante los modelos de detección de anomalías. En primer lugar, Isolation Forest analiza la actividad diaria del usuario a partir de ocho variables agregadas (sección 8.3.1), mientras que el LSTM Autoencoder evalúa secuencias de 50 eventos consecutivos mediante el error de reconstrucción. Cuando ambos modelos cuentan con cobertura completa, sus puntajes se combinan con la misma ponderación. En cambio, durante la etapa inicial, antes de que el usuario complete su primera secuencia de 50 eventos, se utiliza únicamente el puntaje de Isolation Forest. El puntaje obtenido se integra con una línea base personal del usuario, actualizada de manera incremental mediante el algoritmo incremental de Welford (1962), cuya influencia aumenta a medida que se acumula historial. Sobre esta base, el sistema calcula el riesgo acumulado, que disminuye con una vida media de 3 días. Este decaimiento se consolida al cierre de cada día y se aplica de forma provisional a los eventos del día en curso, por lo que el puntaje de riesgo correspondiente también tiene carácter provisional. Finalmente, el sistema determina el nivel de riesgo según los umbrales vigentes, con una regla de piso que lo eleva a alto cuando cualquiera de los dos modelos detecta una anomalía. A partir del nivel asignado, se selecciona la acción correspondiente mediante el mapeo nivel $\rightarrow$ acción. Además, se genera una explicación basada en hasta tres variables de Isolation Forest que presentan las mayores desviaciones respecto de los valores de la población de entrenamiento, siempre que estas superen al menos una desviación estándar.

Cuando el nivel asignado está configurado para notificar, la API envía un correo al administrador con el puntaje, el nivel y los eventos recientes del usuario, respetando un intervalo mínimo de 10 minutos por usuario. La redacción del correo puede asistirse con un modelo de lenguaje externo; si este no está disponible, se utiliza un texto predefinido (sección 9.2.3).

La integración con el proveedor IAM, cuando está configurada, opera en ambos sentidos. Por un lado, la API incorpora el rol y el departamento del usuario como contexto informativo, con una caché de 30 minutos, y una falla del proveedor no interrumpe la evaluación. Por otro, cuando el nivel del usuario cambia, la API informa el nuevo nivel al proveedor y, si el nivel es crítico, solicita el cierre de sus sesiones. Con Keycloak, un nivel alto o crítico exige además un segundo factor (OTP) en el próximo inicio de sesión.

La API detecta también los corrimientos significativos de la línea base personal y los registra como alertas de *drift*. El estado vigente de cada usuario y una lista acotada de sus eventos recientes se mantienen en Redis, mientras que el historial diario, con su explicación, y los eventos crudos se persisten en PostgreSQL. Los eventos crudos se encadenan mediante

hashes por usuario, lo que permite detectar modificaciones posteriores.

9.2.3 Redacción asistida del correo

La redacción asistida (RF-31) utiliza Gemini, un modelo de lenguaje externo que recibe telemetría parcialmente controlada por el usuario vigilado, como los nombres de archivo y de proceso. Esto la expone a la inyección indirecta de instrucciones, que OWASP y NIST ubican entre los principales riesgos de los sistemas de IA generativa (OWASP Foundation, 2024; Vassilev *et al.*, 2025). El diseño parte de un principio: el modelo no tiene autoridad sobre ninguna decisión. El nivel y la acción ya están decididos y persistidos antes de la llamada, y la salida solo se usa como un párrafo de un correo en texto plano, que no se almacena ni vuelve al agente. Sobre esa base, los datos se envían saneados, truncados y dentro de un bloque delimitado que las instrucciones declaran como información; la salida se valida antes de usarse y, ante cualquier incumplimiento o error, se reemplaza por el texto predefinido. Además, el usuario, el nivel, el puntaje, la acción y la explicación de la alerta figuran siempre en un bloque fijo del correo, de modo que el administrador nunca depende únicamente del texto generado. La llamada es síncrona y puede demorar la respuesta al agente hasta 6 segundos, aunque no demora la decisión.

9.2.4 *Dashboard*

El *dashboard* consulta la API cada 2 segundos (sección 7.6) y se organiza en nueve pantallas: inicio de sesión, usuarios, detalle de usuario, explicación del puntaje, usuarios con historial, alertas, configuración, auditoría y estado del sistema. El diseño de cada una se presenta en la sección 5.4.

La pantalla de configuración concentra la administración de las políticas en tiempo de ejecución. Desde ella, el administrador edita los umbrales y la acción asociada a cada nivel, la periodicidad y la ventana horaria del reentrenamiento, el umbral de aprendizaje y los niveles que generan notificaciones, junto con sus destinatarios. También configura los proveedores IAM y consulta el registro de reentrenamientos. En la pantalla de alertas, el administrador puede marcar a los usuarios como reconocidos durante la sesión.

9.2.5 Reentrenamiento periódico

Un planificador integrado en la API verifica si se cumple la periodicidad configurada y si el momento actual se encuentra dentro de la ventana horaria. Cuando ambas condiciones se cumplen, exporta los eventos crudos acumulados, excluidos los de prueba y las reproducciones, junto con el conjunto de datos original, y ejecuta el *pipeline* de entrenamiento en un proceso separado. Antes de reemplazar cualquier archivo, respalda el juego completo de artefactos vigentes (modelos, escaladores, codificación y referencias de percentil), de modo que, ante un rechazo, todos se restauran juntos. La exportación de las referencias de percentil es el último

paso del *pipeline*. El *pipeline* tiene un tiempo máximo de ejecución, de 4 horas por defecto y configurable con la variable de entorno `SCORING_REENTRENAMIENTO_TIMEOUT_SEC`.

Finalizado el entrenamiento, se aplica un criterio de promoción de no inferioridad sobre los escenarios de la partición de desarrollo (DEV) del benchmark de detección descrito en la sección 10.7. El modelo candidato y el vigente se puntúan sobre los mismos escenarios, sin que HOLDOUT participe en ningún caso. El candidato se promueve solo si cumple las dos condiciones siguientes:

(a) el ROC-AUC medio del híbrido en los cuatro escenarios primarios sin país (S2 con $k = 2$, 5 y 10, y S3) es al menos el del modelo vigente menos 0,02;

(b) su tasa de falsos positivos en nivel alto o superior sobre los días limpios de DEV es, como máximo, la del modelo vigente más 0,01.

Si el candidato se promueve, la API recarga los modelos en memoria sin reiniciarse. El candidato tampoco se promueve, y se registra el motivo, cuando faltan escenarios, cuando su corte temporal entre entrenamiento y prueba no coincide con el de la partición original (sección 8.3.3) o cuando falla el puntuado. La verificación del corte garantiza que los días de los escenarios de DEV no formen parte del entrenamiento del candidato, lo que inflaría artificialmente sus métricas. Ante cualquier rechazo se restaura el respaldo. La evaluación agrega entre 5,5 y 7,5 minutos al reentrenamiento, según la máquina.

Este criterio reemplaza al anterior, que comparaba la tasa de anomalías de Isolation Forest y el error de reconstrucción del LSTM y exigía que el valor del modelo nuevo fuera menor o igual al del vigente. Ninguna de esas dos magnitudes mide la capacidad de detección: con esa regla, un modelo que no marcara nada resultaría el mejor. Los márgenes de 0,02 y 0,01 se fijan de antemano y son del orden de la variación entre semillas de entrenamiento. En consecuencia, un candidato equivalente al vigente puede rechazarse por azar: el criterio protege contra regresiones grandes, pero no distingue diferencias pequeñas.

El criterio está implementado y cuenta con 13 pruebas automatizadas. Su comportamiento se comprueba, además, con el script de evaluación sobre los modelos actuales: el modelo vigente, evaluado contra sí mismo, cumple ambas condiciones y se promueve, mientras que un juego alternativo de modelos (v2), aunque mejora el ROC-AUC, se rechaza porque su tasa de falsos positivos supera el máximo admitido. En el sistema en funcionamiento, en cambio, el criterio todavía no se ha ejecutado desde el planificador con un modelo genuinamente nuevo: los reentrenamientos registrados son anteriores a su incorporación, se evaluaron con la regla anterior y ninguno se promovió. La migración que habilita el registro de las métricas del criterio está aplicada y el esquema lo soporta, pero el criterio todavía no registró ninguna evaluación en la base.

El juego de modelos vigente proviene de la última corrida manual de reentrenamiento. La regla anterior lo rechaza por diferencias del orden del ruido, y se adopta después como vigente por la consistencia del juego completo, no como resultado de una promoción (sección 10.5). El conjunto de variables del modelo queda versionado y, con la versión 1 vigente, la salida del puntaje no cambia (sección 10.7.3). En el despliegue en la nube, el planificador está desactivado.

Cada corrida queda registrada con su fecha, la cantidad de eventos, las métricas de ambos modelos y el motivo de la decisión. El administrador puede registrar también los reentrenamientos realizados en forma manual.

9.2.6 Usuarios nuevos y período de aprendizaje

Un usuario se da de alta automáticamente con su primer evento y permanece en período de aprendizaje hasta acumular la cantidad de eventos configurada, que es de 20 por defecto y puede fijarse entre 1 y 1000. Durante ese período, sus eventos se evalúan normalmente y el nivel informado no se modifica, pero la acción se atenúa a `alertar`. La excepción son los eventos de creación, modificación, renombrado y borrado de archivos, que reciben la política normal. El *dashboard* muestra el progreso de cada usuario respecto del umbral, y la salida del período es automática.

9.2.7 Control de acceso

La API expone 34 *endpoints*, agrupados en cuatro niveles de acceso que se resumen en la tabla 9.II. La credencial de cada agente y el *token* de sesión del *dashboard* se describen en la sección 7.6.

TABLA 9.II: Niveles de acceso de la API

Nivel	***Endpoints***	**Alcance**	**Credencial**
Público	4	Estado del servicio, inicio y cierre de sesión.	Ninguna.
Consulta	16	Lecturas del *dashboard*.	*Token* de sesión de cualquier rol o clave fija de consulta.
Administración	12	Cambios de configuración.	*Token* de sesión con rol administrador o clave fija de administración.
Agente	2	Envío de eventos y confirmación de acciones.	Clave individual del agente o clave fija de administración.

Fuente: elaboración propia.

En el nivel de agente, la API rechaza con un código 403 cualquier evento o confirmación de acción que no corresponda a la identidad del agente. En el código actual, cuando la API corre en modo estricto, que es el que usa el despliegue en la nube, ese nivel rechaza además la clave de administración con un código 403; en el entorno local de desarrollo la acepta, para los *scripts* de evaluación. Esta corrección todavía no está publicada en la instancia (sección 9.3). En el *dashboard*, el inicio de sesión rechaza las contraseñas por defecto o de ejemplo, y el *token* vence a las 8 horas o al cerrar la sesión. El rol operador tiene acceso de solo lectura y recibe un 403 en los *endpoints* de administración. Por último, cada cambio de configuración queda registrado en la auditoría con un identificador derivado de la credencial utilizada, que en las sesiones del *dashboard* indica además el rol.

9.3 Estado del despliegue

El producto se encuentra desplegado en la nube, que constituye su configuración de referencia: la API, el *dashboard* y Keycloak se ejecutan en la instancia de AWS descrita en la sección 7.5.2, y el agente, en el equipo Windows que vigila, se comunica con ella por HTTPS. El entorno local (sección 7.5.1) se reserva para el desarrollo, las pruebas automatizadas y la medición del cómputo. Ambas configuraciones comparten Redis y PostgreSQL gestionados, por lo que no se ejecutan en simultáneo.

De la infraestructura definida en Terraform, todos los recursos están aplicados salvo CloudFront; el *bucket* del *dashboard* existe, pero no se utiliza, porque el *dashboard* lo sirve la propia instancia. Las versiones de la API y del *dashboard* se publican en forma manual, y la instancia se mantiene apagada fuera de las pruebas y las demostraciones. La verificación de extremo a extremo sobre la instancia, con un agente real, se presenta en la sección 10.4.3. Las correcciones del rechazo de la clave de administración en los *endpoints* del agente, de la suspensión de procesos sin registro recuperable, del *buffer* del agente con el *circuit breaker* abierto y con el tope alcanzado, del registro de los reentrenamientos fallidos y de la vuelta del panel al inicio de sesión cuando la sesión vence están implementadas y probadas en el código, pero no forman parte de la release desplegada (b499fa3); hasta la próxima publicación, la instancia sigue aceptando la clave de administración en el envío de eventos y la confirmación de acciones.

9.4 Tratamiento de datos personales y viabilidad legal

El sistema actúa como herramienta de una organización que monitorea los equipos que provee a sus empleados. En un despliegue real, la organización cliente es la responsable del

tratamiento en los términos de la Ley 25.326, y el proveedor del sistema actúa como prestador de servicios de tratamiento por cuenta de ella. La tabla 9.III relaciona cada principio del marco legal (sección 2.1.9) con la forma en que el sistema lo contempla y con las obligaciones que quedan a cargo de la organización o pendientes.

TABLA 9.III: Principios de la Ley 25.326 y su tratamiento en el sistema

Principio	**Cómo lo contempla el sistema**	**A cargo de la organización / pendiente**
Finalidad (art. 4)	Finalidad única y declarada: detectar el uso indebido de credenciales y responder ante él. Los datos no se usan para medir la productividad ni para otros fines.	Declarar la finalidad en la política interna y no reutilizar los datos para otros fines.
Datos no excesivos (art. 4)	El agente recolecta solo metadatos de actividad (RNF-08): no captura el contenido de archivos, mensajes, pantallas ni pulsaciones de teclado. Las cuentas identificadas por dirección IP y las de volumen muy alto quedan fuera del puntaje.	Configurar las carpetas y aplicaciones vigiladas de forma acotada.
Consentimiento e información (arts. 5 y 6)	El panel muestra, para cada puntaje, las variables que lo explican, lo que permite informar al empleado por qué se toma una acción.	Informar a los empleados la existencia del control, su finalidad y sus derechos mediante una política de uso aceptable o una cláusula contractual. La LCT exige que los controles relativos a la actividad del trabajador sean conocidos por este (art. 71).

Principio	**Cómo lo contempla el sistema**	**A cargo de la organización / pendiente**
Seguridad (art. 9)	Cifrado con TLS y certificado verificado entre el panel o el agente y la API en la nube (sección 7.5.2); el agente se niega a usar `http://` fuera de *loopback*. Credencial individual por agente y *token* de sesión del panel con vencimiento (sección 9.2.7). Cadena de *hashes* sobre los eventos crudos, seguridad a nivel de fila en seis de las siete tablas (sección 8.5) y secretos en el almacén de parámetros de la nube. Lo verificado en la instancia figura en la sección 10.4.3, y lo pendiente, en la tabla 9.IV.	Gestionar los accesos al panel y rotar las claves.
Confidencialidad (art. 10)	Acceso al panel con inicio de sesión y roles diferenciados de consulta y administración; registro de auditoría de los cambios de configuración.	Limitar el acceso al personal de seguridad.
Transferencia internacional (art. 12): infraestructura	Los servicios gestionados procesan datos fuera de Argentina: la API corre en una instancia de AWS en Estados Unidos (región us-east-2), mientras que PostgreSQL (Supabase) y Redis (Upstash) se alojan en la región de São Paulo, Brasil.	Ni Estados Unidos ni Brasil figuran en la lista de países con legislación adecuada de la Disposición 60-E/2016, por lo que la transferencia requiere cláusulas contractuales tipo. Corresponde formalizarla con esas cláusulas o desplegar en una región con protección adecuada.

Principio	Cómo lo contempla el sistema	A cargo de la organización / pendiente
Transferencia internacional (art. 12): redacción asistida	El servicio opcional de redacción de correos (Gemini) recibe el identificador del usuario (equipo-usuario), el puntaje, el nivel, las variables que lo explican y hasta los 10 eventos más recientes de la alerta, con nombres de archivo o de proceso y, en los accesos a recursos compartidos, la dirección y el puerto remotos. Solo redacta la sección narrativa del correo, sin intervenir en el nivel ni en la acción (sección 9.2.3).	Desactivar el servicio de redacción o minimizar los datos que se le envían.
Acceso, rectificación y supresión (arts. 14 a 16)	El panel permite consultar el historial de un usuario. La API permite eliminar su estado y su historial de puntajes, pero conserva los eventos crudos y las alertas de corrimiento asociadas, por lo que no constituye un mecanismo de supresión completo.	Pendiente: definir un plazo de conservación y un procedimiento de supresión que alcance a los eventos crudos. Ese procedimiento entra en tensión con la cadena de *hashes* por usuario, porque borrar una fila impide verificar las siguientes (sección 9.4.1).
Registro (art. 21)	No aplica al proveedor.	Evaluar la inscripción de la base según el uso que la organización haga de ella.

Fuente: elaboración propia a partir de la Ley 25.326 y la Ley de Contrato de Trabajo.

9.4.1 Conservación de los datos y cadena de hashes

Actualmente, los eventos crudos y el historial de puntajes no tienen un plazo de conservación definido, y el borrado que ofrece la API no constituye un mecanismo de supresión completo (tabla 9.III). La cadena de *hashes* que protege la integridad de los eventos (sección 8.5) dificulta, además, la supresión, porque eliminar una fila rompe la verificación de las filas siguientes del mismo usuario. Se identifican tres alternativas para conciliar ambos requisitos:

1. cerrar la cadena por período (por ejemplo, mensualmente), conservar el último *hash* de

cada período y eliminar los períodos vencidos;

2. reemplazar el identificador del usuario por un seudónimo calculado con una clave secreta, de modo que destruir la clave anonimice los registros sin modificarlos;

3. eliminar el contenido de la fila y conservar solo su *hash*.

Se adopta como trabajo futuro la primera alternativa, por ser la que preserva la verificación de los períodos vigentes con el menor cambio en el modelo de datos.

9.4.2 Datos de entrenamiento

El modelo inicial se entrena con CLUE-LDS, un conjunto público de registros reales seudonimizados mediante identificadores descriptivos y distribuido bajo licencia CC BY 4.0 (sección 8.1). Su uso respeta la licencia mediante la atribución a sus autores y no requiere el tratamiento de datos de personas identificables.

El reentrenamiento periódico, en cambio, incorpora los eventos que el agente registra en la organización (RF-19), que constituyen datos personales de los empleados en los términos de la Ley 25.326. En el prototipo, la exportación copia esos eventos sin seudonimizar (identificador del usuario, nombres de archivo y de proceso, direcciones y puertos remotos y ubicación) a un archivo local excluido del control de versiones, que se sobrescribe en cada corrida pero no se elimina. Reentrenar el modelo de detección puede considerarse compatible con la finalidad declarada del tratamiento (tabla 9.III); sin embargo, el prototipo no aplica controles específicos sobre ese archivo. Un despliegue productivo requiere seudonimizar los identificadores antes de la exportación, eliminar el archivo al finalizar cada reentrenamiento e incluirlo en el plazo de conservación (sección 9.4.1).

9.4.3 Descargo de responsabilidad

El sistema es una herramienta de apoyo a la seguridad de la información y no reemplaza el criterio del personal de seguridad. Las acciones automáticas que ejecuta, como la terminación de procesos o la denegación de acceso a carpetas, pueden afectar el trabajo legítimo de un empleado ante un falso positivo. Por ese motivo, en la configuración por defecto las acciones más severas se reservan para el nivel crítico y pueden revertirse cuando el sistema operativo lo permite. La organización que adopte el sistema es responsable de configurar las políticas de respuesta, de informar a sus empleados y de cumplir la normativa de protección de datos y laboral aplicable.

9.5 Limitaciones conocidas

La tabla 9.IV reúne las limitaciones conocidas del producto, agrupadas según el componente o el aspecto al que afectan, junto con su impacto y el tratamiento previsto. Las limitaciones

relacionadas se presentan en una misma fila. No se incluyen los comportamientos propios del entorno local de desarrollo, que no aplican al despliegue en la nube: allí la API rechaza las solicitudes sin claves configuradas (modo estricto) y el agente exige HTTPS fuera de *loopback* (sección 7.6).

TABLA 9.IV: Limitaciones conocidas del producto

Limitación	**Impacto**	**Tratamiento**
Modelo y detección		
Sensibilidad baja ante ataques de corta duración	Los escenarios inyectados rara vez alcanzan el nivel alto y ninguno el crítico (sección 10.6). La evaluación con escenarios etiquetados lo confirma (sección 10.7.4).	Trabajo futuro: variables con granularidad menor al día y evaluación con datos etiquetados del dominio del agente.
El país actúa como interruptor	En ambos modelos, la ubicación, y no el comportamiento, decide la detección operativa de los ataques con país y el nivel crítico del escenario de extremo a extremo (sección 10.7).	Trabajo futuro: regla explícita de ubicación en el motor de decisión, que reemplace a las variables de país dentro de los modelos.

Limitación	Impacto	Tratamiento
Aporte limitado del LSTM	No aprovecha el orden de los eventos: permutar los 50 eventos de una secuencia no cambia el ordenamiento (Spearman 0,989), y el cambio de país explica cerca del 72 % del error de reconstrucción en el período de test. Además, un puntaje impulsado por el LSTM no identifica qué lo causó, y al cerrarse la primera secuencia de un usuario el puntaje pasa de golpe de depender solo de Isolation Forest a combinar ambos modelos.	Trabajo futuro: rediseñar el LSTM o reemplazarlo por un modelo explicable, con una transición gradual entre ambos cálculos.
Datos de entrenamiento de otro dominio	El modelo se entrena con registros de una plataforma de archivos compartidos; los eventos del sistema operativo se traducen a ese vocabulario, y algunos no aportan a las variables de Isolation Forest. Las variables horarias se calculan en UTC, no en la hora local del usuario.	Documentado como decisión de diseño; trabajo futuro: reentrenar con telemetría propia de *endpoints* y calcular las variables horarias en hora local.
Calibración sin datos independientes	El peso de cada modelo, la regla de piso y los umbrales se calibran sin escenarios etiquetados, y la línea base personal tiende a valores altos en usuarios con poco historial, lo que eleva sus alertas.	La recalibración evaluada con los escenarios etiquetados (sección 10.7) y cinco alternativas para la línea base no mejoran la detección (sección 10.9); los umbrales son editables en tiempo de ejecución.
Agente local		

Limitación	Impacto	Tratamiento
Captura por sondeo	Las operaciones que ocurren y se deshacen entre dos consultas pueden perderse, y las lecturas de archivos no generan eventos.	Inherente al diseño sin controladores del sistema operativo.
Alcance de las mitigaciones	Un proceso terminado no puede restaurarse, y la acción se reintenta mientras el nivel se mantiene. Sin privilegios de administrador (`SeRestorePrivilege`), la reversión de la denegación de carpeta recurre a `icacls /remove:d` y pierde las denegaciones que el usuario ya tenía.	La terminación se reserva para el nivel crítico (RF-07) y el agente se ejecuta como administrador.
Alcance de la observación	El agente solo observa los equipos donde está instalado. El uso de credenciales robadas desde un equipo sin agente no genera telemetría, y solo se cubre en forma parcial mediante la integración IAM (segundo factor y cierre de sesiones en Keycloak).	Inherente al enfoque basado en el *endpoint*; trabajo futuro: incorporar los eventos de autenticación del proveedor IAM como fuente adicional.
Reentrenamiento		

Limitación	Impacto	Tratamiento
Partición del candidato con datos del agente	Al sumar datos del agente, el *pipeline* recalcula el corte temporal y el criterio rechaza por precaución todo candidato; el LSTM, además, separa entrenamiento y prueba por sorteo de usuarios, que los usuarios nuevos alteran sin que el criterio lo detecte. Por eso todavía no se ha ejecutado una promoción desde el planificador con un modelo genuinamente nuevo (RF-21, sección 9.2.5).	Trabajo futuro: partición por origen del dato, con todos los datos del agente en entrenamiento y el conjunto de datos posterior al corte como prueba, y verificación de que ninguna víctima de los escenarios participe del entrenamiento.
Eventos incorporados sin revisión	El reentrenamiento incorpora los eventos recibidos sin una revisión previa, por lo que un atacante podría introducir actividad maliciosa en forma gradual (*drift* inducido, sección 2.1.7.2). El criterio de no inferioridad protege contra regresiones de detección, pero no contra esa contaminación.	Trabajo futuro: excluir del reentrenamiento los eventos de usuarios con alertas en nivel alto o crítico y revisar la nueva línea base antes de promoverla.
Autenticación y comunicaciones		
Clave de administración aceptada en el nivel de agente	En el modo estricto (despliegue en la nube) la API rechaza la clave de administración en los *endpoints* del agente; en el entorno local de desarrollo se acepta para los *scripts* de evaluación.	Corregido en el código; pendiente de publicar en la instancia.

Limitación	**Impacto**	**Tratamiento**
Sin autenticación mutua (mTLS) ni firma de las respuestas	El agente se autentica con una clave individual, de modo que una clave robada sirve para reportar los eventos del usuario al que está ligada. La integridad de las respuestas del PDP depende de TLS; la respuesta solo indica la clase de acción, y una acción desconocida no se ejecuta.	Trabajo futuro: certificados de cliente y firma de las respuestas (sección 13.3).
Sin política de seguridad de contenido (CSP) en el *dashboard*	El *token* de sesión se guarda en el almacenamiento de sesión del navegador, por lo que un ataque de *cross-site scripting* podría leerlo mientras dure la sesión.	Trabajo futuro: CSP en el proxy. El *token* vence a las 8 horas y se invalida al cerrar la sesión; HSTS ya está activo en el proxy.
Microsoft Entra ID sin validación real	El proveedor está probado con solicitudes simuladas, sin acceso a un *tenant* real.	Validación pendiente; Keycloak está validado contra un servidor real.
Inyección de instrucciones en la redacción asistida (Gemini)	Un nombre de archivo o de proceso puede contener instrucciones dirigidas al modelo. El peor caso es un correo engañoso, porque el nivel y la acción los decide el motor de *scoring* (RNF-04).	Controles en la entrada y la salida (sección 9.2.3).
Datos personales		
Conservación y seudonimización	Los eventos crudos y las alertas de corrimiento de un usuario no se suprimen, y la exportación del reentrenamiento copia los eventos del agente sin seudonimizar a un archivo local que no se elimina.	Trabajo futuro: plazo de conservación y supresión compatible con la cadena de *hashes*, y seudonimización del archivo exportado (secciones 9.4.1 y 9.4.2).

Fuente: elaboración propia.

9.6 Síntesis

El producto implementa el ciclo completo de detección, decisión y mitigación sobre el *endpoint*, con políticas configurables en tiempo de ejecución, auditoría de los cambios, reentrenamiento periódico controlado y tratamiento específico de los usuarios nuevos. Los 31 requerimientos funcionales están implementados, aunque en el caso de RF-21 todavía no se ha ejecutado una promoción desde el planificador con un modelo genuinamente nuevo (sección 9.2.5). Las limitaciones principales no se encuentran en la cobertura funcional, sino en la capacidad de detección del modelo y en la ausencia de autenticación mutua por certificado; ambas orientan el trabajo futuro (sección 13).

10 Pruebas y resultados

Esta sección presenta la verificación del sistema: la estrategia de pruebas, las pruebas automatizadas, funcionales y de rendimiento, la evaluación del modelo sin etiquetas, con escenarios inyectados y con escenarios etiquetados, la evaluación de usabilidad, las decisiones tomadas a partir de los resultados y las limitaciones de las pruebas.

10.1 Estrategia de pruebas

La estrategia combina pruebas automatizadas, que se ejecutan en cada cambio del código, con verificaciones manuales y mediciones puntuales para los aspectos que dependen del sistema operativo, de los servicios externos o del comportamiento del modelo sobre datos reales. La tabla 10.I resume las técnicas aplicadas, la herramienta utilizada y el alcance de cada una.

TABLA 10.I: Técnicas de prueba, herramientas y alcance

Técnica	**Herramienta**	**Alcance**
Pruebas unitarias	pytest	Reglas del motor de *scoring* (decaimiento, niveles, regla de piso), proveedores IAM, notificaciones, respaldo de modelos y componentes del agente (colectores, *buffer*, *circuit breaker*, reversión), con las dependencias del sistema operativo simuladas.
Pruebas de integración de la API	pytest, cliente de pruebas de FastAPI y Redis simulado en memoria	Endpoints de configuración, autenticación, auditoría, integración IAM y salud del servicio, sin servicios externos.
Pruebas de extremo a extremo del *scoring*	pytest con los modelos entrenados	Evaluación de eventos completos con los modelos reales: período de aprendizaje, persistencia de la explicación y recarga de modelos sin reinicio.

Técnica	Herramienta	Alcance
Prueba automatizada de extremo a extremo PDP→PEP	pytest con los modelos entrenados y el código real del agente	Ciclo completo entre el punto de decisión y el de aplicación, con los efectos sobre el sistema operativo reemplazados por un registro en memoria (sección 10.3).
Medición de cobertura	coverage.py con pytest-cov	Cobertura de líneas y de ramas de la API y del agente, medida por separado (sección 10.2.4).
Pruebas de contrato	pytest	Estructura del evento que el agente envía a la API, contrato de los endpoints de salud y validación de rangos de configuración.
Pruebas de regresión	Script propio de regresión	Comparación del puntaje calculado en línea contra el cálculo fuera de línea sobre historiales reales del conjunto de datos.
Análisis estático y compilación	oxlint, compilador de TypeScript, Vite y npm audit	Calidad, tipado, construcción y dependencias vulnerables del *frontend*.
Integración continua	GitHub Actions	Ejecución automática de las suites, del análisis estático y de la validación de la infraestructura en cada *push*.
Pruebas funcionales manuales	Scripts de demostración y ensayo	Escenarios de extremo a extremo contra Redis y PostgreSQL reales, incluida la ejecución de mitigaciones en el *endpoint*.
Pruebas de rendimiento	Scripts de medición con requests y psutil	Latencia de evaluación de eventos (RNF-01) y consumo de recursos del agente (RNF-02).

Técnica	Herramienta	Alcance
Evaluación del modelo	Métricas sin etiquetas, escenarios inyectados y escenarios etiquetados	Comportamiento del modelo híbrido sobre el conjunto de datos y sensibilidad ante escenarios de ataque simulados; detección y falsos positivos sobre escenarios de etiqueta conocida en una partición reservada (sección 10.7); matriz de confusión y controles negativos sobre escenarios adicionales (sección 10.7.6).
Evaluación de usabilidad	Evaluación heurística	Interfaz del *dashboard* contra las diez heurísticas de usabilidad de Nielsen.

Fuente: elaboración propia.

10.2 Pruebas automatizadas

Las pruebas automatizadas se ejecutan en cada cambio del código. Esta subsección presenta su inventario, el resultado de la ejecución completa, el pipeline de integración continua y la cobertura alcanzada, tanto de código como de requerimientos.

10.2.1 Inventario

El repositorio contiene 667 pruebas automatizadas, 477 de la API y 190 del agente (algunas funciones de prueba se ejecutan con varios juegos de parámetros). La tabla 10.II las agrupa por componente.

TABLA 10.II: Inventario de pruebas automatizadas por componente

Componente	Archivos	Pruebas	Tipos y foco
API de *scoring*	44	477	Unitarias, de integración, de extremo a extremo con modelos reales, de contrato y de regresión. Cubren autenticación y sesiones, ligadura de las claves de agente, configuración y su atomicidad, auditoría, período de aprendizaje, explicación persistida, IAM, notificaciones con y sin el modelo de lenguaje, persistencia con una base de datos simulada, planificador de reentrenamiento y el ciclo PDP→PEP, el criterio de promoción del modelo y la paridad de las variables entre versiones.
Agente local	15	190	Unitarias con el sistema operativo simulado: colectores, filtro de procesos, *buffer* local, *circuit breaker*, exigencia de HTTPS, confirmación de acciones, reversión de la ACL y contrato del evento.
Frontend	–	–	Sin pruebas unitarias; se valida con análisis estático, verificación de tipos y compilación.

Fuente: elaboración propia.

10.2.2 Resultados de la ejecución

La tabla 10.III presenta el resultado de la ejecución completa de las pruebas, en un entorno aislado, sin servicios externos configurados y sin ejecución real de mitigaciones.

TABLA 10.III: Resultados de la ejecución de las pruebas automatizadas

Suite	Resultado
API, suite completa con los modelos entrenados	477 aprobadas, 0 fallidas, 0 omitidas

Suite	Resultado
API, configuración de integración continua (sin los modelos entrenados)	445 aprobadas, 23 omitidas, 0 fallidas
Agente, suite completa en Windows	190 aprobadas, 0 fallidas
Frontend, análisis estático	Sin errores
Frontend, compilación	Correcta, con una advertencia por el tamaño del paquete de la biblioteca de gráficos

Fuente: elaboración propia.

Las 23 pruebas omitidas en la configuración de integración continua dependen de artefactos que no están versionados: 16 requieren los modelos entrenados, 3 verifican la paridad de las variables con la segunda versión del modelo, 3 dependen de las salidas del *benchmark* controlado y 1 de las salidas de la fase 6. La cobertura de código se mide y se informa en la sección 10.2.4.

10.2.3 Integración continua

El repositorio cuenta con un *pipeline* de GitHub Actions que se ejecuta en cada *push* y está compuesto por cuatro trabajos independientes:

- ***Frontend*** (Ubuntu, Node 24): análisis estático y compilación; no tiene umbral de cobertura, porque el *frontend* no tiene pruebas.
- **API** (Ubuntu, Python 3.11): pruebas de la API sin los artefactos de modelo, con un umbral del 85 % de cobertura combinada de líneas y ramas (sección 10.2.4). Allí se ejecutan también cuatro archivos de pruebas del agente que no dependen del sistema operativo.
- **Agente en Windows (`agent-windows`):** suite completa del agente, con un umbral del 85 % de cobertura de líneas.
- **Infraestructura** (Ubuntu, Terraform 1.16.4): verificación de formato y validación de la configuración, sin aplicar cambios.

Sobre la versión que incluye las correcciones descritas en la sección 9.3, el *pipeline* finaliza con los cuatro trabajos aprobados. Las pruebas que requieren los modelos entrenados, entre ellas la de extremo a extremo PDP→PEP, y la prueba de regresión se ejecutan localmente.

10.2.4 Cobertura de código

La cobertura se mide con *coverage.py* (mediante *pytest-cov*), con medición de ramas activada, sobre todo el código del producto que se ejecuta en operación:

- el punto de decisión de políticas (PDP), es decir, el código de la API;
- los dos módulos auxiliares de *scripts* que la API importa en ejecución;
- el punto de aplicación de políticas (PEP), es decir, el agente.

El alcance está versionado en el repositorio. Las únicas exclusiones son el envoltorio de ejecución del punto de entrada del agente y una función que solo usa un análisis fuera de línea. No se excluye ningún módulo del producto por depender de servicios externos: la persistencia en PostgreSQL, el planificador de reentrenamiento, los colectores y la aplicación de acciones se prueban con dobles (un motor de base de datos simulado, subprocesos triviales, bibliotecas del sistema simuladas y carpetas temporales).

Cada componente se mide por separado con su propia suite: la API con los artefactos de modelo entrenados y el agente en Windows, su sistema operativo soportado. La evidencia del objetivo del 85 % es esta medición local completa, que se realiza con un *script* del repositorio. El umbral se fija sobre la cobertura de líneas, y la cobertura combinada de líneas y ramas se informa como dato adicional. La tabla 10.IV presenta los resultados por componente.

TABLA 10.IV: Cobertura de código por componente

Componente	**Pruebas**	**Sentencias**	**% líneas**	**% líneas y ramas**
API (PDP)	477	2 808	**94,8**	93,5
Agente (PEP)	190	1 107	**91,8**	91,1
Total (suma de ambos componentes)	**667**	3 915	**93,9**	92,8

Fuente: elaboración propia.

En integración continua, la API se mide sin los modelos entrenados, por lo que el núcleo de *scoring* no se ejercita: esa medición da 88,50 % de líneas y 87,11 % de líneas y ramas y funciona como protección contra regresiones, no como evidencia del objetivo.

Frontend. El *dashboard* queda fuera del umbral, y se declara así explícitamente. Por una invariante de la arquitectura, el *frontend* no contiene lógica de negocio: no calcula el puntaje, no aplica el decaimiento ni combina modelos. Solo muestra lo que expone la API y edita la configuración operativa, que la API valida. El riesgo funcional del sistema reside en la API y en el agente, que son los componentes medidos. El *frontend* se valida con análisis estático y verificación de tipos en cada *push*, y de forma manual contra la API.

10.2.5 Cobertura de los requerimientos

Los requerimientos funcionales tienen prueba automatizada, salvo RF-08 (ejecución real de las acciones en el equipo) y el indicador de aprendizaje del *dashboard* (RF-26), que se verifican a mano. Los no funcionales que dependen del entorno se verifican con las mediciones y ensayos de las secciones siguientes: RNF-01 y RNF-02 (rendimiento), RNF-09, RNF-10 y RNF-14 (pruebas funcionales), RNF-12 y RNF-13 (despliegue) y RNF-15 (usabilidad).

10.3 Pruebas funcionales de extremo a extremo

La integración entre el punto de decisión (API) y el punto de aplicación (agente) se valida con una prueba automatizada que reproduce el guion de la demostración: 46 eventos, de los cuales 9 son de calentamiento, 31 de exfiltración de archivos y 6 desde un país simulado. El agente usa su código real para construir cada evento, interpretar la respuesta y confirmar la acción, y la API decide con los modelos entrenados; como el guion no completa una secuencia de 50 eventos, el puntaje proviene solo de Isolation Forest. Únicamente los efectos sobre el sistema operativo (terminar procesos y denegar la carpeta) se reemplazan por un registro en memoria. La prueba verifica que:

- cada evento recibe puntaje, nivel y una acción coherente con la política configurada;
- el nivel escala hasta alto y luego crítico;
- en crítico, el agente termina los procesos y deniega la carpeta una sola vez;
- la confirmación del agente queda registrada y la API la expone.

La validación de la ventana temporal de los eventos queda activa durante la prueba, que además comprueba el rechazo de un evento fechado en el futuro.

Contra Redis y PostgreSQL reales se realizan, además, las siguientes pruebas funcionales manuales:

- **Demostración de seis escenas.** Seis escenarios recorren los casos de uso CU-01 y CU-02: un usuario de bajo riesgo, una exfiltración de archivos con mitigación en el *endpoint*, una aplicación no monitoreada, el catálogo de acciones de mitigación, una conexión de red y la configuración de umbrales con un rechazo por validación. Cada corrida genera un reporte de auditoría automático.
- **Ensayo de la cadena de decisión.** Un *script* envía una secuencia de eventos de exfiltración y registra la evolución del nivel. El primer evento queda en nivel medio, el nivel alto se alcanza en el evento 15 y el crítico en el evento 44, con la acción correspondiente devuelta al agente en cada caso.

- **Período de aprendizaje.** Con la API conectada a los servicios reales, se verifica la lectura y modificación del umbral de aprendizaje, el rechazo de valores fuera de rango y la exigencia de autenticación de administrador.
- **Reentrenamiento y promoción.** Se verifica en vivo el reemplazo del modelo sin reiniciar la API y el rechazo de un modelo peor. Una corrida real disparada por el planificador dura cerca de 1 h 50 min y no promueve el modelo, porque el error del LSTM empeora de 0,1155 a 0,1175 (sección 9.2.5).
- **Integridad de los eventos crudos.** La verificación de la cadena de *hashes* sobre la tabla de eventos crudos resulta correcta en el 100 % de las filas, antes y después de registrar un evento nuevo.
- **Concurrencia sobre PostgreSQL.** Con hasta 50 escrituras concurrentes no se producen errores, y el disparador que calcula la cadena de *hashes* agrega en promedio 0,042 ms por inserción.
- **Concurrencia sobre Redis.** Con el Redis gestionado, entre 3 y 4 de cada 20 escrituras simultáneas sobre un mismo usuario fallan por conflicto de transacción; con reintentos y una espera aleatoria, se completan 70 de 70 sin error (RNF-14).

Como complemento, el código del agente, de la API y del *frontend* se somete a revisiones estáticas de seguridad y mantenibilidad. La auditoría de dependencias del *frontend* finaliza sin vulnerabilidades reportadas.

10.4 Pruebas de rendimiento

Esta subsección mide los dos requerimientos de rendimiento del sistema: la latencia de evaluación de eventos (RNF-01), en el entorno local y en la nube, y el consumo de recursos del agente (RNF-02). Incluye además la verificación del despliegue en la nube.

10.4.1 Latencia de evaluación de eventos (RNF-01)

Se mide la latencia de extremo a extremo de la evaluación de eventos desde el lado del cliente. La prueba envía en secuencia 1000 eventos, precedidos por 50 de calentamiento que se descartan, distribuidos entre cinco usuarios con una mezcla de tipos representativa de la actividad que captura el agente. La API se ejecuta en el mismo equipo, con Redis en memoria y sin base de datos. La tabla 10.V presenta los resultados.

TABLA 10.V: Latencia de evaluación de eventos (RNF-01)

Métrica	**Valor**
Media	16,96 ms
Mediana	13,35 ms
Percentil 95	14,91 ms
Percentil 99	148,87 ms
Máximo	880,26 ms
Errores	0 de 1000
Rendimiento secuencial	59 eventos por segundo

Fuente: elaboración propia a partir de las mediciones del sistema.

El umbral fijado para RNF-01 es un percentil 95 menor o igual a 500 ms y un percentil 99 menor o igual a 1 s. El criterio se justifica porque el *dashboard* consulta el estado cada 2 s y el agente captura actividad con una frecuencia del orden de un segundo: un evento evaluado en menos de medio segundo no se acumula. El umbral se aplica al cómputo de la evaluación medido en entorno aislado, y el resultado lo cumple con amplio margen. La latencia con servicios gestionados en la nube se informa por separado en la sección 10.4.2, sin una meta propia.

La misma prueba, ejecutada en un segundo equipo (Windows 11, procesador AMD de 16 núcleos lógicos), da un percentil 95 de 13,0 ms y un percentil 99 de 108,9 ms, con 1000 de 1000 eventos evaluados sin error.

Las latencias más altas coinciden con los eventos que completan una secuencia de 50 eventos de un usuario, momento en que se ejecuta la inferencia del LSTM. Esta relación se infiere de la posición de los valores extremos y no está instrumentada. La medición tiene dos limitaciones: Redis en memoria no representa la latencia de red de un Redis gestionado, y los eventos se envían de forma secuencial, sin carga concurrente de varios agentes.

10.4.2 Latencia en la nube

La misma operación se mide sobre la instancia desplegada en la nube, desde un cliente en Argentina y por HTTPS. La prueba envía en secuencia 300 eventos reales del conjunto de datos, precedidos por 20 de calentamiento. El percentil 95 es de 3 110 ms (media 3 051 ms, mediana 3 036 ms, percentil 99 de 3 362 ms, máximo de 4 057 ms), con 0 errores de 320. La API informa un promedio de 2 489 ms dentro de la evaluación del evento, alrededor del 82 % de la media que ve el cliente; el resto corresponde al trayecto entre el cliente y la instancia.

El tiempo no se debe al cómputo del modelo (14,9 ms en entorno aislado) sino a las idas y vueltas hacia los servicios gestionados de datos. Medidos desde la instancia con la conexión reutilizada (n = 50), cada comando a Redis y cada consulta a PostgreSQL tardan unos 124 ms,

contra 43 a 48 ms desde un cliente en Argentina. Un evento requiere unos 20 viajes secuenciales: 16 a Redis, contados con un servidor simulado que registra cada ida y vuelta, y 4 a PostgreSQL, estimados por lectura del código. El producto, $(16 + 4) \times 124$ ms $\approx 2\,480$ ms, coincide con los 2 489 ms informados por la API. La coincidencia depende de la estimación de los viajes a PostgreSQL (con 2 o 3 la suma sería de 2 240 o 2 360 ms) y proviene de una única jornada de medición. La misma cuenta aplicada a la medición local contra los mismos servicios (17 viajes a Redis y 4 a PostgreSQL) da unos 930 ms, frente a 921 ms medidos.

Con esta topología, la latencia extremo a extremo depende de la distancia entre la instancia y los servicios de datos y de la cantidad de viajes por evento. Reducirla exige acercar los servicios a la región de la API o disminuir los viajes por evento. Como la nube es la configuración de referencia del producto (sección 9.3), esta es la latencia que percibe hoy el agente desplegado: la meta de RNF-01 se cumple en el cómputo de la evaluación, pero no de extremo a extremo con la topología actual, en la que la instancia (us-east-2) y los servicios de datos (São Paulo) están en regiones distintas. Ubicar la instancia en la misma región que los servicios de datos es la primera medida para reducirla.

10.4.3 Verificación del despliegue

En la instancia corre la release `b499fa3`, con Python 3.11.16, y los seis artefactos de modelo comprobados (modelos de Isolation Forest y LSTM, los dos escaladores y las dos referencias de percentiles) tienen el mismo SHA-256 que los del repositorio local. Desde el exterior, el certificado TLS de Let's Encrypt es válido y el HTTP redirige a HTTPS con un código 308, la documentación interactiva responde 404, el puerto de la API no responde, y la recepción de eventos devuelve 401 sin clave y con una clave falsa, y 200 con una clave de agente válida. Tras detener y volver a arrancar la instancia, el proxy y la API se restablecen sin intervención.

Sobre la instancia se verifica, además, el funcionamiento de extremo a extremo:

Agente real. Un agente envía eventos por HTTPS con su credencial individual y alcanza el nivel crítico (97,06), con la acción de terminar el proceso y denegar la carpeta, que ejecuta. El nivel alto no se observa, porque el puntaje pasa de 52 a 97 en un solo evento.

Control de acceso. La API rechaza con 403 los eventos con usuario o identificador de agente ajenos y la confirmación de un usuario ajeno. Una clave de agente revocada recibe 401, y el agente abre su *circuit breaker*. El inicio de sesión del administrador entrega un *token* de 43 caracteres, distinto de las claves fijas; el operador recibe 403 en los *endpoints* de administración, y el *token* queda inválido tras cerrar la sesión.

Integración IAM. Con Keycloak en la instancia, la API incorpora el rol y el departamento del usuario a su estado y a la respuesta del evento, sin que intervengan en el puntaje.

El control de acceso, la revocación de la clave y el rearranque tras detener la instancia se verificaron en sesiones previas sobre la misma instancia, entre el 6 y el 15 de octubre. La suite que trae la release se ejecuta en la propia instancia con los artefactos reales: 372 pruebas aprobadas, 3 omitidas y 3 con error, porque importan scripts que la release no incluye a propósito, con una cobertura de líneas y ramas del 91,71 %. Esta medición confirma que el código desplegado pasa su propia suite con las dependencias de la instancia; no agrega información sobre la calidad de las pruebas.

10.4.4 Consumo de recursos del agente (RNF-02)

Para RNF-02 se registra, cada 5 s durante 30 minutos de uso normal del equipo, el consumo de CPU del proceso del agente, normalizado sobre el total de núcleos lógicos, y su memoria residente. El agente se ejecuta en modo de simulación de mitigaciones, de modo que la medición refleja la captura y el envío de eventos sin efectos sobre el equipo. El umbral es un consumo medio de CPU menor o igual al 5 % de la máquina y una memoria residente menor o igual a 150 MB. La medición se realiza en un equipo con Windows 11 Pro y 16 núcleos lógicos: se toman 360 muestras sin pérdidas y el agente envía unos 112 eventos, todos respondidos. La tabla 10.VI presenta los resultados.

TABLA 10.VI: Consumo de recursos del agente (RNF-02)

Métrica	**Media**	**Percentil 95**	**Máximo**
CPU (% de la máquina)	0,09	0,14	0,16
Memoria residente (MB)	33,02	33,24	33,25

Fuente: elaboración propia a partir de las mediciones del sistema.

El agente cumple el umbral con un margen amplio: su consumo medio de CPU es más de cincuenta veces menor que el límite y su memoria residente se mantiene estable durante toda la medición, cerca de un quinto del máximo admitido. La medición refleja el uso normal del equipo; no incluye una ráfaga de eventos de archivo como la del escenario de exfiltración, en la que el percentil 95 y el máximo podrían ser mayores.

10.5 Evaluación del modelo sin etiquetas

Las métricas de esta sección corresponden al modelo híbrido entrenado sobre CLUE-LDS (sección 8.2). El conjunto de datos no incluye etiquetas de actividad maliciosa (Landauer *et al.*, 2022b), por lo que sobre él no se pueden calcular exactitud, precisión, exhaustividad, F1 ni curvas ROC. La sección se organiza en dos partes: primero se presentan las métricas sin etiquetas, que

describen el comportamiento del modelo y el acuerdo entre sus dos componentes, y luego se fijan las metas de evaluación y se contrastan con los resultados.

10.5.1 Métricas sin etiquetas

Ante la ausencia de etiquetas, el modelo se evalúa con métricas de comportamiento y de acuerdo entre sus dos componentes, presentadas en la tabla 10.VII. La escasez de datos etiquetados es una limitación frecuente en la detección de anomalías sobre registros de actividad (Landauer *et al.*, 2023). Estas métricas describen cómo se comporta el modelo y no cuántos ataques detecta: la detección se evalúa en las secciones 10.6 y 10.7, con escenarios de ataque inyectados.

TABLA 10.VII: Métricas sin etiquetas del modelo híbrido

Métrica	**Valor**	**Lectura**
Tasa de anomalías de Isolation Forest en prueba	0,81 % (99 de 12 236 usuario-días)	Inferior a la proporción de contaminación fijada en el entrenamiento (2 %).
Tasa de anomalías del LSTM Autoencoder en prueba	4,18 % (1 558 de 37 254 secuencias)	Cercana al 5 % esperable por usar el percentil 95 del error como umbral.
Error de reconstrucción del LSTM	Media 0,1225; umbral 0,1180	Umbral definido como el percentil 95 del error en entrenamiento.
Distribución del puntaje híbrido	Mediana 42,0; percentil 95 69,3; percentil 99 82,8	La mayor parte de la actividad queda por debajo del umbral del nivel alto (70).
Correlación entre modelos	$-0{,}22$ (Pearson; 234 usuarios con cobertura completa, $p < 0{,}001$)	Correlación débil y negativa: los modelos capturan aspectos distintos del comportamiento.
Coincidencia de anomalías	Índice de Jaccard 0,111 (6 usuarios marcados por ambos modelos)	Las anomalías que marca cada modelo casi no se superponen.

Fuente: elaboración propia a partir de la evaluación del modelo sobre CLUE-LDS.

La correlación se calcula sobre los 234 usuarios con cobertura de ambos modelos, porque los conjuntos de prueba de cada modelo solo comparten 15 usuarios; restringida a esos 15, resulta

$r = -0{,}41$ ($p = 0{,}13$, no significativa). La baja coincidencia indica que los modelos no son redundantes, en línea con la decisión de combinarlos. Sin embargo, estas métricas no demuestran que la combinación detecte mejor que cada modelo por separado, y el peso de 0,5 asignado a cada uno carece de respaldo cuantitativo. Además, los conjuntos de prueba se construyen con criterios distintos (partición temporal para Isolation Forest y por usuario para el LSTM), por lo que la comparación entre ambos es limitada.

10.5.2 Metas de evaluación

Como las métricas sin etiquetas no miden la capacidad de detección, las metas de la tabla 10.VIII combinan dos fuentes: el comportamiento del modelo sobre datos sin etiquetar y la detección de escenarios de ataque inyectados (secciones 10.6 y 10.7). Ninguna fase del *pipeline* utiliza etiquetas externas, y el entrenamiento no aplica técnicas de balanceo de clases (sección 8.1).

TABLA 10.VIII: Metas de evaluación del modelo y resultado obtenido

Métrica	Meta	Resultado	Cumple
Tasa de anomalías de Isolation Forest en prueba	entre 1 % y 3 % (contaminación del 2 %)	0,81 %	No
Tasa de anomalías del LSTM en prueba	entre 3 % y 7 % (umbral en el percentil 95)	4,18 %	Sí
Detección atribuible del escenario combinado (E4) con el umbral del nivel alto (70)	$\geq$ 50 % de los usuarios	13,3 % (2 de 15)	No
Detección atribuible promedio de los cuatro escenarios con umbral 70	$\geq$ 33 %	5,0 % (3 de 60)	No
Usuario-días sin inyección que terminan en nivel alto o crítico	$\leq$ 10 %	15,4 %	No
Latencia de evaluación (cómputo, entorno aislado), percentil 95 (RNF-01)	$\leq$ 500 ms	14,9 ms	Sí
Latencia extremo a extremo en la nube, percentil 95 (informativa)	Sin meta propia	3 110 ms	–

Fuente: elaboración propia.

Cada tasa de anomalías se compara con el parámetro con que su modelo fija el umbral: una tasa muy inferior indica que el umbral resulta más estricto en prueba que en entrenamiento. La meta de detección exige que al menos la mitad de los ataques combinados, que son los más evidentes, lleven al usuario al nivel alto; la meta de alertas limita la carga de revisión sobre

actividad normal a uno de cada diez usuario-días. El sistema cumple las metas de latencia y de comportamiento del LSTM, pero no las de Isolation Forest, detección ni alertas. Esta es la principal limitación técnica del proyecto, y sus causas se analizan en la sección 10.6.4. Las metas se mantienen sin cambios en la evaluación de la sección 10.7.

10.6 Validación por escenarios inyectados

Como el conjunto de datos no incluye ataques etiquetados, esta subsección estima la capacidad de detección inyectando escenarios de ataque sobre historiales reales. Se describen el método, los resultados con la política de niveles del sistema, la sensibilidad según el umbral y la interpretación de los resultados.

10.6.1 Método

Para obtener una medida de la capacidad de detección sin etiquetas, se inyectan escenarios de ataque sintéticos sobre historiales reales. Se seleccionan al azar, con semilla fija, 15 usuarios del período de prueba con entre 50 y 4000 eventos y al menos cinco días de actividad. Para cada usuario se reproduce su historial completo a través de la API, se toma una instantánea del estado y, a partir de ella, se inyecta cada escenario por separado, restaurando el estado entre uno y otro:

- **E1, exfiltración:** entre 30 y 60 eventos de creación y escritura de archivos, uno cada 5 s, en horario laboral y desde el país habitual.
- **E2, fuera de horario:** hasta 40 eventos reales del último día de actividad, reubicados entre las 2 y las 5 de la mañana (UTC).
- **E3, cambio de país:** los mismos eventos, en su horario original, informados desde otro país.
- **E4, combinado:** la exfiltración de E1 en horario nocturno y desde otro país.

Se considera *detección atribuible* a la inyección que lleva el nivel del usuario a alto o crítico cuando antes de inyectar estaba por debajo de alto. Así se descartan los usuarios que ya se encontraban en nivel alto por el riesgo acumulado. Como referencia de alertas sobre actividad presuntamente legítima, se registra el nivel de cierre de cada día del período de prueba sin inyección (650 usuario-días).

10.6.2 Resultados

La tabla 10.IX presenta los resultados con la política de niveles del sistema, en la que el nivel alto comienza en un puntaje de 70 y el crítico en 90.

TABLA 10.IX: Resultados de la validación por escenarios (15 usuarios por escenario)

Escenario	Alto o crítico	Ya en alto antes	Atribuibles	Crítico
E1, exfiltración	2	2	0	0
E2, fuera de horario	3	2	1	0
E3, cambio de país	2	2	0	0
E4, combinado	4	2	2	0

Fuente: elaboración propia a partir de la validación por escenarios inyectados.

En los días sin inyección, el 15,4 % de los usuario-días (100 de 650) termina en nivel alto y ninguno en crítico. La proporción es del 14,3 % (79 de 553) en los días con cobertura completa de ambos modelos y del 21,6 % (21 de 97) en los de cobertura parcial, y se concentra en los usuarios con pocos días de historial. Estas proporciones usan el nivel de cierre del día, que incluye la regla de piso; con el puntaje numérico de cierre y el umbral de 70, el total es del 14,2 %. Los 8 días de diferencia tienen cobertura completa: un modelo marca anomalía y la regla de piso eleva el nivel.

Las inyecciones elevan la mediana del puntaje entre 3,5 y 5,6 puntos respecto del valor previo, pero el puntaje máximo mediano de cada escenario queda entre 63,5 y 65,6, por debajo del umbral del nivel alto. Las tres detecciones atribuibles corresponden a dos usuarios con cobertura completa de ambos modelos. Uno cruza el umbral en el escenario combinado (de 64,4 a 70,6) y el otro en los escenarios fuera de horario y combinado (de 68,8 a 72,9 y a 72,8). En los tres casos el puntaje supera apenas el umbral de 70, sin intervención de la regla de piso, y el aumento se explica solo por variables de Isolation Forest. De hecho, todas las explicaciones generadas provienen de esas variables (proporción de actividad fuera de horario, hora promedio y entropía de tipos de evento); en 7 de los 60 casos ninguna supera el umbral de explicación.

10.6.3 Sensibilidad según el umbral

Para analizar el compromiso entre sensibilidad y alertas sobre actividad normal sin modificar la configuración del sistema, se recalcula la detección atribuible para umbrales entre 40 y 90. La figura 10.1 muestra el resultado.

La detección atribuible alcanza su máximo en la zona de 55 a 65 puntos, con un 33,3 % para el escenario combinado en los umbrales de 55 y de 65, y nunca supera un tercio de los usuarios. La curva no es monótona porque, al bajar el umbral, una proporción creciente de usuarios ya lo supera antes de la inyección: con umbral de 40 parte por encima el 93,3 % de los

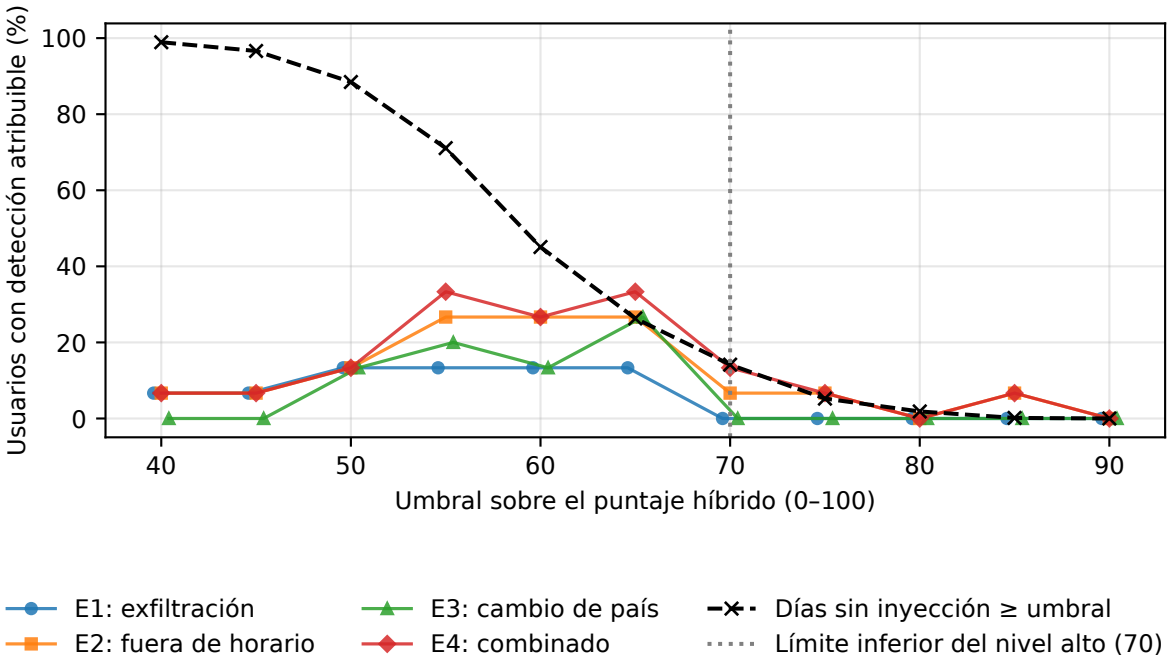


Figura 10.1: Detección atribuible por escenario según el umbral, y tasa de alertas sobre días sin inyección (porcentaje de usuario-días) para umbrales entre 40 y 90

Fuente: elaboración propia.

usuarios, y con umbral de 70 solo el 13,3 %. Con el puntaje de cierre de cada día, la tasa de días sin inyección que superan el umbral cae de 98,9 % con umbral de 40 a 71,1 % con 55, 26,3 % con 65, 14,2 % con 70 y 0 % con 90. Por lo tanto, en la zona de máxima detección entre una cuarta parte y dos tercios de los días normales también superarían el umbral, y en ningún umbral la detección atribuible supera con claridad a la tasa de alertas sobre días normales.

10.6.4 Interpretación

El sistema detecta pocos de los escenarios inyectados y ninguno alcanza el nivel crítico, por lo que la mitigación más severa no se dispara ante estos ataques simulados. Esto es coherente con una política conservadora, que reserva la terminación de procesos y la denegación de acceso para el nivel crítico, pero también indica una sensibilidad baja ante ataques de corta duración.

Varias causas están verificadas. El 99,95 % de los eventos del conjunto de datos tiene el país registrado como desconocido, por lo que la variable de cambio de país casi no varía durante el entrenamiento. Esto explica que el escenario E3 no se detecte y que, cuando esa variable cambia, domine el error de reconstrucción del LSTM. Además, el LSTM no aprovecha el orden de los eventos: permutar los 50 eventos de una secuencia no cambia el ordenamiento. Su riesgo correlaciona $-0{,}68$ con el logaritmo del volumen de actividad del usuario, de modo que tiende a marcar a los usuarios poco activos. Las demás causas son inferidas y no se aíslan

experimentalmente:

- Isolation Forest trabaja con variables agregadas por día, en las que una ráfaga de 30 a 60 eventos no resulta atípica para un usuario con un historial variable. El escenario de pico corto de la sección 10.7.6 apunta en el mismo sentido (ROC-AUC de 0,62 para este componente), sin aislar la causa.
- El LSTM evalúa secuencias de 50 eventos, por lo que una inyección corta completa a lo sumo una secuencia y su señal se diluye.
- La combinación con la línea base personal y el decaimiento temporal amortiguan los cambios puntuales; en el caso del decaimiento, la evaluación con escenarios etiquetados confirma que empeora el ordenamiento en ventanas cortas (sección 10.9).

La alta proporción de alertas en usuarios con pocos días de historial es consistente con el sesgo conocido del componente de riesgo personal en usuarios con historial escaso. Los resultados deben leerse con cautela: se trata de 15 usuarios por escenario, con una sola inyección por caso, escenarios diseñados por el propio equipo y una referencia de normalidad sin verificación. Una diferencia de un usuario equivale a 6,7 puntos porcentuales.

10.7 Evaluación con escenarios etiquetados

Esta sección evalúa la detección con un conjunto amplio de usuarios víctimas, escenarios de etiqueta conocida, una partición en dos subconjuntos e intervalos de confianza. Con etiquetas construidas de este modo es posible calcular sobre el sistema en producción las métricas que la ausencia de etiquetas impide obtener sobre los datos originales: el área bajo la curva ROC, la exhaustividad (*recall*) y la tasa de falsos positivos. Una última subsección agrega escenarios controlados adicionales, con matriz de confusión y controles negativos (sección 10.7.6). En adelante, este conjunto de escenarios etiquetados se denomina benchmark de detección. Se denomina víctimas a los usuarios sobre cuyo historial se construye cada escenario, y se las reparte en dos particiones: DEV, que se usa para el desarrollo y la calibración, y HOLDOUT, reservada para la evaluación final (sección 10.7.2).

10.7.1 Escenarios

Como CLUE-LDS no incluye ataques, los escenarios se construyen sobre el historial real de cada víctima a partir de un instante T. La tabla 10.X los describe.

TABLA 10.X: Escenarios del benchmark de detección

Escenario	Qué simula	Construcción
S1 similar y S1 disímil	Toma de cuenta	Desde el instante T, los eventos de la víctima en una ventana de 7 días se reemplazan por los de otro usuario activo en la misma ventana: el más parecido (similar) o el menos parecido (disímil), según una similitud que pondera con 0,3 el cociente de eventos por día y con 0,7 el índice de Jaccard de los tipos de evento.
S2, con k = 2, 5 y 10	Exfiltración	En cada día activo de la ventana se inyecta una ráfaga de eventos de archivo y de compartición de k veces la mediana diaria de eventos de archivo de la víctima, en una hora habitual para ella.
S2 solo archivos, con k = 10	Exfiltración sin compartir	Igual que S2, pero solo con eventos de archivo, para separar el efecto de la compartición.
S3	Uso fuera de horario	Los eventos de cada día se reubican entre las 2 y las 5 de la mañana, hora de Viena, conservando su orden.

Fuente: elaboración propia a partir del benchmark de detección.

Cada escenario se construye en dos versiones. En la versión sin país, los eventos conservan su ubicación original, desconocida en casi todos los casos, por lo que el escenario mide el comportamiento; en la versión con país, los eventos modificados llevan un país atacante, lo que mide el efecto de la ubicación sobre los modelos. El escenario S1 reproduce la fórmula y los pesos de similitud de la herramienta publicada por los autores del conjunto de datos (Landauer *et al.*, 2022b), con cuatro diferencias: se toman los extremos de similitud en lugar de pares al azar, el reemplazo es unidireccional, la etiqueta se asigna por usuario-día dentro de la ventana y los usuarios donantes se restringen a los que el LSTM no vio en su entrenamiento.

10.7.2 Partición y métricas

Se toman como víctimas los 123 usuarios con al menos 5 días activos posteriores al corte temporal de Isolation Forest (2 de agosto de 2021), repartidos por estrato de actividad previa en dos particiones: DEV, con 63 víctimas, y HOLDOUT, con 60. Con al menos una ventana válida para los escenarios quedan 62 y 57, respectivamente. La sección presenta los resultados de HOLDOUT, que no interviene en ningún ajuste del sistema. Isolation Forest se entrena con una partición temporal, por lo que sus resultados en HOLDOUT no se solapan con su entrenamiento; el LSTM, en cambio, se entrena con una partición por usuario, y 47 de las 57 víctimas de HOLDOUT forman parte de su entrenamiento.

La unidad de evaluación es el usuario-día. Los positivos son los días modificados por cada escenario, y los negativos, los días limpios posteriores al corte de las mismas víctimas. La prevalencia de positivos se ubica entre 0,08 y 0,09, que es también el área bajo la curva de

precisión y exhaustividad (PR-AUC) de una clasificación al azar.

Se calculan el área bajo la curva ROC (ROC-AUC), el PR-AUC, el *recall* y la tasa de falsos positivos con los umbrales de producción: 40, 70 y 90 para el puntaje híbrido, con la regla de piso, y un riesgo de 70 y de 90 para cada componente por separado. La tasa de falsos positivos se calcula sobre los negativos de cada partición y sobre todo el período de test de Isolation Forest, formado por los usuario-días posteriores al corte.

Los intervalos de confianza al 95 % se obtienen por *bootstrap* con 1 000 remuestreos sobre víctimas y no sobre días, porque los días de una misma víctima están correlacionados. Para comparar dos variantes se utiliza el mismo remuestreo, lo que da intervalos pareados de la diferencia.

10.7.3 Resultados en HOLDOUT

El sistema evaluado es el que opera en producción: el riesgo del LSTM se calcula como media acumulada de las secuencias cerradas, los dos componentes se combinan en partes iguales, se aplica el decaimiento temporal y los umbrales son 40, 70 y 90. Cada día se evalúa cerrado, sin el agregado parcial ni la línea base personal que la producción aplica en cada evento. La tabla 10.XI presenta el ROC-AUC de cada componente y del híbrido en los escenarios sin país.

TABLA 10.XI: ROC-AUC en HOLDOUT, escenarios sin país [IC 95 %]

Escenario	Isolation Forest	LSTM	Híbrido
S1 similar	0,46 [0,37–0,55]	0,56 [0,51–0,61]	0,58 [0,52–0,65]
S1 disímil	0,62 [0,52–0,70]	0,62 [0,56–0,67]	0,68 [0,63–0,73]
S2, $k = 2$	0,76 [0,70–0,82]	0,57 [0,53–0,61]	0,75 [0,71–0,80]
S2, $k = 5$	0,85 [0,80–0,91]	0,61 [0,57–0,65]	0,79 [0,76–0,84]
S2, $k = 10$	0,88 [0,82–0,93]	0,62 [0,58–0,66]	0,80 [0,76–0,84]
S2 solo archivos, $k = 10$	0,59 [0,53–0,65]	0,63 [0,59–0,67]	0,67 [0,63–0,72]
S3	0,90 [0,85–0,95]	0,56 [0,51–0,60]	0,80 [0,77–0,84]

Fuente: elaboración propia a partir del benchmark de detección.

En todos los escenarios, las diferencias del híbrido entre DEV y HOLDOUT caen dentro de los intervalos de confianza. La tabla 10.XII presenta la detección operativa del híbrido: la proporción de días atacados que alcanzan el nivel alto o superior y el nivel crítico, con la regla de piso aplicada.

TABLA 10.XII: *Recall* del híbrido en HOLDOUT, con y sin país [IC 95 %]

Escenario	Alto o superior, sin país	Alto o superior, con país	Crítico, sin país	Crítico, con país
S1 similar	0,12 [0,06–0,19]	0,12 [0,06–0,19]	0,00	0,00
S1 disímil	0,18 [0,10–0,27]	0,18 [0,10–0,27]	0,00	0,00
S2, $k = 2$	0,19 [0,12–0,28]	0,91 [0,87–0,94]	0,01	0,12 [0,07–0,18]
S2, $k = 5$	0,27 [0,18–0,37]	0,99 [0,98–1,00]	0,00	0,12 [0,07–0,18]
S2, $k = 10$	0,30 [0,20–0,41]	0,99 [0,98–1,00]	0,01	0,10 [0,05–0,16]
S2 solo archivos, $k = 10$	0,11 [0,04–0,19]	0,79 [0,71–0,86]	0,00	0,10 [0,05–0,16]
S3	0,29 [0,20–0,41]	0,30 [0,20–0,41]	0,04 [0,01–0,07]	0,04 [0,01–0,08]

Fuente: elaboración propia a partir del benchmark de detección.

La tabla 10.XIII presenta la tasa de falsos positivos sobre usuario-días limpios, calculada sobre los negativos de DEV, los de HOLDOUT y todo el período de test de Isolation Forest.

TABLA 10.XIII: Tasa de falsos positivos sobre usuario-días limpios [IC 95 %]

Base	Isolation Forest ≥ 70	LSTM ≥ 70	Híbrido, alto o superior	Híbrido, crítico
Negativos DEV (6 127 días, 62 usuarios)	0,23 [0,15–0,31]	0,10 [0,04–0,18]	0,06 [0,02–0,11]	0,00
Negativos HOLDOUT (5 894 días, 57 usuarios)	0,31 [0,19–0,44]	0,08 [0,03–0,14]	0,04 [0,02–0,09]	0,00
Período de test de Isolation Forest (12 236 días, 262 usuarios)	0,26 [0,20–0,34]	0,09 [0,05–0,14]	0,05 [0,03–0,09]	0,00

Fuente: elaboración propia a partir del benchmark de detección.

10.7.4 Lectura de los resultados

HOLDOUT es una estimación limpia del sistema en producción, porque ningún ajuste del sistema se selecciona con DEV. Isolation Forest sostiene la detección por volumen y por horario, con un ROC-AUC de 0,76 a 0,88 en S2 y de 0,90 en S3, y queda cerca del azar en la toma de cuenta (0,46 a 0,62 en S1). El híbrido ordena peor que Isolation Forest solo en lo que este detecta (0,80 contra 0,90 en S3 y 0,80 contra 0,88 en S2 con $k = 10$), y algo mejor en la toma de cuenta disímil (0,68 contra 0,62).

En términos operativos, con una tasa de falsos positivos en nivel alto del 4 % al 5 % y

prácticamente nula en crítico, el sistema detecta en nivel alto entre el 12 % y el 30 % de los días atacados sin país; la exfiltración solo con archivos queda en 0,11. Cuando la exfiltración introduce un país nuevo mezclado en el día, la regla de piso de Isolation Forest lleva la detección al rango del 91 % al 99 %. Sin país, el nivel crítico casi no se alcanza. La detección operativa más alta del sistema proviene, por lo tanto, de la ubicación y no del comportamiento.

Las cifras del LSTM en HOLDOUT son optimistas, porque 47 de las 57 víctimas forman parte de su entrenamiento, y aun así el componente queda cerca del azar sin país (0,56 a 0,63). Las 10 víctimas restantes tienen tan poca actividad que su historia no llega a cerrar una secuencia de 50 eventos, por lo que no permiten una estimación del LSTM fuera de su entrenamiento.

10.7.5 Contraste con las metas

Al aplicar los límites de las metas de la sección 10.5.2 a los resultados de HOLDOUT, la tasa de falsos positivos en nivel alto cumple el límite del 10 % de la meta de alertas, mientras que la detección en nivel alto sin país no alcanza el 50 % de la meta de detección. Con país, la detección de la exfiltración supera ese valor. El contraste es indicativo, porque la meta de detección se expresa en usuarios y el benchmark mide usuario-días.

10.7.6 Escenarios controlados adicionales

Una evaluación complementaria suma cuatro escenarios de etiqueta conocida y calcula, por modelo, la matriz de confusión con los umbrales de producción. Es exploratoria: usa solo víctimas de DEV, no interviene en ningún ajuste y deja intacto HOLDOUT. La tabla 10.XIV describe los escenarios. Todos conservan el país habitual de la víctima. Cada combinación de una víctima con una ventana de escenario se denomina mundo.

TABLA 10.XIV: Escenarios controlados adicionales

Escenario	Etiqueta	Construcción	Mundos
S4, secuencia inusual	1	Los tipos de evento se permutan dentro de cada día; horas, conteos y país no cambian.	138
S5, pico corto	1	En cada día activo, una ráfaga de 5 veces los eventos de archivo habituales en 5 minutos o menos, con tipos del perfil propio.	167
S6, control de identidad	0	Ventana original sin modificar.	167
S7, control benigno	0	Ventana corrida una hora, con 10 % de eventos duplicados con una separación de 1 a 30 s.	167

Fuente: elaboración propia a partir del benchmark de detección.

Se omiten 29 mundos de S4 porque ningún día de esas ventanas tenía tipos distintos que permutar. Los modelos se cargan desde los artefactos existentes, sin entrenamiento ni

reentrenamiento; el SHA-256 de los nueve artefactos es idéntico antes y después del puntaje. Los datos son posteriores al corte temporal de Isolation Forest. La cifra principal excluye a las víctimas que forman parte del entrenamiento del LSTM (32 víctimas, 26 en S4), porque incluirlas favorece a ese componente. La unidad es el usuario-día, salvo para el LSTM por secuencia, que se evalúa por bloque de 50 eventos y no es comparable con las demás. Los negativos son los días originales de las mismas víctimas, y los controles S6 y S7 se informan aparte para no contar dos veces los mismos días.

Reglas de alerta. Esta evaluación usa la regla de alerta de producción de cada modelo: `predict == -1` para Isolation Forest, un riesgo mayor que 95 para el LSTM y el nivel alto o crítico para el híbrido. Son reglas distintas de las de la tabla 10.XIII (riesgo de 70 para cada componente), por lo que las cifras de ambas tablas no se comparan entre sí. Por ejemplo, la tasa de falsos positivos de Isolation Forest es 0,6 % con la regla de producción, frente a 0,23 a 0,31 con riesgo de 70.

La tabla 10.XV presenta la matriz de confusión sobre S4 y S5 reunidos y por separado. El híbrido es el sistema con decaimiento temporal, el mismo de las secciones anteriores. El LSTM por bloque se presenta aparte en la tabla 10.XVI, porque su unidad es distinta.

TABLA 10.XV: Matriz de confusión por escenario con los umbrales de producción (usuario-día; DEV, sin víctimas del entrenamiento del LSTM)

Modelo	Escenario	TP	FP	TN	FN	Precisión	*Recall*	F1	Especificidad	ROC-AUC [IC 95 %]
Isolation Forest	S4 y S5	15	21	3 572	639	0,417	0,023	0,043	0,994	0,56 [0,50–0,61]
	S4	1	21	3 452	305	0,045	0,003	0,006	0,994	0,49 [0,43–0,55]
	S5	14	21	3 572	334	0,400	0,040	0,073	0,994	0,62 [0,56–0,69]
LSTM (día)	S4 y S5	1	0	3 593	653	1,000	0,002	0,003	1,000	0,54 [0,47–0,60]
	S4	0	0	3 473	306	n/d	0,000	0,000	1,000	0,53 [0,45–0,60]
	S5	1	0	3 593	347	1,000	0,003	0,006	1,000	0,55 [0,47–0,62]
Híbrido	S4 y S5	46	121	3 472	608	0,275	0,070	0,112	0,966	0,56 [0,51–0,63]
	S4	2	36	3 437	304	0,053	0,007	0,012	0,990	0,51 [0,46–0,58]
	S5	44	121	3 472	304	0,267	0,126	0,172	0,966	0,62 [0,56–0,69]

Fuente: elaboración propia a partir del benchmark de detección. n/d: sin predicciones positivas.

TABLA 10.XVI: Matriz de confusión del LSTM por bloque de 50 eventos (exploratoria; su umbral no decide nada en producción)

Escenario	TP	FP	TN	FN	Precisión	*Recall*	F1	Especificidad	ROC-AUC [IC 95 %]
S4 y S5	74	319	12 288	1 659	0,188	0,043	0,070	0,975	0,68 [0,57–0,77]
S4	29	308	12 238	806	0,086	0,035	0,049	0,975	0,62 [0,51–0,76]
S5	45	319	12 288	853	0,124	0,050	0,071	0,975	0,73 [0,60–0,81]

Fuente: elaboración propia a partir del benchmark de detección.

Los puntajes son percentiles de ranking, no probabilidades calibradas. Los intervalos son *bootstrap* sobre víctimas. El PR-AUC de los tres modelos por usuario-día va de 0,19 a 0,21 en conjunto y la exactitud balanceada de 0,50 a 0,53, es decir, cerca del azar. La precisión del LSTM

por día (1 de 1) no es una medida útil, porque se apoya en un único acierto. La tabla 10.XVII presenta los controles negativos, donde solo hay falsos positivos y verdaderos negativos.

TABLA 10.XVII: Controles negativos S6 y S7: falsos positivos y verdaderos negativos (FP / TN)

Modelo	S6	Especificidad S6	S7	Especificidad S7
Isolation Forest	1 / 347	0,997	2 / 356	0,994
LSTM (día)	0 / 348	1,000	0 / 358	1,000
Híbrido	22 / 326	0,937	19 / 339	0,947

Fuente: elaboración propia a partir del benchmark de detección.

Lectura. Con los umbrales de producción, la detección es baja en ambos escenarios y para todos los modelos: el *recall* global es de 0,07 en el híbrido, 0,02 en Isolation Forest y casi nulo en el LSTM por día. Son escenarios difíciles para el sistema vigente, y no se ajustan los umbrales sobre estos mismos casos. En S4, Isolation Forest no puede ver el cambio por construcción (ROC-AUC de 0,49 [0,43–0,55], al nivel del azar) y el LSTM por día tampoco lo detecta; por bloques el ROC-AUC sube a 0,62 [0,51–0,76], con un *recall* de 0,035. En S4 los intervalos de los tres modelos por usuario-día incluyen 0,5, por lo que no hay evidencia de detección por encima del azar. Esto concuerda con la limitación ya verificada de que el LSTM casi no usa el orden de los eventos (sección 10.6.4). En S5 la detección es débil: el híbrido alcanza un *recall* de 0,13, un F1 de 0,17 y un ROC-AUC de 0,62 [0,56–0,69]; por bloques, el LSTM llega a 0,73 [0,60–0,81]. La causa no se investiga en este trabajo; queda por verificar si Isolation Forest, que evalúa el agregado diario, diluye una ráfaga de minutos en el total del día.

Sin el decaimiento, el híbrido detecta algo más (*recall* de 0,10) a costa de más falsos positivos (4,2 % en lugar de 3,4 % de los días originales, especificidad de 0,958). En los controles, el híbrido con decaimiento marca el 6,3 % de S6 y el 5,3 % de S7, por encima del 3,4 % de los días originales de las mismas víctimas.

Diferencia en S6. S6 reproduce los días originales sin modificarlos, por lo que sus puntajes deberían coincidir con los de esos días. Una auditoría lo confirma: las 685 filas de S6 coinciden con los días originales por usuario y fecha, sin duplicados, huérfanos ni diferencias en eventos, puntajes, niveles ni anomalías (lo verifica una prueba automatizada), de modo que no hay un error del *pipeline*. La diferencia de falsos positivos con el resto de los días se explica por la población comparada y por la concentración en pocos usuarios: 16 de los 26 falsos positivos del híbrido sin decaimiento en S6 provienen de 2 de las 32 víctimas. Sin ellas, S6 da 3,1 % y los días originales 2,3 %.

Reproducibilidad y verificación. Una segunda corrida da puntajes y errores por bloque idénticos bit a bit, y los nueve artefactos conservan su SHA-256 antes y después del puntaje. Con la misma semilla (42) y 300 réplicas de *bootstrap*, el archivo de resultados con las matrices sale idéntico byte a byte (SHA-256 `7858a253...`). El puntaje fuera de línea de Isolation Forest

coincide con el de la fase de entrenamiento en los 61 284 días cruzados, y el del LSTM, con el de su fase, en los 36 usuarios comparados (diferencia relativa nula). Los intervalos de confianza son anchos por tener solo 32 víctimas. Una suite de 18 pruebas, aprobadas todas, verifica el cálculo de las métricas, el determinismo, la construcción de los escenarios y que el código no invoca ningún entrenamiento.

10.8 Evaluación de usabilidad

La usabilidad del *dashboard* (RNF-15) se evalúa con una evaluación heurística: el equipo revisa sus nueve pantallas contra las diez heurísticas de Nielsen (Nielsen, 1994) y clasifica cada problema con su escala de severidad, de 0 (no es un problema) a 4 (catastrófico). Se identifican 15 problemas: 4 mayores, 5 menores y 6 cosméticos, ninguno catastrófico. Los cuatro mayores y dos menores se corrigen solo en el *frontend* (textos y tildes, formato de fechas, términos internos del desarrollo, mensajes de error de validación, etiquetas de la explicación del puntaje y descripción de los eventos recientes). Siguen abiertos tres problemas menores: el nivel mostrado no se recalcula al cambiar los umbrales, que es el comportamiento especificado en RF-12; la configuración del reentrenamiento no indica si el modo automático está activo; y la auditoría muestra los valores en formato técnico, aceptable para el perfil administrador.

10.9 Decisiones tomadas a partir de los resultados

La tabla 10.XVIII resume las decisiones de diseño e implementación que se toman a partir de los resultados de las pruebas y los análisis realizados durante el desarrollo.

TABLA 10.XVIII: Decisiones tomadas a partir de los resultados de las pruebas

Resultado observado	**Decisión**
El tiempo que tarda un usuario en acumular 20 eventos varía entre 35 minutos (percentil 25) y unos 93 días (percentil 90); el 59,5 % no llega a 20 eventos en su primer día.	Mantener 20 eventos como umbral de aprendizaje por defecto y volverlo configurable en tiempo de ejecución, en un rango de 1 a 1000.
El componente de riesgo personal presenta un sesgo en usuarios con historial escaso; se evalúan cinco alternativas de cálculo y ninguna lo corrige sin degradar otros casos.	Mantener el cálculo actual y documentar el sesgo como limitación conocida.

Resultado observado	**Decisión**
Diferencias de redondeo del orden de 10^{-16} hacen fallar la comparación de métricas en casos de empate.	Redondear las métricas a seis decimales antes de comparar. El criterio final de comparación es el de no inferioridad sobre escenarios etiquetados (sección 9.2.5).
Un modelo rechazado queda guardado en disco y se carga al reiniciar la API.	Respaldar los modelos instalados antes del reentrenamiento y restaurarlos si el modelo nuevo no se promueve.
La resolución del nombre `localhost` en Windows agregaba unos 2 s por conexión.	Utilizar la dirección 127.0.0.1 en los clientes, lo que reduce la latencia de 2067 ms a 16,7 ms por solicitud (fenómeno distinto de los 3,1 s medidos en la nube).
Los navegadores generan la mayor parte de los eventos de procesos y agotan el período de aprendizaje en pocos minutos.	Agrupar los eventos de procesos de navegadores, lo que reduce un 80 % los eventos que generan.
La prueba de regresión del puntaje presenta seis diferencias contra el cálculo fuera de línea; cinco se explican por la incorporación de la línea base personal.	Aceptar las cinco diferencias como divergencia esperada del diseño y declarar como limitación la sexta, que no tiene causa identificada.
La integración continua falla en un entorno limpio porque las pruebas requieren los modelos entrenados.	Incorporar artefactos simulados para la integración continua y ejecutar localmente las pruebas que necesitan los modelos reales.
El 19,6 % de los usuarios del conjunto de datos nunca completa una secuencia de 50 eventos para el LSTM.	Mantener el puntaje con Isolation Forest para esos usuarios (cobertura parcial) y declararlo como limitación.
El disparador de la cadena de *hashes* agrega 0,042 ms por inserción y no produce errores con hasta 50 escrituras concurrentes.	Mantener la configuración del grupo de conexiones a la base de datos sin ampliarla.

Resultado observado	Decisión
La validación por escenarios muestra una sensibilidad baja ante ataques cortos.	No recalibrar umbrales ni pesos del modelo con estos 15 usuarios, porque ajustarlos a escenarios diseñados por el propio equipo, sin datos etiquetados, sobreajustaría el resultado. La mejora se plantea como trabajo futuro.

Fuente: elaboración propia.

Además de las decisiones de la tabla, la evaluación con escenarios etiquetados (sección 10.7) permite probar variantes del cálculo del puntaje. Los experimentos se realizan solo sobre DEV, en su mayoría con 27 víctimas, por lo que sus cifras no son comparables con las de HOLDOUT. Ninguna variante se adopta.

Recalibración de umbrales. Calibrar los umbrales por cuantiles sobre los usuario-días de entrenamiento da 50,1, 71,9 y 81,8 para los niveles medio, alto y crítico. Con ellos, el nivel medio deja de marcar el 60 % de los días limpios y pasa a marcar el 32 %, pero el *recall* en nivel alto queda parecido: la mejora es de reparto entre niveles y no de detección. Además, con los umbrales calibrados la exfiltración del escenario de extremo a extremo (sección 10.3) cae al nivel bajo al cerrar la primera secuencia del LSTM. Se mantienen los umbrales 40/70/90; como son editables en tiempo de ejecución, la recalibración queda disponible sin modificar el código.

Agregación del LSTM y combinación. Se prueban variantes de agregación del riesgo del LSTM (media de las secuencias del día y máximo diario, frente a la media acumulada del sistema) y de combinación de los dos componentes (otros pesos, el máximo, e Isolation Forest como puntaje con el LSTM solo como piso). Una selección por pasos sobre 13 víctimas elige el máximo diario, pero su ventaja desaparece en las 14 víctimas restantes, y la variante seleccionada queda por debajo del sistema. Una prueba confirmatoria fijada de antemano, con Isolation Forest como puntaje, el LSTM como piso y un decaimiento asimétrico, mejora el ordenamiento pero pierde *recall* operativo, y en el escenario de extremo a extremo la exfiltración sin cambio de país no llega al nivel alto. Con tan pocas víctimas, la selección persigue diferencias que la prueba no confirma.

Decaimiento temporal. El decaimiento empeora el ordenamiento en todos los escenarios de ventana corta, entre 0,004 y 0,10 de ROC-AUC, y el mismo efecto se observa en HOLDOUT. Quitarlo es la única mejora de ordenamiento que se sostiene en las dos mitades de los datos de DEV, pero no se traduce en más *recall* en nivel alto. Se mantiene porque su efecto operativo neto no es concluyente y porque su vida media responde a la mediana real de los intervalos de actividad (3 días).

Modelos corregidos. Se entrenan versiones corregidas de ambos modelos: sin variables

de país, con partición temporal también para el LSTM, con la hora local de Viena y con una variable nueva de eventos de compartición. El Isolation Forest corregido mejora mucho en S2 sin país, pero toda esa mejora la explica la variable de compartición, que es en parte circular con la construcción del escenario: en S2 solo archivos, sin compartición, las dos versiones empatan. Además, empeora en la toma de cuenta, pierde la detección basada en la ubicación (en el escenario de extremo a extremo, la exfiltración con cambio de país ya no llega a crítico) y el criterio de promoción lo rechaza por falsos positivos (sección 9.2.5). Los modelos corregidos no se promueven.

La decisión principal que surge de estos resultados es mantener el modelo actual y establecer, para el reentrenamiento, un criterio de promoción basado en escenarios etiquetados (sección 9.2.5).

10.10 Limitaciones de las pruebas

- La prueba de regresión del puntaje no está en verde. Es un *script* y no una prueba de la suite, y presenta seis diferencias contra el cálculo fuera de línea: cinco, de un mismo usuario, se explican por el componente personal inactivo con cobertura parcial, y la sexta, de otro usuario, no tiene causa atribuida. Se declara como limitación conocida y no como prueba superada.

- Varias pruebas de puntaje real dependen de los modelos entrenados y se omiten sin ellos, y cuatro pruebas que levantan la API completa quedan fuera de la integración continua. Por eso el umbral del 85 % de la integración continua actúa como red contra regresiones, y la cifra de cobertura de la sección 10.2.4 se mide en forma local.

- El *frontend* no tiene pruebas automatizadas, por declaración: no contiene lógica de negocio y se valida con análisis estático, verificación de tipos y revisión manual. Tampoco las tiene el indicador de aprendizaje del *dashboard* (RF-26).

- Las pruebas de las mitigaciones usan un `icacls` simulado: la ejecución real en el equipo, incluida la reversión, se verifica a mano. La promoción de un modelo genuinamente nuevo se prueba solo con objetos simulados.

- Faltan pruebas automatizadas de la cadena de *hashes* (RNF-09), que se verifica con *scripts* manuales contra PostgreSQL, y de la concurrencia con varios usuarios (RNF-14). Para TLS (RNF-13) hay pruebas del cliente que rechazan `http` fuera de *loopback*, pero no de la verificación del certificado en el despliegue.

- La latencia del cómputo se mide con Redis en memoria y sin carga concurrente, y la medición en la nube es también secuencial. No se miden el rendimiento ni la concurrencia

en la nube, el uso de CPU y memoria de la API sola en la instancia, la disponibilidad, los respaldos ni el monitoreo. El consumo del agente (RNF-02) se mide con uso normal del equipo, sin una ráfaga de eventos de archivo como la del escenario de exfiltración.

- La evaluación del modelo carece de etiquetas. La validación por escenarios usa 15 usuarios con ataques diseñados por el equipo, y el benchmark, escenarios sintéticos (ráfagas uniformes, reubicación lineal) sobre el día cerrado, sin el agregado parcial ni la línea base personal de la producción.
- El benchmark tiene pocas víctimas (62 en DEV y 57 en HOLDOUT), con intervalos de $\pm$0,05 a 0,10 de ROC-AUC, por lo que las diferencias pequeñas entre variantes no son significativas, y sus cifras del LSTM son optimistas, porque la mayoría de las víctimas forma parte de su entrenamiento.
- No se mide la tasa de falsos positivos ante cambios de ubicación legítimos, como viajes o una VPN corporativa, y ninguna cifra del benchmark se transfiere sin más al agente por la brecha de dominio entre una plataforma en la nube y la telemetría de un equipo Windows.
- La integración con Microsoft Entra ID se prueba solo con respuestas simuladas, sin un *tenant* real; la de Keycloak se verifica contra un servidor real.
- Los escenarios controlados adicionales (sección 10.7.6) son solo de DEV y exploratorios, y S7 usa un corrimiento fijo de una hora hacia adelante. No representan una IP ni un recurso inusual: los modelos solo leen la hora, el tipo de evento y el país, y los datos no traen IP. Las ventanas S6 y S7 se agrupan por víctima (dos víctimas aportan el 62 % de los falsos positivos de S6), y la evaluación del LSTM por bloque no tiene una versión por usuario-día, porque falta definir a qué día se asigna cada bloque.
- La evaluación de usabilidad es heurística y la realiza el propio equipo: no incluye pruebas con administradores de seguridad externos, que quedan como la siguiente validación del panel.

10.11 Síntesis

Las 667 pruebas automatizadas (477 de la API y 190 del agente) se ejecutan sin fallas, con una cobertura de líneas del 94,8 % en la API y del 91,8 % en el agente, y la integración continua verifica la API, el agente en Windows, el *frontend* y la infraestructura en cada cambio. Las pruebas funcionales de extremo a extremo confirman el ciclo de detección, decisión y mitigación contra la infraestructura real. La latencia del cómputo de evaluación y el consumo de recursos del agente cumplen holgadamente los umbrales de RNF-01 y RNF-02; extremo a extremo en la nube, el percentil 95 es de 3,1 s, dominado por unos 20 viajes de 124 ms a Redis y PostgreSQL.

La evaluación del modelo muestra dos componentes complementarios, pero la validación por escenarios inyectados revela una sensibilidad baja ante ataques de corta duración, y la evaluación con escenarios etiquetados lo confirma: sin país, el nivel alto detecta entre el 12 % y el 30 % de los días atacados, y la detección más alta proviene de la ubicación. Los escenarios controlados adicionales de secuencia inusual y de pico corto lo refuerzan: con los umbrales de producción, el *recall* del híbrido es de 0,07 en conjunto (0,13 en el pico corto) con una especificidad de 0,97. Esta es la principal limitación técnica del sistema, y sus causas orientan el trabajo futuro: variables con granularidad menor al día, una regla explícita de ubicación y el rediseño del LSTM (sección 13).

11 Análisis de mercado y competitividad

Esta sección analiza el posicionamiento del producto en el mercado. Presenta el *marketing mix* (producto, precio y plaza), una estimación del tamaño del mercado objetivo, el análisis FODA, las cinco fuerzas de Porter y la matriz BCG.

11.1 Marketing mix: producto, precio y plaza

Esta sección describe el producto, su rango de precios y su plaza, es decir, los canales y la modalidad con que llega al cliente.

11.1.1 Producto

Sistema de seguridad conductual (UEBA) alineado a Zero Trust (NIST SP 800-207), compuesto por un agente liviano local (PEP) que recolecta actividad del usuario, una API central (PDP) que calcula un *score* de riesgo dinámico con un modelo híbrido (Isolation Forest + LSTM Autoencoder) con decaimiento temporal, y un *dashboard* donde el administrador define umbrales y acciones.

Diferencial del producto. El análisis de mercado compara el producto con las tres plataformas UEBA relevadas (Sentinel, Splunk UBA y Exabeam). Microsoft Entra ID Protection queda fuera de esta comparación porque es una solución de protección de identidad, complementaria más que sustituta, cuya respuesta se limita al acceso condicional en la autenticación (sección 2.2.1.4); del mismo modo, Okta se trata aparte en la sección 3.1. Las tres plataformas UEBA detectan y alertan, pero dejan la respuesta en manos de un analista o de una plataforma SOAR externa; el diferencial del producto es que la API que detecta la anomalía decide la respuesta y el agente la ejecuta en el *endpoint*, en segundos, sin depender de un analista (sección 2.2.6).

- Frente a Exabeam, que según el propio estado del arte “no incorpora de forma nativa un agente ligero y configurable para la recolección directa de datos desde los equipos finales”, el proyecto lo tiene como pieza central de la arquitectura: no depende de que la infraestructura ya tenga *logs* centralizados, sino que recolecta la actividad directamente en el *endpoint* del usuario.
- Frente a Splunk UBA, del que el estado del arte señala que “las acciones de respuesta suelen depender de integraciones externas o configuraciones adicionales, ya que no incorpora de forma nativa mecanismos de respuesta adaptativa basados en el nivel de riesgo detectado” (sección 2.2.1.2), el agente PEP ejecuta la acción (suspensión o terminación de procesos, denegación del acceso a carpetas) directamente en el *endpoint*, sin *re-login* y sin un componente externo que haya que integrar y configurar aparte.

- Frente a Microsoft Sentinel, que el estado del arte describe con "falta de visibilidad en el funcionamiento de sus algoritmos de detección", el sistema puede exponer la razón concreta de cada alerta en una notificación que informa las variables de Isolation Forest que más contribuyen a cada alerta, redactada en forma opcional por un modelo de lenguaje, en vez de una caja negra que solo informa "riesgo alto".

- Frente a las plataformas EDR/XDR orientadas a PyMEs, como Microsoft Defender for Business o Wazuh, que detectan técnicas maliciosas o reglas conocidas (sección 2.2.3.4), el producto evalúa si un usuario con credenciales válidas se aparta de su conducta habitual, mantiene un puntaje de riesgo con continuidad entre sesiones y gradúa la respuesta según ese puntaje. Se posiciona como complemento de un EDR, no como su reemplazo.

11.1.2 Precio

Rango sugerido de suscripción mensual por *endpoint* monitoreado, deliberadamente bajo porque el segmento elegido (PyME) tiene un presupuesto de seguridad muy inferior al de una empresa grande: un precio de nivel *enterprise* sería incompatible con el posicionamiento definido en la plaza y con el mercado objetivo.

- **Business** (detección + respuesta automática configurable): USD 2 a 5 por *endpoint*/mes. Para una PyME de referencia con 50-100 equipos, esto representa un gasto total de aproximadamente USD 100 a 500 por mes, un monto accesible para el presupuesto de una PyME.

- **Enterprise** (incluye reentrenamiento periódico configurable): USD 6 a 10 por *endpoint*/mes. La promoción automática de modelos desde el planificador está pendiente de validación (sección 9.2.5), por lo que este plan supone completarla antes de su comercialización. Sobre la misma base de 50-100 equipos, esto representa un gasto total de entre USD 300 y 1.000 por mes.

La viabilidad económico-financiera de este esquema de precios se evalúa en la sección 12.4.

11.1.3 Plaza

La plaza define cómo llega el producto al cliente. Se organiza en tres aspectos: los canales de distribución, la modalidad de despliegue y el alcance geográfico.

- **Canales de distribución.** Se prevé una distribución digital directa con alta autogestionada, complementada con un canal de reventa a través de integradores y proveedores de servicios de seguridad gestionados (MSSP) que ya atienden PyMEs.

- **Modalidad de despliegue.** El producto está diseñado para desplegarse en la nube: la API y las bases de datos (Redis en Upstash y PostgreSQL en Supabase) funcionan como servicios gestionados, y del lado del cliente solo se instala el agente en cada equipo Windows. No requiere infraestructura propia del cliente, a diferencia de Splunk UBA, cuya implementación inicial el propio estado del arte describe como compleja. El prototipo se verifica en un entorno local, con almacenamiento en la nube, y en una instancia en la nube con un agente real (sección 7.5).

- **Alcance geográfico.** Argentina, con foco inicial en las PyMEs del Área Metropolitana de Buenos Aires, donde se concentran los integradores y proveedores de servicios de seguridad gestionados del canal de reventa. La comercialización en otros países de América Latina se plantea como una expansión posterior, sujeta a adecuar el tratamiento de datos a la normativa de cada país.

11.2 Tamaño del mercado objetivo

Según el relevamiento de UCEMA PyMEs elaborado a partir de los registros del Sistema Integrado Previsional Argentino (SIPA), en agosto de 2025 había en Argentina 523.207 empresas empleadoras registradas: el 84 % tenía menos de 10 empleados, el 13 % eran pequeñas y el 2 % empleaba entre 51 y 100 trabajadores; en el último año, la cantidad de empresas medianas creció un 1,7 % (Salerno y Rampone, 2025). Ese 2 % equivale a unas 10.500 empresas y es la mejor aproximación disponible al segmento definido en la sección 11.1, de organizaciones con 50 a 100 equipos, bajo el supuesto de que la cantidad de equipos es del orden de la cantidad de empleados.

Esa cifra es una cota superior del mercado al que el producto puede dirigirse, no su demanda: no todas esas empresas trabajan con información sensible ni carecen de un área de seguridad propia, y la fuente no desagrega por sector ni por provincia, por lo que no permite acotar el foco inicial en el Área Metropolitana de Buenos Aires. Con esa base, los clientes activos al cierre del quinto año en los escenarios de la sección 12.4.2 representan alrededor del 0,5 % del segmento en el escenario pesimista (49 clientes), el 1,6 % en el base (168) y el 2,9 % en el optimista (307). La viabilidad, por lo tanto, no depende de captar una porción grande del mercado, sino de la velocidad de adopción y del costo de adquisición, como muestra el análisis de sensibilidad (sección 12.4.4). Las empresas pequeñas, que representan el 13 % del total, unas 68.000, son una posible expansión del segmento, con menos equipos por cliente.

11.3 Análisis FODA

La matriz FODA cruza las fortalezas y debilidades del producto (factores internos) con las oportunidades y amenazas del mercado relevado en el estado del arte (factores externos). Sigue el esquema de análisis de situación FODA (TOWS en la formulación de su autor) (Weihrich, 1982). La figura 11.1 resume la matriz.

	Favorables	Desfavorables
Factores internos	**Fortalezas** • Separación decisión-aplicación; respuesta en el *endpoint*. • Agente liviano y configurable nativo. • Umbrales y acciones editables desde el *dashboard*. • Costos no atados al volumen ingerido. • Notificación con variables que explican cada alerta.	**Debilidades** • Producto nuevo, sin trayectoria ni certificaciones. • No es un SIEM completo. • Capacidad de detección todavía limitada. • Sin canal comercial ni soporte 24/7. • Menor ecosistema de integraciones prearmadas.
Factores externos	**Oportunidades** • Segmento PyME desatendido. • Mercado Zero Trust/UEBA en expansión. • Complemento de soluciones IAM existentes.	**Amenazas** • Herramientas Microsoft ya contratadas percibidas como suficientes. • Competidores ofrecen solución todo en uno. • Innovación en IA: riesgo de desactualización. • Requisitos regulatorios sin certificaciones. • EDR/XDR para PyMEs percibidos como suficientes.

Figura 11.1: Matriz FODA del producto.
Fuente: elaboración propia.

11.3.1 Fortalezas

Las fortalezas son factores internos que favorecen al producto frente a las soluciones relevadas:

- Arquitectura basada en la separación entre punto de decisión y punto de aplicación de NIST SP 800-207, con respuesta ejecutada en el *endpoint* sin *re-login*: cierra el punto ciego que el propio estado del arte identifica como carencia común de Sentinel, Splunk UBA y Exabeam (sección 2.2.6).
- Agente liviano y configurable nativo, algo que Exabeam no ofrece de forma nativa.
- Umbrales y catálogo de acciones editables en tiempo real desde el *dashboard*, sin depender de integraciones externas como sí necesita Splunk UBA.
- Modelo de costos no atado al volumen de datos ingeridos (a diferencia de Sentinel), lo que permite un precio predecible y bajo, acorde al presupuesto de una PyME.
- Una notificación que informa las variables de Isolation Forest que más contribuyen a cada

alerta, redactada en forma opcional por un modelo de lenguaje, atendiendo la falta de transparencia algorítmica que el estado del arte señala en Sentinel.

11.3.2 Debilidades

Las debilidades son factores internos que limitan al producto frente a esas mismas soluciones:

- Producto nuevo en el mercado, sin trayectoria ni certificaciones (SOC 2, ISO 27001) que sí tienen Sentinel, Splunk UBA y Exabeam: la confianza institucional se construye con tiempo, no solo con calidad técnica.
- No es un SIEM completo: se enfoca en el comportamiento del usuario en el *endpoint*, no reemplaza la correlación multi-fuente de eventos de red/nube que sí ofrecen los tres competidores.
- La capacidad de detección del modelo todavía es limitada: entrenado con registros de otra plataforma, detecta en nivel alto una fracción baja de los ataques sin cambio de país (sección 10.7), y depende de la continuidad de los datos de cada usuario.
- Sin canal comercial, soporte 24/7 ni red de *partners* consolidada desde el lanzamiento, algo que Sentinel, Splunk UBA y Exabeam ya tienen resuelto por años de estar en el mercado.
- Menor ecosistema de integraciones prearmadas con otras herramientas de seguridad, comparado con plataformas consolidadas con años de desarrollo de *partners*.

11.3.3 Oportunidades

Las oportunidades son factores externos del mercado que el producto puede aprovechar:

- Segmento PyME desatendido: las tres plataformas UEBA relevadas están dimensionadas y tarifadas para organizaciones grandes con equipo de seguridad dedicado.
- Mercado de Zero Trust/UEBA en expansión.
- Posibilidad de integrarse como complemento de soluciones IAM existentes, mediante el adaptador de identidad, hoy validado con Keycloak, en vez de competir por reemplazarlas.

11.3.4 Amenazas

Las amenazas son factores externos que pueden dificultar la adopción del producto:

- Las herramientas del ecosistema Microsoft que la PyME ya contrata (Defender for Business en Microsoft 365 Business Premium, beneficios de Sentinel en las licencias E5) pueden percibirse como un sustituto sin costo adicional.

- Exabeam y Splunk UBA, al integrar SIEM+UEBA+SOAR, pueden ofrecerse como solución "todo en uno" frente a un producto que hoy resuelve una sola capa.
- Ritmo de innovación muy alto en IA aplicada a seguridad: riesgo de quedar desactualizado sin inversión continua.
- Requisitos regulatorios/de *compliance* que una solución nueva sin certificaciones podría no cumplir en una primera etapa.
- Plataformas EDR/XDR accesibles para PyMEs (Defender for Business, Wazuh) que pueden percibirse como suficientes, aunque no cubran la desviación conductual de usuarios con credenciales válidas.

11.4 Cruz de Porter: 5 fuerzas

El análisis sigue el modelo de las cinco fuerzas competitivas (Porter, 1979), aplicado al segmento elegido.

1. **Rivalidad entre competidores existentes, alta en el segmento *enterprise*, media en el segmento elegido.** Sentinel, Splunk UBA y Exabeam compiten entre sí por el cliente grande y no están diseñados ni tarifados para PyMEs. En ese segmento, en cambio, las plataformas EDR/XDR (Microsoft Defender for Business, Wazuh) compiten por el mismo presupuesto de seguridad, aunque detectan otro tipo de amenaza (sección 2.2.3.4).
2. **Amenaza de nuevos competidores, media.** La barrera técnica (modelos de comportamiento confiables) es real, pero la infraestructura *cloud* abarata el costo de entrada. El crecimiento del mercado Zero Trust también atrae nuevos entrantes.
3. **Amenaza de productos sustitutos, alta.** El sustituto más directo no es otro UEBA, sino mantener la situación actual y continuar con las herramientas del ecosistema Microsoft que la organización ya contrata (Sentinel ofrece un beneficio de ingesta de datos a las licencias Microsoft 365 E5, y Defender for Business viene incluido en Microsoft 365 Business Premium), aunque tengan las limitaciones de costo por volumen y opacidad que señala el propio estado del arte, o con una plataforma EDR/XDR como las descritas en la sección 2.2.3.4.
4. **Poder de negociación de los compradores, alto en *enterprise*, más bajo en PyME.** Las grandes organizaciones tienen alternativas consolidadas (Sentinel, Splunk, Exabeam) y capacidad de negociar. El comprador PyME hoy no tiene una alternativa dedicada a su tamaño entre estas tres, lo que da más previsibilidad al posicionamiento propuesto.

5. **Poder de negociación de los proveedores, medio.** Dependencia de servicios *cloud* gestionados (AWS, Redis, Postgres, API de Gemini) reemplazables sin bloquear el producto. El *dataset* de entrenamiento (CLUE-LDS) es público, con licencia CC BY 4.0, y no depende de un proveedor comercial de datos.

11.5 Matriz Boston Consulting Group (BCG)

Con un único producto, la matriz (Henderson, 1970) se usa para posicionarlo dentro de su mercado, cruzando crecimiento del mercado vs. participación relativa. La figura 11.2 muestra la posición resultante del producto.

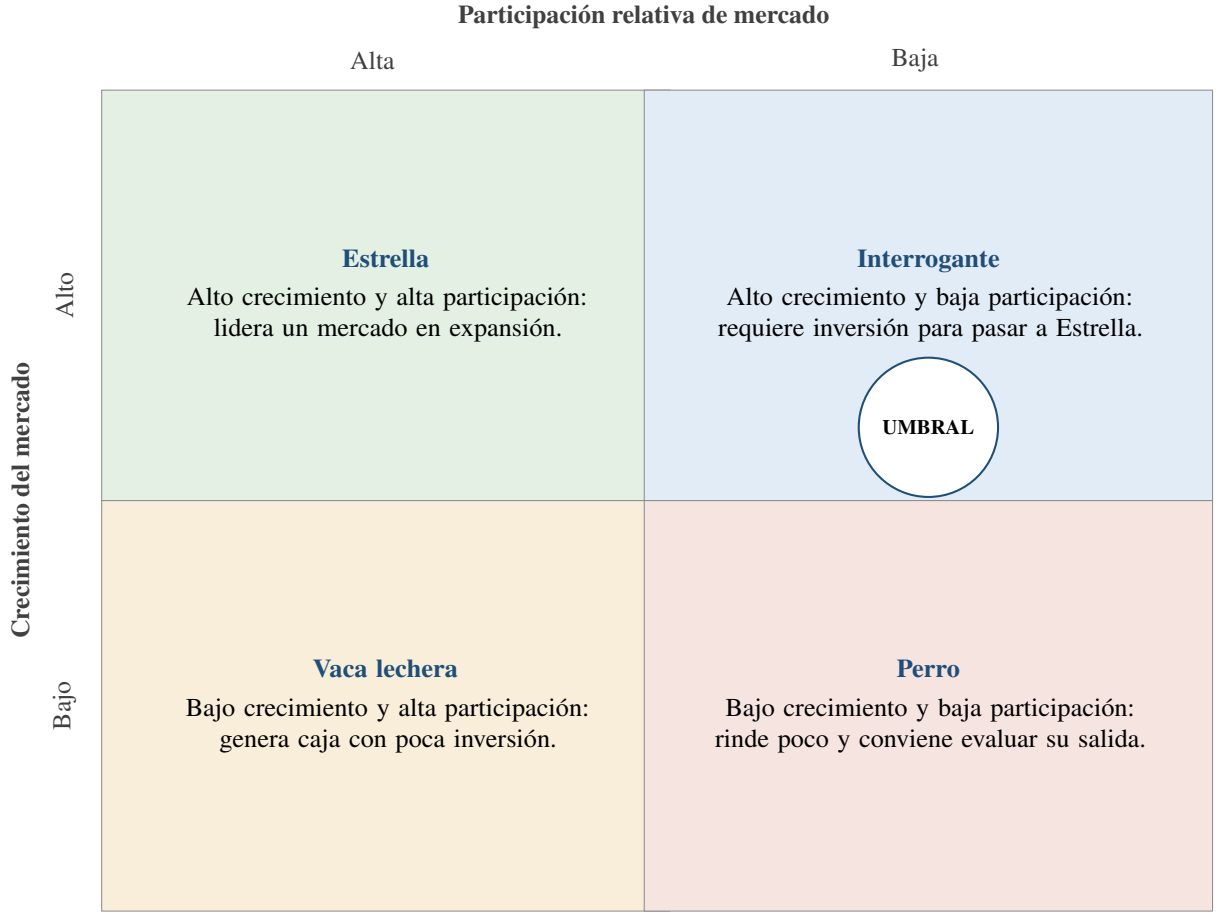


Figura 11.2: Matriz Boston Consulting Group (BCG) del producto.
Fuente: elaboración propia.

- **Eje crecimiento del mercado: alto.** Se ubica en el extremo alto por dos motivos. Primero, un cambio estructural: el trabajo remoto y la migración a servicios en la nube reducen la eficacia de la seguridad perimetral, premisa de la que parte el enfoque Zero Trust (Rose *et al.*, 2020), y obligan a controlar la actividad posterior al inicio de sesión (sección 2.1.1).

Segundo, la literatura sobre UEBA y control de acceso adaptativo relevada en el estado del arte es en su mayoría reciente, lo que indica un campo en desarrollo activo. La valoración es cualitativa en lo que respecta al mercado de seguridad: el tamaño del segmento se estima en la sección 11.2, pero el proyecto no cuenta con datos sobre la tasa de crecimiento del gasto en soluciones UEBA o Zero Trust en el segmento PyME.

- **Eje participación relativa de mercado: baja.** La participación relativa se mide contra el líder del segmento. Las tres plataformas UEBA relevadas tienen una posición consolidada: Sentinel se distribuye integrado al ecosistema de Microsoft, Splunk tiene una trayectoria extensa en el mercado de SIEM y Exabeam combina capacidades de SIEM, UEBA y SOAR. El producto, en cambio, no tiene clientes, marca reconocida ni implementaciones previas, por lo que su participación inicial es nula. La participación se construye con tiempo de operación en el mercado y no depende solo de la calidad técnica del producto.

Interrogante / Dilema (*Question Mark*). Mercado de alto crecimiento donde el producto todavía no tiene participación, por lo que requiere inversión para intentar moverse hacia el cuadrante "Estrella". La estrategia recomendada para este cuadrante es la seguida en el posicionamiento: no competir de frente contra Sentinel, Splunk UBA y Exabeam en su propio segmento (*enterprise*), sino ganar adopción en el corto plazo en el nicho PyME que esas tres soluciones dejan desatendido por su modelo de costos e implementación.

12 Modelo de negocio y viabilidad económico-financiera

Esta sección describe cómo el producto crea, entrega y captura valor (Osterwalder y Pigneur, 2010), y evalúa si puede sostenerse y ser rentable en el tiempo. Los supuestos parten del análisis de mercado de la sección anterior (segmento, precio y canales) y de los costos reales de la infraestructura del prototipo.

12.1 Cliente, usuario y pagador

El producto es un servicio B2B. El **usuario** del panel es el responsable de seguridad o de tecnología de la organización, que revisa los niveles de riesgo y configura las políticas. Los empleados cuyos equipos ejecutan el agente no son usuarios del producto, sino titulares de los datos que este trata (sección 9.4). El **cliente** que decide la compra es el responsable de tecnología o, en las empresas más chicas, la dirección. El **pagador** es la organización, en forma directa o a través del proveedor de servicios de seguridad gestionados (MSSP) que le revende el producto.

12.2 Lienzo del modelo de negocio

La tabla 12.I resume el modelo en los nueve bloques del lienzo (Osterwalder y Pigneur, 2010).

TABLA 12.I: Lienzo del modelo de negocio

Bloque	**Contenido**
Segmentos de clientes	PyMEs argentinas de 50 a 100 equipos con información sensible y sin centro de operaciones de seguridad propio; unas 10.500 empresas emplean entre 51 y 100 trabajadores (sección 11.2); en la encuesta, el 51 % de los 185 participantes que utilizan una computadora provista por su empresa declara acceder a datos o sistemas de criticidad media-alta o alta, como indicio y no como estimación del segmento (muestra por conveniencia, sección 3.6).
Propuesta de valor	Detección del uso indebido de una sesión válida y respuesta automática en el propio equipo, sin depender de un analista ni de una plataforma de orquestación externa, con la explicación de las variables que más contribuyen a cada alerta y a un precio acorde al presupuesto de una PyME.

Bloque	Contenido
Canales	Venta directa, con alta autogestionada prevista, y reventa a través de integradores y MSSP que ya atienden PyMEs. La elección del canal de reventa es consistente con la encuesta, donde la recomendación de proveedores es el factor de adopción más mencionado (21 %) (sección 3.6).
Relación con los clientes	Alta autogestionada con período de aprendizaje automático; soporte por correo; acompañamiento del MSSP en los clientes que llegan por ese canal.
Fuentes de ingresos	Suscripción mensual por equipo monitoreado en dos planes: Business (de USD 2 a USD 5) y Enterprise, con reentrenamiento periódico configurable (de USD 6 a USD 10).
Recursos clave	Modelo de detección entrenado y su pipeline de reentrenamiento; agente, API y panel; equipo de desarrollo; infraestructura de nube.
Actividades clave	Desarrollo y mantenimiento del producto; reentrenamiento y evaluación del modelo; soporte; gestión del canal de reventa.
Socios clave	Integradores y MSSP; proveedores de nube (AWS, Upstash, Supabase); proveedores de identidad (Keycloak u otros) para la integración IAM.
Estructura de costos	Equipo (costo fijo principal); infraestructura de nube escalonada según los equipos monitoreados (fija por tramo) y almacenamiento por equipo (variable); comisiones del canal y del procesador de pagos (variables); costo de adquisición de clientes; contador, mesa de ayuda, certificado de firma de código y asesoramiento legal.

Fuente: elaboración propia sobre el esquema del lienzo del modelo de negocio (Osterwalder y Pigneur, 2010).

12.3 Monetización y economía unitaria

El esquema de suscripción por equipo se elige porque el costo variable del producto crece con la cantidad de equipos monitoreados (eventos procesados, almacenamiento y cómputo de la API), de modo que el ingreso escala con el mismo factor que el costo. Con una mezcla supuesta de 70 % de equipos en el plan Business a USD 4 y 30 % en Enterprise a USD 8, el ingreso promedio es de USD 5,20 por equipo y de USD 390 por mes para un cliente de 75 equipos. Descontados el costo variable de nube por equipo (USD 0,10), las comisiones de pago e impuestos sobre ventas (6 %) y la comisión del canal (20 % sobre la mitad de las ventas), el margen de contribución es de USD 320 por cliente y por mes.

El costo variable de nube se estima a partir de los gastos del despliegue y no como un valor por equipo fijado de antemano. Con la carga medida en el prototipo (unos 3,7 eventos por minuto por equipo, o unos 37.000 eventos al mes en jornadas de 8 horas), cada evento requiere unos 17 comandos a Redis y una escritura en PostgreSQL. A esa escala los servicios gestionados conviene contratarlos por plan y no por uso: Redis con un plan fijo de USD 20 por mes admite hasta 10.000 comandos por segundo, mientras que el cobro por comando (USD 0,20 cada 100.000, unos USD 1,30 por equipo y por mes) solo resulta más barato por debajo de 16 equipos en total. PostgreSQL gestionado (plan Pro de USD 25 por mes con 8 GB incluidos y USD 0,125 por GB adicional) crece con el volumen almacenado. Por eso la mayor parte del gasto de nube es fija y escalonada (tabla 12.II), y lo que varía con el cliente es sobre todo el almacenamiento de los eventos crudos: con una retención supuesta de 90 días y unos 1,5 KB por evento (valor no medido), son unos 170 MB por equipo, o USD 0,02 por equipo y por mes. Se adopta USD 0,10, cinco veces ese resultado, para cubrir lo que el prototipo no mide: la concurrencia en la nube, el tamaño real del evento y el tráfico de salida. Los precios corresponden a los publicados por los proveedores en octubre de 2026.

TABLA 12.II: Gasto mensual de nube y servicios de soporte por tramo de equipos monitoreados (USD)

Concepto	USD por mes
Dos instancias `t3.medium` (alta disponibilidad; USD 0,0416 por hora cada una), discos, IPv4 y balanceador	95
PostgreSQL gestionado (plan Pro con cómputo pequeño)	30
Redis gestionado (plan fijo de 1 GB)	20
Monitoreo, dominio y correo	34
Base, hasta 1.500 equipos	**179**
Más de 1.500 equipos (cómputo de PostgreSQL medio)	+45
Cada 3.000 equipos por encima de los primeros 3.000 (otro par de instancias)	+73
Cada 5.000 equipos por encima de los primeros 5.000 (otro Redis)	+20
Más de 6.000 equipos (cómputo de PostgreSQL grande)	+100
Contador, mesa de ayuda y renovación anual del certificado de firma	167

Fuente: elaboración propia a partir de la infraestructura del prototipo y de los precios publicados por los proveedores en octubre de 2026; los tramos de capacidad son estimaciones.

Con un costo de adquisición de USD 1.500 y una tasa de abandono del 2 % mensual (escenario base), el valor de vida de un cliente es de USD 320 / 0,02 = USD 16.000, la relación

entre el valor de vida y el costo de adquisición es de 10,7 y el costo de adquisición se recupera en 4,7 meses.

Disposición a pagar. El proyecto no cuenta con una medición directa de la disposición a pagar. El precio se fija por debajo del de las soluciones del segmento corporativo, que se tarifan por volumen de datos o por usuario con montos dimensionados para grandes empresas, y se contrasta con la encuesta, donde el costo aparece como factor determinante de adopción para el 14 % de los participantes. Validar el precio con clientes potenciales es la primera acción comercial prevista.

12.4 Viabilidad económico-financiera

La viabilidad económico-financiera se evalúa en cuatro pasos. Primero se fijan los supuestos del análisis; luego se plantean tres escenarios de adopción (pesimista, base y optimista) y se calculan para cada uno el valor actual neto, la tasa interna de retorno, el período de recupero y la necesidad máxima de fondos; por último, se interpretan esos indicadores y su sensibilidad a la tasa de descuento.

12.4.1 Supuestos

El análisis se realiza sobre el flujo de fondos anual, en dólares estadounidenses constantes para aislarlo de la inflación local, con un horizonte de cinco años. El horizonte se justifica porque el ingreso es recurrente y el costo de adquirir cada cliente se recupera a lo largo de varios meses: en tres años los escenarios todavía reflejan sobre todo la etapa de adquisición. No se considera valor residual al final del horizonte, lo que hace que la evaluación sea conservadora. La tabla 12.III resume los supuestos.

TABLA 12.III: Supuestos del análisis económico-financiero

Supuesto	**Valor y fundamento**
Inversión inicial	USD 23.000: horas del equipo valorizadas (1.000 horas a USD 15 por hora, USD 15.000), pasaje del prototipo a producto (instalador, firma de código, endurecimiento; USD 6.000), constitución de la sociedad y asesoramiento legal (USD 1.500) y certificado de firma de código (USD 500).
Precio y mezcla de planes	USD 5,20 por equipo y por mes (70 % Business a USD 4, 30 % Enterprise a USD 8), dentro de los rangos de la sección de precio.

Supuesto	Valor y fundamento
Tamaño del cliente	75 equipos, punto medio del segmento de 50 a 100.
Costo variable	Nube: USD 0,10 por equipo y por mes (almacenamiento con retención de 90 días más un margen por lo no medido; sección de economía unitaria); procesador de pagos 3 %; impuesto sobre los ingresos brutos 3 % (supuesto conservador); comisión del 20 % al MSSP sobre la mitad de las ventas.
Costo fijo	Equipo y soporte, por mes: USD 3.500 el año 1 (dos integrantes a tiempo parcial), USD 6.000 el año 2, USD 9.000 el año 3, USD 11.000 el año 4 y USD 12.000 el año 5; infraestructura de nube escalonada según los equipos monitoreados (USD 179 por mes hasta 1.500 equipos, USD 224 hasta 3.000, USD 317 con 6.000 y USD 583 con 12.000; tabla 12.II); contador, mesa de ayuda y renovación del certificado de firma de código: USD 167 por mes (USD 125 el primer año, porque el certificado ya figura en la inversión inicial).
Impuesto a las ganancias	25 % sobre el resultado positivo de cada año (supuesto simplificado: la alícuota societaria vigente es escalonada, por lo que en los años de mayor resultado el impuesto sería mayor; no se consideran quebrantos trasladables).
Tasa de descuento	25 % anual en dólares, construida por acumulación (ver el párrafo siguiente), con sensibilidad entre 20 % y 35 %.

Fuente: elaboración propia.

La tasa de descuento se construye por acumulación. Parte del rendimiento del bono del Tesoro de los Estados Unidos a diez años, cercano al 5,3 % según la serie DGS10 de la Reserva Federal de St. Louis (Board of Governors of the Federal Reserve System, 2026), y le suma el riesgo país de Argentina, de 650 puntos básicos, su máximo del año según el índice de J. P. Morgan (MDZ Online, 2026). El resultado, cercano al 12 %, representa el costo de financiarse en dólares para un emisor argentino. A ese valor se agrega una prima por riesgo de

emprendimiento de 13 a 14 puntos porcentuales, que refleja que el producto todavía no tiene clientes ni historial comercial. Esa prima es un supuesto del equipo y el componente menos fundamentado de la tasa; por eso el valor actual neto se informa también con tasas del 20 %, 30 % y 35 %. Como los rendimientos son nominales en dólares y los flujos están en dólares constantes, la tasa resulta algo mayor que la real equivalente, lo que vuelve la evaluación más conservadora.

El costo de adquisición, la tasa de abandono y la velocidad de incorporación de clientes son supuestos del equipo, sin una fuente externa ni datos propios que los respalden. Por eso los tres escenarios los varían en conjunto, y la validación comercial (sección 13.3) apunta primero a medirlos.

12.4.2 Escenarios

Los tres escenarios difieren en la velocidad de adopción, la tasa de abandono y el costo de adquisición (tablas 12.IV y 12.V), y cada uno responde a una hipótesis sobre el mercado:

- **Pesimista**: la resistencia a la adopción observada en la encuesta (el 34 % de los participantes considera improbable que su empresa adopte el sistema) se traduce en un ciclo de venta largo y caro. Se incorpora un cliente cada dos meses el primer año, uno por mes el segundo y dos por mes desde el tercero, con un abandono del 3 % mensual y un costo de adquisición de USD 2.500.

- **Base**: el canal de MSSP empieza a aportar clientes desde el segundo año. Se incorporan 1, 3, 5, 6 y 6 clientes por mes en cada año, con un abandono del 2 % mensual y un costo de adquisición de USD 1.500.

- **Optimista**: el canal se activa desde el primer año y el producto se recomienda entre clientes. Se incorporan 2, 5, 8, 10 y 10 clientes por mes, con un abandono del 1,5 % mensual y un costo de adquisición de USD 1.000.

TABLA 12.IV: Clientes activos al cierre de cada año por escenario

Escenario	Año 1	Año 2	Año 3	Año 4	Año 5
Pesimista	5	14	30	41	49
Base	11	41	86	132	168
Optimista	22	74	150	236	307

Fuente: elaboración propia a partir del modelo financiero.

TABLA 12.V: Flujo neto de fondos por escenario (USD)

Escenario	Año 0	Año 1	Año 2	Año 3	Año 4	Año 5
Pesimista	−23.000	−49.438	−67.565	−84.122	−57.108	−34.215
Base	−23.000	−40.422	−24.606	37.244	135.648	242.657
Optimista	−23.000	−22.447	43.458	175.454	372.723	586.307

Fuente: elaboración propia a partir del modelo financiero.

12.4.3 Indicadores

TABLA 12.VI: Indicadores económico-financieros por escenario

Escenario	VAN al 25 % (USD)	TIR	Recupero simple	Recupero descontado	Necesidad máx. de fondos (USD)
Pesimista	−183.466	no existe	no recupera	no recupera	315.448
Base	83.059	56,0 %	3,4 años	3,9 años	88.028
Optimista	421.476	154,3 %	2,0 años	2,1 años	45.447

Fuente: elaboración propia a partir del modelo financiero.

TABLA 12.VII: Sensibilidad del VAN a la tasa de descuento (USD)

Escenario	20 %	30 %	35 %
Pesimista	−201.091	−168.508	−155.708
Base	110.716	61.148	43.650
Optimista	505.379	353.718	298.499

Fuente: elaboración propia a partir del modelo financiero.

TABLA 12.VIII: Sensibilidad del VAN al 25 % al costo variable de nube por equipo (USD)

Escenario	USD 0,10	USD 0,30	USD 0,60
Pesimista	−183.466	−192.538	−206.147
Base	83.059	61.533	29.245
Optimista	421.476	384.163	328.194

Fuente: elaboración propia a partir del modelo financiero. USD 0,60 es un valor holgado, usado como contraste.

TABLA 12.IX: Sensibilidad del VAN al 25 % del escenario base al costo de adquisición y a la tasa de abandono (USD)

Costo de adquisición por cliente	USD 1.000	USD 1.500	USD 2.500
VAN	130.806	83.059	−13.758
Abandono mensual	**1,5 %**	**2 %**	**3 %**
VAN	111.805	83.059	33.579

Fuente: elaboración propia a partir del modelo financiero. Se varía un supuesto por vez; el resto se mantiene en el valor del escenario base (USD 1.500 y 2 % mensual).

El punto de equilibrio operativo es de 12 clientes activos el primer año y crece hasta 41 en el quinto, a medida que aumentan el costo fijo del equipo y la infraestructura escalonada: con un margen de contribución de USD 320 por cliente, cada USD 1.000 de costo fijo mensual adicional exige tres o cuatro clientes más. La tabla 12.X calcula el equilibrio de cada año como el costo fijo mensual (con la infraestructura que corresponde a los clientes del escenario base) dividido por el margen de contribución, redondeado hacia arriba, y lo compara con los clientes activos al cierre del año en cada escenario. En negrita figuran los valores que alcanzan o superan el equilibrio.

TABLA 12.X: Punto de equilibrio operativo frente a los clientes activos al cierre de cada año

Año	Costo fijo mensual (USD)	Equilibrio	Pesimista	Base	Optimista
1	3.804	12	5	11	**22**
2	6.464	21	14	**41**	**74**
3	9.657	31	30	**86**	**150**
4	11.730	37	**41**	**132**	**236**
5	12.822	41	**49**	**168**	**307**

Fuente: elaboración propia a partir del modelo financiero.

12.4.4 Interpretación

En el escenario base (tabla 12.VI) el proyecto genera valor: el VAN al 25 % es de USD 83.059, la TIR de 56,0 % supera la tasa de descuento y la inversión se recupera en 3,4 años (3,9 con flujos descontados). El resultado es sensible a la tasa (tabla 12.VII), pero sigue siendo positivo aun al 35 %, con USD 43.650. Los dos primeros años tienen flujos negativos, por lo que hay que financiar hasta USD 88.028 acumulados antes de generar caja. En el escenario optimista

el VAN es de USD 421.476 y la inversión se recupera en 2,0 años. En el pesimista no se recupera dentro del horizonte y la necesidad de fondos llega a USD 315.448: con una adopción tan lenta, el costo fijo crece más rápido que la base de clientes.

El resultado depende poco del costo variable de nube (tabla 12.VIII): con USD 0,60 por equipo, seis veces el valor adoptado, el VAN del escenario base baja a USD 29.245 y sigue siendo positivo. Lo que sí pesa es el piso fijo: aun con pocos clientes, la infraestructura con alta disponibilidad, el contador y la mesa de ayuda suman unos USD 350 por mes antes de pagar al equipo. Esta conclusión supone que dos instancias atienden unos 3.000 equipos y que Redis y PostgreSQL se contratan por plan. Ninguna de las dos cosas se mide en la nube (sección 10.4.2), por lo que medirlas es la primera verificación técnica de este análisis.

Los supuestos que más pesan son el costo de adquisición y el abandono (tabla 12.IX): con un costo de adquisición de USD 2.500 el VAN del escenario base pasa a -13.758 y se vuelve negativo a partir de unos USD 2.370 por cliente, un 58 % por encima del supuesto. Con un abandono mensual del 3 % el VAN sigue siendo positivo (USD 33.579) y se volvería negativo recién con un abandono cercano al 3,8 %.

La tabla 12.X muestra cuándo se alcanza el equilibrio. En el escenario optimista se alcanza en el séptimo mes y el primer año cierra con 22 clientes frente a 12 necesarios. En el base se alcanza en el mes 16, a mitad del segundo año, que cierra con 41 clientes frente a 21. En el pesimista se alcanza recién hacia el final del tercer año, y de forma sostenida en el cuarto (41 clientes frente a 37).

Que los flujos sigan negativos después de superar el equilibrio es coherente con el modelo, por dos razones. Primero, el equilibrio es operativo: no incluye el costo de adquisición ni el impuesto a las ganancias. Segundo, la tabla compara los clientes al cierre del año, mientras que el flujo se calcula con la base de cada mes. En el escenario base, el segundo año tiene en promedio 28 clientes activos y USD 54.000 de costo de adquisición, por lo que el flujo todavía es negativo; desde el tercer año la base supera con holgura el equilibrio y el flujo se vuelve positivo. En el pesimista, aun por encima del equilibrio, los USD 60.000 anuales de adquisición de los años 4 y 5 no se cubren, y por eso la inversión no se recupera. Llegar al equilibrio en algo menos de un año y medio, como en el base, es razonable para una suscripción que depende de un canal de MSSP que recién aporta clientes desde el segundo año; llegar recién al final del tercero, como en el pesimista, no lo es.

La viabilidad depende, por lo tanto, de la velocidad de adopción y del costo de adquirir cada cliente más que del precio o del costo variable de infraestructura. Esto define qué validar primero: la disposición a pagar de las PyMEs y la capacidad de los MSSP de aportar clientes a un costo menor que el de la venta directa. Como regla de decisión, si al cabo del primer año la base de clientes queda por debajo del punto de equilibrio y el costo de adquisición observado supera los USD 2.000, se replantea el canal o el segmento antes de aumentar el costo fijo.

12.5 Identidad de marca

La identidad de marca se compone del nombre del producto, su logotipo y el mensaje con que se posiciona frente al segmento elegido.

12.5.1 Nombre

El producto se llama **UMBRAL**, por los umbrales de riesgo que separan el comportamiento habitual de un usuario de una desviación que merece respuesta. Es una palabra corta, en español, y no describe una tecnología puntual, así que el nombre puede acompañar la evolución del producto.

12.5.2 Logotipo

La figura 12.1 presenta el logotipo. El isotipo es un escudo con una línea de actividad que cruza una línea horizontal: la primera representa lo que hace el usuario durante la sesión, la segunda el umbral, y el punto en el pico marca el momento en que el sistema interviene. La paleta combina un azul oscuro, frecuente en productos de seguridad, con un ámbar de acento, el mismo color que usa el panel para el riesgo medio.



Figura 12.1: Logotipo del producto.
Fuente: elaboración propia.

12.5.3 Posicionamiento y mensaje

El eslogan *"confianza continua, después del login"* resume la propuesta: un sistema que actúa y no solo alerta, con un precio y una puesta en marcha pensados para PyMEs. En la comunicación, el producto se presenta como una protección de las credenciales de cada persona y no como una herramienta para vigilar empleados, por el peso de la reacción de los empleados que muestra la encuesta y por el marco legal.

13 Conclusiones y trabajo futuro

Esta sección cierra el documento. Analiza el cumplimiento del objetivo general y de cada objetivo específico, resume los resultados principales del proyecto en sus aspectos técnicos, económicos y legales, y propone las líneas de trabajo futuro, priorizadas según su impacto sobre la principal limitación del sistema.

13.1 Cumplimiento de los objetivos

El objetivo general se cumple en su alcance funcional: el sistema evalúa cada evento durante toda la sesión, mantiene un puntaje de riesgo con continuidad entre sesiones y ejecuta en el equipo una respuesta graduada, con la decisión centralizada en la API y la aplicación distribuida en los agentes. Siete de los nueve objetivos específicos se cumplen y dos se cumplen en forma parcial: el segundo, referido al modelo híbrido, y el sexto, referido al reentrenamiento, porque todavía no se ejecutó una promoción desde el planificador con un modelo genuinamente nuevo. La tabla 13.I detalla la evidencia de cada uno.

TABLA 13.I: Cumplimiento de los objetivos específicos

Objetivo	Evidencia
1. Agente liviano con canal cifrado y autenticado	Recolección de metadatos (RF-01, RNF-08); TLS en el despliegue y rechazo de `http` fuera de *loopback* (RNF-13); credencial individual, revocable y ligada al agente y a sus usuarios (RF-02); consumo medio de 0,09 % de CPU y 33 MB de memoria (RNF-02); verificado con un agente real contra la instancia por HTTPS (sección 10.4.3)
2. Modelo híbrido evaluado contra metas	**Parcial.** Entrenado sobre CLUE-LDS; cumple 1 de las 5 metas de comportamiento y detección, y la de latencia (tabla 10.VIII). Con el umbral de 70, la detección atribuible es de 0 a 13,3 % por escenario frente a un 15,4 % de días normales en nivel alto (sección 10.6); en la partición reservada de escenarios etiquetados, el ROC-AUC del híbrido va de 0,58 a 0,80 según el escenario (sección 10.7)

Objetivo	Evidencia
3. Puntaje con continuidad y latencia ≤ 500 ms	Continuidad y decaimiento implementados (RF-03, RF-04); percentil 95 de 14,9 ms y percentil 99 de 148,9 ms medidos desde el cliente en entorno local aislado (Redis en memoria); con Redis y PostgreSQL gestionados en la nube, el percentil 95 es de 3,1 s, dominado por unos 20 viajes de red de 124 ms (sección 10.4.2), que se informan sin meta propia
4. Respuesta graduada y reversible	Seis acciones configurables por nivel (RF-07, RF-08); la denegación de carpeta se revierte restaurando la ACL previa desde un respaldo (RNF-06), con pruebas con `icacls` simulado y una prueba de extremo a extremo del ciclo de decisión y aplicación (sección 10.3); la terminación de procesos no es reversible por limitación del sistema operativo; la prueba manual de reversión da resultado satisfactorio con el agente como administrador (sección 9.5)
5. Panel con explicación y configuración en tiempo de ejecución	CU-02 implementado (RF-12 a RF-17, RNF-07); evaluación heurística con los cuatro problemas mayores corregidos; la explicación cubre las variables de Isolation Forest, pero no el LSTM (RNF-11, parcial)
6. Reentrenamiento aislado y período de aprendizaje	**Parcial.** CU-03 y CU-04 implementados. Las tres corridas reales de reentrenamiento (una automática y dos manuales) generan candidatos que la regla de promoción anterior rechaza (RF-21). El criterio de no inferioridad está implementado, con 13 pruebas automatizadas: el modelo vigente se promueve contra sí mismo y el juego v2 se rechaza por falsos positivos. Falta ejecutar una promoción desde el planificador con un modelo genuinamente nuevo

Objetivo	Evidencia
7. Credenciales y canal protegidos	TLS con certificado verificado; clave de agente individual, ligada a su identificador y a sus usuarios (403 si no corresponde); *token* de sesión del panel opaco, con vencimiento de 8 horas y cierre de sesión; secretos en el almacén de parámetros de la nube; la autenticación mutua por certificado queda como extensión (RF-02, RNF-03, RNF-13); verificado contra la instancia (sección 10.4.3)
8. Análisis de la normativa de datos personales	Marco legal (sección 2.1.9) y análisis del tratamiento (sección 9.4); quedan pendientes el plazo de conservación y la supresión completa de los datos de un usuario
9. Pruebas con cobertura $\geq$ 85 %	667 pruebas automatizadas (477 de la API y 190 del agente), con una cobertura de líneas del 94,8 % en la API y del 91,8 % en el agente (sección 10.2.4); el *frontend*, sin lógica de negocio, queda fuera del umbral; prueba de extremo a extremo del ciclo de decisión y aplicación, y evaluación heurística de usabilidad

Fuente: elaboración propia.

De los 31 requerimientos funcionales, los 31 están implementados, y de los 15 no funcionales, 12 están implementados y 3 en estado parcial (RNF-05, RNF-09 y RNF-11) (sección 4).

13.2 Resultados principales

El resultado técnico más relevante es la arquitectura: el sistema cierra el ciclo de detección, decisión y respuesta en el equipo, que es el hueco que el estado del arte identifica en las soluciones comerciales, y lo hace con un percentil 95 de latencia de cómputo de 14,9 ms frente al límite de 500 ms, con el consumo del agente y la cobertura de las pruebas dentro de sus umbrales (tabla 13.I). La separación entre el punto de decisión y el de aplicación permite cambiar umbrales y acciones sin modificar los agentes.

El resultado más débil es la capacidad de detección. Sobre escenarios de ataque inyectados en el historial de 15 usuarios, la detección atribuible nunca supera un tercio de los usuarios en ningún umbral, y con el umbral vigente del nivel alto llega al 13,3 % en el escenario combinado, mientras que el 15,4 % de los días sin ataque termina en nivel alto. La evaluación con escenarios etiquetados sobre un conjunto mayor de víctimas, en una partición reservada para la evaluación final, lo confirma: sin país, el sistema detecta en nivel alto entre el 12 % y el 30 % de los días atacados, con una tasa de falsos positivos del 4 % al 5 % en ese nivel; cuando la exfiltración

introduce un país nuevo, la detección sube al rango del 91 % al 99 %, por efecto de la ubicación y no del comportamiento (sección 10.7). Entre las causas verificadas están que casi todos los eventos del conjunto de entrenamiento tienen el país registrado como desconocido, que la variable de cambio de país domina el error del LSTM, que este no aprovecha el orden de los eventos y que su riesgo se asocia en forma inversa al volumen de actividad del usuario; la granularidad diaria de las variables de Isolation Forest, que diluye una ráfaga corta de eventos, sigue siendo una causa inferida. Estos resultados se basan en una muestra chica y en escenarios diseñados por el propio equipo, pero alcanzan para concluir que el modelo, tal como está entrenado, no detecta de forma confiable ataques de corta duración.

El análisis económico muestra que el producto puede ser rentable en un escenario de adopción moderada, con un VAN de USD 83.059 al 25 %; en el escenario pesimista no recupera la inversión (VAN de USD -183.466), por lo que su viabilidad depende de la velocidad de adopción y del costo de adquirir clientes: el VAN base se vuelve negativo con un costo de adquisición de unos USD 2.370 por cliente, y el escenario base requiere, al quinto año, alrededor del 1,6 % de un segmento de unas 10.500 empresas (sección 11.2). El marco legal no impide el uso del sistema, pero exige que la organización que lo adopte informe a sus empleados y formalice la transferencia internacional de los datos.

13.3 Trabajo futuro

El trabajo futuro se prioriza según el impacto sobre la principal limitación del sistema:

1. **Capacidad de detección**: incorporar variables con granularidad menor al día, reemplazar las variables de país dentro de los modelos por una regla explícita de ubicación en el motor de decisión, introducir una transición gradual al cerrar la primera secuencia del LSTM y revisar el componente personal en usuarios con historial escaso (secciones 10.6.4 y 10.7).

2. **Rediseño del LSTM**: el componente no aprovecha el orden de los eventos; rediseñarlo o reemplazarlo por un modelo no secuencial sobre la misma ventana, que además permita explicar los puntajes que hoy no identifican qué los causó.

3. **Datos propios**: reentrenar el modelo con telemetría de equipos Windows y evaluarlo con escenarios etiquetados de ese dominio, para eliminar la traducción de vocabulario y la variable de país sin información y medir la brecha de dominio.

4. **Benchmark con reproducción evento a evento**: evaluar el sistema con el agregado parcial y la línea base personal que aplica la producción, y definir la partición del reentrenamiento por origen del dato, de modo que los datos del agente se incorporen al entrenamiento sin desplazar el corte temporal del criterio de promoción ni contaminar los escenarios con los que este evalúa al candidato.

5. **Conservación de datos**: implementar el cierre de la cadena de hashes por período y un plazo de conservación configurable (sección 9.4), y la seudonimización de la telemetría usada en el reentrenamiento.

6. **Redacción asistida del correo**: sacar la redacción y el envío del correo del procesamiento del evento, evaluar el envío de variables agregadas en lugar de nombres crudos y probar los controles contra el servicio real (sección 9.2.3).

7. **Pruebas**: agregar pruebas al *frontend*, a la cadena de hashes (RNF-09) y a la concurrencia con varios usuarios (RNF-14), automatizar la verificación de las mitigaciones en el equipo y medir la latencia con el Redis gestionado y varios agentes concurrentes.

8. **Seguridad**: implementar la autenticación mutua por certificado y la firma de las respuestas del PDP (un segundo sitio del proxy en un subdominio, con una autoridad certificadora propia y la huella del certificado asociada a la clave del agente; la firma solo agrega protección frente a un intermediario que termine TLS, como un proxy de inspección), agregar una política de seguridad de contenido al *dashboard* y verificar la integración con Microsoft Entra ID contra un *tenant* real (sección 9.5).

9. **Validación comercial**: medir la disposición a pagar y el costo de adquisición a través del canal de MSSP, que son las variables que más influyen en la viabilidad.

Bibliografía

AGENCIA DE ACCESO A LA INFORMACIÓN PÚBLICA, 2018. *Resolución 47/2018. Medidas de seguridad recomendadas para el tratamiento y conservación de los datos personales* [Boletín Oficial de la República Argentina, n.º 33.918, 25 de julio de 2018]. [consultado 2026-10-07]. Disponible en: https://servicios.infoleg.gob.ar/infolegInternet/verNorma.do?id=312662.

ALIYU, Muhammad Bello; GARBA, Muhammad; GABI, Danlami; SURU, Hassan U. y ARGUNGU, Musa S., 2024. Dynamic Access Control at the Network Edge Using an Adaptive Risk-Based Access Control System (ad-RACs). *Journal of Theoretical and Applied Information Technology* [En línea]. Vol. 102, n.º 3, págs. 980-1000 [consultado 2026-10-11]. Disponible en: http://www.jatit.org/volumes/Vol102No3/17Vol102No3.pdf.

AL-SHEHARI, Taher; AL-RAZGAN, Muna; ALFAKIH, Taha; ALSOWAIL, Rakan A. y PANDIARAJ, Saravanan, 2023. Insider Threat Detection Model Using Anomaly-Based Isolation Forest Algorithm. *IEEE Access*. Vol. 11, págs. 118170-118185. Disponible en: DOI: 10.1109/ACCESS.2023.3326750.

ANSARI, Meraj Farheen y ALI, Syed Sharik, 2025. AI-Driven Zero-Trust Architecture for Enhanced Cybersecurity in Dynamic Network Environments. *IJIREEICE*. Vol. 13, n.º 12. Disponible en: DOI: 10.17148/IJIREEICE.2025.131221.

ARTIOLI, Pierpaolo; MACI, Antonio y MAGRÌ, Alessio, 2024. A comprehensive investigation of clustering algorithms for User and Entity Behavior Analytics. *Frontiers in Big Data*. Vol. 7, pág. 1375818. Disponible en: DOI: 10.3389/fdata.2024.1375818.

ATLAM, Hany F. y YANG, Yifu, 2025. Enhancing Healthcare Security: A Unified RBAC and ABAC Risk-Aware Access Control Approach. *Future Internet*. Vol. 17, n.º 6, pág. 262. Disponible en: DOI: 10.3390/fi17060262.

BAGUI, Sikha S.; KHAN, Mohammad Pale; VALMYR, Chedlyne; BAGUI, Subhash C. y MINK, Dustin, 2025. Model Retraining upon Concept Drift Detection in Network Traffic Big Data. *Future Internet*. Vol. 17, n.º 8. Disponible en: DOI: 10.3390/fi17080328.

BENOVA, Lenka y HUDEC, Ladislav, 2024. Comprehensive Analysis and Evaluation of Anomalous User Activity in Web Server Logs. *Sensors*. Vol. 24, n.º 3, pág. 746. Disponible en: DOI: 10.3390/s24030746.

BOARD OF GOVERNORS OF THE FEDERAL RESERVE SYSTEM, 2026. *Market Yield on U.S. Treasury Securities at 10-Year Constant Maturity, Quoted on an Investment Basis [DGS10]* [En línea]. FRED, Federal Reserve Bank of St. Louis. [consultado 2026-10-11]. Disponible en: https://fred.stlouisfed.org/series/DGS10.

CHANDRAMOULI, Ramaswamy y BUTCHER, Zack, 2023. *A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Location Environments*. Inf. téc., NIST SP 800-207A. National Institute of Standards and Technology. Disponible en: DOI: 10.6028/NIST.SP.800-207A.

DIRECCIÓN NACIONAL DE PROTECCIÓN DE DATOS PERSONALES, 2016. *Disposición 60-E/2016. Cláusulas contractuales tipo de transferencia internacional* [Boletín Oficial de la República Argentina, n.º 33.507, 18 de noviembre de 2016]. [consultado 2026-10-07]. Disponible en: https://servicios.infoleg.gob.ar/infolegInternet/verNorma.do?id=267922.

FIELDING, Roy Thomas, 2000. *Architectural Styles and the Design of Network-based Software Architectures*. Tesis doct. University of California, Irvine.

GAMA, João; ŽLIOBAITĖ, Indrė; BIFET, Albert; PECHENIZKIY, Mykola y BOUCHACHIA, Abdelhamid, 2014. A Survey on Concept Drift Adaptation. *ACM Computing Surveys*. Vol. 46, n.º 4, 44:1-44:37. Disponible en: DOI: 10.1145/2523813.

GLÖCKLER, Jana; SEDLMEIR, Johannes; FRANK, Muriel y FRIDGEN, Gilbert, 2024. A Systematic Review of Identity and Access Management Requirements in Enterprises and Potential Contributions of Self-Sovereign Identity. *Business & Information Systems Engineering*. Vol. 66, n.º 4, págs. 421-440. Disponible en: DOI: 10.1007/s12599-023-00830-x.

HABER, Stuart y STORNETTA, W. Scott, 1991. How to Time-Stamp a Digital Document. *Journal of Cryptology*. Vol. 3, n.º 2, págs. 99-111. Disponible en: DOI: 10.1007/BF00196791.

HARIRI, Sahand; CARRASCO KIND, Matias y BRUNNER, Robert J., 2021. Extended Isolation Forest. *IEEE Transactions on Knowledge and Data Engineering*. Vol. 33, n.º 4, págs. 1479-1489. Disponible en: DOI: 10.1109/TKDE.2019.2947676.

HENDERSON, Bruce D., 1970. *The Product Portfolio* [En línea]. Boston: The Boston Consulting Group [consultado 2026-10-11]. Disponible en: https://www.bcg.com/publications/1970/strategy-the-product-portfolio.

HOCHREITER, Sepp y SCHMIDHUBER, Jürgen, 1997. Long Short-Term Memory. *Neural Computation*. Vol. 9, n.º 8, págs. 1735-1780. Disponible en: DOI: 10.1162/neco.1997.9.8.1735.

HU, Vincent C.; FERRAIOLO, David; KUHN, Rick; SCHNITZER, Adam; SANDLIN, Kenneth; MILLER, Robert y SCARFONE, Karen, 2014. *Guide to Attribute Based Access Control (ABAC) Definition and Considerations*. Inf. téc., SP 800-162. National Institute of Standards and Technology. Disponible en: DOI: 10.6028/NIST.SP.800-162.

KARANTZAS, George y PATSAKIS, Constantinos, 2021. An Empirical Assessment of Endpoint Detection and Response Systems against Advanced Persistent Threats Attack Vectors. *Journal of Cybersecurity and Privacy*. Vol. 1, n.º 3, págs. 387-421. Disponible en: DOI: 10.3390/jcp1030021.

KUHN, D. Richard; COYNE, Edward J. y WEIL, Timothy R., 2010. Adding Attributes to Role-Based Access Control. *Computer*. Vol. 43, n.º 6, págs. 79-81. Disponible en: DOI: 10.1109/MC.2010.155.

KUPPA, Aditya y LE-KHAC, Nhien-An, 2022. Learn to Adapt: Robust Drift Detection in Security Domain. *Computers & Electrical Engineering*. Vol. 102, pág. 108239. Disponible en: DOI: 10.1016/j.compeleceng.2022.108239.

LANDAUER, Max; ONDER, Sebastian; SKOPIK, Florian y WURZENBERGER, Markus, 2023. Deep learning for anomaly detection in log data: A survey. *Machine Learning with Applications*. Vol. 12, pág. 100470. Disponible en: DOI: 10.1016/j.mlwa.2023.100470.

LANDAUER, Max; SKOPIK, Florian; HÖLD, Georg y WURZENBERGER, Markus, 2022a. A User and Entity Behavior Analytics Log Data Set for Anomaly Detection in Cloud Computing. En: *2022 IEEE International Conference on Big Data (BigData)*. Disponible en: DOI: 10.1109/BigData55660.2022.10020672.

LANDAUER, Max; SKOPIK, Florian; HÖLD, Georg y WURZENBERGER, Markus, 2022b. *Cloud-based User Entity Behavior Analytics Log Data Set*. Zenodo. Disponible en: DOI: 10.5281/zenodo.7119953. Licencia CC BY 4.0.

LARMAN, Craig y BASILI, Victor R., 2003. Iterative and Incremental Development: A Brief History. *Computer*. Vol. 36, n.º 6, págs. 47-56. Disponible en: DOI: 10.1109/MC.2003.1204375.

LIU, Fei Tony; TING, Kai Ming y ZHOU, Zhi-Hua, 2008. Isolation Forest. En: *2008 Eighth IEEE International Conference on Data Mining (ICDM)*. IEEE, págs. 413-422. Disponible en: DOI: 10.1109/ICDM.2008.17.

MALHOTRA, Pankaj; RAMAKRISHNAN, Anusha; ANAND, Gaurangi; VIG, Lovekesh; AGARWAL, Puneet y SHROFF, Gautam, 2016. LSTM-based Encoder-Decoder for Multi-sensor Anomaly Detection. En: *ICML 2016 Anomaly Detection Workshop*. Disponible en: arXiv: 1607.00148.

MDZ ONLINE, 2026. *El riesgo país trepa a 650 puntos básicos, su nivel más alto en once meses* [En línea]. 2026-10-02. [consultado 2026-10-11]. Disponible en: https://www.mdzol.com/economia/2026/10/2/el-riesgo-pais-trepa-a-650-puntos-basicos-su-nivel-mas-alto-de-2026-los-bonos-argentinos-vuelven-a-c-1985298.html.

NIELSEN, Jakob, 1994. Enhancing the explanatory power of usability heuristics. En: *Proceedings of the SIGCHI Conference on Human Factors in Computing Systems*. ACM, págs. 152-158. Disponible en: DOI: 10.1145/191666.191729.

OSTERWALDER, Alexander y PIGNEUR, Yves, 2010. *Business Model Generation: A Handbook for Visionaries, Game Changers, and Challengers* [En línea]. Hoboken, NJ: John Wiley & Sons [consultado 2026-10-11]. ISBN 978-0-470-87641-1. Disponible en: https://www.wiley.com/en-us/Business+Model+Generation-p-9780470876411.

OWASP FOUNDATION, 2024. *OWASP Top 10 for LLM Applications 2025. LLM01:2025 Prompt Injection* [En línea]. OWASP GenAI Security Project. [consultado 2026-10-09]. Disponible en: https://genai.owasp.org/llmrisk/llm01-prompt-injection/.

PORTER, Michael E., 1979. How Competitive Forces Shape Strategy. *Harvard Business Review* [En línea]. Vol. 57, n.º 2, págs. 137-145 [consultado 2026-10-11]. Disponible en: https://hbr.org/1979/03/how-competitive-forces-shape-strategy.

REPÚBLICA ARGENTINA, 1974. *Ley 20.744 de Contrato de Trabajo (texto ordenado por Decreto 390/1976)* [Boletín Oficial de la República Argentina, n.º 23.003, 27 de septiembre de 1974]. [consultado 2026-10-07]. Disponible en: https://servicios.infoleg.gob.ar/infolegInternet/anexos/25000-29999/25552/texact.htm.

REPÚBLICA ARGENTINA, 2000. *Ley 25.326 de Protección de los Datos Personales* [Boletín Oficial de la República Argentina, n.º 29.517, 2 de noviembre de 2000]. [consultado 2026-10-07]. Disponible en: https://servicios.infoleg.gob.ar/infolegInternet/anexos/60000-64999/64790/texact.htm.

REPÚBLICA ARGENTINA, 2019. *Ley 27.483. Aprobación del Convenio para la Protección de las Personas con Respecto al Tratamiento Automatizado de Datos de Carácter Personal y su Protocolo Adicional* [Boletín Oficial de la República Argentina, n.º 34.025, 2 de enero de 2019]. [consultado 2026-10-07]. Disponible en: https://servicios.infoleg.gob.ar/infolegInternet/verNorma.do?id=318245.

REPÚBLICA ARGENTINA, 2022. *Ley 27.699. Aprobación del Protocolo Modificatorio del Convenio para la Protección de las Personas con Respecto al Tratamiento Automatizado de Datos de Carácter Personal* [Boletín Oficial de la República Argentina, n.º 35.058, 30 de noviembre de 2022]. [consultado 2026-10-07]. Disponible en: https://servicios.infoleg.gob.ar/infolegInternet/verNorma.do?id=375738.

RESCORLA, Eric, 2018. *The Transport Layer Security (TLS) Protocol Version 1.3*. RFC, 8446. Internet Engineering Task Force. Disponible en: DOI: 10.17487/RFC8446.

ROSE, S.; BORCHERT, O.; MITCHELL, S. y CONNELLY, S., 2020. *Zero Trust Architecture*. Inf. téc., SP 800-207. National Institute of Standards and Technology. Disponible en: DOI: 10.6028/NIST.SP.800-207.

SALERNO, Anatilde y RAMPONE, Mauricio, 2025. *Evolución de las Pymes en Argentina y su impacto en el empleo* [En línea]. Buenos Aires, 2025-12 [consultado 2026-10-20]. Informe. Universidad del CEMA, UCEMA PyMEs. Disponible en: https://cl2.ucema.edu.ar/sites/default/files/2025-12/IndicadoresPyMES122025.pdf.

SHARMA, Bimal; POKHAREL, Pradip y JOSHI, Basanta, 2020. User Behavior Analytics for Anomaly Detection Using LSTM Autoencoder — Insider Threat Detection. En: *Proceedings of the 11th International Conference on Advances in Information Technology (IAIT)*. ACM. Disponible en: DOI: 10.1145/3406601.3406610.

SHEN, Xiangmin; LI, Zhenyuan; BURLEIGH, Graham; WANG, Lingzhi y CHEN, Yan, 2024. Decoding the MITRE Engenuity ATT&CK Enterprise Evaluation: An Analysis of EDR Performance in Real-World Environments. En: *Proceedings of the ACM Asia Conference on Computer and Communications Security (ASIA CCS '24)*. Singapur: ACM. Disponible en: arXiv: 2401.15878.

STYLIOS, Ioannis; CHATZIS, Sotirios; THANOU, Olga y KOKOLAKIS, Spyros, 2023. Continuous authentication with feature-level fusion of touch gestures and keystroke dynamics to solve security and usability issues. *Computers & Security*. Vol. 132, pág. 103363. Disponible en: DOI: 10.1016/j.cose.2023.103363.

TIAN, Tian; GONG, Yiru; JIANG, Bo; LIU, Junrong; FENG, Huamin y LU, Zhigang, 2023. Insider Threat Detection Based On Heterogeneous Graph Neural Network. En: *2023 IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*. IEEE, págs. 628-635. Disponible en: DOI: 10.1109/TRUSTCOM60117.2023.00096.

VASSILEV, Apostol; OPREA, Alina; FORDYCE, Alie; ANDERSON, Hyrum; DAVIES, Xander y HAMIN, Maia, 2025. *Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations*. Inf. téc., NIST AI 100-2 E2025. National Institute of Standards and Technology. Disponible en: DOI: 10.6028/NIST.AI.100-2e2025.

VILLARREAL-VASQUEZ, M.; MODELO-HOWARD, G.; DUBE, S. y BHARGAVA, B. K., 2023. Hunting for Insider Threats Using LSTM-Based Anomaly Detection. *IEEE Transactions on Dependable and Secure Computing*. Vol. 20, n.º 1, págs. 451-462. Disponible en: DOI: 10.1109/TDSC.2021.3135639.

WEIHRICH, Heinz, 1982. The TOWS Matrix—A Tool for Situational Analysis. *Long Range Planning*. Vol. 15, n.º 2, págs. 54-66. Disponible en: DOI: 10.1016/0024-6301(82)90120-0.

WELFORD, B. P., 1962. Note on a Method for Calculating Corrected Sums of Squares and Products. *Technometrics*. Vol. 4, n.º 3, págs. 419-420. Disponible en: DOI: 10.1080/00401706.1962.10490022.

WU, Zonghan; PAN, Shirui; CHEN, Fengwen; LONG, Guodong; ZHANG, Chengqi y YU, Philip S., 2021. A Comprehensive Survey on Graph Neural Networks. *IEEE Transactions on Neural Networks and Learning Systems*. Vol. 32, n.º 1, págs. 4-24. Disponible en: DOI: 10.1109/TNNLS.2020.2978386.

XIAO, Shiyu; YE, Yuhang; KANWAL, Nadia; NEWE, Thomas y LEE, Brian, 2022. SoK: Context and Risk Aware Access Control for Zero Trust Systems. *Security and Communication Networks*. Vol. 2022, pág. 7026779. Disponible en: DOI: 10.1155/2022/7026779.

Anexo A: Cronograma de actividades

Este anexo presenta la planificación inicial del proyecto (figura A.1). El diagrama de Gantt muestra las fases, las tareas de cada una, su duración y sus dependencias, junto con los hitos del proyecto. La organización en dos incrementos que describe la sección 1.4 surge de la ejecución posterior.

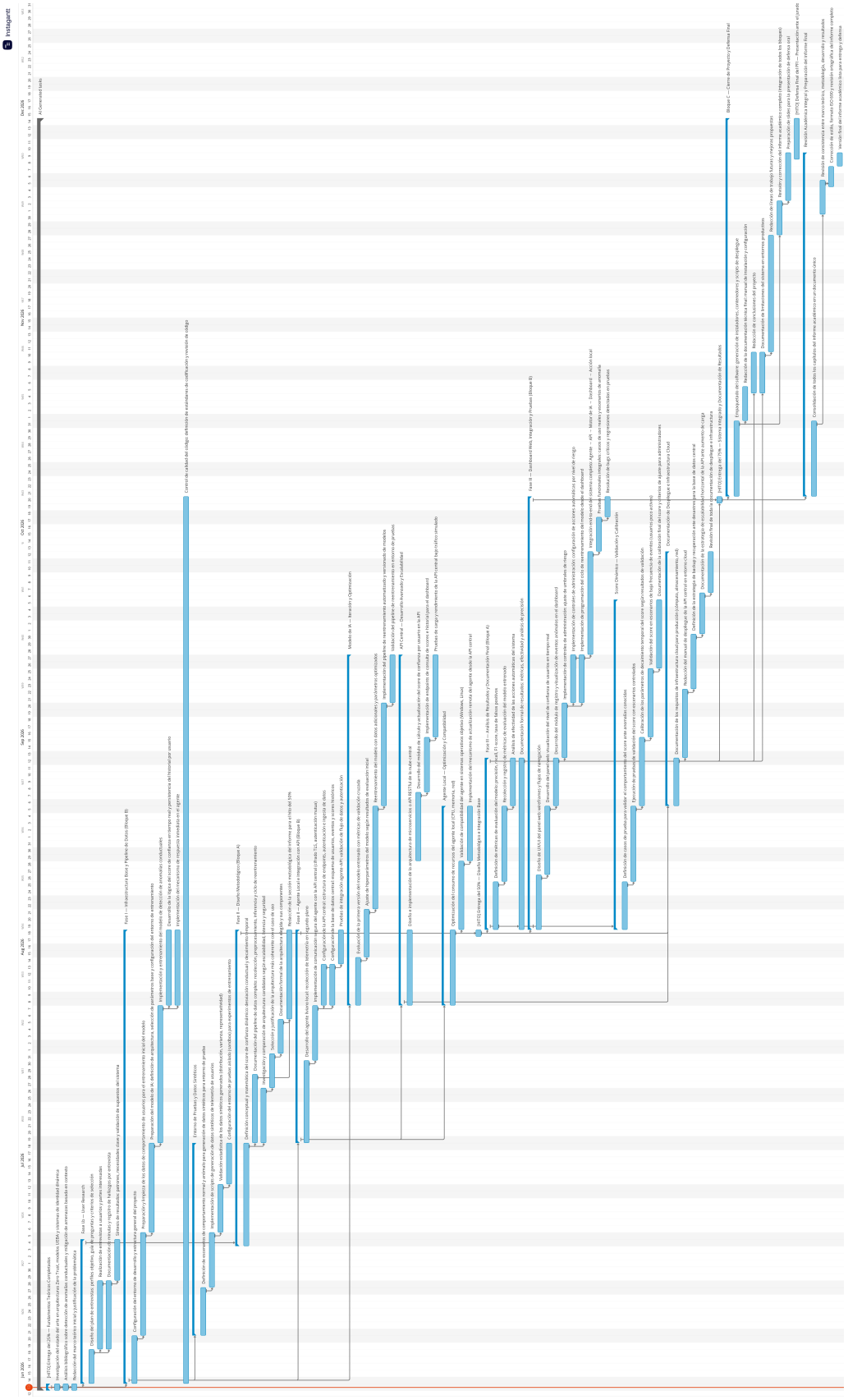


Figura A.1: Diagrama de Gantt del proyecto: planificación de hitos y distribución de tareas
Fuente: elaboración propia.

Anexo B: Resultados de la encuesta

La encuesta se elabora en Google Forms y se difunde a través de grupos de WhatsApp, por lo que la muestra es no probabilística y por conveniencia. Las figuras siguientes corresponden a los resultados de la encuesta desarrollada; el análisis completo se encuentra en la sección 3.6.



Figura B.1: ¿Usás una computadora provista por tu empresa para trabajar? (n=240)
Fuente: elaboración propia a partir de los resultados de la encuesta.

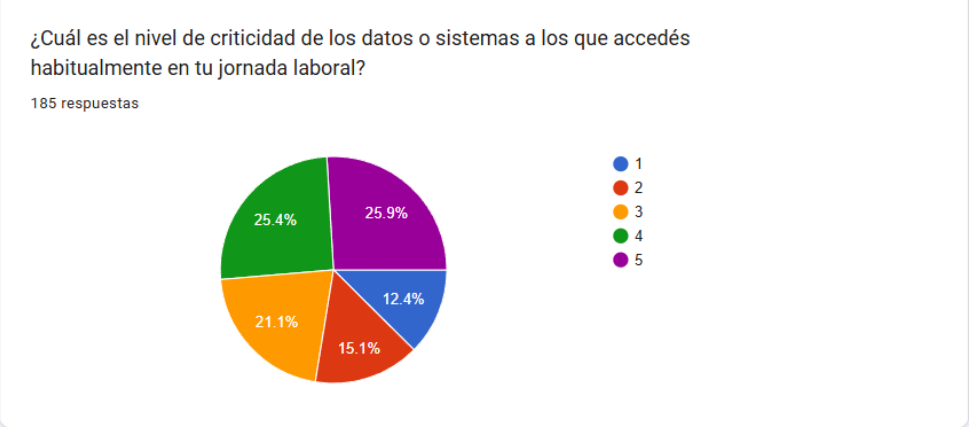


Figura B.2: Nivel de criticidad de los datos o sistemas a los que accede habitualmente (n=185)
Fuente: elaboración propia a partir de los resultados de la encuesta.

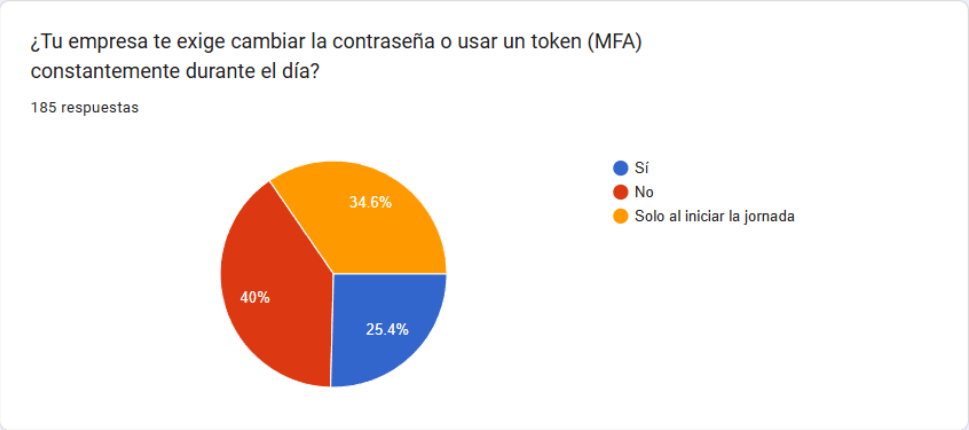


Figura B.3: ¿Tu empresa te exige cambiar la contraseña o usar un token (MFA) constantemente durante el día?

Fuente: elaboración propia a partir de los resultados de la encuesta.

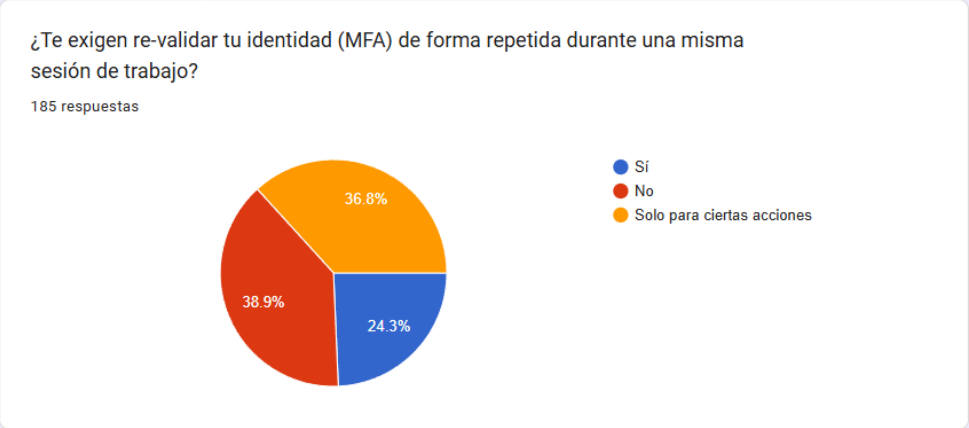


Figura B.4: ¿Te exigen re-validar tu identidad (MFA) de forma repetida durante una misma sesión?

Fuente: elaboración propia a partir de los resultados de la encuesta.

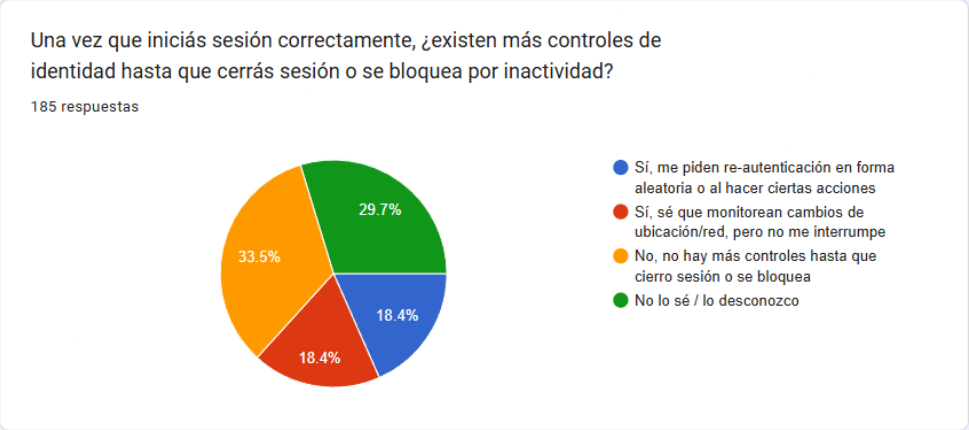


Figura B.5: Una vez iniciada sesión correctamente, ¿existen más controles de identidad hasta el cierre o bloqueo por inactividad?
Fuente: elaboración propia a partir de los resultados de la encuesta.



Figura B.6: Cuando te alejás de tu computadora, ¿qué hacés habitualmente?
Fuente: elaboración propia a partir de los resultados de la encuesta.

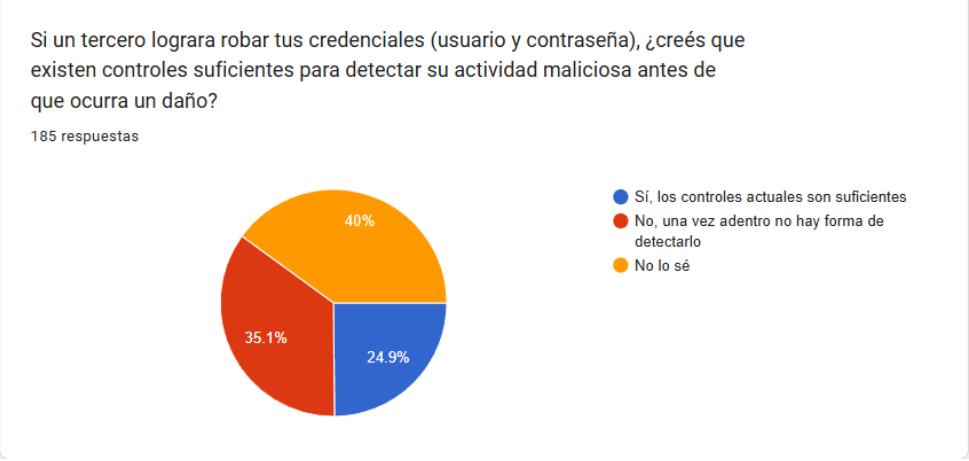


Figura B.7: Si un tercero robara tus credenciales, ¿creés que existen controles suficientes para detectar su actividad maliciosa antes de que ocurra un daño?
Fuente: elaboración propia a partir de los resultados de la encuesta.

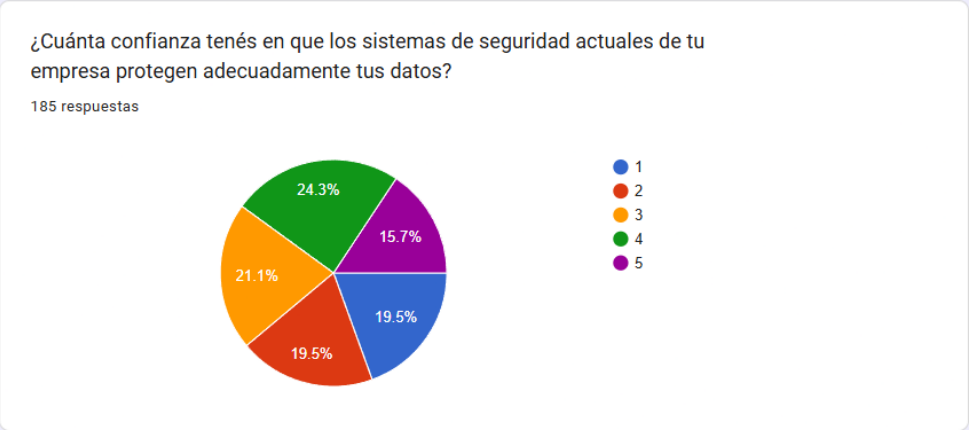


Figura B.8: ¿Cuánta confianza tenés en que los sistemas de seguridad actuales de tu empresa protegen adecuadamente tus datos?

Fuente: elaboración propia a partir de los resultados de la encuesta.



Figura B.9: Una vez superado el inicio de sesión, ¿qué tan protegido creés que está tu entorno de trabajo frente a un uso indebido de tu cuenta?

Fuente: elaboración propia a partir de los resultados de la encuesta.



Figura B.10: ¿Tu empresa cuenta con alguna política de seguridad informática que vos conozcas?
Fuente: elaboración propia a partir de los resultados de la encuesta.

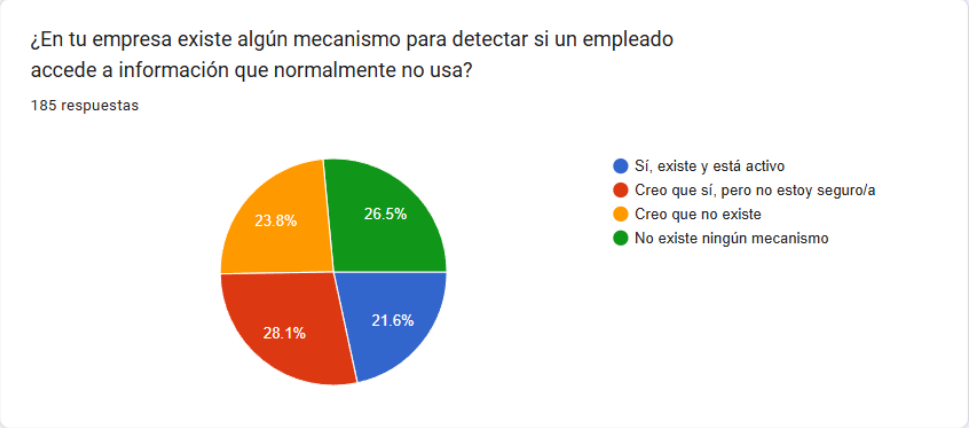


Figura B.11: ¿En tu empresa existe algún mecanismo para detectar si un empleado accede a información que normalmente no usa?
Fuente: elaboración propia a partir de los resultados de la encuesta.



Figura B.12: ¿Qué importancia le asignás a que las herramientas de seguridad actúen de forma preventiva (bloqueo) en vez de solo alertar después del incidente?
Fuente: elaboración propia a partir de los resultados de la encuesta.



Figura B.13: Ante una detección de riesgo moderado, ¿cuál de estos métodos de respuesta te parece MENOS disruptivo para tu trabajo?
Fuente: elaboración propia a partir de los resultados de la encuesta.

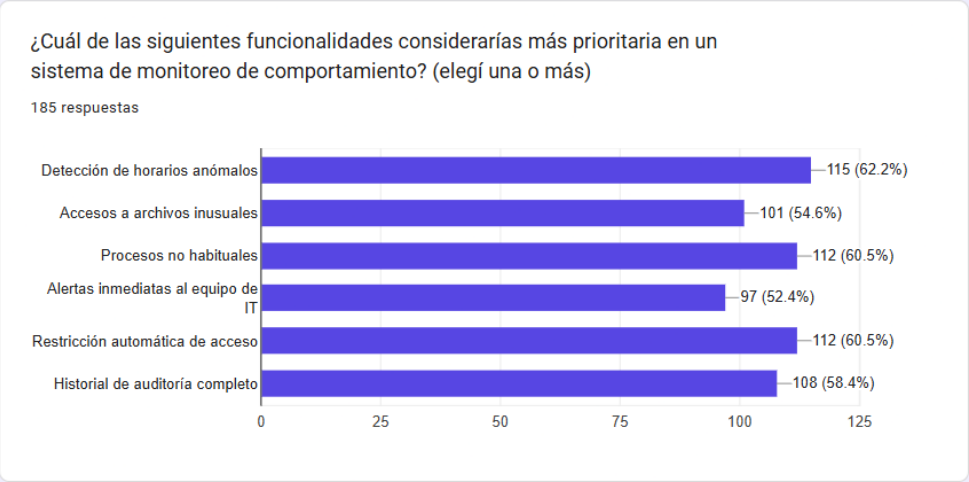


Figura B.14: ¿Cuál de las siguientes funcionalidades considerarías más prioritaria en un sistema de monitoreo de comportamiento? (elegí una o más)

Fuente: elaboración propia a partir de los resultados de la encuesta.

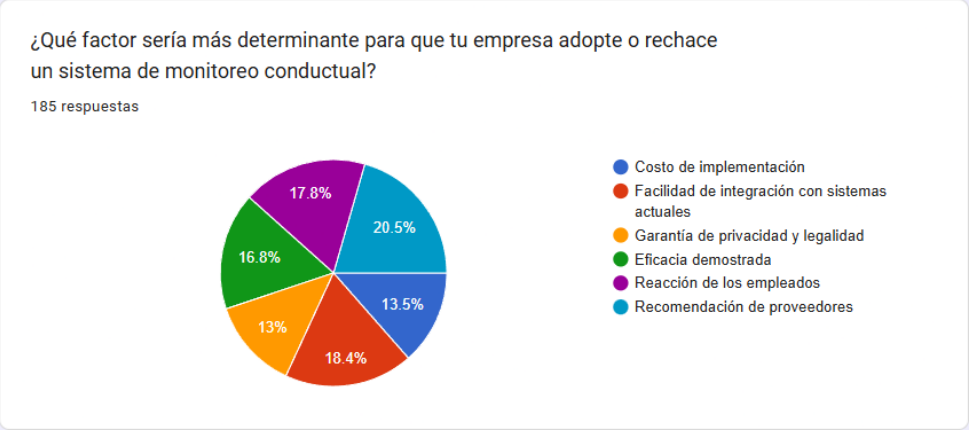


Figura B.15: ¿Qué factor sería más determinante para que tu empresa adopte o rechace un sistema de monitoreo conductual?

Fuente: elaboración propia a partir de los resultados de la encuesta.



Figura B.16: Considerando todo lo descrito, ¿qué tan probable creés que sería que tu empresa adoptara un sistema de monitoreo de este tipo?

Fuente: elaboración propia a partir de los resultados de la encuesta.

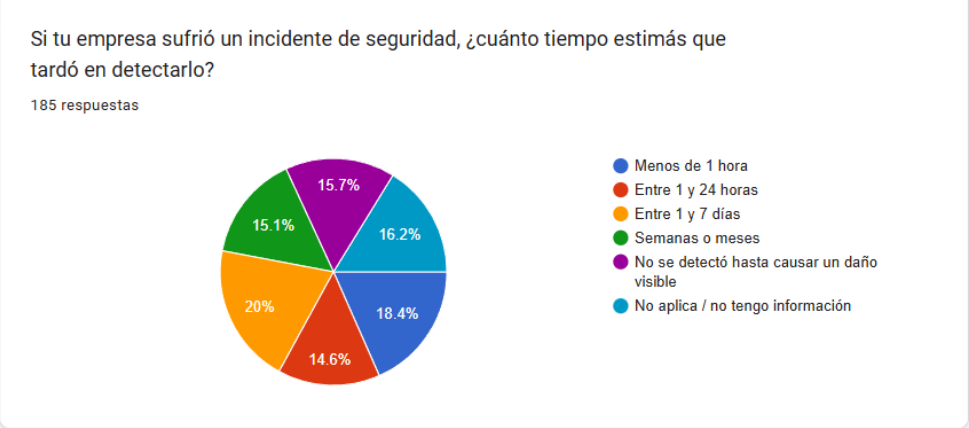


Figura B.17: Si tu empresa sufrió un incidente de seguridad, ¿cuánto tiempo estimás que tardó en detectarlo?

Fuente: elaboración propia a partir de los resultados de la encuesta.

Anexo C: Transcripción de la entrevista a Pablo Rodolfo Villarino

Entrevistado: Villarino Pablo Rodolfo (ingeniero DevOps, IBM Argentina)
Entrevistadores: Muntaabski Federico, Mociulsky Santiago

MUNTAABSKI FEDERICO: Bueno.

MOCIULSKY SANTIAGO: Genial, ahí está.

MUNTAABSKI FEDERICO: Perfecto, bien, bueno, ahora vamos a arrancar con la entrevista al profe Pablo. Vamos a arrancar con lo que sería el primer punto, que sería ¿Cómo describirías el mayor desafío de seguridad que hoy vos ves en la actualidad o que tuviste en tus organizaciones o empresas en las que trabajaste?

VILLARINO PABLO RODOLFO: Perfecto. Bueno, primero contarles que actualmente me desempeño como ingeniero DevOps en IBM Argentina para los clientes de IBM Argentina. Yo trabajo aquí hace más o menos unos 14 años y me he movido por diferentes roles dentro de la compañía. Puntualmente, este rol dentro del mundo DevOps, el ingeniero DevOps se caracteriza por ser un rol donde nosotros tenemos que integrar un montón de software para armar plataformas de automatización que le permitan a los proyectos de software poder. Bueno, como ustedes sabrán, poder confeccionar diferentes partes de aplicaciones o software, testear esos códigos, promulgarlos a otros ambientes de ejecución y todo eso habitualmente no se hace con un único software, sino que se integran herramientas. Tomando un poco tu pregunta, Federico, yo creo, y desde el lugar donde estoy trabajando actualmente, creo que uno de los puntos más o los desafíos más importantes en la seguridad es que justamente esa integración de herramientas diferentes que tienen y siguen estándares. Diferentes de desarrollo pueda ser realmente segura. Lo que lo que ocurre habitualmente es que podemos integrar. Podemos hacer que esas herramientas se vean entre sí, pero muchas veces esas herramientas son on premise, están dentro de nuestra red. o a veces dentro de la red de los clientes o muchas veces son, vamos a decir, plataformas online, es decir, las plataformas cloud como pueden ser GitLab o GitHub. Y ahí empiezan necesariamente que aparecer métodos en los cuales vamos a tener que integrar esas herramientas. Pero a la vez, segurizar las comunicaciones entre las diferentes piezas de la misma plataforma, ¿no? Y entonces eso es un desafío porque... no todas las herramientas son compatibles con todas las técnicas de segurización de datos y muchas veces hay que hacer un poco de tuneo para que esa integración realmente sea segura en este tipo de proyectos DevOps y DevSecOps. El problema es que... si nosotros no segurizamos correctamente ese ensamblaje de herramientas, esa integración, bueno, empiezan a aparecer superficies de ataque en cada unión. Es como si tuvieras una sábana toda llena de parches por todos lados y eso no está bien cocido. El día que en esta parte fuerte rompiste

todo, ¿no? Entonces acá pasa un poco eso, hay muchas integraciones, de acuerdo al proyecto podemos tener 20, 25 herramientas diferentes y si eso no está bien integrado y bien segurizado, es un lío. Así que en mi expertise creo que ese es uno de los grandes desafíos, el primero por lo menos.

MOCIULSKY SANTIAGO: Sí, bueno, yo te quería consultar también si en uno de estos problemas ves involucrado la actividad del usuario. O sea, si como repregunta lo primero, si alguno de estos principales problemas es alguna interacción o algún factor en el que puede intervenir los usuarios que usan el software en el día a día.

VILLARINO PABLO RODOLFO: Bueno, acá en mi especialidad en particular, quien va a usar esta plataforma para poder desarrollar aplicaciones, testearlas, etcétera. Básicamente son usuarios con expertise técnico informático, es decir, no es el típico usuario final el que va a usar. El software completando ventanas o campos, sino que son otros ingenieros, licenciados o licenciadas que conocen del mundo IT que se encargan de una parte del ciclo de desarrollo de software. Entonces, no sé, por ejemplo, los ingenieros DevOps nos encargamos de hacer todo ese ensamblaje de herramientas de software. y de mantenerlas, pero después van a venir los … y solo van a utilizar las herramientas de testeo o van a venir los especialistas en observabilidad y monitoreo que solo van a utilizar las herramientas de observabilidad y monitoreo. Entonces, si tomo tu pregunta, Santiago, para mí usuarios es esa persona que va a usar una parte de esta plataforma de integración … y es ese perfil, esa persona, es una persona que sabe del mundo de tecnología, ¿no? Entonces, si la integración. Y las herramientas que usamos como integración. ¿Están correctamente configuradas? Cada una de estas herramientas permite lo que se llama segregación de usuarios, es decir, cada una de las herramientas le va a otorgar un rol a cada usuario. Y ese rol solo va a tener los permisos únicos y necesarios Para las acciones que debe hacer ese usuario, no. Sobre todo en plataformas cloud, los usuarios dentro de un mismo proyecto van a tener un usuario y una password que solo les va a permitir y autorizar a hacer una limitada cantidad de acciones, ¿no? Y esa, como ustedes sabrán, también esas acciones van a ser. trazables dentro de la plataforma, es decir, la misma plataforma, en este caso GitHub, que es una parte de esta gran plataforma de …, va a poder dejar documentado quién se logueó, qué acciones hizo, en qué momento, etcétera, etcétera. Entonces. Es un desafío, sí, de alguna manera seguir, conocer a los usuarios, pero estos usuarios no son inexpertos, no saben que están tocando, sino que son usuarios calificados y como usuarios calificados desde el punto de vista de la seguridad son más riesgosos también porque… siempre está la curiosidad, no de este tipo de usuarios. Entonces, sus acciones son muy limitadas dentro de cada herramienta que deben usar. Sí, salvo que uno utiliza alguna herramienta open source que es totalmente abierta. Es muy raro en el mundo DevOps, pero la mayoría todas. Son capaces de segregar usuarios y trazar su actividad. Entonces los tenemos como bien acotados, no van a poder, por decir así, desintegrar. 23 herramientas, las

configuraciones pasan por otro tipo de roles que no se les asignan a ellos.

MUNTAABSKI FEDERICO: Bárbaro. Bueno, seguimos con la siguiente pregunta, que sería vos en tu rol de DevOps, vos, ¿qué tipo de incidentes de seguridad son los que más tienen presencia o que vos sentís que ¿Que aparecen más?

VILLARINO PABLO RODOLFO: Claro, es una buena pregunta. En los proyectos donde estoy ahora son proyectos relativamente medianos y grandes, con lo cual ya hay un equipo más pequeñito que justamente son los ingenieros DevSecOps. Específicamente se dedican a la segurización de toda esta plataforma de herramientas integradas que les comento para que tengan una idea por cada proyecto IBM consensúa con su cliente. ¿Cuál va a ser el stack tecnológico? Es decir, hacen como una listita. De las herramientas que van a ser utilizadas en esa plataforma para sus proyectos DevOps en común. Entonces podemos tener cuatro o 5 clientes diferentes y tener plataformas diferentes, no con herramientas que se van integrando de manera diferente. entonces. Que. Hay una diversidad de herramientas y la segurización específica de estas plataformas está encargada a este grupo de DevSecOps. Ahora, lo que yo veo que habitualmente ocurre, o mejor dicho, se intenta de remediar Y probar antes de que ocurra son lo que se llaman denegaciones de servicio, porque IBM trabaja con varias nubes. IBM tiene su propia cloud, que es muy chiquitita, muy específica. IBM Cloud se llama, no es muy conocida, pero está abocada a ciertas empresas. Pero todas estas plataformas que les comento utilizan AWS, utilizan Google, utilizan Azure como proveedoras cloud más conocidas. Incluso hay un proyecto que tenemos donde están integradas las tres nubes, no todos los servicios de las tres nubes. Pero el cliente utiliza la base de datos en una nube, los servidores en otro, las APIs en otra. Bueno, entonces ese tipo de diagramas que está bueno, es interesante ver y les trae un poco de dolor de cabeza a los DevSecOps, a los … DevSecOps. porque… tienen muchos puntos de ataque y todos aquellos que son sí, sobre todo lo que se llaman. Api Gateway, no que por ejemplo en AWS son puntos donde se abre de alguna manera un puerto para que la información de esa infraestructura dentro de la nube salga por ese puerto, ¿no? Bueno, todo esto ese tráfico que sale y que entra necesita ser escaneado, analizado. Y también ese puerto que está abierto y que se usa para transaccionar. Muchas veces es una superficie de ataque donde desde afuera, bueno, se puede intentar alguna denegación de servicio, algún otro, alguna otra técnica. No, entonces es mi. En mi día a día lo que yo veo son más denegaciones de servicio. Directamente a esta plataforma pasó muy poco, pero sí a algún proveedor de esta plataforma. Nosotros usamos, como les digo, tres nubes, son proveedores externos a esta plataforma. alguno de los de las herramientas de esta plataforma están hosteadas en servidores … del cliente de IBM y otras son directamente plataformas como como les decía recién GitHub, GitLab. Entonces lo que puedo, lo que habitualmente ocurre no muy seguido, pero que por ejemplo se indisponibiliza la consola de GitLab y entonces no se pueden lanzar pipelines. Bueno, no es un problema directo de IBM y de sus herramientas, sino más bien que

estamos consumiendo los servicios de GitLab y de pronto, bueno, indisponibilizaron la consola a través de denegación de servicios. No, eso sí ocurre, no muy seguido, pero ocurre. ¿Cómo es decir, como la pregunta iba a una técnica de? Vamos a decir así de seguridad y les pongo un ejemplo. A veces otras cosas que ocurren es que, por ejemplo, no sé, algún servicio de AWS está caído o la región donde tenemos los servicios, bueno, no está funcionando. Ok, eso no sería un ataque propiamente, pero bueno, tenemos inconvenientes para poder hacer funcionar toda la plataforma de DevOps, ¿no? Pero el ataque más conocido de negación de servicio.

MUNTAABSKI FEDERICO: Claro. Perfecto, bueno, pasamos a la siguiente pregunta. Una vez que. que vos planteas esto de que usan un entorno, o sea en tu trabajo usas un entorno de múltiples nubes o que usas diferentes servicios, como mencionaste, Git DevOps o GitLab, no me acuerdo bien cual era...

VILLARINO PABLO RODOLFO: Correcto, GitLab, sí.

MUNTAABSKI FEDERICO: ¿Qué forma tienen ustedes de visibilidad del equipo de trabajo? O sea, ¿cómo ustedes aseguran de que el grupo de trabajo o los usuarios que están trabajando en los proyectos ¿Puedan ustedes controlar los procesos, qué herramientas, o sea, cómo se guían con eso?

VILLARINO PABLO RODOLFO: Bueno. Aquí nosotros usamos, mi equipo, los ingenieros DevOps, pero también hay un equipo en particular que es el equipo de observabilidad, así le llamamos. Tenemos dos tipos de herramientas, digamos, usamos por un lado, Hacemos lo que se llama una herramienta que usamos, por ejemplo, Grafana. Es una de las herramientas que utilizamos para crear dashboard a partir de datos que se censan en diferentes equipos de las diferentes herramientas que conforman la plataforma, no por ejemplo. Como les decía, GitLab, nosotros no lo tenemos instalado … dentro de uno de los clientes, sino que usamos directamente su servicio cloud. Entonces nosotros a través de Grafana miramos una como si fuera una pantalla de check que tiene GitLab para ver que sus servicios estén. Todos levantados, es como si fuera un HTML donde vos tenés en verde todos los servicios fundamentales de GitLab. Eso es lo que tienen habitualmente las plataformas cloud, que te muestran su estado de funcionamiento. Las nubes también lo tienen. Pero cuando usamos una herramienta que tenemos instalada en algún servidor on-premise, sea del cliente o sea de IBM. Nosotros tenemos un agente. Grafana en sí trabaja con otro tipo de bases de datos más este, digamos, no relacionales, como puede ser Elasticsearch o como puede ser Prometheus. Entonces, a esas bases donde se junta y se acopian datos, se le integran. Pequeños agentes, como podrían ser los agentes de … y esos pequeños agentes instalados en los servidores donde se realizan las acciones de los usuarios, nos ayudan a recolectar datos. Esos agentes, bueno. No son, no son agentes de IA agéntica, pero básicamente son como si fueran aplicaciones, muchas en Java, muchas en Python, que van a ir tomando los

datos de diferentes variables de entorno de el sistema operativo donde vos lo instales, ¿no? Hay muchas plataformas de observabilidad que tienen este tipo de agéntica, porque no sé, la más emblemática, ya tiene como 30 años, es nagios. Entonces, vos gracias a ese agente que le reporta a tu servidor central, tenés los consumos de recursos, las transacciones que ocurren allí. puedes monitorear alguna carpeta, algún archivo específico en orden a esto que charlábamos recién, si hay algún cambio, alguna modificación. Bueno, volviendo a tu pregunta, nosotros lo que tenemos es una herramienta de observabilidad que en su primera capa, en la capa vamos a decir así gráfica, Es grafana. Esa es la herramienta que me que nos permite crear gráficos. Y después en su capa backend, bueno, vamos a tener una serie de servidores que van a recibir la información de diferentes agentes y esos agentes, luego de reportar la información, las vamos a guardar en una base. Habitualmente una base llamada Prometheus, que es una base no relacional que le permite a Grafana mirar esos datos y armar gráficos con esos datos. no? Entonces yo sé que hay 20 usuarios conectados en el servidor en el servidor A. porque hay un agente en el servidor que está reportando. Bueno, qué se está haciendo ahí, cuántos usuarios hay, qué cantidad de memoria de almacenamiento se está utilizando, qué archivos están escribiendo, etcétera. No son herramientas específicamente de seguridad, pero las usamos. Para hacer lo que se llama observabilidad, que justamente es eso, no observar qué es lo que se hace ahí, no y de qué manera, etcétera. Entonces nosotros usamos eso. Después el equipo de DevSecOps, es decir, los ingenieros de seguridad para este mismo proyecto, tienen otras herramientas un poco más sofisticadas como para ver si uno de esos usuarios no quiso acceder a una carpeta que no le correspondía, por ejemplo.

MUNTAABSKI FEDERICO: Claro, entiendo.

MOCIULSKY SANTIAGO: Ok te puedo hacer una pregunta con respecto a esto en lo que vos nombraste lo más en el entorno … lo de los múltiples agentes. Eso como output daría la información de la actividad que estuvieron haciendo on premise. Pero cómo se procede después. O sea, cómo sería el paso a paso que se hace

VILLARINO PABLO RODOLFO: sí. Sí.

MOCIULSKY SANTIAGO: Después de que llega esa información, se actúa al momento o se actúa, cuánto se tarda en resolver ese problema.

VILLARINO PABLO RODOLFO: Bien. Perfecto, es decir, una cosa es la recolección. De hecho, la observabilidad desde el punto de vista de infraestructura implica que vos puedas ver, ¿no? Entonces, esto que les cuento es, ni más ni menos, la posibilidad de poder ver en tiempo real lo que está sucediendo. Eso es lo que te permite Grafana con Prometheus y, por ejemplo, los agentes de… Entonces vos tenés que esos agentes le reportan un server central. Ese server central manda los datos a la base de datos que va creciendo porque es no relacional y Grafana, de acuerdo

a diferentes vamos a decir query del tipo JSON, etcétera, vos podés armar gráficos con grafana. Entonces en tiempo real vos ves qué es lo que ocurre. Ahora, todo esto que te estoy contando no fue pensado originalmente para hacer seguridad, sino para hacer observabilidad. Así todo, con este tipo de Mirada observabilidad, nosotros podemos detectar que de pronto hay un usuario que está queriendo acceder a una carpeta que no le corresponde. Y entonces en mi dashboard de Grafana me empiezan a aparecer mucho registro o qué sé yo, no sé, como si yo les dijera permission denied. Sin muchos registros de tal usuario que tienen esta notificación en particular, no … en ese caso nosotros. Y acá viene un poco la salvedad, reportaríamos el problema al equipo de seguridad. Nosotros como ingenieros DevOps en un proyecto de nuevo grande, como es este que, como son estos que les estoy contando, no accionamos directamente en lo que es, no sé, limitarle los Permisos a este usuario. Porque nuestro scope de trabajo es la seguridad en la plataforma. Es decir, si alguien, si un usuario me estuviera queriendo cambiar la configuración de integración entre 2 herramientas, ahí sí nosotros podemos de alguna manera desactivar ese usuario. Lo desactivamos de esa plataforma, sí le cortamos la sesión y que eso sería una acción de remediación inmediata más afín a mi rol. Ahora, si ese usuario está queriendo escribir una carpeta que no le corresponde, bueno, nosotros en este tipo de proyectos no entraríamos tanto en juego. Pero sí podríamos reportarlo al equipo de DevSecOps de seguridad y ahí habitualmente, bueno, sí, hay algún tipo de aviso, generalmente Y. Si el usuario, ya les digo, son usuarios administradores, es decir, o son usuarios que tienen expertise técnico. Entonces, en la terminal donde está queriendo hacer esa acción, suele aparecerle algún tipo de cartel, no como para que sepa que está haciendo una acción que no está permitida y ellos tienen. Herramientas donde ese mismo usuario se va, se va copiando de ese usuario las diferentes acciones con prohibiciones. No, por ejemplo, quiere ejecutar, no sé, la sentencia sudo o el comando sudo en un terminal donde no está permitido. Bueno. Los ingenieros de DevSecOps tienen herramientas que le reportan a los gerentes directos de ese usuario que está queriendo hacer una acción ilegal todas esas acciones que efectivamente no debe poder hacer, no entonces. En este punto podría averiguarles si hay en tiempo real algo que ellos hagan en relación a un usuario que ya está en el sistema, distinto a que vos me digas, encontraron un proceso que nadie sabe de qué software es. Eso es otro digamos ¿Otra acción, no? Yo sé que en este caso sí, los ingenieros de DevSecOps para este tipo de proyectos tienen la potestad de matar ese proceso, lo destruyen, hacen un kill de ese proceso y se acabó ese proceso. ¿Por qué? Porque no pertenece a un catálogo. No sabemos de dónde salió ese proceso, podría ser un malware. Pero referido a un usuario. Sé que le dan aviso, sé que le avisan al gerente directo, no sé si hacen algo más, yo entiendo que no, porque ese usuario está identificado, se conoce quién es, etcétera. Entonces, en tiempo real, volviendo a la pregunta de Santiago, en tiempo real, yo como ingeniero DevOps no hago nada, si no es básicamente una Sí, un ataque, por decir así, a la integración de 2 herramientas dentro de una misma plataforma. En el caso de que veamos otra cosa, se lo reportamos al equipo de seguridad que él tiene. Ellos

tienen más herramientas, incluso para hacer escaneo de tráfico o escaneo de ciertas acciones. Dentro de un mismo ser.

MUNTAABSKI FEDERICO: Claro, entiendo. Perfecto. Bueno, paso a la siguiente pregunta que es, o sea con lo que mencionaste, la observabilidad. O sea que tu área o el área en el que estás vos se dedica a lo que es O tienen herramientas que permiten observar el comportamiento. Pero como que la parte de la seguridad la delegan a otro área.

VILLARINO PABLO RODOLFO: Claro, la seguridad referida a la acción de los usuarios, la seguridad en cuanto a la integración de herramientas si la manejamos nosotros, pero ahí no hay otros usuarios que no seamos nosotros. Si yo tengo que unir Jenkins, que es una herramienta de despliegue con un ambiente de un servidor que está

MUNTAABSKI FEDERICO: . . . Claro.

VILLARINO PABLO RODOLFO: . . . yo hago la integración y hago que esa integración sea segura habilitándole, bueno, secrets, encriptación de datos en esa integración para que las 2 plataformas se vean entre sí. Eso lo hago yo ahora. Yo lo que cuido o mi equipo lo que cuida es la seguridad de la plataforma y de esas integraciones. Sí, ¿qué pasa dentro de cada una de esas plataformas? Ahí es donde de alguna manera tenemos divididos los roles con los ingenieros DevSecOps.

MOCIULSKY SANTIAGO: Y entonces volviendo un poco desde que ustedes hacen una petición o sea ven algo y lo reportan a seguridad al área de ciberseguridad ¿Cuánto tarda en darle un feedback o solucionar ese problema que se está teniendo aproximadamente de tu experiencia?

VILLARINO PABLO RODOLFO: Sí. Y buena pregunta. Mira, nosotros ahora en este proyecto que tengo en la mente que les estoy contando. Ya no tenemos software de tickets, sino que nos manejamos con una metodología . . . muy parecida a Scrum, aunque no somos desarrolladores y utilizamos una herramienta que se llama Jira. Capaz que la conocen. Jira es como una herramienta donde vos. Las más diferentes peticiones. En forma de tarjetas y esas tarjetas van cambiando de estado en la medida en que los equipos de trabajo van tomando y trabajando sobre esos temas. Si yo te dijera un tiempo y ponele, calculale, voy a ser exagerado, pero calculale. En una, no sé, un tema que podría tener una severidad o no sé, una severidad media, quizás 2 días hábiles. Lo que tiene . . . como herramienta y en el cliente donde estoy trabajando, en el cliente de IBM, no está demasiado maduro esta parte, este procedimiento, con lo cual. A veces las tarjetas no siguen un tiempo determinado. No es que todas se cierran a los 3 días hábiles, 4 días hábiles. No está muy automatizado eso. Jira es muy flexible, entonces dependemos mucho de. . . bueno, de que responda otro el otro equipo, que el otro equipo no tenga prioridades más

altas, pero bueno, si quieren un número, pongámosle así, 2 días hábiles en recibir una respuesta del equipo de seguridad.

MOCIULSKY SANTIAGO: Okay. Y no hace ninguna acción intermedia como para mitigar el problema. Volvamos un poco más orientado a nuestro problema. Estamos tratando de ver. Por ejemplo, un usuario que tiene permisos hace actividad sospechosa. Ustedes lo ven por el sistema de observabilidad. No hace ninguna acción inmediata o

VILLARINO PABLO RODOLFO: Sí.

MOCIULSKY SANTIAGO: Temprana para tratar de mitigar ese problema o tienen que esperar hasta esos 2 días.

VILLARINO PABLO RODOLFO: Claro, nosotros como ingenieros DevOps no hacemos ningún inconveniente, ¿no? Lo que sí podemos hacer es crear una tarjeta sí con una severidad alta, reportando ese inconveniente en el servidor que lo vimos, pero tampoco nosotros somos el canal uno o la mesa de ayuda tecnológica, no , sino que somos un equipo.

MOCIULSKY SANTIAGO: Hmm.

VILLARINO PABLO RODOLFO: Uno de tantos de los que trabaja en el proyecto, que con una de sus herramientas que sirve para otra cosa, detectó un comportamiento anómalo. Está bien, ese sería como el escenario. Entonces, sí, si fuera una tarjeta de carácter urgente o crítica, quizás. En … horas, bueno, el equipo de seguridad se puso a mirar el tema. No creo, primero que nunca no pasó, pero no creo que sea mucho más rápido porque para que se den una idea, los ingenieros DevOps son los especialistas en seguridad. para los proyectos DevOps, pero no son los únicos que hacen seguridad para la compañía o para el cliente de IBM, sino que después están los equipos de seguridad estándar, seguridad de usuario, seguridad de red, ¿no? Entonces imagínense que todos esos están permanentemente mirando los comportamiento de toda la red, sí, del cliente. Entonces lo más probable es que este tema de usuarios en particular salga o lo detecten bueno seguridad de usuarios y perfiles por ejemplo con sus propias herramientas que son herramientas específicas para ver qué hacen los usuarios en la red. Sí, me explico. Es decir, el problema que estamos analizando puede darse en una infraestructura DevOps, pero luego se va a ir corriendo como problema a los equipos que naturalmente lo van a tener que resolver.

MOCIULSKY SANTIAGO: Sí.

VILLARINO PABLO RODOLFO: Que son los equipos tradicionales de seguridad.

VILLARINO PABLO RODOLFO: Por eso los tiempos que yo te puedo decir son, pero 3 horas para resolver un problema de seguridad, tienen un agujero por todos lados. Claro,

porque son tiempos de problemas que no son los naturales a nuestro, básicamente a nuestro expertise, diferente a que yo tuviera un problema de... Integración de una herramienta, yo veo que integración de una herramienta directamente se perdió la integración o yo veo que la en la integración de una herramienta con una nube hay un montón de request permanentemente request. y entonces ahí sí nosotros salimos a investigar qué pasa porque no se está tirando ningún deploy a AWS pero de … tengo 50, 70 request por segundo. Para algo pasa acá. Ahí sí nos ponemos a analizar qué está sucediendo y bueno ahí puede haber, puede haber algún malware. ¿Puede haber algún tipo de actividad anómala, pero ya no es un usuario, no?

MUNTAABSKI FEDERICO: Genial, bueno, ahora pasamos a otra pregunta.

MUNTAABSKI FEDERICO: Vos, teniendo en cuenta las herramientas que mencionaste, Jenkins, Grafana, también esta metodología de trabajo con Jira y todo esto. Si vos pudieses, por ejemplo, proponer alguna mejora para este sistema. O cómo lo cambiarías para que a vos se te facilite más el trabajo de, por lo menos la observabilidad, de sentir que uno puede tomar más acciones o que se tiene que preocupar por menos cosas.

VILLARINO PABLO RODOLFO: Bien, buena pregunta. Sí, a ver. Acá la respuesta que te puedo dar es la siguiente. Dentro de lo que hace mi equipo, que como les digo, los objetivos del ingeniero DevOps es sostener. Es decir, darle mantenimiento a cada una de las herramientas del ciclo de vida DevOps, no herramientas de despliegue, herramientas de creación de imágenes, de testeo, etcétera. Ese es nuestro trabajo. Y la integración de esas herramientas para que todos trabajen en equipo. La seguridad de esas herramientas ya está como salvaguardada dentro de las acciones que realizamos, ¿no? Si yo tuviera que dar o pedir una mejora, podrían ser 2 caminos, o pido una mejora de una incluir una herramienta nueva. Porque vamos a tener nuevas, nuevas tareas relacionadas más con la seguridad. Entonces ahí yo buscaría algún tipo de herramienta para poder ponerle escanear el tráfico en nuestra plataforma. Eso podría ser una alternativa. Podríamos nosotros hoy en día no tenemos permiso para usar ni nmap ni Wireshark. Pero podría ser una alternativa, pero sería como adicionar a mi equipo tareas que actualmente no las tenemos definidas. Es decir, ¿quién escanea la red en este cliente donde trabajo? Bueno, la escanea seguridad de redes. Es decir, ellos son los que hacen esa tarea. Y. En mi equipo en particular, digamos, actualmente tenemos las herramientas adecuadas para hacer lo que está estipulado que nosotros hagamos. Yo lo que podría pedir sería una mejora de esas herramientas. No sé, en vez de usar, qué sé yo, Jenkins, que es una herramienta open source que no tenés una empresa que está detrás dándote soporte, quizás la cambiaría por no sé, GitHub. Action o GitLab, donde la plataforma y la empresa que está atrás es mucho más potente que el grupo de desarrolladores de Jenkins. No decir se nos desconfigura Jenkins y tenemos que salir a investigar a ver qué se tocó y cómo remediarlo, porque es open source, no. Entonces yo haría eso. cambiaría a un, por

supuesto, la empresa utiliza herramientas open source porque no tienen una licencia paga, se ahorran mucho dinero por eso, ¿no? Yo haría ese tipo de cambios. Cambiaría una herramienta por otra para mejorar nuestro trabajo. Desde el punto de vista de la seguridad, nosotros lo único que integramos es una herramienta que se llama... Es una herramienta específica para validar. Bueno, nos permite hacer ciertos testeos. ... también nos permite hacer ciertos testeos de imágenes, etcétera. No hacemos escaneos de imágenes de containers, por ejemplo, pero bueno, es una herramienta que nos facilita los testeos. No, entonces ahí tenés otra otra acción que realiza mi equipo relacionada con la seguridad en un proyecto. Pero los cambios de herramientas serían esos. Esos serían las mejoras que podría utilizar. No saldría a pedir una herramienta específicamente de seguridad porque está fuera de... ¿Diferente a que yo trabajar en un equipo de DevSecOps y ahí mi ciento por ciento mi día sería hacer seguridad en muchas capas, no? En este caso no, yo hago algunas cosas de seguridad, algunas. Puedo conocer más, pero solo algunas por mi rol.

VILLARINO PABLO RODOLFO: No sé si te respondí.

MOCIULSKY SANTIAGO: sí se entendió perfecto.

MUNTAABSKI FEDERICO: sí, entonces es perfecto.

VILLARINO PABLO RODOLFO: Okay.

MOCIULSKY SANTIAGO: Ahora te quería consultar más relacionado a ustedes en el acceso diario a los sistemas que tienen, cómo es el tema del control de acceso a identidades en su día a día trabajando en datos confidenciales, en la nube, aplicaciones que son críticas, etcétera.

VILLARINO PABLO RODOLFO: Sí. Perfecto, y si eso que vos preguntas, Santiago, es re importante, es re importante tanto para mi empleador, IBM, como para su cliente. De hecho, antes de que comenzara este proyecto, esas 2 empresas firman un acuerdo y un contrato. En particular, donde los empleados de ambas compañías que van a. Estar trabajando dentro de este proyecto. Van a cumplir ciertos procesos para asegurar que la información no se filtre. Entonces, desde haber firmado un acuerdo de confidencialidad, es decir, yo tuve que firmar para este para este contrato puntualmente un acuerdo de confidencialidad donde. Mi empleador, pero de alguna manera mi persona se hace responsable de la información del cliente que pasa por mi computadora, por mis manos. Entonces yo estoy penalizado desde lo laboral o desde lo penal. Si de pronto filtro datos, no filtro datos del cliente, no en particular es un cliente financiero. Entonces ahí es como que está más. Más como auditado todo, ¿no? Entonces, primero eso, desde lo legal, todos los que formamos parte de este proyecto tenemos un acuerdo de confianza y confidencialidad con nuestro empleador y mi empleador con su cliente. Eso primera idea, con penalidades, etcétera. Segunda idea, la computadora que nosotros utilizamos. Sí, la que nos da, en este caso, el cliente. Si nosotros tenemos una de IBM, pero a partir de este proyecto tenemos

una computadora específica para trabajar para este cliente. Esa computadora es lo que a mí me gusta decirle, es un dispositivo totalmente bobo, bobo en el sentido que no le puedes conectar nada. De hecho, si yo se las muestro, es una Lenovo, está buenísima y tiene mil puertos y no se conecta a ningún puerto, están todos los puertos limitados y su conexión solamente se da a través de esto. Esto que ustedes ven aquí es un dispositivo 3G, tiene un chip adentro, como si fuera un USB Y adentro tiene un chip Movistar y entonces la computadora tiene acceso a la red ni Internet a la red a través de este dispositivo. Es un módem. Sin este dispositivo la computadora tiene una imagen en su sistema operativo que no te permite usar ningún puerto, ni tarjeta de red ethernet, ni tarjeta Wi-Fi, no te funciona nada. Vos prendes todo y no detecta nada. Tiene todo filtrado salvo cuando le pones este este módem 3g y ahí directamente se conecta vía 3g a través de un chip Movistar a la red del banco. Y entonces ahí empieza a pedir información usuario password y token del Cliente de este cliente IBM, que es un banco, es lo primero que te pide. Una vez que te pidió de eso, encripta la levanta una VPN, encripta la comunicación entre este equipo y los servidores de... del banco y ahí recién, digamos, está segura la conexión entre mi dispositivo, esté donde esté en el globo terráqueo y los servidores del banco. Y ahí, si yo quiero acceder a mis aplicaciones, porque la máquina es de nuevo, es totalmente boba, no tiene instalado ningún. Más que creo que tiene Windows 11, más que Windows no tiene nada, no tiene un notepad, nada. No podés, No podés navegar, no podés escuchar música, no podés hacer nada. Una vez que está levantada la VPN se te habilitan tres íconos donde vos podés acceder a un escritorio remoto del tipo Citrix o …, digamos son escritorios remotos que se ejecutan no localmente sino en servidores de la compañía. Es decir, una vez que la VPN está Activa, vos podés abrir un escritorio remoto y entonces esta máquina termina siendo como una terminal. que todos los recursos tiene como, no sé, 16 gigas, no sé, i7, una bestia, no puedes usar nada de eso y solo sirve para levantar una VPN y un escritorio remoto. Incluso los datos que yo utilizo no están en el equipo, están en los servidores de la compañía del otro lado de la VPN. No, entonces, desde el punto de vista de la seguridad, eso es tremendo. Cada vez que yo tengo que trabajar, incluso cuando hago guardias por la noche, tengo que levantar todo este procedimiento hasta llegar al escritorio remoto que me permite conectarme con los servidores. Dentro del cliente, no, eso tarda. Y sí, tardó como 15 minutos en levantar la máquina, con suerte, ¿no? Como es todo módem 3G, hay lugares donde no tenés señal, entonces yo vivo en un edificio, con lo cual eso influye en las comunicaciones también, tenés que estar al lado de la ventana, etcétera. Y una vez que hago todo el caminito y accedo al escritorio remoto, Del cliente, recién ahí puedo acceder a las consolas de las herramientas que tengo que validar, configurar, etcétera. No, entonces sí, es muy fuerte el proceso de bueno de de logueo y autenticación, autenticación y autorización del usuario. Sin esta computadora, con estas configuraciones, no hay forma de entrar en este cliente, no tenés ni chance.

MUNTAABSKI FEDERICO: Perfecto.

MOCIULSKY SANTIAGO: Genial y con respecto al tema de gestión de identidades un poco ya por curiosidad. Eh, ustedes se manejan en la empresa con un . . . o cómo manejan el tema de que verdaderamente sos vos y qué tanto les permite o controla esa gestión de identidades

VILLARINO PABLO RODOLFO: Bien, buena pregunta. Mira, en este proyecto, es decir, una cosa es IBM, cuando yo trabajo para IBM, uso una computadora, la tengo de este lado. Cuando trabajo para el cliente IBM, uso la otra computadora, e incluso a veces uso las 2, porque Los chats son diferentes y yo tengo que hablar con mi jefe de IBM, con mi gerente, hablo por un chat. Si tengo que hablar con el product owner del proyecto donde trabajo, hablo con otro chat. Desde esa disociación de equipos, incluso estas empresas hacen eso para que los datos del banco no pasen por los dispositivo de IBM, es decir, para eso es que a los empleados nos dan dos dispositivos. Por supuesto es mucho más, vamos a decir agresivo la validación del lado de la computadora del banco, mucho más agresivo. Y ahí el banco hasta lo que yo sé utiliza un servicio tipo IAM de la nube de Azure o alguna integración con la nube de Azure. Ellos se maneja mucho con productos Microsoft. Y la primera validación es local, es decir, la computadora cuando hago el login, cuando levanto el sistema operativo me pide usuario, password, y token. Un token que es básicamente una aplicación que el banco me hizo instalar, configuró. En este banco en particular fue una aplicación que me hicieron bajar a mi celular personal, pero hace unos meses, el año pasado, trabajé para otro cliente de IBM, que era otro banco, e incluso me daban un celular. Era un Samsung A24 creo. ¿Para qué? Para que las aplicaciones móviles no pasaran por mis dispositivos personales, pasaran por los dispositivos del banco. Entonces yo venía con una computadora, un smartphone del banco, la computadora de IBM, entonces irse a un lado, el otro era un lío. ¿Este a ese extremo, no? Entonces, actualmente sí, hay una autorización local de la computadora con estos 3 elementos que te digo, usuario, password, token. Y una vez que se hace esa primera validación, ahí está la segunda validación con casi los mismos datos, pero para acceder a la VPN. Hay también en la máquina del banco. hay. ¿Cómo? Tercer factor de autenticación, datos biométricos, es decir, el face ID y la huella son elementos que esta Lenovo también tiene configurado por default. Bueno, y una vez que levantó la VPN, ya ahí, bueno. La tercera validación seguiría en las consolas de las herramientas donde tengo que ingresar. Por ejemplo, si yo tengo que ingresar a GitLab del banco, me va a volver a pedir un usuario y un password específicamente para entrar a los proyectos del banco. Así que básicamente tengo 3 validaciones de autenticación. Vos me dirás, bueno, pero son los mismos datos. Sí, son los mismos datos. Por ahí a veces cambian el factor de autenticación. Algunos son biométricos, otros son un código. En una aplicación específica. Pero sí, son por lo menos tres seguro. ¿Contra qué lo hace? Yo entiendo que lo hacen contra un servicio de IAM, de Azure. No estoy muy empapado, te lo podría averiguar, pero me parece que sí. Sobre todo para poder levantar todo lo que es la

VPN particular del equipo. No.

MOCIULSKY SANTIAGO: Okay y como última consulta sobre este tema y al momento de que vos haces esa triple verificación tenés alguna limitación o algún control con respecto a la actividad que haces o a qué archivos accedes etcétera se tiene alguna revisión con respecto a eso

VILLARINO PABLO RODOLFO: Bien, esa también es una buena pregunta porque mi proyecto, el proyecto de este banco, según la cultura DevOps, yo soy un grupo, estoy dentro de un grupo de ese proyecto, no es el único proyecto de todo el banco. Y es un proyecto Que está dentro de la órbita de la infraestructura del banco, donde hay otras personas, otros otros procesos, otras otras metodologías. El banco utiliza también ITIL, utiliza también Kanban. Es decir, hay otras metodologías, hay otra. Bueno, Scrum, hay otras metodologías en proyectos IT dentro de este banco, no, por ejemplo. Hace unos años yo trabajaba como sysadmin de Linux, ¿no? Antes de ser ingeniero de DevOps, hoy como ingeniero DevOps en este banco puedo ingresar algunos algunos servidores Linux. Sí, algunos son . . ., algunos cloud puedo ingresar y yo tengo limitado para mi usuario. Cuando me hicieron el pasaje de grupo, me limitaron, los me cambiaron de perfil, entonces me me cambiaron los permisos. Entonces yo puedo ejecutar ciertos comandos sudo, es decir, es decir, pidiendo ser admin del equipo, pero solo ciertos comandos. Ya no soy más root de los equipos Linux que forman parte de mi proyecto, ¿no? Entonces, bueno, ahí ciertos cambios de variable entorno que no puedo hacer. Sé cómo hacerlo, sé cómo hacerlo, pero si yo intento hacerlo en la consola de tal server, bueno, se activa todo lo que les contaba. Un informe automático que le llega a mi gerente de IBM diciendo: esta persona intentó acceder y ejecutar tal cosa a todo el usuario. Eso no está permitido. La primera vez llega, la segunda se lo reportan a mi empleador y al cliente, digamos al product owner del cliente, y la tercera vez que lo hago seguramente me van a sancionar, me van a llamar la atención. Es decir, bueno, tres veces quisiste ser root y sabés que no es porque querés ser. si ahí empiezan a aparecer las alertas, no. Entonces sí, mi cuando me cambiaron de grupo para este mismo proyecto me limitaron los permisos sobre todo en la administración de los servidores que venía dándole servicio. No, sí, porque ahora yo ya no administro servers. Yo administro aplicaciones, sí, o estas aplicaciones DevOps dentro de alguno de los servers.

MOCIULSKY SANTIAGO: Ok, pero entonces estas acciones que se realizaban con respecto a seguridad se hacían al momento de que vos hacías la acción no tenían una revisión previa para confirmar de que vas por un lado que no tendrías que ir, por ejemplo.

VILLARINO PABLO RODOLFO: Claro, no, en este caso que te digo, que es la ejecución de un comando dentro de un Linux, se hacían en tiempo real con herramientas que tenía la gente de seguridad de sistemas operativos, que no tienen nada que ver con seguridad de DevSecOps. Es algo más amplio.

MOCIULSKY SANTIAGO: Okay, genial.

VILLARINO PABLO RODOLFO: A ellos le sale una alerta y esa alerta, es che, mira, tal usuario está haciendo esto, sí.

MOCIULSKY SANTIAGO: Y con respecto a otros acciones que hacías, había algún tipo de revisión de las acciones o.

VILLARINO PABLO RODOLFO: que no sea ejecución en un server, otro tipo de acciones. Bueno, por ejemplo, si en algún equipo Windows yo quisiera copiar carpetas o acceder a un disco, un disco compartido, está dentro de la red, pero compartido, que no tengo permisos, ahí también. Que sale el cartelito de permission denied. Es en tiempo real la validación, pero eso es una política que tiene ese servidor o esa carpeta y también la reiterada acción de esa situación se la reportan a mis jefes. Sí.

MOCIULSKY SANTIAGO: Genial.

MUNTAABSKI FEDERICO: Bueno, perfecto. Vamos a ir medio cerrando porque ya pasó bastante tiempo. Las últimas preguntas son más que nada de todo lo que hablamos. Si hay alguna pregunta que pensás que te deberíamos haber hecho y no te hicimos algo que se te ocurra ahora en el momento.

MUNTAABSKI FEDERICO: Y nada, si querés agregar algo, agregar algo antes de finalizar.

VILLARINO PABLO RODOLFO: Buena pregunta. Como alguna pregunta que me debieran haber hecho, no, la verdad que no se me ocurre. Fue bastante como amplia las preguntas que me hicieron y fuimos por diferentes partes de la seguridad de un proyecto. En particular, bueno, este que les contaba. del mundo DevOps simplemente agregar quizás o agregarles que actualmente en este banco nosotros no estamos integrando herramientas que tengan Inteligencia artificial. Porque hay una regulación del Banco Central de la República Argentina que limita el uso de … en Entidades financieras. Entonces el Banco Central de la República Argentina, por ahora, le dice a los bancos que pueden usar y que no dentro de las nuevas tecnologías. Por ejemplo, un banco no puede tener bases de datos en nubes cloud, no hay, no está permitido, entonces por eso los bancos. que son bancos en Argentina y que están digamos categorizados así, tienen que cumplir esas disposiciones distintas. Si yo le dijera Nubank o Brubank que son entidades financieras que pueden trabajar en Argentina pero no son Definidos como banco, no. Entonces esas siguen otro tipo de, vamos a decir así, de reglas de juego. No, que ustedes sepan que la aplicación de inteligencia artificial en las entidades bancarias está por ahora restringido. Eso capaz que cambia, pero por ahora está restringido. Porque todavía no se sabe a ciencia cierta qué hace esas herramientas de IA con la información que tienen los bancos, que en el 99.9 %

es información sensible. Sí, como no sabemos o que o como el mercado todavía no sabe. Está donde la herramienta de IA puede llegar o puede transaccionar si se la deja libre, por decir así. Entonces, por ahora no hay implementado software de IA, por ejemplo, en los proyectos donde yo trabajo, por ahora no hay, incluso tampoco para hacer monitoreo ni observabilidad. Pero eso es como anecdótico para que si ustedes siguen pensando este proyecto que ustedes tienen, bueno, quizás una limitante sea, bueno, el rubro financiero en Argentina no se lo van a poder vender, por ejemplo.

MUNTAABSKI FEDERICO: Sí, esa es muy buena información. No estábamos al tanto de que el rubro financiero estaba regulado por el Banco Central, habías dicho, ¿verdad?

VILLARINO PABLO RODOLFO: Sí, eso es cambiante, habría que averiguar, pero entiendo que no está permitido todavía.

MUNTAABSKI FEDERICO: Perfecto, bueno, eso sería todo.

Anexo D: Transcripción de la entrevista a Luciana Jacubovich

Entrevistada: Jacubovich Luciana (responsable de seguridad y gestión de accesos, grupo económico financiero)

Entrevistadores: Muntaabski Federico, Mociulsky Santiago

JACUBOVICH LUCIANA: Yo les cuento, yo trabajo en lo que es seguridad hace más de 20 años. Empecé como analista de seguridad en una empresa de seguros y hoy en día lidero un equipo de 7 personas dentro de lo que es el área de operaciones de seguridad y accesos, gestión de accesos de un grupo económico que se llama Grupo ST. El grupo es un grupo financiero, o sea, que está conformado por una aseguradora, un banco, una SGR, o sea, una compañía que brinda leasing, o sea, es un múltiples compañías que conforman este grupo financiero. Y bueno, yo estoy a cargo de todo lo que dentro del área de lo que sería seguridad, de todo lo que es seguridad en operaciones y gestión de accesos. O sea, sería una gran interesada del producto de ustedes para obtenerlo. Así que, nada, está buenísima la idea, me parece buenísima. Ahí como para darle una utilidad y poder generar una acción más proactiva para la gestión de los accesos de los usuarios y mitigar riesgos. Bárbaro, bárbaro.

MUNTAABSKI FEDERICO: Perfecto, porque eso, o sea, nos viene perfecto también entender un poco cuál es el trasfondo que tenés vos de carrera, pues también las preguntas nos permite también encaminarlas un poco por eso. Buenísimo. Bueno, ¿te molesta si empezamos la entrevista? Tranquilo, disparen. Y como consultita.

MOCIULSKY SANTIAGO: Más que nada por el tema de transcripción, la minuta después, ¿te molestas y grabamos? Para nada, chicos, graben. Genial, gracias. Bueno, ¿pones vos, Santi? Sí, ahí te grabamos. Ok, ahí... Ah, perfecto. Ahí está, ahora ya apareció. Ahí está. Bueno, ahora vamos a arrancar la entrevista. Dale.

MUNTAABSKI FEDERICO: Vamos a ir con lo que es la primera pregunta. La primera pregunta sería, ¿cómo describirías el mayor desafío de seguridad que hoy ves relacionado a tu organización o empresa?

JACUBOVICH LUCIANA: El mayor desafío hoy es la inteligencia artificial. No solamente saber cómo usarla, sino también cómo lograr que los usuarios que la usan no expongan información de las compañías y de nuestros clientes, en definitiva. El objeto final del área de seguridad nuestro siempre es cuidar la información de nuestros clientes. Entonces, lo fundamental es eso, que no se termine exponiendo ninguna información. como activo de la compañía, como información de clientes nuestros, a través de una buena intención del uso de la inteligencia artificial

para mejorar algún proceso o algo. Entonces el mayor desafío hoy está en poder potenciar a la compañía permitiendo el uso de esa inteligencia artificial, pero en forma limitada para que esto no suceda. La gran disyuntiva está ahí porque hay una gran presión de los accionistas para poder hacer uso de estas inteligencias artificiales y potenciar a la compañía. Pero a su vez también nosotros tenemos que hablar por la información de nuestros clientes y que no sea expuesta. Entiendo, perfecto. Claro, ahí está la acción entre medir los beneficios que traen estas herramientas de inteligencia artificial. contra los riesgos que presenta en la privacidad y todo lo relacionado a los datos. Sí, después también está la arista, no lo nombré, pero también es importante, los atacantes también utilizan esta inteligencia artificial y entonces los ataques... Se mueven mucho más rápido, se movilizan mucho más rápido que en otras épocas o simulan mucho más a un humano que lo que lo hacían antes. Antes uno era mucho más fácil de detectar cuando tenías algún bot o algo atrás que te estaba queriendo atacar a través de alguna herramienta que estaba utilizando algún atacante. Hoy ya eso es más difícil de detectar, dado la... al uso de la inteligencia artificial atrás y la propia inteligencia ya va aprendiendo y va cambiando su comportamiento, entonces eso también hace que sea más desafiante el poder cuidar los activos de la compañía de esa forma. O sea, si me preguntas hoy cuál es tu desafío de la inteligencia artificial en todos sus aristas, o sea, desde el uso hasta el cuidado y hasta el poder protegernos de los atacantes que hacen uso de esa inteligencia artificial.

MUNTAABSKI FEDERICO: Claro. Perfecto. Bueno, pasamos a la siguiente pregunta, que sería, ¿qué tipos de incidentes de seguridad relacionados con usuarios son los que más han tenido impacto en tu empresa o organización en las que has trabajado en los últimos años? Sí.

JACUBOVICH LUCIANA: Se me ocurren dos, o sea, como principales, filtración de datos inintencionadamente, digamos, sin intención de algún usuario que mandó algún archivo con algún adjunto o algo, alguna dirección errónea o alguien que no lo tenía que mandar. Ese es uno de los incidentes más comunes, digamos, con mayor impacto. Y por otro lado, los phishings. O sea, parece ya viejo, pero sigue estando presente todos los días y evoluciona con esto también de la inteligencia artificial. Cada vez es más artesanal, más dirigido a cada persona, pero la gente sigue cayendo en el phishing, entonces también trabajamos muy duro en concientizar a los usuarios en cuanto a eso.

MOCIULSKY SANTIAGO: Claro, perfecto. O sea, el phishing es una de las principales problemáticas que se presentan. Sí. Perfecto. Bueno, si querés, hago yo un poco para variar. Después te quería consultar más orientado a la gestión de acceso, que vos dijiste que estabas laburando en eso. Con respecto a la … o el monitoreo de usuarios, ¿ustedes qué nivel de acciones pueden llegar a ver?

JACUBOVICH LUCIANA: ¿Qué tanto pueden ver de la actividad del día a día del usuario?

A ver, tenés diferentes capas, ¿no? O sea, por lo general uno tenés como capas o aristas, digamos, de lo que hace un usuario. Podés verlo desde que se conecta a nivel red, ¿sí? ¿A qué webs? está accediendo o qué aplicaciones tiene instalada en su máquina, un usuario, a qué aplicaciones. Después tenés las actividades que realiza dentro de un aplicativo, si el aplicativo tiene un logueo, depende del nivel al que loguea la aplicación. Eso va a depender de cada aplicación. Nosotros tenemos ciertos estándares, pero muchas veces vienen aplicaciones ya dadas que no tienen. que solamente tienen un login básico, de un login o un logout, y ya está, te quedaste ahí, y no sabes qué acciones realizan dentro del aplicativo. Cuando son aplicaciones críticas de negocio, nosotros solicitamos que tengan ese login de, bueno, realizó esta acción crítica dentro de la aplicación, ¿no? No sé, por decir algo relacionado a seguros, modificó el monto de la prima de una póliza, ¿sí? O el monto asegurado de una póliza. Entonces, esa acción es crítica, bueno. Se tiene que quedar registrado que esa persona realizó esa acción. Entonces, va a depender, en ese caso, del aplicativo que tanto lo... Pero, como te decías, como uno va a depender el tipo de usuario, también cuánta profundidad va a tener. Porque capaz un usuario que no accede a ninguna aplicación, sino que meramente utiliza, no sé, su correo electrónico y navega por internet. No vas a tener mucho nivel de detalle, más que eso, pero va a depender un poco de la actividad y los privilegios también que tenga ese usuario.

MOCIULSKY SANTIAGO: Ok, y por ejemplo, los usuarios que tienen privilegios, por ejemplo, para hacer la base de datos o datos críticos, ¿será este un seguimiento de actividad que realizan o cómo es ese chequeo?

JACUBOVICH LUCIANA: Se loguea, queda logueado, queda registrado. Pero no quiere decir que se haga un seguimiento, ¿sí? No se revisa ese log en forma diaria, sino que lo que se hace es como el control inverso. Si hay alguien que está realizando una tarea crítica que no está dentro del grupo de usuarios que está permitido, ahí se genera una alerta. ¿Sí? Es como la situación inversa. Porque tenés ciertas personas que ya tienen esa actividad permitida. Yo de esas personas sí voy a tener un registro de qué es lo que están haciendo, por una cuestión de control, si requiero alguna auditoría posterior a eso. Pero de la situación como más reactiva, preventiva, lo que voy a tener es un control de una alerta si hay una actividad de, por ejemplo, una persona que tiene privilegios de administración de base de datos. pero que no está dentro de las personas que yo sé que son las administradoras de base de datos. ¿Sí? Que por algún motivo tengo algún usuario que ganó esos privilegios y puedo detectarlo fácilmente porque está ejecutando tareas que no son propias de su usuario. ¿No? Ok. Genial. Sería como medio un control por oposición de alguna forma. Ok.

MOCIULSKY SANTIAGO: Y con respecto a esto que vos nombraste, los registros, lo de auditoría, ¿qué herramientas se utiliza para eso? Tenemos un SIEM, que es el de Azure, el

Sentinel, donde se colectan ahí todos los eventos. Después cada plataforma, cada herramienta tiene su propio login, pero lo que hacemos es recolectarlos después todos. en este aplicativo que es el Sentinel. Entonces ahí lo que puedes empezar a hacer son las correlaciones estas de eventos. Genial, eso se entendió perfecto. Ahora pasamos a otra pregunta que es principalmente ¿cuánto tiempo pasa de por ejemplo que ocurre una actividad que es sospechosa dentro de un usuario hasta que verdaderamente el equipo lo detecte y lo soluciona? ¿se entiende? más o menos

JACUBOVICH LUCIANA: Sí, va a depender de la criticidad de ese evento, ¿no? Si hay una actividad sospechosa probablemente esté siendo alertada y eso es, te diría que casi inmediato de cuando ocurre esa actividad sospechosa. Ahora, después hay todo un proceso de investigación, que eso sí ya puede llevar más tiempo, pues, no sé, desde... Una hora, hasta cinco horas, depende de qué tanto te cueste rastrear eso. La idea es justamente tener todos los eventos dentro de la consola para poder hacer ese análisis. Pero muchas veces requiere poder contactar al usuario, al equipo del usuario, secuestrar de alguna forma al equipo del usuario, tomar posesión de ese equipo para poder hacer una investigación más profunda por si el equipo estuvo... tomado por el incidente. Entonces va a depender. Pero desde el momento en que se detecta que es casi al unísono de que sucede porque nada, tenemos las alertas y tenemos la consola generando esos eventos. Después el tiempo de investigación va a depender del tipo de incidente.

MUNTAABSKI FEDERICO: Una pregunta medio relacionada por ese estilo de los incidentes. En el caso de que ustedes detecten una actividad sospechosa de algún usuario, ¿cómo sería el proceso desde que se detecta hasta que se llevan las acciones? Perdón, me te consulto. Una pregunta que viene un poco antes de esa es, ¿usted tiene un equipo SOC? supongo, dentro de la organización. Sí. Chiquito, pero sí. Todavía somos medio … en ese sentido, pero sí. Estamos evolucionando, vamos de a poco evolucionando. Así que no, la pregunta era, primero, si tenían equipo SOC y después cómo es ese proceso desde que se detecta la amenaza hasta el proceso en el cual se finaliza la amenaza ya sea bloqueando o haciendo la acción correspondiente.

JACUBOVICH LUCIANA: Primero, aclaración es, yo tengo un evento. No sé si es un incidente o no es un incidente, que es un poco lo que les decía antes. Yo tengo esa alerta, a mí me llega esa alerta y no sé en qué deriva. Por eso en cantidad de horas no les puedo decir, el promedio es tanto. Si querés te digo, el promedio son dos horas de análisis, ¿sí? Por lo general, hasta que uno dice, fue un incidente, no fue un incidente, está contenido, no está contenido, o sea, en el promedio son dos horas, ¿sí? Pero hay veces que son diez minutos que descartás el evento, decís, esto no es un evento, no es un incidente, digo, ya está, listo, lo descartaste. Pero la alerta la tenés que analizar. Sí, ese trabajo te lo tenés que tomar. Entonces, cada evento que llega, cada alerta que llega, se analiza y se …, no sé, un acceso, como hablábamos antes, de una persona que está ejecutando una tarea de administración de base de datos y no está dentro de los

usuarios permitidos. Eso es un evento, ¿sí? Y yo voy a empezar a investigar cómo esa persona obtuvo sus accesos. quién es ese usuario, si es un usuario que está en nómina o no está en nómina, se empieza a hacer todo ese traqueo de información, ver qué otros eventos se ejecutaron con ese usuario. Voy a empezar a hacer todo ese análisis y va a depender un poco, tenemos ciertos runbooks por cada tipo de evento, qué acciones ir tomando.

MUNTAABSKI FEDERICO: Pero un poco es eso, perdón, pero me fui y no me acuerdo exactamente qué era que me habías consultado. No, igual está bien. O sea, está bien que te …, pues no, nos sirve también, pues no, nos da información. La pregunta original era: cuando se detectan los eventos, como dijiste vos, en una sesión de un usuario, ¿cómo es el proceso desde la detección hasta, por así decirlo, el cierre del evento? ¿O la finalización que se dice: esto no es, o sea, no es nada peligroso, o esto puede ser un problema de seguridad para la organización?

JACUBOVICH LUCIANA: Bueno, un poco es esto que les venía diciendo, ¿no? O sea, es detectar ese evento, poder hacer el análisis de acuerdo al runbook del tipo de evento que sea, o si es algo que está por fuera de los runbooks, poder... o sea, el equipo ya está reunido analizando el evento. Y una vez que se determina si hay algún impacto o no, si es un incidente o no, todo eso queda registrado en un informe, que después está abierto a que todo el equipo lo comparta. Se sube toda la evidencia registrada durante el análisis, todo esto se... Por más que no sea un incidente, nosotros vamos tomando evidencia para poder tenerla también a futuro, por si se repite alguna situación similar. Decir, para, esto ya nos pasó, voy y consulto y tengo la evidencia de lo que sucedía anteriormente en un caso similar. Y es eso, se cierra con el informe. Y muchas veces dentro de ese informe lo que se incluye son mejoras, posibles mejoras que podemos tener también dentro, por ejemplo, de la herramienta del SIEM, decir, no, pará, che, me está alertando esto, que en realidad es cualquier cosa, ¿no? Mejoremos. Entonces, ahí haces otra correlación de eventos que sea mejor. O, uy, pará, este usuario ahora sí tenía que tener estos permisos de administrar de base de datos porque... Pasó de rol y no actualizamos en nuestras reglas del SIEM que esta persona ahora tenía que tener estos permisos y esto no es ningún incidente. Simplemente se pone como un falso positivo y se avanza. Pero se deja registrado como mejora que hay que cambiar las reglas de la consola del SIEM. Perfecto.

MUNTAABSKI FEDERICO: Bueno, pasamos a la siguiente pregunta, un poco también relacionada con las mejoras que vos decís, de tipo, che, esto ya no sirve, o quizás el usuario ahora sí necesitaba tener este rol o registro. La siguiente pregunta sería, ¿cuáles son los principales desafíos que hoy en día vos pensás que hay en lo que es? El monitoreo de usuarios. O sea, pueden ser mejoras, por ejemplo, se me ocurre, menores tiempos o algo que se te ocurra por ese estilo. ¿Mejoras en cuanto al monitoreo de los usuarios? Sí. Sí, que ya no son los usuarios los que hacen las acciones.

JACUBOVICH LUCIANA: O sea, el mayor desafío hoy en día es esto que hablábamos al principio de la inteligencia artificial, que hoy ya no es el propio usuario el que está haciendo las acciones, sino que capaz es un agente que lo está haciendo por el usuario. Entonces, a veces poder discernir en eso, o que el usuario tenga esa conciencia de esa autonomía que le está dando. Es la parte difícil de poder detectar esa diferencia entre un usuario y un agente. Entonces, ahí yo creo que están las mejoras que uno puede ir haciendo de poder acercarse a diferenciar esto, porque claramente una cosa es que la acción la da un usuario y otra que le está haciendo un agente automatizado. Y por otro lado, de poder detectar también el uso de esos agentes que a veces no tenemos en radar. O sea, directamente los usuarios los generan y nosotros no tenemos conciencia de que esos agentes existen. Entonces, estar detectando esos agentes hoy dentro de la red.

MOCIULSKY SANTIAGO: Perfecto, quedó re claro. Y como otra pregunta más orientada al tema del uso de las herramientas, como comentaste antes, usan herramientas para muchos casos, ¿qué es lo que más se valora en una herramienta al momento de ayudar al equipo de seguridad? O sea, ¿qué son las características que más se toman en cuenta para usar una herramienta y no otra?

JACUBOVICH LUCIANA: Los costos. No, la realidad es que hoy este tipo de herramientas de seguridad son súper costosas y cuanto más funcionalidades te dé la herramienta por menor costo, la realidad es que es la herramienta que va a ganar dentro del mercado o inclusive la... La interoperabilidad, digamos, el poder adaptarse a trabajar con otras herramientas de otras marcas diferentes. La realidad es que hoy en día es eso. Hoy para las empresas argentinas, por lo menos, es súper costoso cualquier herramienta que uno quiera adquirir, que no sea open source, que sea paga. Es bastante costoso y si no, si vos querés desarrollar algo más open source, utilizar algo más open source, que por lo general requiere mucha más parametrización, más armado, necesitas mucho más tiempo de … y necesitas un equipo más grande para eso. Entonces también es costo. Entonces a veces es como, bueno, ¿dónde pongo las ganas? Va a depender de una decisión más corporativa, directivo, que si se quiere del área propiamente dicho.

MOCIULSKY SANTIAGO: Ok, y con respecto a, ya fuera del tema de costos, que es totalmente entendible en las empresas, el tema de funcionalidades, o sea, ¿qué es lo que se tomaría en cuenta suponiendo el caso de que el costo no es el principal problema?

JACUBOVICH LUCIANA: O sea, ¿qué se tomaría en cuenta como ventaja de una herramienta con respecto a otra? Que cumpla la funcionalidad de lo que vos estás buscando en esa herramienta. O sea, básicamente es eso, que te cubra lo que vos estás buscando y capaz hasta que te dé algún valor … de algo que vos no estabas viendo, que podías llegar a, no sé, pensando en una herramienta de monitoreo, como hablábamos antes. Pensar en monitorear algo que ni se te ocurría que podías monitorear. Creo que es eso un poco. Que sea adaptable, que pueda tener

interoperabilidad con otras aplicaciones de otras marcas y que te sumen funcionalidades que vos no tenías en cuenta. Ok, genial.

MOCIULSKY SANTIAGO: Otra pregunta, aparte de este tema anterior, es ¿qué factores vos considerás que aumentan el riesgo asociado a un usuario? Por ejemplo, si depende de rol o depende de la actividad que realiza. ¿Qué acciones generan más riesgo? O sea, ¿qué considerás que aumenta el riesgo más en la actividad de un usuario? Si se depende por el rol o por la actividad que realiza. No sé si se llega a entender.

MUNTAABSKI FEDERICO: Sí, pero no. Un ejemplo, a ver si capaz me clarifica. O sea, la pregunta está enfocada básicamente en vos monitoreas un grupo de usuarios y lo habíamos pensado tipo, vos siendo por ejemplo un usuario con un rol bajo o teniendo otro con un rol alto. ¿Qué cosas aumentan el riesgo en cada uno de esos casos? ¿Es preferible, por ejemplo, que los usuarios con un rol bajo tengan la misma visibilidad que los de un rol alto? Factores así. No sé si me expliqué bien, la verdad.

JACUBOVICH LUCIANA: Seguridad, para mí es como un principio, un pilar, si se quiere, es todo lo que es el mínimo privilegio. Siempre a los usuarios basándose en el mismo, inclusive validando siempre identidades, o sea, si bien como el concepto de Zero Trust, si bien no... es muy difícil de implementar al 100 % el cero trust, como tener esa visión de cero trust, y siempre basándose en el mínimo privilegio. O sea, ahí siempre vas a reducir riesgo. O sea, que el usuario tenga, no quiere decir que no pueda haber un acceso basado en roles. Por eso me generaba un poco de confusión, porque vos podés tener un... un rol y que ese rol tenga el mínimo privilegio que requiera el usuario. No necesitas salir de lo que son los accesos por roles para llegar a que el usuario tenga el mínimo privilegio y no incrementar un riesgo. Perfecto. No sé si respondí o no respondí la pregunta. Sí, o sea...

MUNTAABSKI FEDERICO: La pregunta quedó, o sea, ahora leyéndola no estaba muy bien formulada, así que... No, no, no. O sea, puedo yo no haber interpretado correctamente por eso. No, no, no. No fue un problema tuyo. La verdad que pensamos que íbamos por un lado, pero como no terminó de... No le pudimos sacar jugo a esta pregunta, porque no la pudimos plantear bien. Bueno, si quieren...

MOCIULSKY SANTIAGO: Tienen otra idea, tírenla y le respondo. O sea, no hay problema. Pregúntenme sobre esa, capaz. O sobre lo que les dije. Si se les ocurre, no sé. Dame un medio segundo. Les estoy sacando del libreto. A mí lo que me puse a pensar es... O sea, vos dijiste que monitorean constantemente y hacen, por ejemplo, una investigación de los problemas. capaz la pregunta puede ir por ese lado, o sea, ¿qué son las características que definen que primero investigamos este problema antes que otro? Nosotros tenemos estipulado cuáles son

las actividades riesgosas, si se quieren, no sé, privilegios altos, yo voy a estar monitoreando cualquier privilegio elevado o usuarios que tienen.

JACUBOVICH LUCIANA: en realidad yo no monitoreo todos los usuarios, pero lo que yo estoy monitoreando es qué usuarios están realizando una actividad con privilegios elevados. Como les decía antes, el ejemplo de los usuarios con base de datos, con permiso de administración de base de datos. Así como base de datos tenés en todos los aspectos, ¿no? Cualquier tipo de administrador. Entonces, esas son las cosas que yo voy a monitorear después. Tengo otros controles también sobre sus usuarios, más allá del monitoreo, ¿sí? Que me van a disminuir mi riesgo. Que otras actividades riesgosas monitoreo, actividades sospechosas que no son habituales, ¿sí? Entonces, todas esas van a ser alertadas, no sé. la ejecución de un programa que normalmente no se ejecuta. Hay un nuevo programa que se está ejecutando, eso va a ser una alerta. No quiere decir que después termine siendo un incidente, pero sí va a ser alertado. Entonces actividades sospechosas en ese sentido también. Entonces son como diferentes tipos de alertas, de eventos que uno va a monitorear. ¿Sí? Va a dar monitoreos. Hay muchos. Alertas son una porción de eso. ¿Sí? Yo monitoreo, monitoreo el login, el logout, el login fallido. O sea, hay millones de eventos que se monitorean y va a depender también de qué tecnología o qué herramienta, qué aplicación estás monitoreando. Como les dije antes, también en ciertas aplicaciones, ¿cómo se llama? Acciones críticas que se realicen dentro de una aplicación, también los vas a estar monitoreando. Una actividad crítica de cualquier usuario dentro de ese aplicativo, vas a estar monitoreándolo. Entonces, va a depender de qué es lo que estás monitoreando, qué es lo que vas a monitorear. Ahora, de todos esos eventos, que es una bolsa de gatos enorme, es decir, bueno, de todo esto que es lo que estoy alertando, bueno, voy a alertar, sí, lo que me genere más riesgo, o cuando se me dé cierta correlación de esos eventos. Yo siempre pongo el ejemplo más pavo, el que ya no aplica, pero es que cuando antes uno venía todos los días a la oficina y decías, bueno, la máquina la tenías en la oficina. Y no estaba el evento de que la persona había pasado por el molinete y después la persona se conectaba a la máquina. Y eso tenía que ser un rojo en todos lados, saltando por todos lados. Porque cómo puede ser que esa persona se estuviera conectando si no habían ingresado a la oficina. Algún control pasó, algo está fallando. Esos son los tipos de correlaciones de eventos que tenemos que ver. No, esa obviamente hoy en día ya no aplica. Se traslada de otra forma, ¿sí? Por decirlo, si hay una aplicación que es interna, que no está expuesta a internet, si el usuario no se conectó a la VPN, no se puede estar conectando a esa aplicación. Si tenemos todo dentro de esa red securizada, tiene que primero conectarse a la VPN. el usuario. Entonces tiene que estar ese evento de login del usuario en la vpn para después poder estar ese evento de login en el aplicativo. Si eso no sucede, no sea de esa forma, tiene que haber un alerta. Es como el paralelismo a lo que les decía antes del molinete. Entonces todo ese tipo de acciones sospechosas y eventos críticos son los que se alertan. No es que es. Si sucede

este evento, se alerta. A veces es, sucede este evento, más este evento, más este evento, o no sucede un evento previo a ese. Si tengo que ir a buscar si previamente sucedió el otro evento, y si no, te lo alerto. Todo eso es, nada, horas de configuración del SIEM, y bueno, habrá mucho de inteligencia artificial también meterle ahí. Cosas de … o cosas como las que están pensando en desarrollar ustedes también es parte, puede ser parte, puede ser parte.

MUNTAABSKI FEDERICO: Bueno, perfecto, ya vamos a ir dándole un cierre a esto. Ya hicimos creo que la mayoría de las preguntas que tengan muchísimo valor. Así que nada, vamos. La última es, básicamente, si hay alguna pregunta que vos pensás que deberíamos haber hecho, que ahora se te ocurra, o que durante la entrevista habrás dicho, che, me tendrían que preguntar esto que no te hicimos. Ok.

JACUBOVICH LUCIANA: No, ahí lo que creo que es importante para que tengan, no sé si como preguntas, sino como darles como información, digamos, que no agrupar a los usuarios bajo una misma categoría, bajo un mismo grupo, por experiencia lo digo. Es decir, bueno, todos los usuarios de finanzas, ustedes hablaban de niveles de riesgo y, o sea, que no, por ser de finanzas tienen un nivel de riesgo y por ser, no, cada usuario es un mundo. O sea, porque por ser de un grupo determinado o tener un rol, que hablábamos antes de los roles, o sea, no. Cada usuario tiene que tener su propio índice de riesgo y que se tiene que ir autogenerando. Y poder cambiar solo. Esa es la parte difícil, si se quiere. Como poder, generando su nuevo rating, ¿sí? Dentro de ese ranking de riesgo, automáticamente en base a su comportamiento, ¿no? Es decir, bueno, está accediendo a esta aplicación, a esta página que es riesgosa o no es riesgosa, como poder hacer ese análisis individualmente por usuario y no como ya presetearle algo por ser de este área o de este otro área. como que tiene que tener ese aprendizaje, la herramienta del usuario. Obviamente que ahí está lo rico que ustedes le tienen que dar de qué es lo riesgoso y qué es lo que no. Pero bueno, ahí entra el desafío.

MUNTAABSKI FEDERICO: Sí, sí, total. Justo lo que decís es exactamente el desafío que hay es crear ese... esa línea base de comportamiento, o sea, algo general, y después decir, che, para los usuarios se comportan de forma diferente. Dos gerentes pueden comportarse de forma diferente, pueden hacer actividades totalmente diferentes y no necesariamente es posible ponerlos a todos en una misma bolsa, por así decirlo. Pero bueno, eso serían todas las preguntas.

JACUBOVICH LUCIANA: ahí podés parar de grabarse antes si querés. Ok, bueno, buenísimo chicos. No sé lo que necesiten. Si después se les queda alguna duda o algo, me avisan. Y espero que sea con suerte que salga adelante. No se dejen intimidar por Hugo. No, no, no, Hugo no quiere. Bueno, muchísimas gracias por el tiempo y por todo. Esto es invaluable. Bueno, espero que haya servido y que... Nada, si se me ocurre a alguien más que puedan llegar a entrevistar, les aviso. En este momento no... Porque las personas que están en la facu no tienen, o sea, como esta

orientación. que yo conozca no quiere decir que no haya otros pero les aviso muchas gracias por todo muchas gracias a ustedes un beso suerte

Anexo E: Transcripción de la entrevista a Guillermo Pita

Entrevistado: Pita Guillermo (CISO, ANSES, también perito judicial)
Entrevistadores: Muntaabski Federico, Mociulsky Santiago

PITA GUILLERMO: No a vos en particular, ¿no? Mañana vamos a tomar un café a la luna y volvemos y total... Ah . . . pero si total... Pero me dicen, ¿pero cómo? ¿Qué me estás diciendo? Es una boludez, se agarra un . . . y irá a la luna. Entonces, a lo que voy con esta ironía es que muchas veces se enuncian cosas que luego, cuando vas... O sea, cuando vas al qué es muy bonito y cuando vas al cómo, que es lo que estoy desafiando a propósito, es donde te encontraste. Digo, porque, a ver... Puedo hablar con propiedad porque nosotros, en todos los años que tengo acá, y esta instalación es enorme, toda esta casuística ya la tenemos relevada. No es sencillo relevar esta casuística, por eso te digo que tampoco es tan directa la obtención de esa información solamente del sistema operativo así per se. Existen recopiladores de información, agentes como el tipo, un agente gratuito del X-Log, que loguea determinadas cosas, otras no las loguea. Y la actividad en general de ese tipo se obtiene de diferentes fuentes. En donde muchas veces, por la característica de los sistemas operativos, otra vez, por eso la enunciación, o esa información está incompleta o no está en todos lados. o se obtiene de lugares en donde tenés que tener determinados privilegios, entonces es riesgoso que un agente, un agente de software, se coloque en un lugar con determinados privilegios. Por eso te digo, entonces, no es lo mismo estar en una plataforma Linux que en una plataforma Windows. Si lo tienen que hacer. Por eso te digo, yo no sé si ustedes están llegando a presentar el qué, o el qué y el cómo, y la ejecución propiamente dicha. No sé cuál es el alcance del trabajo.

MUNTAABSKI FEDERICO: Mira, nosotros, para lo que es la parte de... O sea, nosotros hicimos una etapa inicial donde nosotros presentamos la idea de lo que queríamos hacer con el objetivo, el alcance y una breve descripción de todo lo que involucraba. Y esa etapa fue el qué, o sea, el qué queríamos hacer. Nosotros venimos avanzando, tenemos ya armado por lo menos la interfaz operativa, entrenado los modelos con un dataset que encontramos. La gente está en proceso.

PITA GUILLERMO: Pero bueno, igual me sirve que vos me des esa visión del programa. Yo lo que te diría es lo siguiente. Vos lo que vas a estar haciendo con lo que describís, decime si me equivoco, creo que no, es, vas a estar recolectando eventos. Correcto. Ok. Entonces, Windows tiene trillones de eventos, y no solo tiene trillones de eventos, sino que para que te des una idea, Creo que es 49-20, si mal no recuerdo, porque es el que más usamos acá, que es el de login, pero no es lo... Creo que el 49-20 tiene a su vez siete sub... Categorías. Claro, subcategorías. Entonces,

digo, te digo, a ver, yo soy muy detallista cuando... O sea, me describo un poco porque a mí lo general, si bien obviamente es por donde se arranca, me gusta la ejecución. Entonces, desde ese lugar, yo te digo, puedo hablar con propiedad porque esto lo hacemos. De hecho respondemos oficios judiciales por fraudes que cometen los mismos empleados de acá y sabemos dónde se logonean, qué hacen, qué no hacen, cuándo cortan, cuándo no cortan. No es lo mismo el login en un Active Directory, ¿sabes lo que es el Active Directory?

MUNTAABSKI FEDERICO: Sí, cuando vos te conectás a una máquina, o sea, desde tu máquina abrís un SSH,

PITA GUILLERMO: No, no, no, no. El Active Directory, el directorio activo, es básicamente, no, no, es una mega herramienta, que es una herramienta muy nativa de Microsoft para manejo de identidades y de objetos. Y ahí nosotros, nuestro manejador de identidades y de objetos, entendiendo por objeto, un objeto es un impresor, un teléfono, un ser humano, o sea, no un ser humano justamente, las credenciales de alguien. Y ahora te voy a dar un tip que, llévatelo porque es muy importante. Y te lo digo porque si decís esto, creo que te van a tomar con mucha más seriedad. No te garantices que un ser humano estuvo frente a una computadora haciendo algo. Garantiza que recabaste información para que la identidad digital de esa persona se presentó en esa estación de trabajo. ¿Qué te digo con esto? Yo te doy a vos mi usuario y mi password. O vos me miraste por arriba del hombro, ¿sí? Y viste mi password y sabés mi usuario. Vos soy yo. No. Entonces, a mí, no, no, claro, pero vos sabés qué tema es esto con la justicia. Porque a mí me dicen, bueno, dígame, Guillermo Pita estuvo frente, yo te voy a decir, las credenciales de Guillermo Pita fueron utilizadas de acuerdo a nuestros registros, en tal y tal. No es lo mismo que las credenciales han sido usadas. Que ahora, como todo, si ladra, levanta la pata y tiene pelos, y levanta la pata va a ser pis, y tiene pelos, generalmente no es un flamenco. Es un perro. Entonces, vos decís, che, este tipo ingresó por tal puerta, tenemos una cámara de seguridad que lo tiene registrado. El tipo metió su registro biométrico a las 3 de la tarde, tuvo su primer login a las 3 y 8, que es más o menos lo que tarda el ascensor en subir, bla, bla, bla, bla, y así durante... Es él y el tipo puede decir, no, mirá, nunca fui yo. Esto es como cuando vos vas, yo soy perito también, en caso de que... Perdón que me vaya por las ramas, pero te quiero dar la certeza del manejo de la información tan delicada como puede ser la presencia de una persona frente a una máquina. Vos decís, che, apareció una persona asesinada en tal domicilio. Te vieron entrar, te vieron salir y cuando salías tenías la camisa con sangre y salías con una valija que colgaba una zapatilla y decís, la mató. Y sí, yo no tengo la afirmación de que la mató, pero la probabilidad de que la haya matado es muy alta. Y el tipo, en cana igual. Esto es lo mismo. A lo que voy es, cuidado con el, ahora voy para otro lado, cuidado con el manejo de eventos, porque si no lo mirás en detalle, pues te lo voy a decir en el mejor castellano que tengo, puedes estar informando una boludez. Porque otra vez, el tema de manejo de eventos, del event log de Windows, no voy a decir que es

delicado. Pero no siempre el Windows, de hecho yo soy anti-Windows, por supuesto, como buen informático, no siempre responde, regularmente a lo que tiene que responder. Entonces, te diría que, como … poco aprieta, fíjense si el alcance que le quieren dar a esto, en términos de riesgo, es un alcance en donde ustedes están analizando, digo una boludez, 5.000 eventos, no te metas en esa. O sea, para analizar 5.000 eventos necesitas un SIEM, no sé si sabés lo que es un SIEM.

MUNTAABSKI FEDERICO: Es decir, seguridad, ¿verdad? Es donde se almacenan los logs.

PITA GUILLERMO: Sí, ponele, es un recopilador más que de logs, sí de logs, pero lo que tiene es una herramienta que si bien ingesta logs, lo que tiene es la capacidad de colección, o sea, recolectar y correlación. Por ejemplo, nosotros tenemos un SIEM muy grande que colecciona los eventos de las 15 .000 estaciones de trabajo, 2.000 servidores que tenemos acá, y por ejemplo, si... tu credencial está siendo usada en Buenos Aires y en La Rioja, automáticamente te bloquea el usuario. Porque correlacionó. Hay una regla que le dice, un tipo no puede estar en dos ubicaciones al mismo tiempo. Ahora, si el tipo se movió dentro de Buenos Aires con diferencia de media hora y … en dos máquinas, me va a dar una alerta. No me va a bloquear, pero me va a decir, che, pará, este tipo … en Paseo Colón y ahora está en Córdoba y Maipú. ¿Qué pasó? Pasó dos horas. Y puede ser que haya dejado abierta la sesión, pero me va a generar una alerta. Entonces, lo que digo es, la información de riesgo de gestión tiene que ser información correlacionada. Y ahí es donde yo te sugiero que ustedes, como parte del trabajo, digan o pongan dos o tres casos de uso, en donde. Porque eso le va a dar, me parece, un poquito de valor agregado a la tarea, de decir, che, mirá, por ejemplo, el ejemplo que te puse. Nosotros estudiamos que si dos personas se están logoneando con diferencia de 200 kilómetros al mismo tiempo o en 5 minutos, no va. Ahí te manda un bloqueo. Nosotros tenemos, nosotros, en general en ciberseguridad vos tenés dos grandes hitos de trabajo, el bloqueo y la alerta. Hay cosas que se bloquean porque ya sabés, o sea, la probabilidad de que estén mandando una cagada o que estés ya habiendo un fraude es importante. Y otras te alerta, te dice, che, se lo pasa un analista y la alerta tiene. Lo que nosotros llamamos en la jerga cinco tiers, tiers es cinco niveles, de rojo a verde. Algunos se tienen que mirar inmediatamente en el término de 15 minutos, 10 minutos, 5 minutos, otros se pueden ver a fin del día o mañana. Entonces, todo esto forma parte de los motores de riesgo, porque no es solamente, porque vos me decís, veo si se creó una carpeta, y desde el riesgo no me estás diciendo nada que se creó una carpeta. Si vos me decís, no, esa carpeta tiene información porque la tengo censada o la tengo auditada como información confidencial. Y se está metiendo alguien que no tiene que meterse frecuentemente y la está copiando y se está moviendo un Excel que hay ahí adentro, es distinto. Entonces, guarda con la casuística, ¿sí? Porque es lo mismo, otra vez, no es lo mismo. Que la casuística te la da lo que se llama en la jerga el caso de uso. El caso de uso es, si pasa tal cosa, entonces hago tal cosa, si sucede tal otra, disparo tal... un tema de causa-efecto. No sé si te ayuda todo esto.

MUNTAABSKI FEDERICO: Sí, sí, sí. A ver, me da un... O sea, me da otra perspectiva que no me dieron, o sea, por lo menos las otras personas con las que entrevistamos o así no nos dieron esta perspectiva y está bueno. Porque también nos permite ser más realistas.

PITA GUILLERMO: Es que este es el tema, o sea, vos me decís un motor de riesgo, pero te lo digo sinceramente. Entró una persona a tu casa, yo te digo a vos. Y vos me decís, sí, puede ser mi hermana, mi viejo. Digo, entró una persona a tu casa con una escopeta en la mano, encapuchado y con dos cuchillos en la cintura. Es mierda, o sea, no es lo mismo. También la persona.

MUNTAABSKI FEDERICO: Guillermo, creo que ahí Santiago mandó, pues recién se pudo unir. Si le podés aceptar.

PITA GUILLERMO: Para que lo admito, bancame.

MUNTAABSKI FEDERICO: Igual está muy bueno lo que mencionás. Me sirve un montón. porque es una mirada que no nos habían dicho y nos ayudó un montón. También para hacer, o sea, el momento de desarrollar, esto es lo que mencionas de, por ejemplo, los casos de uso. Nosotros habíamos hablado de la idea general de, por ejemplo, cuando nos pusimos a analizar el conjunto, el dataset que teníamos nosotros, para armar los modelos con inteligencia artificial, por ejemplo, nos había pasado que teníamos una cantidad impresionante de usuarios. Pero después, cuando nos poníamos a analizar, por ejemplo, teníamos muchas cuentas que eran bots, que hacían actividades, por ejemplo, de AWS, de servicios de mensajería, tipo newsletter, cosas así. Y está bueno que vos des esa visión de que quizás nosotros nos tenemos que enfocar más en los casos de uso que corresponden a lo que vamos a hacer o a lo que pensamos hacer.

PITA GUILLERMO: Ustedes lo que tienen que hacer es primero, antes que nada, definir los casos de uso. O sea, definir la casuística que va a resolver esta herramienta. Esa casuística generalmente se lo mide por la definición, básicamente. Si googleás casos de uso, vas a ver que hay metodologías para el armado de lo que se llama use cases o casos de uso. Yo no, en máximo en el trabajo práctico, no abundaría en casos de uso, para que te des una idea, nosotros, siendo una organización de 15.000 estaciones, 400 sucursales, yo tengo críticos 49 casos de uso. Pero no es tanto, es un montón. O sea, para que sean críticos, es una bocha. Con lo cual, ustedes yo creo que deberían ceñirse a sugerencias. Tres, como muchos, cinco, te diría muchísimo. Y si fueran tres, mejor. pero muy certeros y muy con este concepto de la colección y la correlación. Claro. ¿Sí? Entonces, vos, una cosa es levantar el evento, coleccionarlo, ¿sí? Pero luego, sea correlacionado o no, vos tenés que decir, bueno, ¿qué valor agregado le doy a esa información? Porque la información tenés que transformarla en datos. La información por si no te dice nada. El tema es el dato. Entonces, ahí yo colocaría, no sé por decir algo, tres casos de uso, Y diría,

bueno, ¿qué eventos necesito para que estos casos de uso sean efectivos? Y no es menor lo que llamamos prueba y contraprueba. Vos tenés que probar que constantemente ese evento está llegando. No podés asumir que el evento... Porque ya te digo, los sistemas operativos son muy inestables, parecen estables, pero son muy inestables y se trata de Microsoft mucho más. Entonces, posiblemente... digas, sí, estoy coleccionando los eventos, pero cuando vas a hacer un análisis semanal, te diste cuenta que el martes a las 3 de la tarde dejó de coleccionar hasta las 3 de la mañana de jueves. Y viene alguien y te dice, bueno, che, ¿qué pasó en ese periodo? No sé, se puede haber apagado un equipo o no, pero tenés que saber qué pasó. Muchas veces, y esto es un error en la ciberseguridad, se asumen un montón de cosas que cuando vas al fino, fino, fino, no son. Bueno, hola.

MOCIULSKY SANTIAGO: ¿Qué tal? ¿Cómo andás? Sí, también estoy de compañero en el TFI. Perdón la demora, pero tome la reunión antes y no me puedo presentar.

PITA GUILLERMO: No pasa nada.

MUNTAABSKI FEDERICO: Bueno, perfecto, Guillermo. Todo lo que dijiste lo grabé para que nos sirva para después tenerlo en cuenta, la charla esta. Si querés, Si querés, primero te paso las preguntas o si querés te las hago y vamos viendo.

PITA GUILLERMO: No, no, decíme, decímelas.

MUNTAABSKI FEDERICO: Ok, ok. Bueno, la primera pregunta sería cuál o cómo describirías el mayor desafío de seguridad que enfrentás hoy en relación con los usuarios de tu organización o del trabajo que realizás.

PITA GUILLERMO: Ok, el mayor desafío y es el enorme y tremendo desafío que tiene. El planeta Tierra que se ha digitalizado tanto, básicamente, o sea, después resumí mi respuesta, ¿no? Es saber que la identidad digital está siendo utilizada por la identidad humana. O sea, que son iguales. O sea, el reemplazo de identidad, básicamente. Vos hoy no tenés perímetro en la ciberseguridad. Cuando digo no hay perímetro, es ya se acabó el tema de tener, en términos físicos, un alambrado alrededor de un terreno. Vos acá tenés accesos desde celulares, desde países distintos, el celular se mueve, esa persona deja el celular en una mesa y automáticamente se conecta con una tableta, o en esa tableta queda una cookie de identidad. Entonces, el mayor desafío que hay es saber que quien está operando digitalmente es quien dice ser realmente. O sea, date una idea. Yo estoy hablando ahora con Federico. Yo no sé si vos sos Federico, yo nunca te vi. Y vos podés ser alguien que se está haciendo pasar por Federico, o yo alguien que se pueda hacer pasar por Guillermo. No es así. Te pongo un ejemplo burdo, para que te des cuenta de que digitalmente no hay una forma de saber a ciencia cierta. Salvo que todas las veces que nos conectamos siempre escuché la misma voz, siempre di la misma foto de perfil, siempre te

mostraste voz, siempre … la misma, siempre los... Bueno, y ahí decís, como te decía al principio, si levanta la pata y ladra para hacer pis, es perro generalmente y no es un flamenco. Entonces, a lo que voy es, el mayor desafío que yo tengo como director de ciberseguridad o experto en ciberseguridad, porque ya hace más de 20 años que estoy en esto, básicamente es enseñarle al individuo común a desconfiar de lo digital. Lo digital no debe generar confianza, debe generar desconfianza naturalmente. ¿Por qué? Porque no hay presencia física, ni hay certeza de que quien dice ser es quien es. Porque si yo me siento con vos, cara a cara, tomar un café 20 veces, vos siempre sos el mismo. Ahora, detrás de una pantalla o detrás de un dispositivo, ¿sos siempre el mismo? No hay forma de garantizarlo.

MUNTAABSKI FEDERICO: Claro. Bueno, paso a la siguiente pregunta, que también está un poco relacionada, que sería, ¿qué tipo de incidentes de seguridad relacionados con usuarios? han tenido más impacto en tu empresa en los últimos dos años, o los años que vos consideres necesarios?

PITA GUILLERMO: A ver, vamos de vuelta, o sea, reformulamela, o sea, repetímela porque no termino de entender la base del concepto.

MUNTAABSKI FEDERICO: Ok, básicamente lo que dice la pregunta es, de los incidentes de seguridad que se presentaron en tu organización en los últimos años, que afectaron a usuarios, ¿cuál vos considerás que son los más importantes?

PITA GUILLERMO: Los más importantes, te diría, intentos de suplantación de identidad, lo que estábamos hablando un poco antes. Claro, el que vos no conoces, ¿quién está detrás de la pantalla? Yo no puedo dar certeza a quién está detrás de la pantalla, yo puedo saber que una identidad de una persona, al cual se le otorgó un usuario y generó una clave, es quien se conectó en una máquina en un determinado momento. Entonces el mayor desafío nuestro es siempre poder informar. De hecho nosotros informamos, como te decía al principio, mucho a la justicia por fraudes que se cometen. Dar certeza, informar de forma lo más … posible que detrás de esa pantalla había una persona cometiendo lo que estuviera haciendo.

MOCIULSKY SANTIAGO: Si querés, pregunto yo, pero así no siempre sos vos. Después de que se loguean, supongo que ustedes en la empresa donde vos laburás utilizan un … para verificar el tema del login y la autenticación. Pero después, o sea, después de que se autentica exitosamente, ¿usted tiene alguna herramienta para visualizar las acciones que hace durante la sesión?

PITA GUILLERMO: A ver, primero, Es como que vos me digas, muchas veces, déjame responder de una forma diferente, muchas veces no se comprende el volumen de información que genera una transacción digital. Esto es ANSES, es Estado, es la Administración Nacional de

Seguridad Social. Vos en 15.000 usuarios, números grandes, que . . . todos los días, la trazabilidad de cada acción no es razonable mantenerla. ¿Desde qué lugar? Desde el volumen bestial de información que genera. Cuando hablo de trazabilidad de información es absolutamente todo lo que hace. Ahora vos me decís, tener registro de lo que hace con un grado de sensibilidad que hemos determinado entre varias direcciones o varias gerencias de ANSES. Sabemos que hay bases de datos que tienen una determinada sensibilidad y a esa base de datos sí le ponemos el ojo y la miramos con total detalle. Ahora. Si vos realmente te logoneaste, abriste un Word, abriste un Excel y trabajaste, es irrelevante y se está llenando almacenamiento de información para algo que no se utiliza para nada. Entonces, la respuesta es distinta desde mi punto de vista. Lo primero que tengo que decirte es no en función de cómo está formulada la pregunta, pero sí en relación a la sensibilidad de la información que ese individuo o quien sea acceda. O sea, no sigo al individuo. O sea, estoy mirando la base de datos, estoy mirando el sitio web, estoy mirando y registro, logueo, logueamos, registro la actividad sobre ese objeto. Luego veo quién es, o sea, no sigo a la persona. Miro el objeto para que el objeto no sea vulnerado. ¿Se entiende?

MOCIULSKY SANTIAGO: Ok, pero en caso de actividades como críticas o sospechosas, ahí sí hay un tipo de visualización para ver si está haciendo una actividad sospechosa o no. Por ejemplo, lo que vos decías de la base de datos, etc.

PITA GUILLERMO: Claro, pero vos fíjate que vos me estás hablando de la persona, de nuevo, o yo por lo menos lo escucho así, y yo te estoy hablando del objeto, que es la base de datos. O sea, yo le pongo la linterna a la base de datos y miro, no miro si Santiago, Federico o Guillermo fueron a la base de datos, miro quiénes fueron. ¿Sí? Y quiénes fueron si luego hay una actividad y alguien pide, che, ¿quiénes estuvieron entre tal hora y tal hora? accediendo a tales datos, te lo puedo decir. Ahora, vos imaginate que en 2.000 servidores la cantidad de carpetas compartidas que hay. No están todas las carpetas compartidas siendo, te pongo otro ejemplo, siendo analizadas a ver quién entró y quién salió de esa carpeta. No, porque es imposible registrar el 100 % de la actividad de todo el mundo porque no es relevante registrar el 100 % de la actividad de todo el mundo. Ahora, y la pregunta fuera, fuera. ¿Yo en este momento me puedo colgar de la sesión de alguien sin que se dé cuenta y ver qué está haciendo? Sí. ¿Puedo entrar a un equipo y analizarlo? Sí, porque es mi función. Ahora, eso no se hace en forma regular, porque es, ya te digo, no es ni económicamente ni funcionalmente relevante que yo vea el paso a paso como una hormiguita de qué está haciendo cada individuo. Yo miro los objetos sensibles. Por eso, con las organizaciones grandes, hay una tarea que se llama clasificación de información. La información se clasifica en función de su grado de criticidad. Si es muy crítica o sensible, menos o irrelevante de crítica. No sé, que yo tenga un Word con un memorándum en este momento en mi carpeta de memorándums. No es información crítica a la hora de la sensibilidad que puede tener versus una base de datos que tiene los sueldos y los aportes previsionales de todo el país.

¿Se entiende? Entonces, O sea, nosotros registramos actividad sobre objetos sensibles. Y si ese objeto sensible en algún momento es posible de una investigación, vemos qué actividad tuvo. O sea, qué personas . . . y desde dónde, y en qué espacio de tiempo . . . en forma remota, local, desde un móvil. Esa trazabilidad la tenemos, pero es posible mirar el 100 % de la información. Porque no es, insisto, como te decía al principio, No es relevante mirarlo porque no me dice nada si vos entraste a una carpeta tuya en tu estación de trabajo. ¿Para qué voy a registrar un evento que es irrelevante? Como que te dijera, estoy filmando el 100 % de tu vida. No, en todo caso, filmo cuando vas a una caja de seguridad. No estoy mirando el 100 %. ¿Se entiende un poco el ejemplo?

MOCIULSKY SANTIAGO: Sí, sí, se entendió perfecto. Ok.

PITA GUILLERMO: Perfecto.

MUNTAABSKI FEDERICO: Bueno, sigo yo, Santi. Volviendo un poco a esa pregunta que vos mencionaste, capaz no es tanto... mirar todo el recorrido que hace el usuario, sino ver los puntos más críticos. ¿Ustedes utilizan alguna herramienta para visualizar o tomar acciones con respecto a esto?

PITA GUILLERMO: Es que tomar acción no tiene... Por eso digo que no... Las preguntas, yo creo que sé a dónde van, pero tal vez no están determinadas, tan bien formuladas. Tomar acción. En el caso de que se requiera, voy y busco qué se hizo. Y sí, particularmente te decía al principio, antes de que llegue, perdón que estoy un poco con carraspera, Santiago. Tenemos un SIEM muy grande, Machazo, una bestia. Que colecciona y correlaciona los eventos que consideramos más importantes que lo que hablamos al principio, para poder tener trazabilidad de la actividad. O sea, la respuesta sería sí, pero obviamente siempre colocando en el tamiz qué evento estoy mirando, que era lo que hablamos al principio.

MUNTAABSKI FEDERICO: Claro, claro, entiendo, entiendo.

PITA GUILLERMO: O sea, es imposible mirar el 100 % de los eventos y categorías de cada evento que tiene Windows, que aparte no te va a decir nada. Es como que estés juntando y juntando y juntando cosas que...

MUNTAABSKI FEDERICO: Sí, no tiene sentido.

PITA GUILLERMO: Que después no usa.

MUNTAABSKI FEDERICO: Claro. Sí, nosotros quizás tenemos... en la propuesta, como mencionaste vos, ir más directo a unos casos de uso específicos y listo. Correcto. Bueno, paso con alguna otra pregunta y así vamos armando un poco el cierre o yo ando directo los puntos.

Por ejemplo, ¿a vos qué tan difícil es con las herramientas que tenés? que obviamente revisan los movimientos críticos, detectar un comportamiento legítimo y distinguirlo de uno que sea, por ejemplo, inusual. O sea, eso yo entiendo que vos mencionaste lo del SIEM, que es el que habías mencionado, que es el agente, no el agente, donde se recolectan la gran mayoría de los logs que llegan y ahí se hace la correlación.

PITA GUILLERMO: Correcto.

MUNTAABSKI FEDERICO: ¿Distinguen ustedes entre los comportamientos inusuales del comportamiento usual que se suele usar?

PITA GUILLERMO: Es que justamente es el caso de uso el que dispara el comportamiento inusual, porque si yo no, o sea, los 49 casos de uso crítico que yo te comentaba, básicamente lo que están buscando es comportamiento inusual. Entonces, a ver, como te decía al principio, si una persona se está logoneando en La Rioja y en Buenos Aires, con diferencia de 5 minutos. Eso salta, o sea, digo, es el caso de uso el disparador de la actividad irregular. Por eso, como decía Santiago antes, la actividad regular, salvo que sea sobre objetos críticos, no se logonea, porque si no, no es una locura. Ahora, no sé, por ejemplo, que una persona haya excedido una carpeta acá, y digo la carpeta porque la habían mencionado antes, acá y en La Rioja. A mí me es irrelevante porque previamente a ese evento tiene que haber un evento de login y ya lo atajo antes. Como que la red del medio mundo la tengo más chiquita al principio para no dejar pasar y no tener que estar mirando cosas que vienen después que van a estar diciendo algo que debería haber visto antes. ¿Se entiende? Sí. Básicamente el disparador es el caso de uso.

MUNTAABSKI FEDERICO: Claro. Consulta que no relacionado con... ¿Eso no sería algo parecido a un . . . o algo así?

PITA GUILLERMO: No, ¿un SIEM?

MUNTAABSKI FEDERICO: No, es la respuesta automática por casos de uso.

PITA GUILLERMO: Sí, podría ser, pero es la naturaleza de un SIEM. SIEM, ya te digo, colecciona y correlaciona, y tiene, si no sería una gran caja coleccionadora, y no tendría el sentido de la correlación. El sentido de correlación es el caso de uso que te analiza la correlación.

MUNTAABSKI FEDERICO: Claro. Bueno, ahí, un minutito. Busco otra pregunta. Bueno, esta es una pregunta bastante más genérica que dice, ¿qué características valorás más vos en una herramienta que ayuda al equipo de seguridad?

PITA GUILLERMO: Me estás hablando, si me gustan más las noruegas, las finlandesas, las brasileras, las herramientas, lo que te quiero decir es una pregunta tan genérica que no te la puedo

responder directamente. Cada herramienta tiene una función y no es lo mismo proteger un sitio web que proteger las conexiones este o este, que son las conexiones internas dentro de un data center, que las conexiones norte-sur, que son las que van y vienen de internet. Cada cosa tiene su importancia relativa. No puedo decirte que algo es más importante que otra cosa. Te puedo decir que lo mínimo indispensable para que un data center esté protegido... decir las tres o cuatro herramientas que no pueden faltar. Pero la pregunta como está formulada de, si mal no recuerdo, me dijiste cuál era la más importante. No hay una más importante. Hay varias muy importantes que hoy con la realidad de la ciberseguridad actual no pueden faltar si lo que está protegiendo o la organización es una organización que se jacte de estar protegiendo sus activos. No sé si se entiende. No es una sola. Son varias. Algunas pueden faltar, sí. No deberían, pero obviamente si tengo que rankear no puedo colocar una delante de otra.

MUNTAABSKI FEDERICO: Claro, entiendo. Ok, pero entonces dentro de esas características que vos nombraste son...

PITA GUILLERMO: Importante es que algunas pueden faltar que no son tan necesarias.

MUNTAABSKI FEDERICO: ¿Cuáles son las que no pueden faltar nunca dentro de todo este ámbito?

PITA GUILLERMO: Lo que no puede faltar, básicamente es un firewall de borde, un Next Generation Firewall, no puede faltar jamás. No puede faltar una herramienta que esté detectando denegaciones de servicio en diferentes capas del modelo OSI, no es lo mismo una negación de servicio sobre el DNS, que es capa 3, capa 4, que es capa 7, que es aplicación. Por eso no quiero entrar en tecnicismos, pero hay cosas que no pueden faltar en relación, a ver, no puede para mí, en un centro de cómputo, no puede faltar una herramienta de microsegmentación. Sería una locura no tener una herramienta de microsegmentación sólida que te permita dividir la red en segmentos y que si alguien quiere hacer lo que se llama, ustedes saben lo que es ransomware, sí. Sí. Bueno, o sea, el ransomware se basa no solo en atacar un equipo, sino hacer movimiento lateral y tratar de ir de un lado al otro. Una herramienta de microsegmentación lo que te permite es controlar el tráfico en cada equipo crítico. Y que cuando alguien intenta hacer un movimiento que no tiene que hacerlo o intenta reemplazar un proceso que ya está hallado previamente por el propio agente de microsegmentación, no permite el reemplazo. O sea, el ransomware actúa normalmente conectándose a un servidor llamado de comando y control. Y empieza a bajar software, que generalmente es software que busca enmascararse en nombre de archivos ya existentes. No sé, sistema, librerías. Y vos tenés, desde el momento en que el agente de … tocó ese equipo, halló todos los procesos y todos los archivos de este tema, y vos querés reemplazarlo, el tipo automáticamente te bloquea y bloquea la conexión. Entonces, hay herramientas que no pueden faltar. Te digo, un Next Generation Firewall, no puede estar faltando. Un … puede faltar, es

una locura, pero puede faltar. Pero el borde tiene que estar protegido. El borde lo proteges con un firewall, el borde lo proteges con un dispositivo de negación de servicio, un WAF, un web application firewall, que es otra cosa distinta. Web application, o sea, aplicaciones web, no puede estar faltando si tienes una presencia de internet fuerte, porque te van a estar destrozando los sitios web. robándote información o denegándote la actividad. Entonces hay cosas que no pueden faltar.

MOCIULSKY SANTIAGO: Ok. Para cerrar, ya medio que cubrimos un poco todo, vos sentís que hay algo que nos faltó preguntarte que pueda ser importante que entendamos para todo lo relacionado a nuestra propuesta, que supongo que te comentó Fede anteriormente.

PITA GUILLERMO: No diría que faltó. Creo que lo que ustedes tienen que llevar, como mochila, y se lo comentaba Federico al principio, o tiene que tener grabado a fuego, es la desconfianza digital. O sea, quien se dedique a ciberseguridad debe ser un maestro en enseñar a desconfiar. Entonces, todo debe ser validado más de una vez, todo debe ser coleccionado y correlacionado y probado en más de una oportunidad, y por otro lado, estar constantemente pensando en que lo que está sucediendo digitalmente no es lo que dice ser. El día que te paras desde ese lugar de la vereda, estás haciendo bastante mejor tu laburo de ciberseguridad. Porque la confianza mata al hombre. Y cuando vos no ves que hay del otro lado, es increíble. Porque yo hasta lo he leído en análisis psicológicos de ciberdelincuentes, no puedo entender todavía como una persona... se deja seducir por una pantalla bonita sin saber que del otro lado, o sea, esa pantalla bonita le está diciendo, le está generando confianza de que del otro lado hay gente seria y responsable. Y no entiendo desde dónde sacan eso. Ahora, el ciberdelincuente aprovecha esa situación para que, y esto tómenlo como estadística porque es una realidad, el cibercrimen en este momento recauda más que el narcotráfico, recauda más que la trata de personas, recauda más que el tráfico de armas en su conjunto. Y en el año 2025 recaudó más que el PBI de la Unión Europea en general. O sea, ni siquiera el PBI de Alemania. El primer PBI del mundo es Estados Unidos, el segundo es China, el tercero es el cibercrimen. Y si la gente desconfiara más de lo digital, no sería así.

MOCIULSKY SANTIAGO: Bueno, con esto yo creo que preguntamos todo lo que necesitábamos. así que ya por mi parte... No sé si Fede quiere aportar algo más.

MUNTAABSKI FEDERICO: A mí, Guillermo, yo te quiero agradecer primero por atendernos. Ya sé que tienen horarios recontro ocupados y bueno, ya tuve 5 llamados en el mes. Así que muchísimas gracias por eso y también muchísimas gracias por el feedback que diste al principio, ok. Porque en todas las entrevistas que habíamos tenido, por lo menos nadie nos había criticado o puesto el foco en lo que quizás es realista. Y eso ayuda un montón.

PITA GUILLERMO: Yo tengo un concepto muy arraigado en mi vida, soy un tipo grande, ya tengo varias heridas de guerra, y aparte fui militar, independientemente de la herida de guerra. como es. Yo soy muy amigo de la crítica constructiva, muy amigo. O sea, a mí, el que me digan las cosas lindas. O sea, lo destructivo sí no me gusta, pero no me molesta en lo absoluto. Que alguien me diga, che, mirá, me parece que es por este lado y no por él, ah, mirá, qué bueno, me convenciste, listo, y voy por ese lado. Entonces, esa fue mi intención desde un principio, o sea, ser crítico constructivamente para que, en todo caso, cambien un poco el enfoque, eso te lo digo desde la experiencia de, dos décadas de estar haciendo esto.

MUNTAABSKI FEDERICO: Claro, perfecto. Así que nada, eso sería todo, pero gracias en sí.

PITA GUILLERMO: No, no, por favor, ningún problema.

MUNTAABSKI FEDERICO: Y después, si no te molesta, si podías completar una encuesta que tarda unos cinco minutos, como mucho, después en algún momento que tengas libre, no es necesario ahora. Dame un segundo, te mando el forms, te lo mando por...

PITA GUILLERMO: Haz una cosa, anotá mi celular. Porque si bien yo tengo mucha actividad de mail, obviamente si no te tengo agendado no te voy a atender. Pero mandame un WhatsApp. Y en todo caso, si hubiera una necesidad más adelante, me pingueas, pingueas, mirá ese ser informático, pingueas, pingueas de la red, ¿no? Y en la … usamos eso, nosotros … pingueo. O sea, me mandás un mensajito por WhatsApp, anótalo, **********. Un poquito más lento. Yo soy medio eléctrico, pero sí. *******. Perfecto. ********. Perfecto. Listo. Muchísimas gracias, Guillermo. Muchas gracias. No, todo bien. Hasta luego. Hasta luego. Buen día.

MOCIULSKY SANTIAGO: Igualmente.

Anexo F: Transcripción de la entrevista a Alejandro Francisco Peña

Entrevistado: Peña Alejandro Francisco (jefe de seguridad, compañía financiera regulada)

Entrevistadores: Muntaabski Federico, Mociulsky Santiago

MUNTAABSKI FEDERICO: Bueno, ahí arranco yo con las preguntas. La primera pregunta sería, ¿cómo describirías el mayor desafío de seguridad que enfrentas hoy en relación al comportamiento de usuarios dentro de tu organización o de las empresas que vos trabajas?

PEÑA ALEJANDRO FRANCISCO: A ver, ¿cuál es el mayor desafío hoy que hay? Justamente un poco el tema de, lo que comentan ustedes, el tema del control. Determinar en todo momento la posición de seguridad de los endpoints, sería.

MUNTAABSKI FEDERICO: Claro. Ehm.

PEÑA ALEJANDRO FRANCISCO: Este. hoy en día este y en tema además de que obviamente los endpoints, cuando hablamos de endpoint, hablamos también de dispositivos móviles, hablamos de sobre todo de las laptops corporativas, ¿no? Desde, bueno,

PEÑA ALEJANDRO FRANCISCO: ¿Qué está haciendo? No el que está haciendo desde un punto de vista por ver qué hace el usuario, ¿no? Pero ¿qué acciones está realizando? Y más allá de eso, ¿qué tipo de software puede llegar a correr? en su entorno, porque si bien yo puedo limitar muchas veces la instalación, por ejemplo, de algún tipo de sistema, hay programas que por ejemplo no piden principios privilegios de administrador y de todas maneras puedo instalarlo, puedo instalar programas portables, etcétera. Eso a veces Puede llegar a ser un riesgo hasta un simple plugin de Chrome, por ejemplo, no, si no, si la compañía no tiene a nivel corporativo, por ejemplo, el Chrome. Con …, sí, una extensión sencilla de Chrome que puede hasta hacer un robo masivo de datos o un simple lector de PDF. Este Sobre todo, es importante también destacar el tema también, por ejemplo, de el phishing, ¿no? Y cuando hablamos de phishing, hablamos de robo, y también el tema del ransomware, no que generalmente los usuarios pueden llegar a descargar, etcétera. Hoy está bastante mitigado por lo que son las herramientas de… ya sea de antivirus por heurística, lo puedes bloquear a nivel firewall, sin esa inspección de… inspección de paquetes. Tenés varias capas. De hecho, la seguridad se basa en capas, no vas a poner una sola herramienta, pero bueno, básicamente eso ahí es donde más me. Y por ejemplo, también que los usuarios no puedan … controles, no por ejemplo, que deshabiliten el proxy, no, por ejemplo, si bien puedo hacerlo por política de AD. Sí, que no puedan tocar esa configuración, obviamente que la vez es muy … en ese sentido. Hay usuarios que por las tareas que realizan, a

veces requieren que yo no pueda tener que bloquear el proxy. Por ejemplo, no sé a los usuarios de TI o ciertos usuarios desarrolladores, no, o sea, necesitan de esa flexibilidad. Y ahí es donde se me complica, porque el desarrollador es un especialista técnico, sabe lo que hace. Pero también es donde más tengo el riesgo, ¿no? Ahí es donde más por ahí apuntaría.

MUNTAABSKI FEDERICO: Perfecto. Bueno, ahí paso a la siguiente pregunta. Bueno, justo mencionas lo de los endpoints Ahora la pregunta va más por el ¿Qué tipo de incidentes de seguridad relacionados con usuarios? Por ejemplo, credenciales comprometidas, uso indebido de datos Por ejemplo, vos mencionabas que hoy en día es importante y hay un montón de herramientas para usar en conjunto para lo que es el tema de evitar esos plugins que pueden aparecer. La pregunta sería ¿Qué tipo de incidente de seguridad? relacionados con usuarios, tuvieron más impacto en los últimos 2 o 3 años que vos te acuerdes que estuviste trabajando en tu empresa.

PEÑA ALEJANDRO FRANCISCO: Sí, puede ser este justamente todo lo que es la parte de robo de de credenciales y abuso de privilegios. ¿O sea, un usuario legítimo, no? Por ejemplo, un… un administrador de los del dominio que se toma ciertas libertades, como por ejemplo. ¿Resetear la … del compañero en un entorno regulado, como puede ser un entorno bancario o similar, no? No respetando el circuito.

MUNTAABSKI FEDERICO: Claro.

PEÑA ALEJANDRO FRANCISCO: Después el tema también de algo muy candente hoy en día es. El tema del uso de la inteligencia artificial también. ¿Qué datos suben los usuarios? ¿A qué tipos de…? Sí. Si vos no tenés una política de proxy bastante granular y selecta. O una buena gobernanza no hacen problemas.

MUNTAABSKI FEDERICO: Bueno, ahí paso con o … Santi.

MOCIULSKY SANTIAGO: Si viene ahora…

MOCIULSKY SANTIAGO: Ok, en mi consulta es, o sea, después de que un usuario se autentica …, supongo que utilizan en su empresa. ¿El área de ciberseguridad tiene algún tipo de visibilidad de las acciones que realiza durante su sesión o de, por ejemplo, elementos críticos a los que accede?

PEÑA ALEJANDRO FRANCISCO: Por supuesto, eso está no solamente auditado para el análisis forense, sino también por regulaciones, ya sea de PCI, Banco Central, etcétera, está regulado. Nosotros no podemos dejar al usuario libremente al azar. De hecho se controla hasta si hiciste click en el mute de Teams para que te hagas una idea. Y cuánto tiempo inclusive pasó

una persona en el call, con quién, si cortó, pero fue la llamada, calidad. Inclusive hasta mide la calidad de la conectividad a internet, para que se den una idea. Se mide todo lo que pasa por proxi. Y después, bueno, cada herramienta también tiene su registro de auditoría, no, pero a lo que es IAM también hay que ver también este. Las posiciones no, por ejemplo, no es lo mismo un usuario que se conecta desde el dispositivo móvil o un usuario que se conecta desde Uruguay, es decir, hay cierto. A ver, cierta. Ahí no me sale. Cierto cambio, digamos, cuando según el contexto, ahí está este que son políticas, acceso condicional, ahí está, no es la palabra, acceso condicional, que es cuando, por ejemplo, el usuario en determinado evento lo dejo o no lo dejo, eso lo hace. Hoy en IAM, sí, lo que también algo muy importante es nosotros tenemos entornos regulados y demás grandes grandes empresas. Se suelen tener bóvedas, no donde yo tengo así como ustedes pueden tener un. . ., por ejemplo, para borrar las contraseñas vieron.

MOCIULSKY SANTIAGO: Mhm.

PEÑA ALEJANDRO FRANCISCO: o un administrador de claves existen administradores de claves corporativos en donde yo puedo guardar todas las claves de todos mis sistemas y servidores y además los accesos privilegiados. Bueno, ante esos casos obviamente El IAM, obviamente no actúa, el que actúa ahí directamente es el. . . cómo se llama el la bóveda no lo que usas de Como por ejemplo no sé . . . les puedo dar un nombre. . . Búsquenlo después para que sea una idea de lo que es. Ese sí me graba inclusive hasta la sesión, audita, etcétera. Lo que Estaría bueno

MOCIULSKY SANTIAGO: Hmm.

PEÑA ALEJANDRO FRANCISCO: Va a ser muy difícil, no creo que lo puedan hacer porque son productos cerrados. este. Pero bueno, ahí tienen algo bastante crítico que es, por ejemplo, cuando un usuario pide acceso administrativo, ¿no?

MOCIULSKY SANTIAGO: Hmm. Ok, o sea, y me puedes repetir un poco lo último que no termine de entender.

PEÑA ALEJANDRO FRANCISCO: Claro. A ver, repetir la pregunta si la contextualizo.

MOCIULSKY SANTIAGO: Sí, o sea que después de que un usuario se autentica exitosamente, el área de ciberseguridad tiene alguna visibilidad de lo que hace cada persona en la sesión.

PEÑA ALEJANDRO FRANCISCO: Okay. Sí, al menos.

MOCIULSKY SANTIAGO: Okay.

PEÑA ALEJANDRO FRANCISCO: Totalmente y de hecho se audita y …, perdón, se audita y se deja, se deja constancia y registro y muchas veces depende del tipo de acciones hasta se pueden. hacer acciones en tiempo real. Como por ejemplo, si yo empiezo a descargar desde Microsoft Drive absolutamente todos mis archivos, porque no sé, los quiero bajar un pendrive, eso automáticamente dispara una alerta en el SOC. Y el SOC actúa inmediatamente notificando al usuario si esa acción es legítima o no. Sí, porque puede haber un robo de datos, por ejemplo.

MOCIULSKY SANTIAGO: … O sea, actúa en casi al momento con respecto a lo que se está haciendo, se encuentra.

PEÑA ALEJANDRO FRANCISCO: … le llega la alerta del tablero y actúa.

MOCIULSKY SANTIAGO: Genial, okay. Y más o menos a esto va como enganche a otra pregunta justo que teníamos ¿Cuánto tiempo tarda entre que sale esa alerta hasta que por ejemplo un equipo lo soluciona? O sea, es casi al momento o, por ejemplo, se tardan un par de días.

PEÑA ALEJANDRO FRANCISCO: Depende, a veces generalmente la alerta es una suerte de aviso vía mail que tiene que resolver el usuario. Y siempre está copiado el jefe del área, por ejemplo, no este y tiene que resolverlo depende que se la no. Dos o tres días, por ejemplo, tiene que dar respuesta de si fui yo. No, no fui yo. Sí, obviamente que ahí se genera una brecha porque si definitivamente te robaron datos y vos no fuiste. No bien, les pongo un ejemplo concreto. Recuerdo yo una vez que fui a las oficinas de Google y fue a un evento, me conecto con la máquina corporativa. Y no me acuerdo por qué se empezó a sincronizar… ¿Qué pasó en la alerta del SOC? ¿Cuál fue como Google tiene una conexión de evidentemente por VPN y yo estaba saliendo? un enlace que era el ISP de Google, saltó una alerta. Dijo: Che, está Alejandro Peña en dos lugares al mismo tiempo, me dijo. O sea, el ya me tenía de alguna manera en Buenos Aires Y de alguna manera Office 365 me decía Çhe, pero estoy saliendo por... por otro lado"Sí, o sea, el IAM, cuando yo hago el Authenticator, vino Microsoft Authenticator que tiene el doble factor, bueno, el celular mío estaba físicamente en Buenos Aires. Y la máquina era como que salía ¿No la conectividad IP con una IP de Estados Unidos que era de Google, no? Entonces era muy particular el asunto, o sea, entonces eso dio una alerta del SOC diciendo, che, comentame acá qué pasó. De hecho, me acuerdo que por qué traigo esto, porque fue un análisis que tuvimos que hacer, es decir, dónde sale esta IP? ¿Quién es? ¿Por qué yo me metí acá? Estuvimos un rato analizando con los chicos hasta que me acordé que yo me había conectado. Sí, este, pero bueno, en todo …, por ejemplo, pasaron 3 días. Sí, hasta que yo me acordé, analicé. Sí, y generalmente ese análisis se hace acompañado en mi caso porque era del área de seguridad, no, pero ese análisis se tiene que hacer acompañado con alguien del SOC. Sí, también hay a veces que es mucho más rápido, por ejemplo, en nuestro caso, que somos una compañía financiera. En el caso, por ejemplo, de que a muchas veces los datos de tarjeta de crédito son muy, son muy sensibles y

estamos regulados. Hay usuarios, por ejemplo, de call center, que son datos …, le dicen: 'Ay, me hacés una planilla que me ordene estos datos de mano mayor.' Ahí la alerta es inmediata y se genera un bloqueo inmediato. El usuario directamente se bloquea, creo que se bloquea el usuario y se manda a ver al jefe, algo así. Totalmente violento. ¿Por qué? Porque ya está filtrando datos, por ejemplo, a un sistema que está totalmente fuera de alcance de la norma. Y ahí sí se toma acción inmediata. O sea, va a depender Mucho del caso y de la particularidad.

MUNTAABSKI FEDERICO: Joya, sigo yo, Santi, si querés. Bueno, voy a pasar a la siguiente pregunta. ¿Qué tan difícil resulta Y. Va, viste, vos mencionaste que justo en esa ocasión trabajabas con un equipo de SOC, según entendí.

PEÑA ALEJANDRO FRANCISCO: Sí.

MUNTAABSKI FEDERICO: ¿O sea, qué tan difícil les resulta distinguir entre un comportamiento legítimo? Un comportamiento legítimo, pero que es inusual y una amenaza real cuando, por ejemplo, hay una sesión.

PEÑA ALEJANDRO FRANCISCO: Es que no podés, siempre te vas a hacer en sospechas.

MUNTAABSKI FEDERICO: Claro.

PEÑA ALEJANDRO FRANCISCO: Y. Entonces, ahí es más fácil. Hasta que no descartaste todas las opciones y hablarte precisamente con la persona o analizaste efectivamente un log, no hay chance de que vos puedas saber. Si se trata de una acción legítima o ilegítima. Siempre se presupone ilegítima.

MUNTAABSKI FEDERICO: Claro, el hecho de el cero trust, el siempre desconfiar y todo, sí, y nada, una pregunta que viene de, o sea, viene en parte de esto, que es como siempre, estás como desconfiando.

PEÑA ALEJANDRO FRANCISCO: Siempre.

MUNTAABSKI FEDERICO: de las acciones. ¿O sea, qué costo tiene para el negocio el falso positivo? O sea, el hecho de bloquear un usuario que en realidad no era, como por ejemplo, viste, vos mencionaste tu caso que saltaban alertas que en realidad vos no habías hecho nada ilegítimo, simplemente fue parte de lo que es la conexión con Google.

PEÑA ALEJANDRO FRANCISCO: No genera costo y depende. Es muy difícil medirlo cuantitativamente, pero sí te puede generar mucho lo que se conoce como roce político. No porque, por ejemplo, yo le puedo bloquear la operación a un desarrollador y ese desarrollador tiene que sacar un feature para hoy que está comprometido con cliente y yo de seguridad lo

bloqueo. y por ahí no le di tiempo, o no le di bola, no le di bolilla a esa resolución. Eso sería un costo político, ¿por qué? Porque se escala. Me dicen "no, yo no puedo trabajar porque a mi seguridad me bloqueó". Entonces, en el mejor de los casos, que todo funciona bien, Si seguridad tiene un SLA de 2 horas, está dentro del SLA. Y vos por ahí retrasaste a ese desarrollador que quería lanzar, no sé, un PR, por ejemplo, por así decirlo, o no puede probar algún feature y lo estás demorando. Y el negocio quiere salir y generalmente seguridad se… se vuelve un bloque, ¿no? Entonces es no pasa tanto por costo monetario, sino más por costo político, que termina siendo monetario en …, no a la larga. genera mucho ruido siempre eso. Por eso siempre hay que tener mucho cuidado. Y por eso cuando ustedes al principio me dijeron esto toma acción automática se me asusta, entendés. Porque, Che, ¿Qué tipo de acción? Primero siempre el sistema tiene modo monitoreo y muy gradualmente ir Ajustando Las acciones que toman de manera autónoma. Si bien, obviamente, yo voy a querer el …, etcétera, primero quiero que la empresa continúe. Trabajando y no. Y no que me llame … o me llame. el c level para explicaciones de Por qué estamos bloqueando a todos los usuarios, no. O por qué se hizo un bloqueo masivo por un falso positivo que esa gente detectó. Sí, eso sería mucho más grave que bloquear por bloquear. O sea, Generalmente seguridad es visto como una como un área que hace poco no aporta valor y que encima bloquea. Esa es la visualización que generalmente se tiene de seguridad hasta que pasa un incidente y se acuerdan de seguridad. O sea, es bastante complejo mostrar al directorio el valor que tiene seguridad. ¿Por qué? Porque obviamente El dolor de seguridad lo vas a ver lamentablemente.

MUNTAABSKI FEDERICO: Sí, muy bueno ese análisis, … del tema de del valor que aporta la seguridad, que claramente, como mencionas, o sea, no lo ves hasta que te pasa.

MUNTAABSKI FEDERICO: Con todos los problemas que lleva una filtración de datos o cosas por el estilo. Y. La pregunta, la siguiente, estaba muy relacionada justo con la duda que tenías vos de tipo que nosotros habíamos mencionado de que nuestra aplicación iba a bloquear de forma automática las sesiones De alto riesgo. Y la pregunta dice literalmente, si se presentas una herramienta que actúas de forma automática sobre sesiones de riesgo tomando acciones, como por ejemplo, te niega el acceso a una carpeta, termina un proceso. ¿O aísla la conexión de red de ese equipo? ¿O sea, qué condiciones vos pensás que deberían ser para que esas acciones se den de forma automática y qué nivel de severidad? ¿Vos necesitarías conocer antes de exigir que una persona, por ejemplo, del SOC, confirme que se ejecuta una acción?

PEÑA ALEJANDRO FRANCISCO: Eso va a depender mucho de del contexto y del contexto. No te puedo dar la respuesta. Tajante porque va a depender mucho del modo de gerenciamiento que vos tengas del área. Va a depender mucho de la organización, del tiempo organizacional, porque las organizaciones obviamente no son siempre estáticas. Entonces, por ahí hay veces que

vas a requerir si bloquea todo durante primeros meses y después viene. Otros aires políticos y te dicen, no, dejame permitir todo. Entonces nada, vas de alguna manera adaptando, sí, siempre con un criterio lógico, las políticas, no, y va a depender mucho también del tipo de rol que tenga esa persona. No es lo mismo bloquearle a un desarrollador, nada de... de hecho, algo de un de un sistema interno a bloquearle, no sé el acceso a su código fuente a un desarrollador que tiene mi hoy tiene mi producto estrella, no. Este, hay que tener muy en cuenta todo el contexto organizacional, no antes de tomar cualquier política. Lo mismo pasó, por ejemplo, esto también un análisis. Similar. ¿Cuando la compañía se implementó el sistema de DLP, no? Entonces, bueno, ¿quién puede cambiar la etiqueta de confidencialidad? ¿Quién puede bajarla si no está el owner, quién desempata, etcétera, no? O sea, se dieron muchos casos particulares y hasta que la organización. Logró en su cultura entender el sistema ... e incorporarlo pasaron más o menos 1 año. Y hablo algo totalmente sencillo, como un DLP configurado casi mínimo, sí, para cumplir una norma. Nada, además a mí, como estando en el área de seguridad, como ustedes me dicen, todo lo que toma acción a mí me da miedo. O sea, en el sentido de ojo, soy cauteloso con todo lo que toma acción automática. Sí, ¿por qué? Porque generalmente las acciones automáticas justamente. Por ... ínfima, por ahí te te hizo una te hizo peor el remedio de la enfermedad, no, porque por ahí te bloqueo en cadena a toda un área entera. Sí, y después tenés que dar vos darle explicaciones de che, ¿qué pasó acá? Entonces hay que ser muy cauteloso en eso. y. o por ahí mismo peor todavía decís çhe, mirá, el SOC es un área crítica.ºk y entramos en un autobloqueo, o sea, yo soy SOC o yo soy analista de seguridad pero me está autobloqueando la misma herramienta, ¿no? ¿Qué pasaría en esos loop, en esos casos también? Planteo que son totalmente válidos, ¿no? Por eso no ... una respuesta única a esa pregunta, pero nada, si yo pusiera un ejemplo, bueno, no sé, debería ser. Hay que analizar también qué tipo de comportamiento, qué tipo de features. Etcétera, va a depender mucho del rol. No es lo mismo, por ejemplo, bloquearle a un C level, no que C level es más complicado. ¿Por qué? Porque es la persona que más libertad quiere y es la persona que más debo proteger, porque es la que quizás más una de las personas que más información confidencial quizá pueda llegar a tener, no entonces. ¿Es ahí bastante complejo, no? Y me imagino bloqueándole que este no sé que la herramienta de ustedes por comportamiento lo bloquea el CEO de la empresa y yo no lo primero que va a decir sácame esto, sí, este. Y vos vas y no tenés, no te quedé otra que decís ... me aceptas el riesgo, sí... Va a depender mucho también de imagínense que este armado los armados este tipo de políticas lo hacen equipo de gobierno de seguridad de la información. Se tiene que hacer un análisis que puede llevar seis meses como mínimo para implementarlo En una empresa mediana, no de mediana a grande. Si hagamos una pyme, bueno, sería un poco más sencillo, sí, y un poco más amigable, y ahí sería otro.

MOCIULSKY SANTIAGO: genial bueno pasamos a la última pregunta había una más pero literalmente la respondiste la respondiste que era con respecto a los roles y había que tomar

mucho en cuenta eso pero ya nos lo dijiste y con

PEÑA ALEJANDRO FRANCISCO: Okay. Sí. . . . lo más importante.

PEÑA ALEJANDRO FRANCISCO: Es uno de los puntos más importantes que tenga distintos tipos de perfiles la herramienta, no, o sea, que yo pueda crear mi propio perfil, sí, y que actúe y no se puede subir o bajar el perfil, no de riesgo, por ejemplo. Es importante también que tenga métricas, que tenga herramientas de monitoreo, la herramienta.

MOCIULSKY SANTIAGO: Sí.

PEÑA ALEJANDRO FRANCISCO: eso es muy importante, las auditorías. A mí el auditor me solicita, me dice: Ah, vos no tenés métricas de esta herramienta. Mostrame. Ah, mostrame que hizo toda la . . . Pepito. Pero después tu herramienta sí me va a servir por ejemplo para un análisis forense, entendés. Ahí sí la voy a valorar mucho por ahí

PEÑA ALEJANDRO FRANCISCO: Este para un forense, para ver todas las . . . que hizo la persona, etcétera, como un complemento quizá de todos los logs que tenga, porque yo lo que tengo que hacer después es una correlación de eventos. Sí, por ejemplo, si yo quiero, no sé, decir que tal persona robó información de manera. Deliberada para la competencia que, de hecho, es un caso real que nos sucede a nosotros en la compañía. Estamos en un juicio de por espionaje industrial justamente por eso. Eh. Y bueno, nada se sospechó de una persona que sí, efectivamente vendía datos en la competencia, este vendía código fuente, básicamente.

MOCIULSKY SANTIAGO: Okay. Sí, nuestro sistema un poco, te comento, justamente tiene planeado eso de que se vaya adaptando al comportamiento normal de cada usuario. Para eso está el modelo de Inteligencia artificial que se va a entrenar con actividades que vayan haciéndose de cada usuario o de cada rol para ser más abarcativo.

MOCIULSKY SANTIAGO: Y en base a eso va a definir lo que es. Raro o no, okey. Pero como última pregunta, un poco es saber si sentís que no te preguntamos algo y que es importante que sepamos o que entendamos para nuestro proyecto sobre lo que te contamos.

PEÑA ALEJANDRO FRANCISCO: Bien. Sí, todo lo que lleva . . . también me genera cierta cuestión. ¿Por qué? Porque yo me imaginé si que tengo el antivirus, tengo el proxy, tengo fulano, tengo Sultano. Cada vez le sumo más cosas a las máquinas, a los . . ., esas cositas que voy sumando, me van consumiendo RAM, me van consumiendo cómputo. Sí, y cada vez como que le agrego más capas. Entonces es como digo, bueno, ¿cómo tienen planeado ustedes hacer ese agente? ¿Le valoran el impacto? ¿Pensar en los dispositivos multidispositivo está pensado para Windows o. . .? ¿Cuéntenme ahí un poco al revés la pregunta, no? Por ejemplo, en la compañía

nosotros tenemos varios desarrolladores que trabajamos Mac, por ejemplo, y siempre es un gran problema Mac, porque la mayoría de las.

PEÑA ALEJANDRO FRANCISCO: De justamente este tipo de agentes, por ejemplo, el Fortinet, por ejemplo, de nuestra VPN, el …, que es el antivirus, el otro agente del proxy y demás, no funcionan de la misma forma como funcionan en Windows de manera totalmente transparente y legítima. No, entonces siempre tenés que buscar. Algún tipo de work around para que funcione en MAC y seguramente hay poco soporte. Entonces siempre se vuelve como una especie de dolor de cabeza. Obviamente que si es compatible con Windows se compra la herramienta, no es un no-go que no tenga para soporte para MAC, pero es indeseable, sí que che. también soporta Mac y lo soporto. Y y ahí te ganaste todos los premios, por ejemplo, de MercadoLibre, que también usa Mac, y un montón de organizaciones medianas a grandes hoy en día. Con la al bajar un poco los … de las Mac y los usuarios sentirse valorados porque le das Mac es un… es un plus muy importante. También el desarrollador que vos le …, se siente muy valorado y a veces la compañía lo suele tratar como un incentivo.

MUNTAABSKI FEDERICO: No.

MOCIULSKY SANTIAGO: En un comienzo lo pensamos para Windows, pues yo según mi opinión, o según lo que tenía entendido, la mayoría de las computadoras corporativas son de Windows, muy pocos casos hay de Mac. Entonces sentimos que era lo que era más abarcativo.

MUNTAABSKI FEDERICO: Sí, pues. Sí.

MOCIULSKY SANTIAGO: pero sí está bueno y para más adelante lo podríamos ver tema adaptarlo para…

MUNTAABSKI FEDERICO: Sí.

PEÑA ALEJANDRO FRANCISCO: O sea, … en el proyecto, … exploratorio, Ustedes me dicen, no, mira, en las próximas versiones va a salir la listo, yo les puedo llegar a comprar.

MUNTAABSKI FEDERICO: Hmm.

PEÑA ALEJANDRO FRANCISCO: Pero la pregunta acá como líder se las había, le digo, che, y esto para MAC porque automáticamente pienso en, es más, se viene a la cabeza 5 o 6 desarrolladores que tienen MAC, varios jefes de seguridad tienen MAC.

MUNTAABSKI FEDERICO: Sí. Sí. Sí.

PEÑA ALEJANDRO FRANCISCO: Okay.

MUNTAABSKI FEDERICO: Sí, los puntos que planteaste son . . . y más, sobre todo el que mencionaste, el de la performance de los agentes cuando cuando les vayamos agregando cosas, es un punto.

PEÑA ALEJANDRO FRANCISCO: Yo pregunto, ustedes . . ., pensaron al revés, ¿qué pasa si un atacante toma posesión de. . .? Pensaron la postura de tu producto.

PEÑA ALEJANDRO FRANCISCO: Desarrollo seguro y demás para este producto, que es un producto de seguridad. Ojo con eso también, o sea, evaluarlo, no digo que lo pongan en el TFI y demás, simplemente de yo a ustedes, digamos, algo así como de . . . de café, no de si este producto de verdad salía del mercado, tienen que pensar eso. Che, estoy . . . un producto de seguridad. Imagínense si viene un. un atacante sí y usa mi producto como caballo . . . porque encontró una vulnerabilidad y como corre en background con . . . elevados y acceso a todas las computadoras de la red ¿Pueden generarme una catástrofe en cadena? Sí, puede ser realmente los que este tipo de agentes suelen ser un punto interesante para los como vector de ataque. ¿No, cómo se va a comunicar? ¿Cómo va a ser la comunicación entre agente y servidor? La arquitectura va a ser distribuida, centralizada, va a ser en la nube, va a requerir Internet. . .

MOCIULSKY SANTIAGO: Okay.

MUNTAABSKI FEDERICO: Claro, sí, esas sí son preguntas que sí.

MOCIULSKY SANTIAGO: Sí.

MUNTAABSKI FEDERICO: Perfecto. Bueno, yo creo que esto sería todo, ¿no, Santi? Sí. Sí.

Anexo G: Cuestionario escrito respondido por Matías Gabriel Ruiz

Entrevistado: Ruiz Matías Gabriel
Formato: cuestionario escrito (10 preguntas), no conversación grabada

Pregunta 1: ¿Cómo describirías el mayor desafío de seguridad que enfrentás hoy en relación con los usuarios de tu organización/lugar de trabajo?

RUIZ MATÍAS GABRIEL: El mayor desafío es garantizar que los usuarios accedan únicamente a la información y funcionalidades que les corresponden, sin afectar la experiencia de uso. También es importante detectar rápidamente comportamientos anómalos, especialmente en aplicaciones críticas donde un uso indebido puede generar un impacto operativo o financiero.

Pregunta 2: ¿Qué tipo de incidentes de seguridad relacionados con usuarios han tenido más impacto en tu empresa en los últimos dos años?

RUIZ MATÍAS GABRIEL: Los incidentes de mayor impacto suelen estar relacionados con el compromiso de credenciales, accesos no autorizados, intentos de phishing y errores operativos derivados de permisos incorrectos. También representan un riesgo los accesos no autorizados desde fuera del país; este tipo representa uno de los campos de mayor alerta en el último tiempo.

Pregunta 3: Después de que un usuario se autentica exitosamente, ¿qué visibilidad tiene el área de ciberseguridad sobre lo que hace durante esa sesión?

RUIZ MATÍAS GABRIEL: La visibilidad depende de las herramientas implementadas por la organización. Generalmente se centralizan eventos mediante SIEM y otras soluciones de monitoreo, registrando autenticaciones, accesos, cambios relevantes y eventos de seguridad. Estas herramientas permiten correlacionar eventos, generar alertas e iniciar investigaciones, aunque no siempre ofrecen una visualización completa de toda la actividad del usuario en tiempo real.

Pregunta 4: ¿Cuánto tiempo pasa normalmente entre que ocurre una actividad anómala y que tu equipo la detecta?

RUIZ MATÍAS GABRIEL: Depende del tipo de evento y de las reglas de monitoreo. En incidentes críticos la detección puede ser prácticamente inmediata mediante alertas automáticas, mientras que otros casos pueden detectarse minutos u horas después durante los procesos de análisis y correlación.

Pregunta 5: Cuando sospechan que hay actividad sospechosa en una sesión activa, ¿cómo es el proceso desde que lo detectan hasta que toman una acción concreta?

RUIZ MATÍAS GABRIEL: Primero se valida la alerta para descartar falsos positivos. Luego se recopilan evidencias, se analiza el contexto del usuario y, si el riesgo lo justifica, se escala al equipo correspondiente para aplicar medidas como bloquear la cuenta, revocar sesiones, limitar accesos o aislar el equipo afectado siguiendo el procedimiento de respuesta a incidentes.

Pregunta 6: ¿Qué tan difícil les resulta distinguir entre comportamiento legítimo inusual y una amenaza real dentro de una sesión activa?

RUIZ MATÍAS GABRIEL: Es uno de los mayores desafíos, especialmente cuando usuarios con privilegios realizan tareas poco frecuentes pero válidas. Por eso resulta fundamental combinar el contexto del negocio, el perfil del usuario, su historial de comportamiento y la información proveniente de múltiples fuentes antes de tomar una decisión.

Pregunta 7: ¿Cuáles son los principales desafíos que enfrenta hoy tu equipo en materia de monitoreo de usuarios?

RUIZ MATÍAS GABRIEL: Los principales desafíos son reducir los falsos positivos, correlacionar información proveniente de diferentes herramientas, obtener contexto suficiente para priorizar incidentes y responder rápidamente sin afectar la continuidad operativa del negocio.

Pregunta 8: ¿Qué características valorás más en una herramienta que ayude al equipo de seguridad?

RUIZ MATÍAS GABRIEL: Valoro especialmente la capacidad de integración con el ecosistema existente (SIEM, XDR, IAM y ticketing), la detección basada en comportamiento, la automatización mediante playbooks, la trazabilidad completa de las acciones, la facilidad para investigar incidentes y la generación de alertas con contexto suficiente para reducir falsos positivos.

Pregunta 9: ¿Qué factores considerás que aumentan el riesgo asociado a un usuario, por ejemplo si depende del rol o de la actividad?

RUIZ MATÍAS GABRIEL: El riesgo depende principalmente del nivel de privilegios del usuario, la criticidad de la información a la que accede, el tipo de operaciones que puede realizar, la ubicación y el dispositivo desde donde accede, el horario de actividad y cualquier desviación significativa respecto de su comportamiento habitual.

Pregunta 10: ¿Hay algo sobre este tema que no te preguntamos y que creés que sería importante que entendiéramos?

RUIZ MATÍAS GABRIEL: Más allá de la tecnología utilizada, el éxito del monitoreo de usuarios depende de una adecuada definición de procesos, roles y políticas. Las herramientas son un facilitador, pero su efectividad está directamente relacionada con la calidad de las reglas de detección, la integración con el resto del ecosistema de seguridad y la capacitación continua de los usuarios y de los equipos de respuesta.

Anexo H: Diagramas ampliados

Este anexo presenta las versiones completas de los diagramas de la sección 6, de las que el cuerpo muestra una vista de diseño: el diagrama de flujo de información (figura 6.1), el de componentes (figura 6.2), el de clases del agente (figura 6.3) y los cinco diagramas de clases de la API (figuras 6.5 a 6.9). Como su tamaño original no permite leer el texto a ancho de página, cada diagrama se divide en una mitad izquierda y una mitad derecha. Cada mitad ocupa una página y reproduce el diagrama original sin cambios. En la versión digital del documento, los diagramas se conservan en formato vectorial, por lo que pueden ampliarse sin pérdida de calidad.

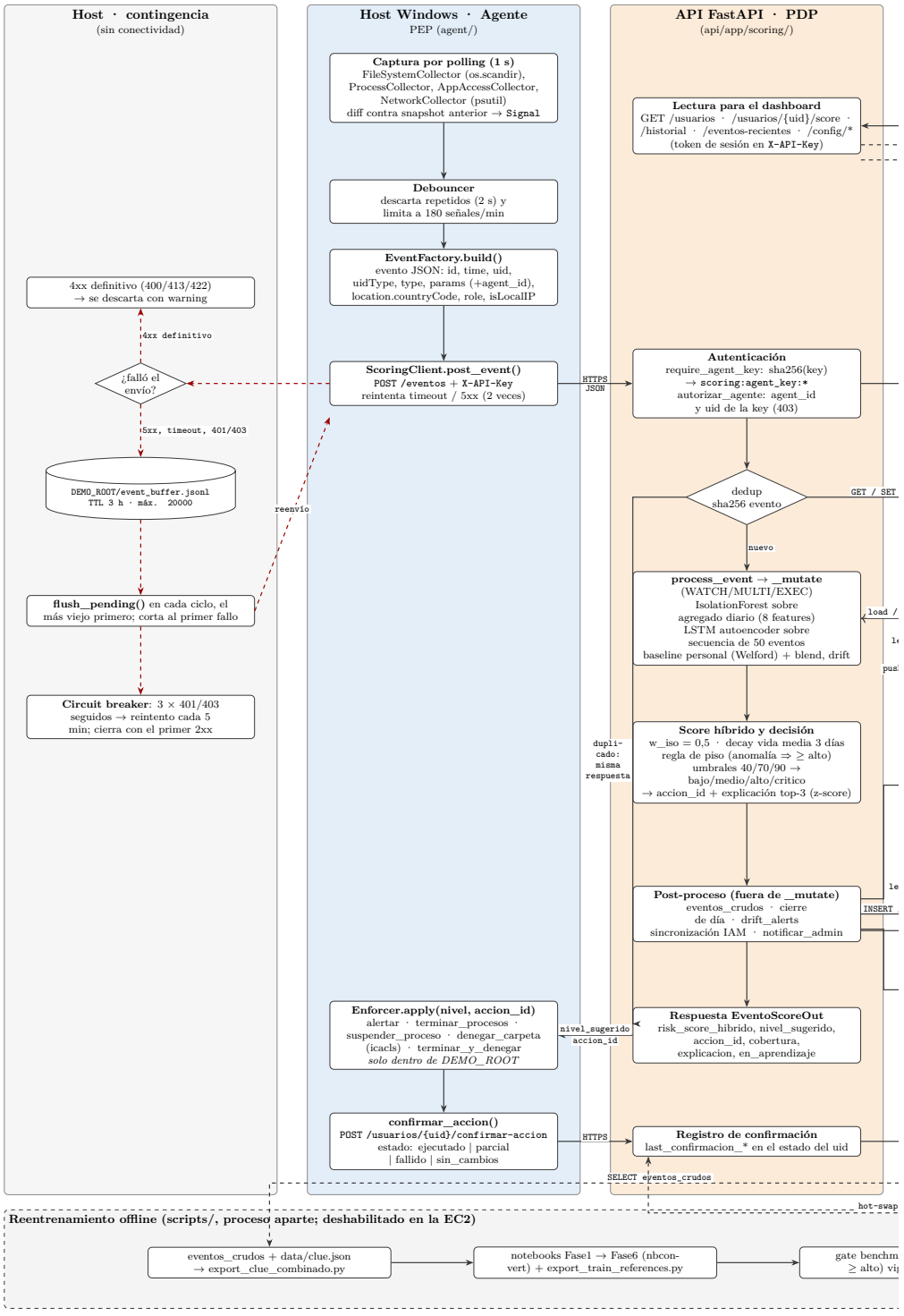


Figura H.1: Diagrama de flujo de información del sistema, versión completa (mitad izquierda)
Fuente: elaboración propia.

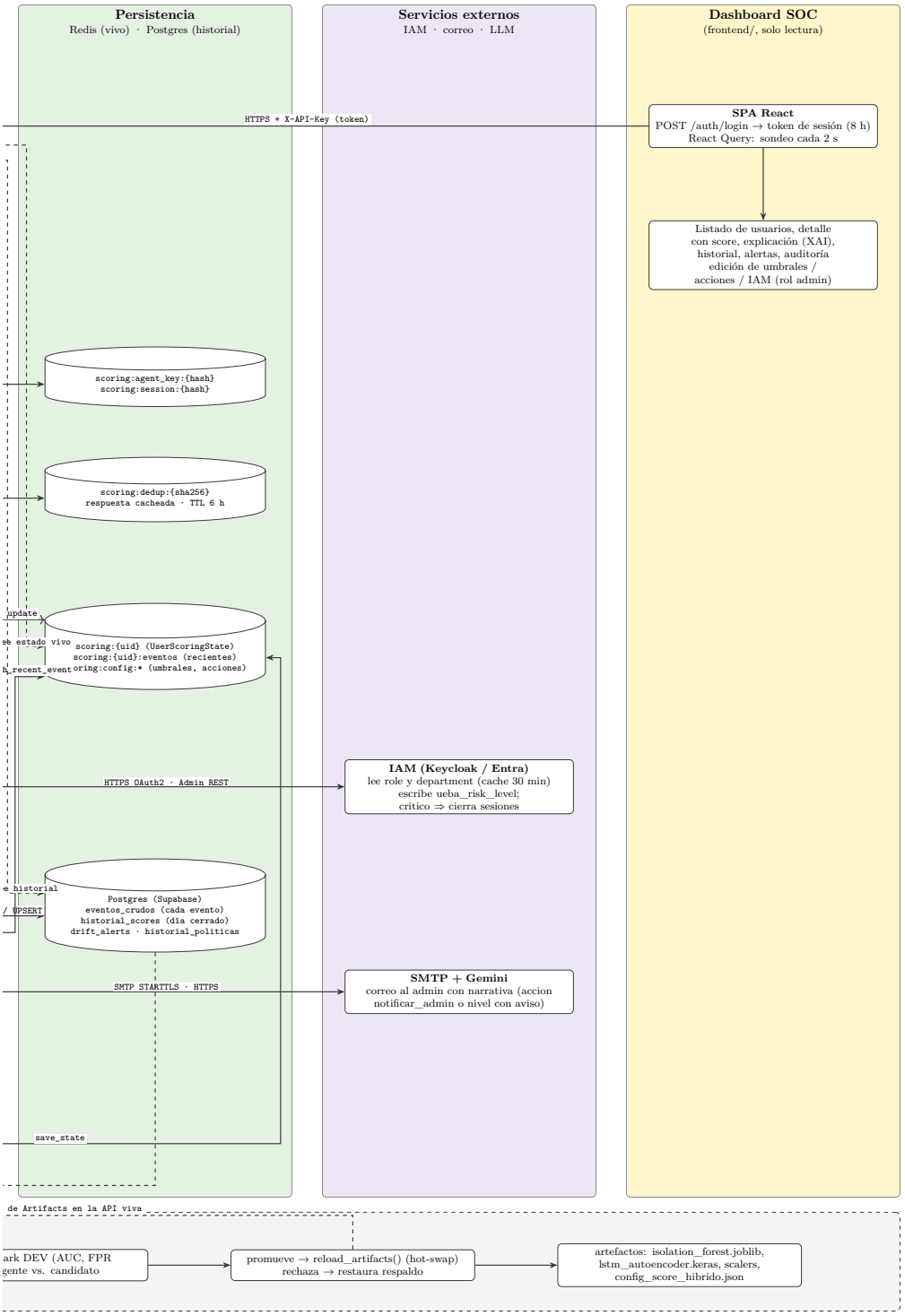


Figura H.2: Diagrama de flujo de información del sistema, versión completa (mitad derecha)
Fuente: elaboración propia.

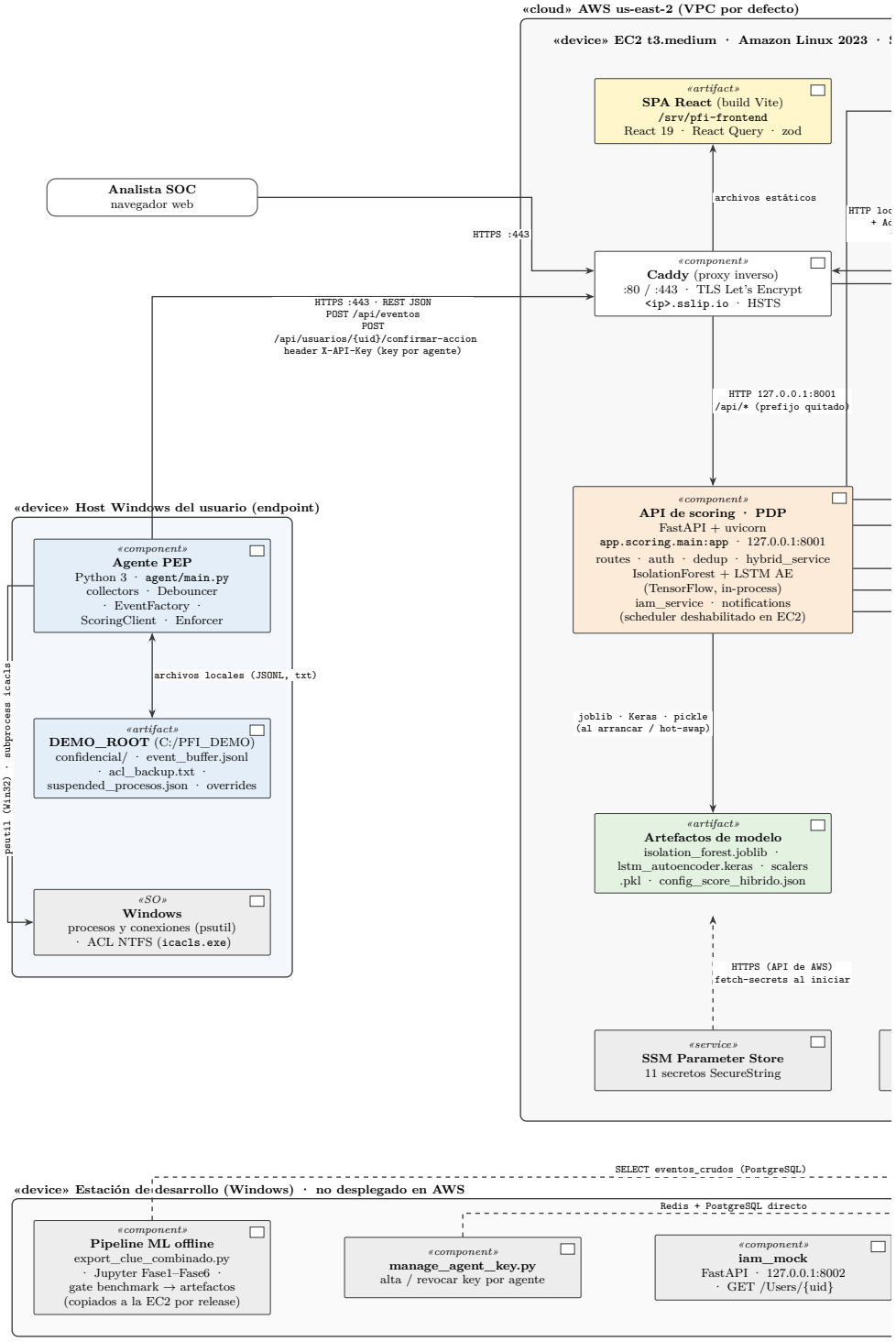


Figura H.3: Diagrama de componentes con protocolos de comunicación, versión completa (mitad izquierda)

Fuente: elaboración propia.

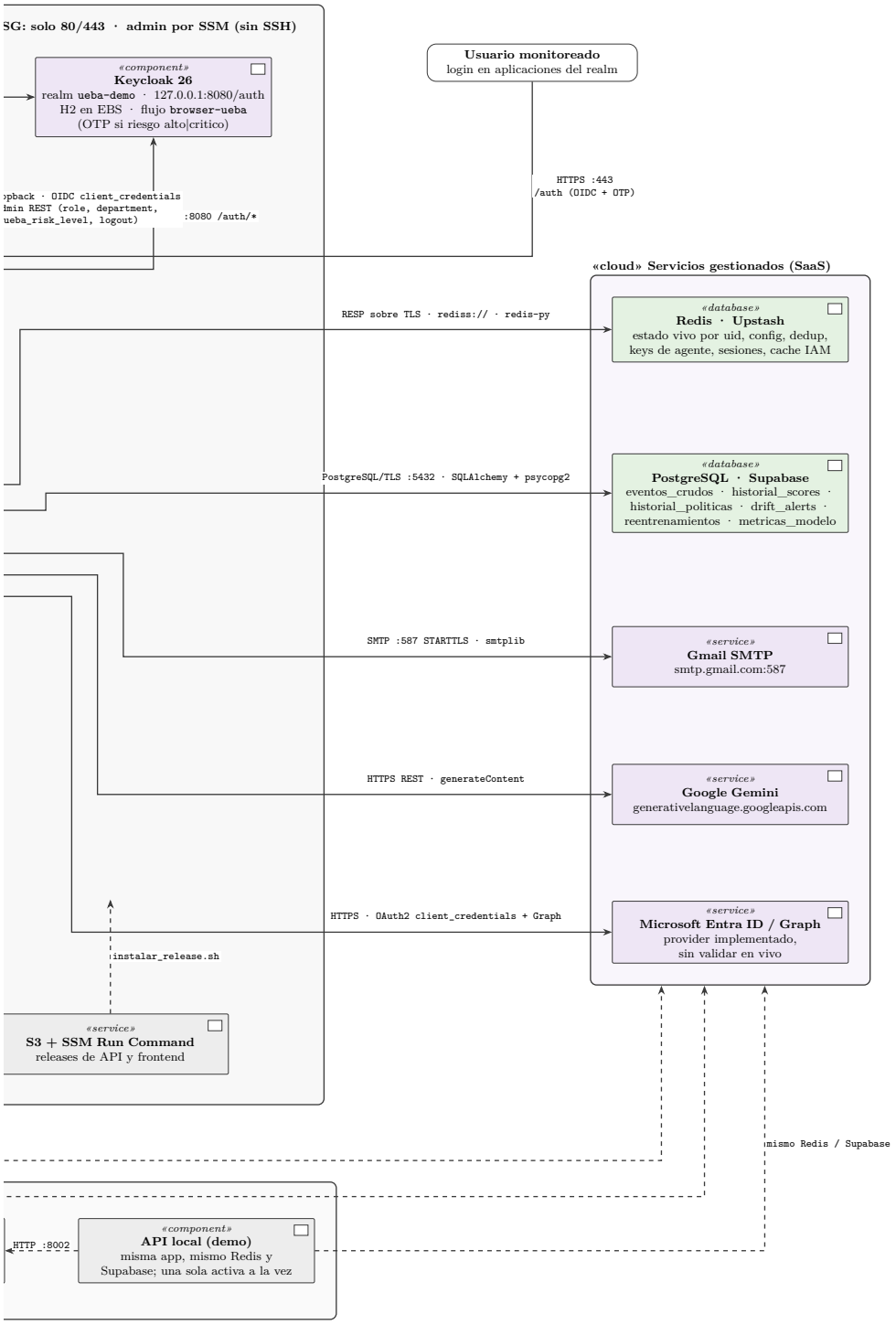


Figura H.4: Diagrama de componentes con protocolos de comunicación, versión completa (mitad derecha)

Fuente: elaboración propia.

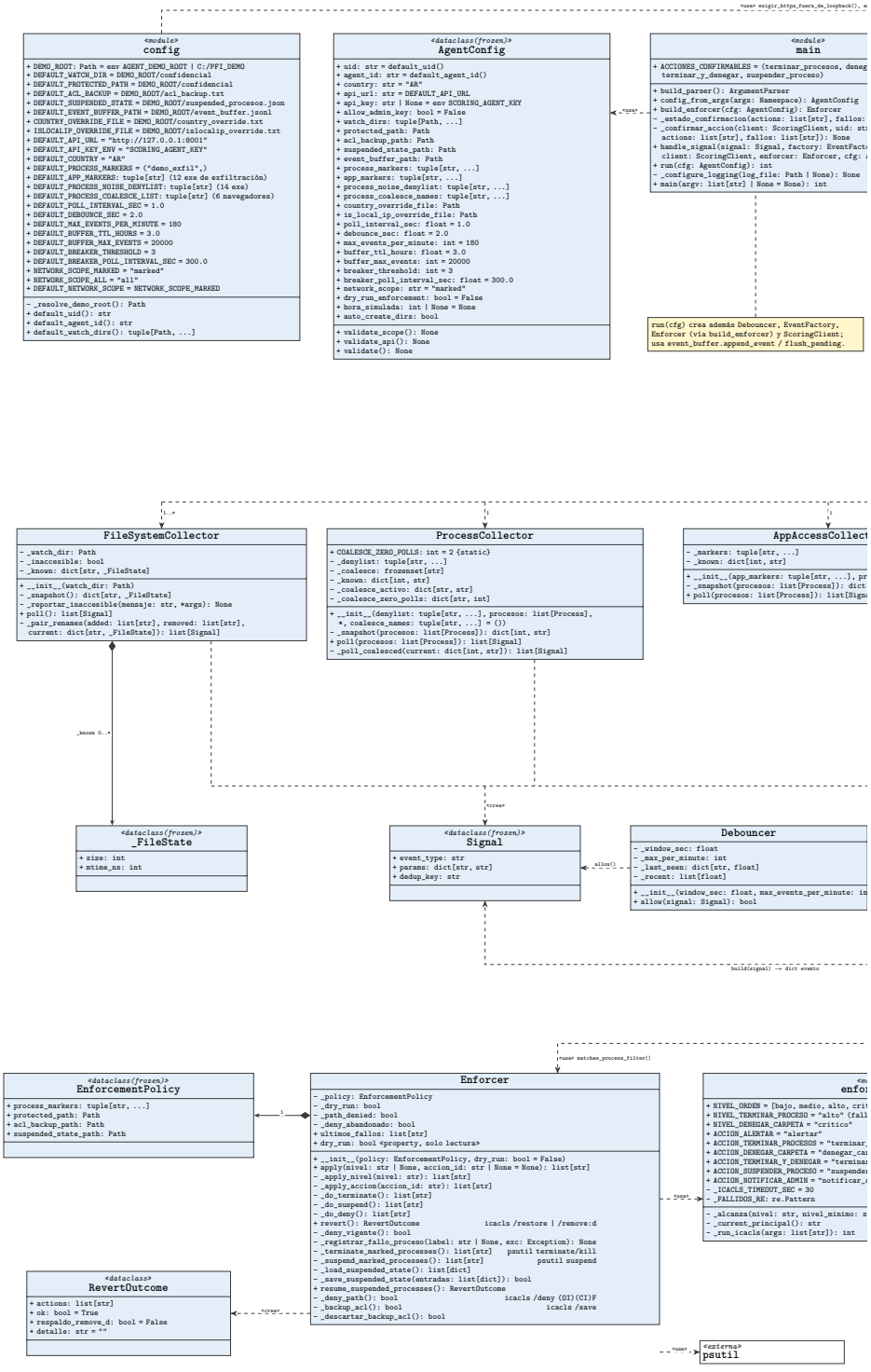


Figura H.5: Diagrama de clases del agente PEP, versión completa (mitad izquierda)
Fuente: elaboración propia.

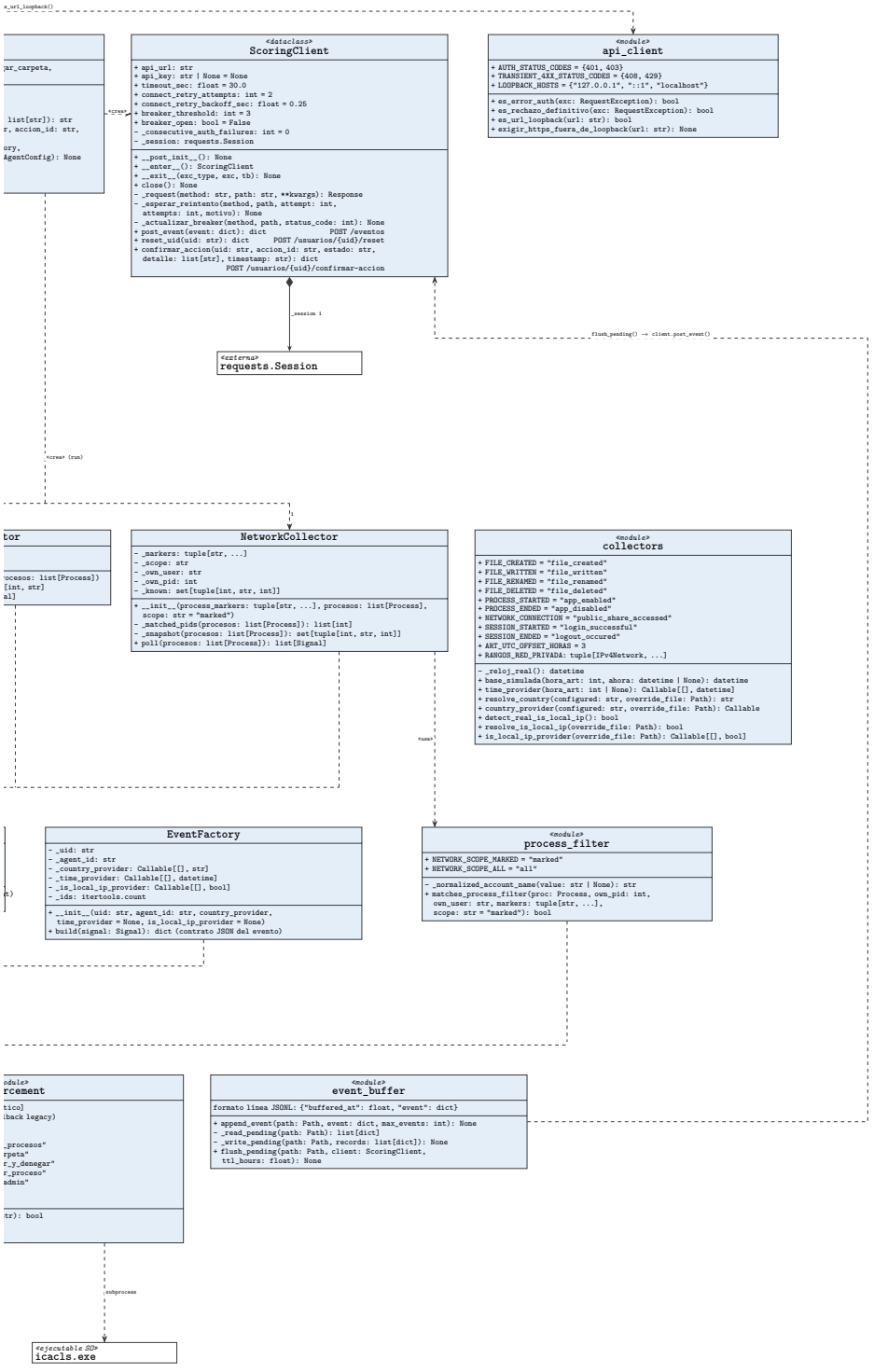


Figura H.6: Diagrama de clases del agente PEP, versión completa (mitad derecha)
Fuente: elaboración propia.

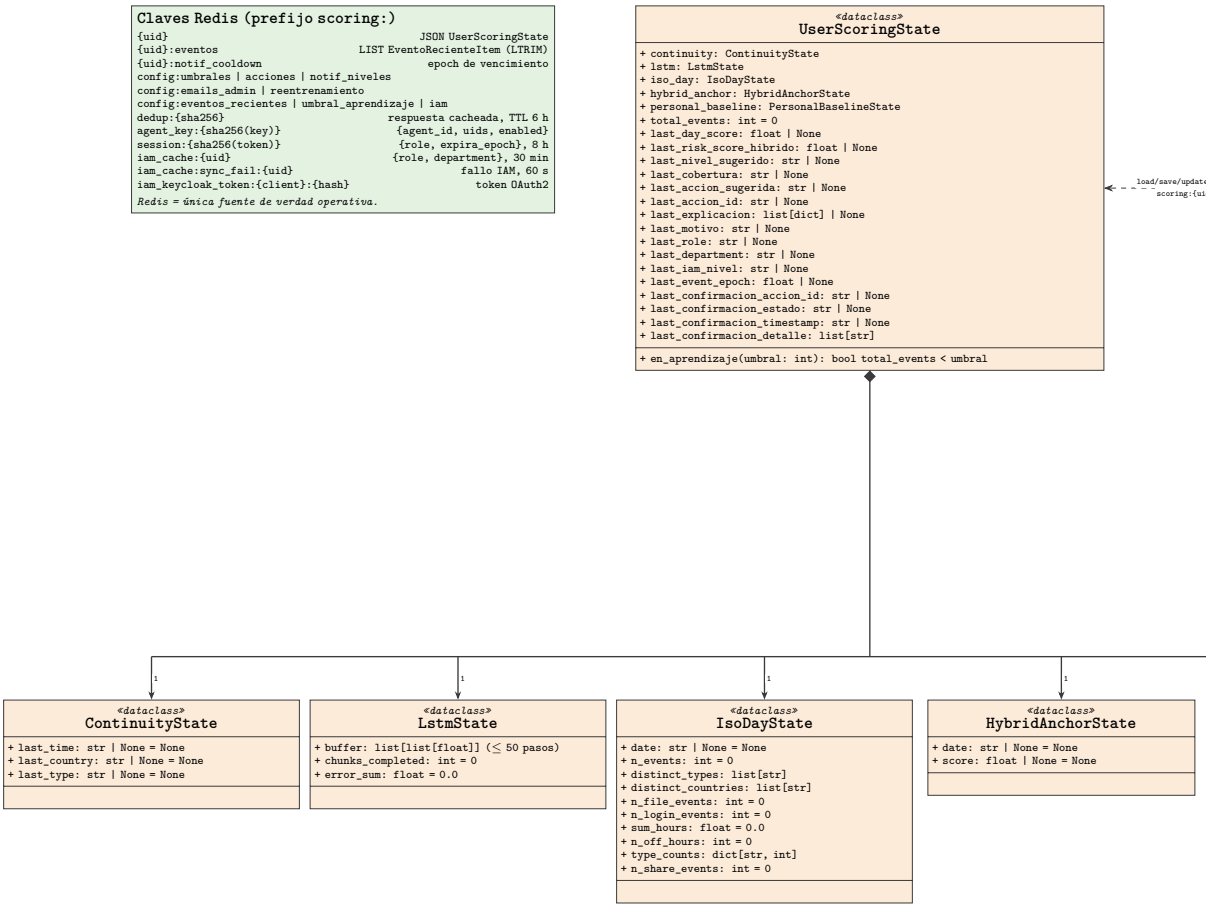


Figura H.7: Diagrama de clases de la API PDP: estado del usuario en Redis, versión completa (mitad izquierda)

Fuente: elaboración propia.

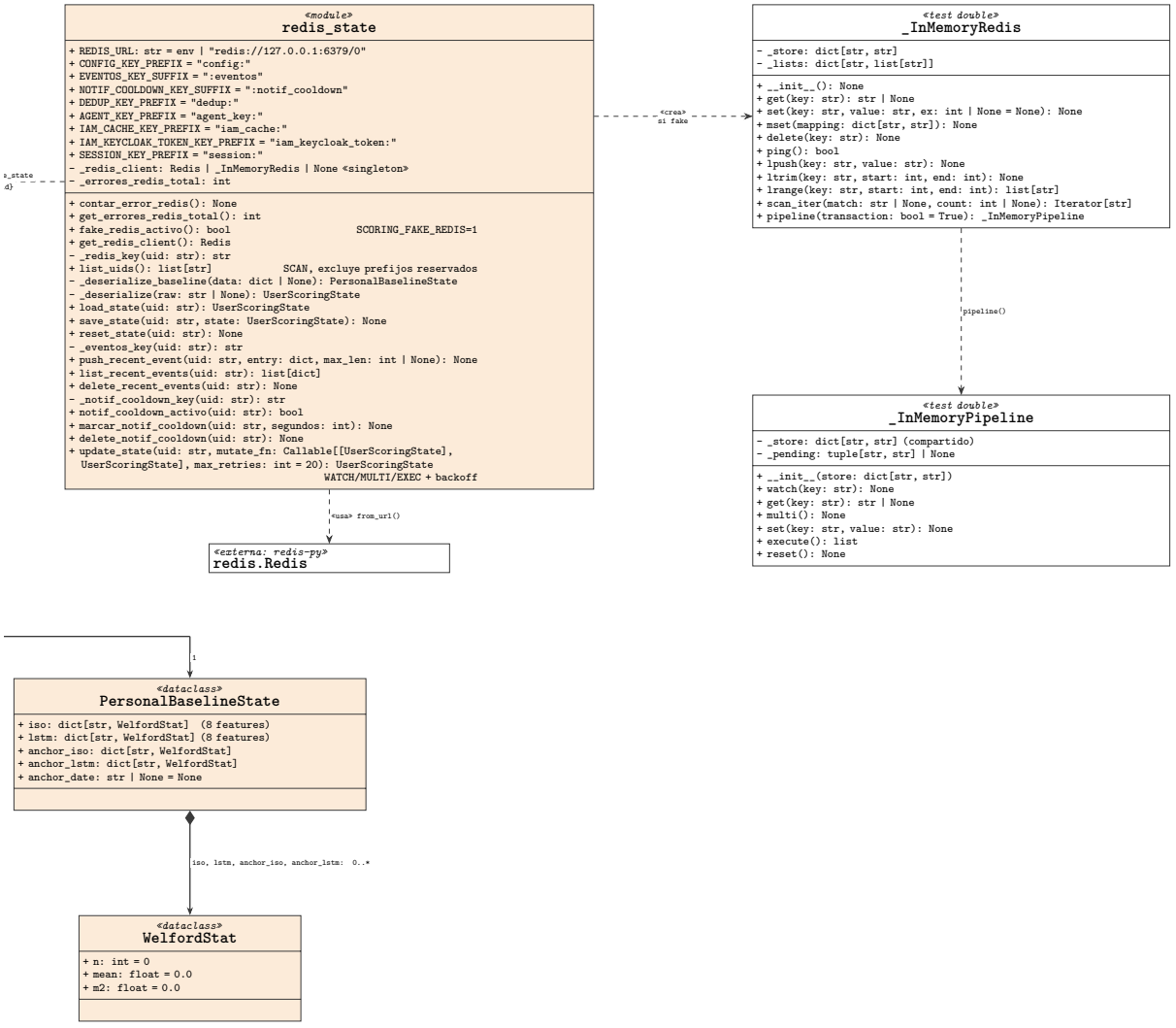


Figura H.8: Diagrama de clases de la API PDP: estado del usuario en Redis, versión completa (mitad derecha)

Fuente: elaboración propia.

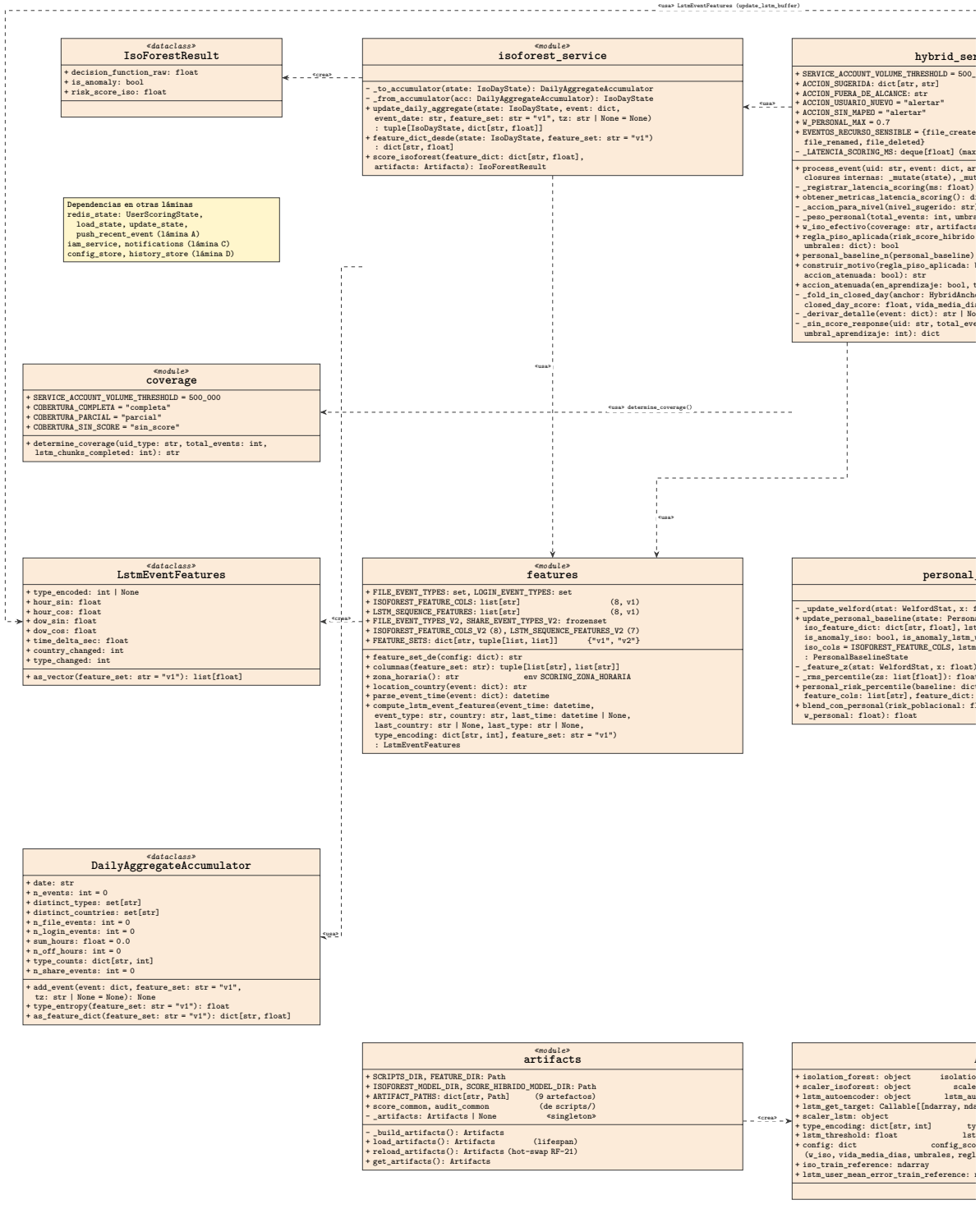


Figura H.9: Diagrama de clases de la API PDP: puntaje y modelos, versión completa (mitad izquierda)

Fuente: elaboración propia.

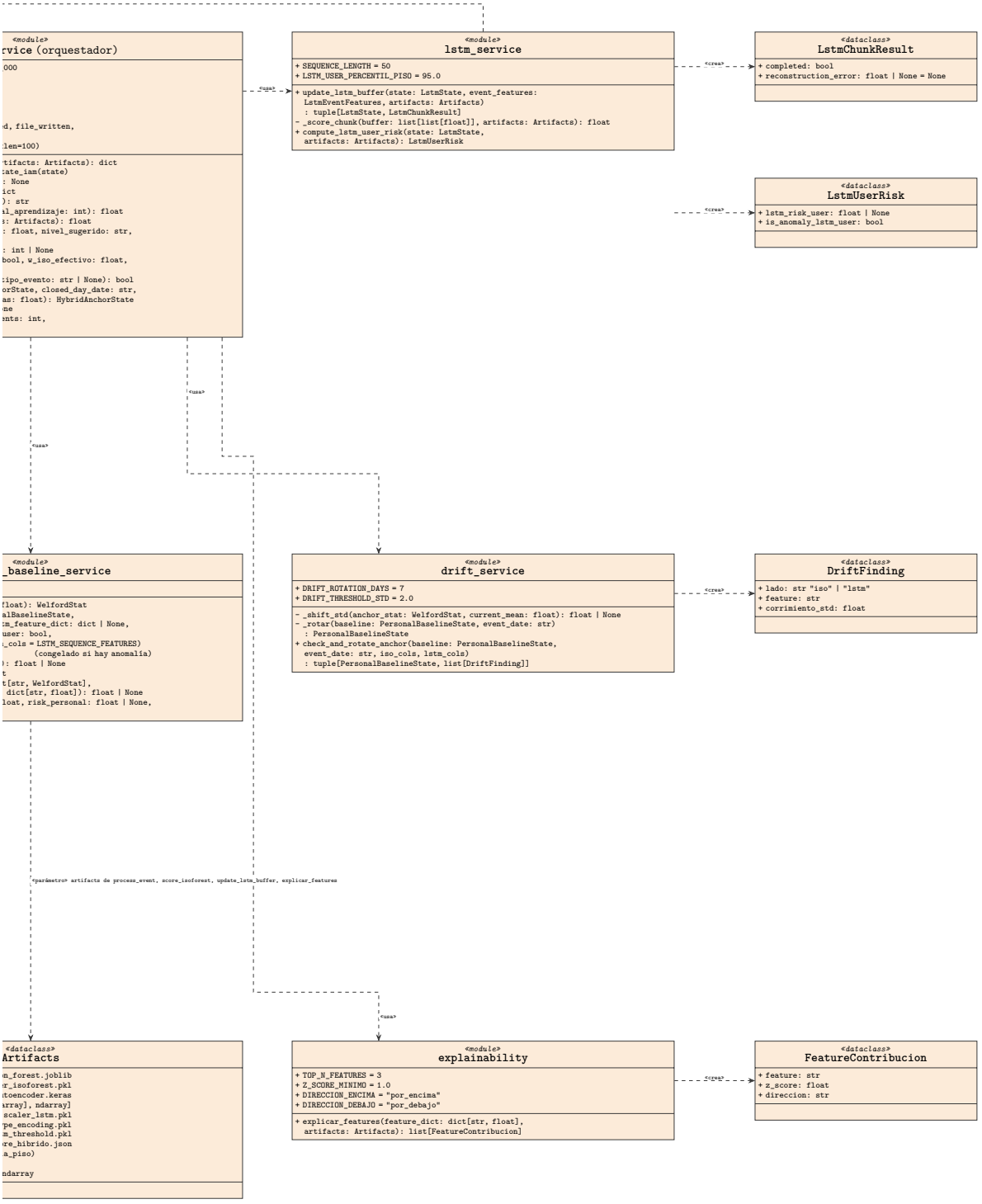


Figura H.10: Diagrama de clases de la API PDP: puntaje y modelos, versión completa (mitad derecha)

Fuente: elaboración propia.

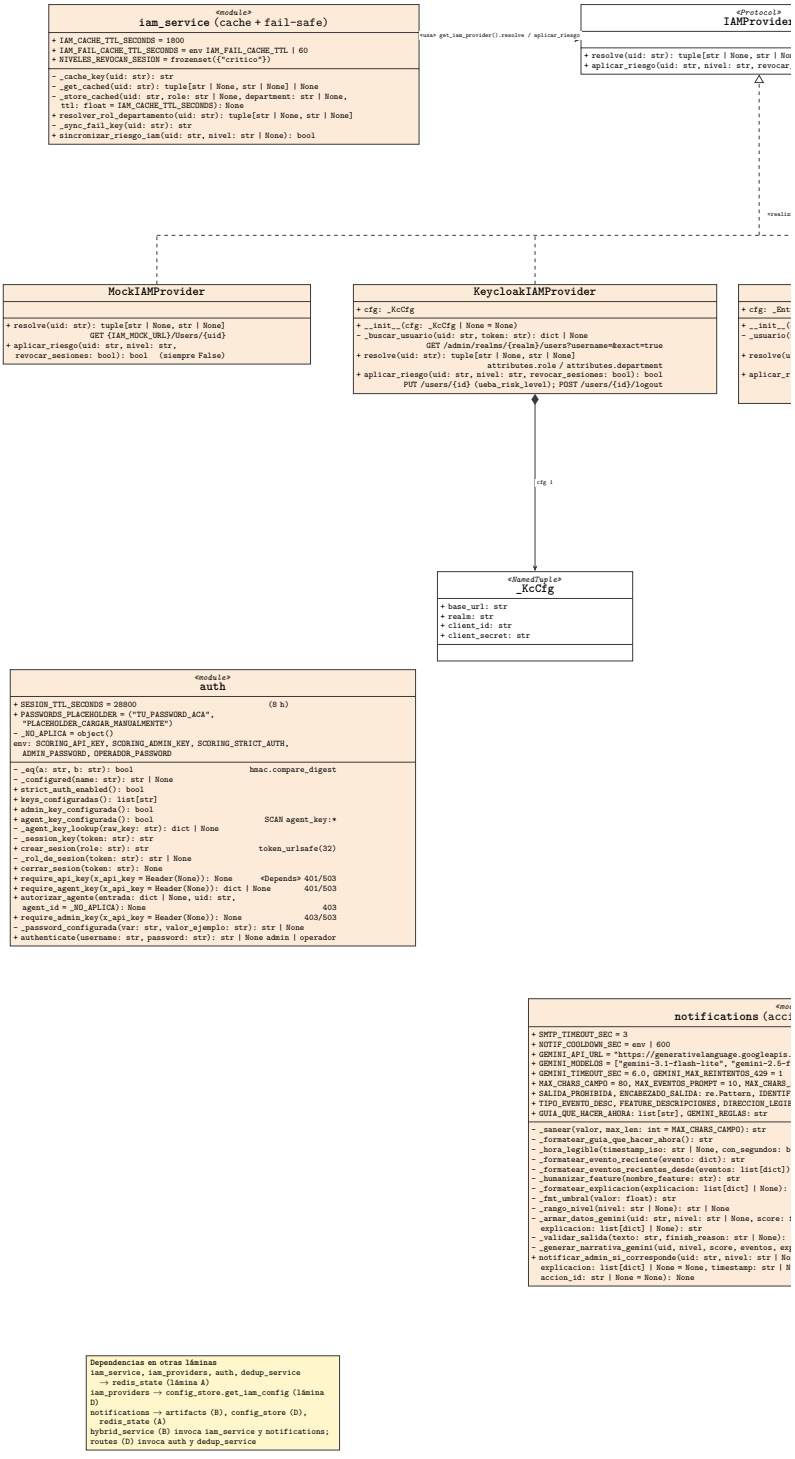


Figura H.11: Diagrama de clases de la API PDP: proveedores de identidad y autenticación, versión completa (mitad izquierda)

Fuente: elaboración propia.

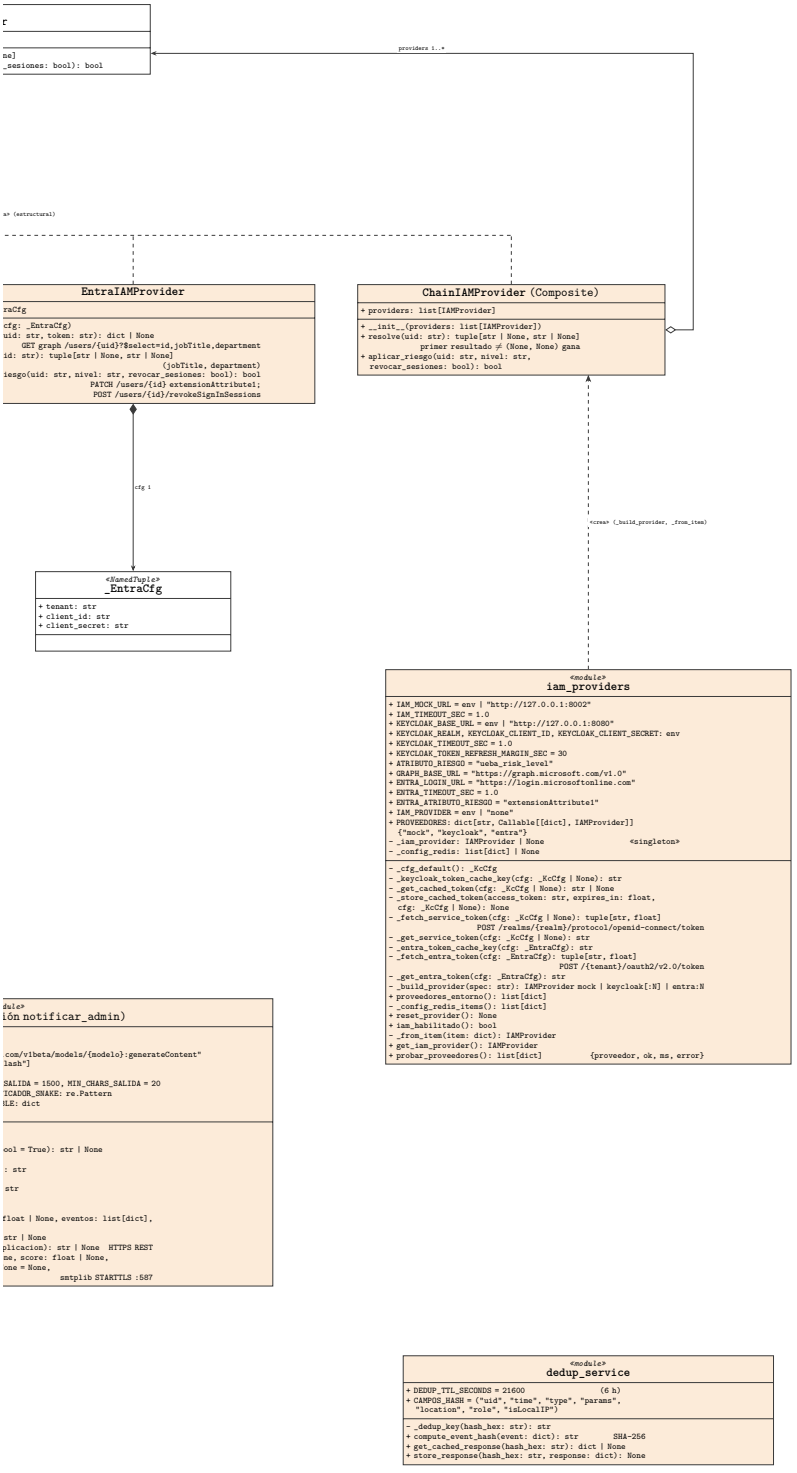


Figura H.12: Diagrama de clases de la API PDP: proveedores de identidad y autenticación, versión completa (mitad derecha)

Fuente: elaboración propia.

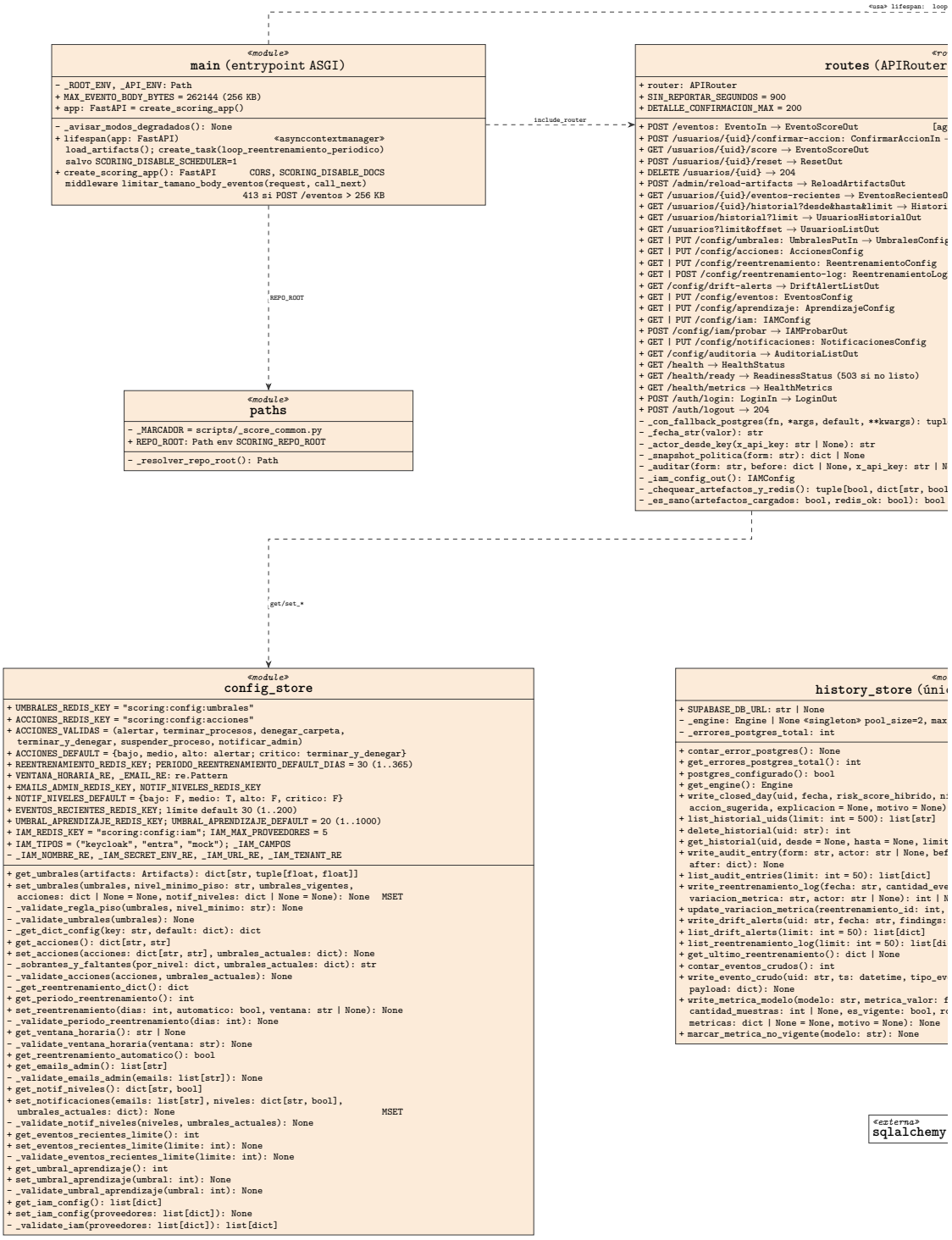


Figura H.13: Diagrama de clases de la API PDP: rutas, persistencia, configuración y reentrenamiento, versión completa (mitad izquierda)

Fuente: elaboración propia.

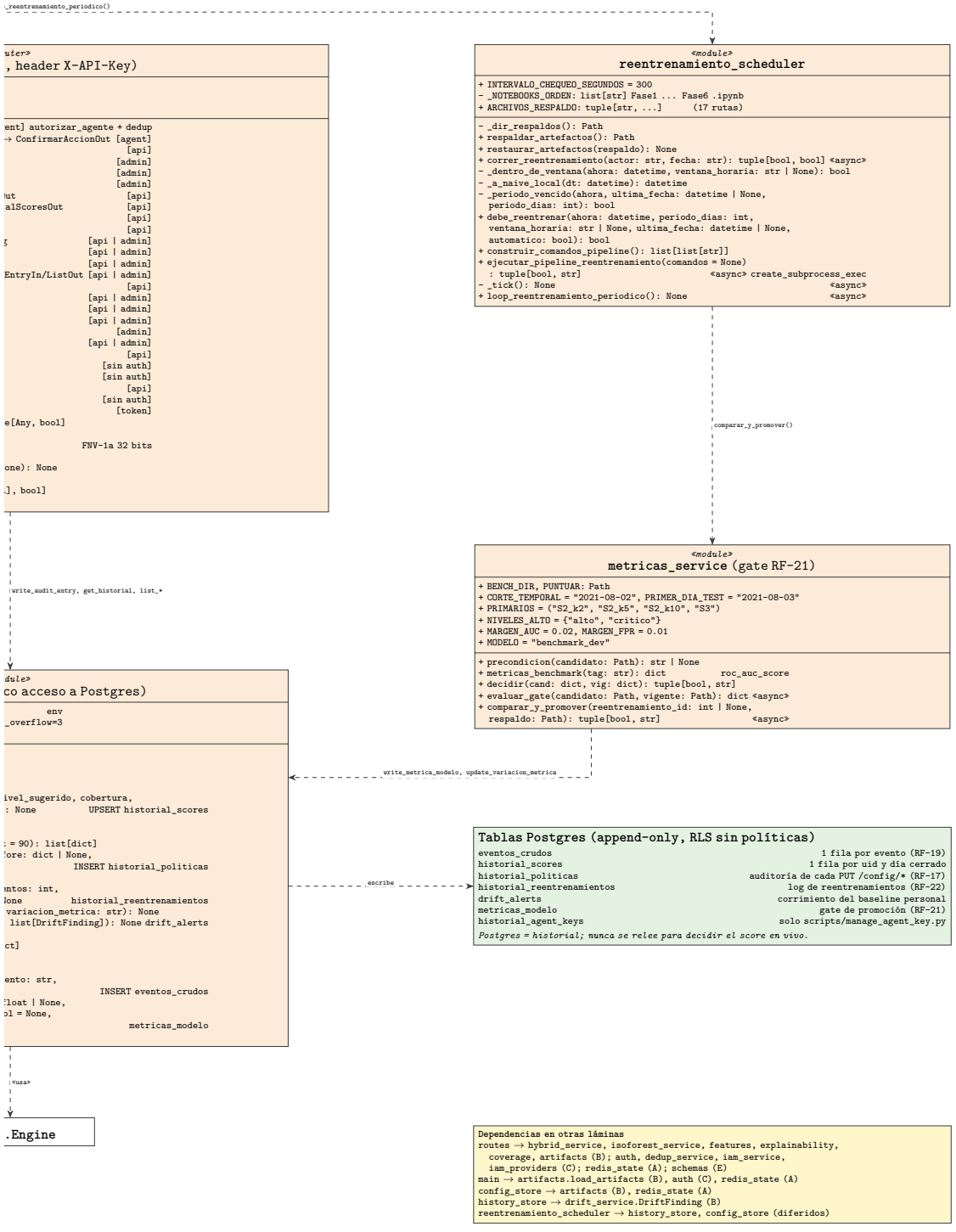


Figura H.14: Diagrama de clases de la API PDP: rutas, persistencia, configuración y reentrenamiento, versión completa (mitad derecha)

Fuente: elaboración propia.

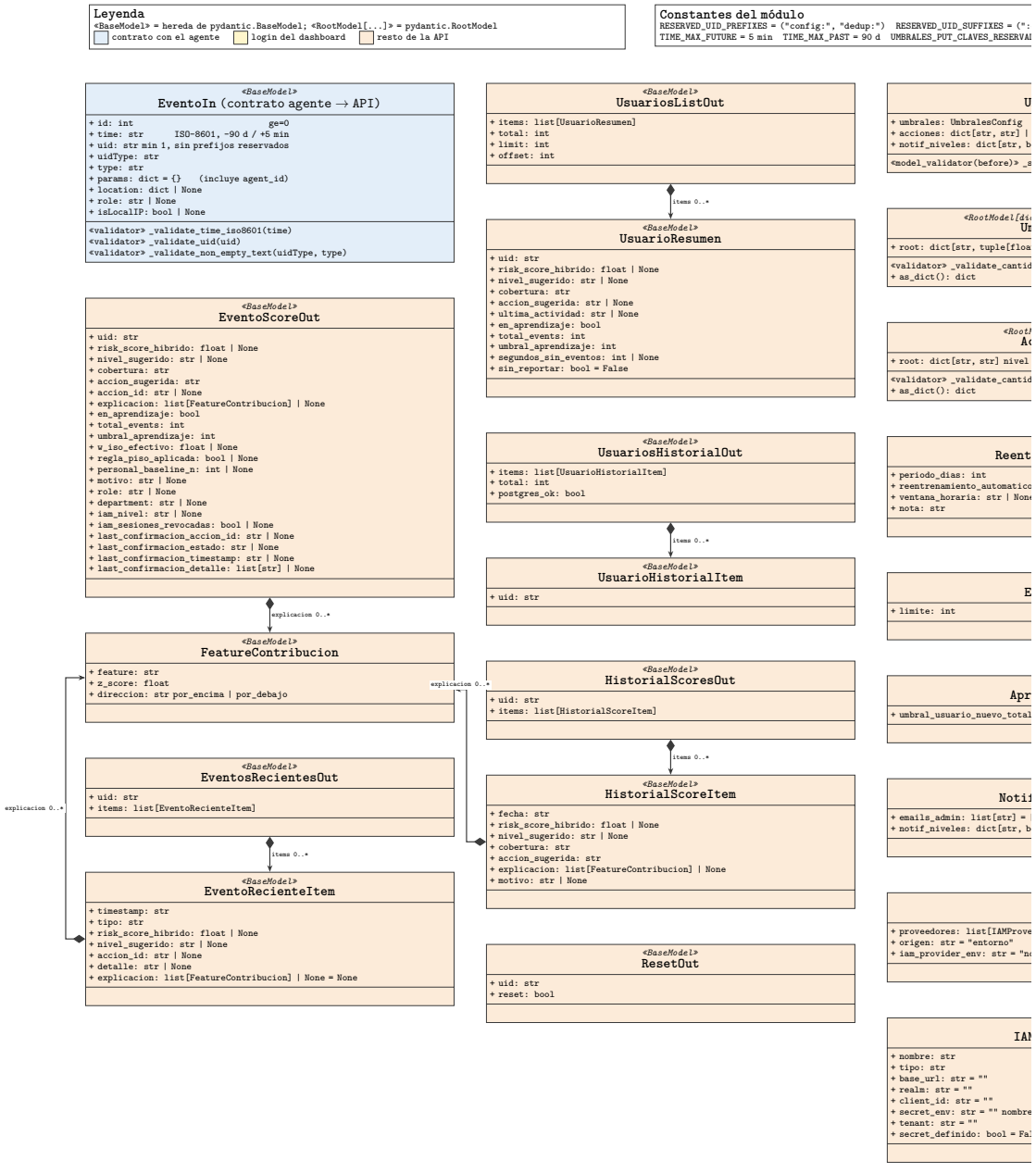


Figura H.15: Diagrama de clases de la API PDP: esquemas HTTP, versión completa (mitad izquierda)

Fuente: elaboración propia.

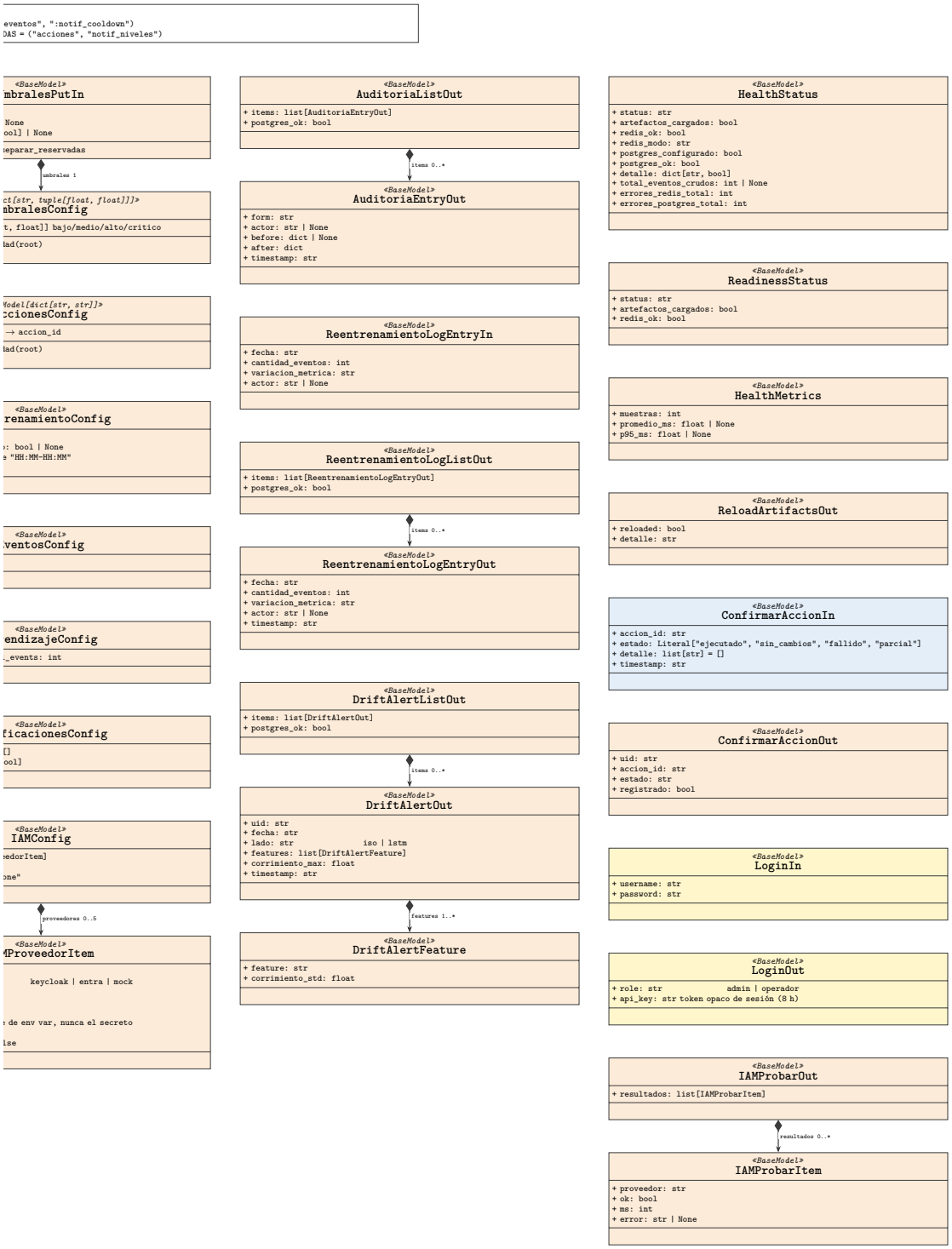


Figura H.16: Diagrama de clases de la API PDP: esquemas HTTP, versión completa (mitad derecha)

Fuente: elaboración propia.

Lista de figuras

5.1 Wireframe de baja fidelidad: Acceso (Login) . . . 73
5.2 Pantalla real: `/login` . . . 73
5.3 Wireframe de baja fidelidad: Usuarios (listado) . . . 75
5.4 Pantalla real: / (listado de usuarios) . . . 75
5.5 Wireframe de baja fidelidad: Detalle de usuario . . . 77
5.6 Pantalla real: `/usuarios/:uid` (detalle) . . . 77
5.7 Wireframe de baja fidelidad: Por qué pasó esto . . . 79
5.8 Pantalla real: Por qué pasó esto (parte superior: resumen y evolución del riesgo) 79
5.9 Pantalla real: Por qué pasó esto (scroll: señales que se desviaron y acción) . . . 80
5.10 Wireframe de baja fidelidad: Alertas . . . 82
5.11 Pantalla real: `/alertas` (con alertas activas) . . . 82
5.12 Wireframe de baja fidelidad: Configuración de umbrales . . . 84
5.13 Pantalla real: `/umbrales` (parte superior: rangos por nivel) . . . 84
5.14 Pantalla real: `/umbrales` (scroll: notificaciones, proveedores de identidad y log de reentrenamientos) . . . 85
5.15 Wireframe de baja fidelidad: Auditoría . . . 87
5.16 Pantalla real: `/auditoria` . . . 87
5.17 Wireframe de baja fidelidad: Estado del sistema . . . 89
5.18 Pantalla real: `/salud` . . . 89
5.19 Wireframe de baja fidelidad: Con historial . . . 91
5.20 Pantalla real: `/historial` . . . 91

6.1 Diagrama de flujo de información del sistema (vista de diseño). . . . 94
6.2 Diagrama de componentes con protocolos de comunicación (vista de diseño). . . 95
6.3 Diagrama de clases del agente PEP (vista de diseño). . . . 96
6.4 Diagrama de clases de la API PDP: vista de paquetes de scoring. . . . 97
6.5 Diagrama de clases de la API PDP: estado del usuario en Redis (vista de diseño). 98
6.6 Diagrama de clases de la API PDP: puntaje y modelos (vista de diseño). . . . 99
6.7 Diagrama de clases de la API PDP: proveedores de identidad y autenticación (vista de diseño). . . . 100
6.8 Diagrama de clases de la API PDP: rutas, persistencia, configuración y reentrenamiento (vista de diseño). . . . 101
6.9 Diagrama de clases de la API PDP: esquemas HTTP (vista de diseño). . . . 102
6.10 Diagrama de objetos con una instancia real (uid `DESKTOP-DEMO-usuario1`). . . 103

7.1 Arquitectura de despliegue local . . . 109
7.2 Arquitectura de despliegue en la nube . . . 110
7.3 Recursos de apoyo de la instancia en la nube . . . 112

8.1 Modelo relacional: puntajes, eventos crudos y alertas de corrimiento . . . 121
8.2 Modelo relacional: auditoría, reentrenamientos, métricas y claves de agentes . . . 123

10.1 Detección atribuible por escenario según el umbral, y tasa de alertas sobre días sin inyección (porcentaje de usuario-días) para umbrales entre 40 y 90 . . . 157

11.1 Matriz FODA del producto. . . . 174
11.2 Matriz Boston Consulting Group (BCG) del producto. . . . 177

12.1 Logotipo del producto. . . . 188

A.1 Diagrama de Gantt del proyecto: planificación de hitos y distribución de tareas . 201
B.1 ¿Usás una computadora provista por tu empresa para trabajar? (n=240) . . . 202
B.2 Criticidad de los datos a los que accede (n=185) . . . 202
B.3 Exigencia de cambio de contraseña o MFA . . . 203
B.4 Revalidación de identidad dentro de la sesión . . . 203
B.5 Controles de identidad posteriores al inicio de sesión . . . 204
B.6 Cuando te alejás de tu computadora, ¿qué hacés habitualmente? . . . 204
B.7 Detección de actividad con credenciales robadas . . . 204
B.8 Confianza en los sistemas de seguridad actuales . . . 205
B.9 Protección percibida tras el inicio de sesión . . . 205
B.10 Conocimiento de la política de seguridad . . . 206
B.11 Mecanismo de detección de accesos inusuales . . . 206
B.12 Importancia de la respuesta preventiva (bloqueo) . . . 207
B.13 Respuesta menos disruptiva ante riesgo moderado . . . 207
B.14 Funcionalidades prioritarias del sistema . . . 208
B.15 Factor determinante para la adopción . . . 208
B.16 Probabilidad de adopción en la empresa . . . 209
B.17 Tiempo de detección de incidentes previos . . . 209
H.1 Diagrama de flujo de información del sistema, versión completa (mitad izquierda) 261
H.2 Diagrama de flujo de información del sistema, versión completa (mitad derecha) 262
H.3 Diagrama de componentes con protocolos de comunicación, versión completa (mitad izquierda) . . . 263
H.4 Diagrama de componentes con protocolos de comunicación, versión completa (mitad derecha) . . . 264

H.5 Diagrama de clases del agente PEP, versión completa (mitad izquierda) 265
H.6 Diagrama de clases del agente PEP, versión completa (mitad derecha) 266
H.7 Diagrama de clases de la API PDP: estado del usuario en Redis, versión completa (mitad izquierda) 267
H.8 Diagrama de clases de la API PDP: estado del usuario en Redis, versión completa (mitad derecha) 268
H.9 Diagrama de clases de la API PDP: puntaje y modelos, versión completa (mitad izquierda) 269
H.10 Diagrama de clases de la API PDP: puntaje y modelos, versión completa (mitad derecha) 270
H.11 Diagrama de clases de la API PDP: proveedores de identidad y autenticación, versión completa (mitad izquierda) 271
H.12 Diagrama de clases de la API PDP: proveedores de identidad y autenticación, versión completa (mitad derecha) 272
H.13 Diagrama de clases de la API PDP: rutas, persistencia, configuración y reentrenamiento, versión completa (mitad izquierda) 273
H.14 Diagrama de clases de la API PDP: rutas, persistencia, configuración y reentrenamiento, versión completa (mitad derecha) 274
H.15 Diagrama de clases de la API PDP: esquemas HTTP, versión completa (mitad izquierda) 275
H.16 Diagrama de clases de la API PDP: esquemas HTTP, versión completa (mitad derecha) 276

Lista de tablas

3.I Comparación: Microsoft Sentinel UEBA . . . 37
3.II Comparación: Splunk UBA . . . 38
3.III Comparación: Exabeam . . . 38
3.IV Comparación: Microsoft Entra ID Protection . . . 39
3.V Comparación: Okta Adaptive MFA . . . 39
3.VI Comparación: RADAC académico (ad-RACs) . . . 40
3.VII Comparación: proyecto propuesto (fila de referencia) . . . 40
3.VIII Matriz de capacidades . . . 41
3.IX Comparación de algoritmos: CatBoost . . . 43
3.X Comparación de algoritmos: LSTM secuencial . . . 43
3.XI Comparación de algoritmos: Graph Neural Networks (GNN) . . . 44
3.XII Comparación de algoritmos: clustering no supervisado . . . 44
3.XIII Comparación de algoritmos: Isolation Forest . . . 44
3.XIV Comparación de algoritmos: revisión sistemática . . . 45
3.XV Comparación de algoritmos: proyecto propuesto . . . 46

4.I Requerimientos funcionales del Módulo 1 . . . 56
4.II Requerimientos funcionales del Módulo 2 . . . 56
4.III Requerimientos funcionales del Módulo 3 . . . 57
4.IV Requerimientos funcionales del Módulo 4 . . . 58
4.V Requerimientos funcionales del Módulo 5 . . . 59
4.VI Requerimientos funcionales del Módulo 6 . . . 60
4.VII Requerimientos funcionales del Módulo 7 . . . 61
4.VIII Requerimientos no funcionales . . . 61

8.I Clasificación de los usuarios del conjunto de datos . . . 116
8.II Configuración y entrenamiento de los modelos de detección de anomalías. . . . 117
8.III Correspondencia entre las señales del agente y los tipos de evento del conjunto de datos . . . 118
8.IV Tablas del modelo relacional . . . 120

9.I Acciones de mitigación del agente . . . 126
9.II Niveles de acceso de la API . . . 130
9.III Principios de la Ley 25.326 y su tratamiento en el sistema . . . 132
9.IV Limitaciones conocidas del producto . . . 136

10.I Técnicas de prueba, herramientas y alcance . . . 142
10.II Inventario de pruebas automatizadas por componente . . . 145
10.III Resultados de la ejecución de las pruebas automatizadas . . . 145
10.IV Cobertura de código por componente . . . 147
10.V Latencia de evaluación de eventos (RNF-01) . . . 150
10.VI Consumo de recursos del agente (RNF-02) . . . 152
10.VII Métricas sin etiquetas del modelo híbrido . . . 153
10.VIII Metas de evaluación del modelo y resultado obtenido . . . 154
10.IX Resultados de la validación por escenarios (15 usuarios por escenario) . . . 156
10.X Escenarios del benchmark de detección . . . 159
10.XI ROC-AUC en HOLDOUT, escenarios sin país [IC 95 %] . . . 160
10.XII *Recall* del híbrido en HOLDOUT, con y sin país [IC 95 %] . . . 161
10.XIII Tasa de falsos positivos sobre usuario-días limpios [IC 95 %] . . . 161
10.XIV Escenarios controlados adicionales . . . 162
10.XV Matriz de confusión por escenario con los umbrales de producción (usuario-día; DEV, sin víctimas del entrenamiento del LSTM) . . . 163
10.XVI Matriz de confusión del LSTM por bloque de 50 eventos (exploratoria; su umbral no decide nada en producción) . . . 163
10.XVII Controles negativos S6 y S7: falsos positivos y verdaderos negativos (FP / TN) 164
10.XVIII Decisiones tomadas a partir de los resultados de las pruebas . . . 165

12.I Lienzo del modelo de negocio . . . 179
12.II Gasto mensual de nube y servicios de soporte por tramo de equipos monitoreados (USD) . . . 181
12.III Supuestos del análisis económico-financiero . . . 182
12.IV Clientes activos al cierre de cada año por escenario . . . 184
12.V Flujo neto de fondos por escenario (USD) . . . 185
12.VI Indicadores económico-financieros por escenario . . . 185
12.VII Sensibilidad del VAN a la tasa de descuento (USD) . . . 185
12.VIII Sensibilidad del VAN al 25 % al costo variable de nube por equipo (USD) . . . 186
12.IX Sensibilidad del VAN al 25 % del escenario base al costo de adquisición y a la tasa de abandono (USD) . . . 186
12.X Punto de equilibrio operativo frente a los clientes activos al cierre de cada año . 186

13.I Cumplimiento de los objetivos específicos . . . 189